

LargoVerse

Návrh cílové architektury

Komponenty · architektonická rozhodnutí · klíčové toky
rizika a opatření · fázování · nezávislá oponentura

Verze 1.0 | 17. srpna 2026

Navazuje na dokument „Bezpečnostní architektura a plán rozvoje“ v. 1.0

Klasifikace: důvěrné. Určeno pouze pro uzavřený investorský okruh.

Návrh, nikoli licenční dokumentace — viz kapitola 9.

Obsah

1. Shrnutí návrhu	4
Pět zásad, na kterých návrh stojí	4
Poznámka k rozsahu, terminologii a verzi	4
2. Kontext a hranice systému	6
Vrstvení cílového systému	6
3. Doménový model a ledger	7
3.1 Komponenty	7
3.2 Architektonická rozhodnutí	12
3.3 Klíčové toky	15
3.4 Rizika a opatření	18
4. Služby a jejich hranice	20
4.1 Komponenty	20
4.2 Architektonická rozhodnutí	23
4.3 Klíčové toky	26
4.4 Rizika a opatření	29
5. Identita a silné ověření klienta	31
5.1 Komponenty	31
5.2 Architektonická rozhodnutí	34
5.3 Klíčové toky	37
5.4 Rizika a opatření	41
6. Compliance jako běhová vrstva	43
6.1 Komponenty	43
6.2 Architektonická rozhodnutí	47
6.3 Klíčové toky	49
6.4 Rizika a opatření	53
7. Blockchainová vrstva	55
7.1 Komponenty	55
7.2 Architektonická rozhodnutí	58
7.3 Klíčové toky	61
7.4 Rizika a opatření	65
8. Data, úložiště a soukromí	67

8.1 Komponenty	67
8.2 Architektonická rozhodnutí	70
8.3 Klíčové toky	72
8.4 Rizika a opatření	76
9. Platforma a provoz	78
9.1 Komponenty	78
9.2 Architektonická rozhodnutí	83
9.3 Klíčové toky	86
9.4 Rizika a opatření	89
10. Klientské aplikace	91
10.1 Komponenty	91
10.2 Architektonická rozhodnutí	94
10.3 Klíčové toky	97
10.4 Rizika a opatření	100
11. Fázování	103
Komponenty fáze 1	103
12. Nezávislá oponentura	109
Posudek přiměřenosti	109
Posudek přiměřenosti — LargoVerse cílová architektura	109
Pohled dohledu	114
Kde se to rozbije	119
Kde se to rozbije	119
13. Bezpečnostní signály	127
Postkvantová kryptografie (PQC) — hybridní výměna klíčů v TLS a příprava dlouhodobých archivů	127
Behaviorální biometrie (behavioural biometrics) v bankovníctví — stav k srpnu 2026	129
ARM Confidential Compute Architecture (CCA) / Realms — stav k srpnu 2026	130
FIDO2 / WebAuthn / passkeys jako prvek SCA pro platební instituci v EU (stav k srpnu 2026)	131
14. Doporučení k bezpečnostním signálům	134
Bezpečnostní signály LargoVerse — věcné doporučení	134
15. Co je nutné rozhodnout	140
Doporučené pořadí	140

1. Shrnutí návrhu

Tenhle dokument popisuje, **co postavit**. Předchozí dokument popisoval, co chybí; tady je návrh cílového systému do hloubky, ve které se dá zadat implementace — s konkrétními tabulkami, invarianty, volbami technologií a jejich cenou.

137 navržených komponent	107 architektonických rozhodnutí	54 popsaných toků	102 rizik s opatřením
68 komponent ve fázi 1	63 ve fázi 2	6 ve fázi 3	3 nezávislé oponentury

Pět zásad, na kterých návrh stojí

- **Server je jediná autorita nad penězi.** Klient je kurýr důkazů, ne rozhodčí. Nesmí spočítat zůstatek, spread ani poplatek — jen zobrazit to, co dostal, a kryptograficky potvrdit, že přesně tohle uživatel viděl.
- **Vadné stavy mají být nevyjádřitelné, ne ošetřené.** Nevývážený žurnál nejde zapsat, cena nemůže vzniknout mimo kotaci, částka v cizí měně nejde zaúčtovat na účet jiné měny. Vynucuje to databáze, ne kontrola v kódu.
- **Zůstatek je odvozený, ne uložený.** Jediným zdrojem pravdy je neměnný podvojný žurnál. Zůstatek je jeho agregát a zároveň registr pozic podle MiCA čl. 75.
- **Token ani jurisdikce nejsou konstanty.** Jsou to verzované datované řádky v tabulce. Rozhodnutí o autorizovaném aktivu ještě nepadlo a architektura ho nesmí předjímat.
- **Compliance je v kritické cestě, ne vedle ní.** Bez podepsaného rozhodnutí compliance jádra se nezaúčtuje žádný pohyb peněz.

Poznámka k rozsahu, terminologii a verzi

Tento dokument popisuje **cílový stav**. Beta aplikace je simulace produktu, ne jeho první verze — některé věci v ní vypadají jinak, protože ukazují záměr, ne implementaci. Tabulka níže mapuje pojmy, aby při čtení nevznikl dojem rozporu.

Pojem	Co znamená v tomto dokumentu
Safe Money	Název funkce v aplikaci. Dokument ho používá všude, kde jde o produkt. Safe Money je vedené vždy v XSGD — vklad z jiné měny je po cestě směna.
„trezor“ jinde v textu	Technický pojem pro oddělené úložiště (PII trezor, AML trezor, break-glass trezor, fyzický trezor pro zálohy klíčů). S produktem nesouvisí a záměrně se nepřejmenovává.
„úschova kryptoaktiv“	Právní pojem podle čl. 75 MiCA (úschova a správa kryptoaktiv jménem klientů). Také se nepřejmenovává — je to znění nařízení.
Fáze 1 / 2 / 3	Kdy se komponenta staví, ne pořadové číslo v seznamu. Fáze 1 = přežije každé budoucí rozhodnutí, staví se hned. Fáze 2 = až po rozhodnutí o licenci. Fáze 3 = až před ostrým provozem.

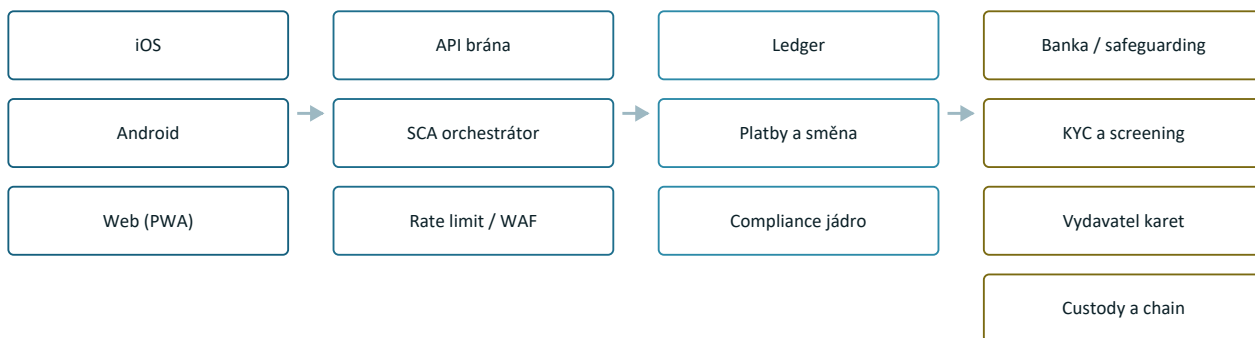
Pojem	Co znamená v tomto dokumentu
Částky v příkladech	Ilustrativní. Neodpovídají zůstatkům v beta aplikaci a nejsou požadavkem na ni — popisují cílový systém.
Karty	V cílovém systému se PAN, CVV ani PIN neukládají vůbec — drží se jen token vydavatele a údaje karty se zobrazují komponentou vydavatele. Beta aplikace je ukazuje simulačně a čísla v ní jsou záměrně neplatná.

Co tenhle dokument není

Není to žádost o licenci ani licenční dokumentace. Dohledová oponentura v kapitole 9 to říká přímo: popis ICT architektury je jedna položka ze seznamu příloh. Chybí program činností, obchodní plán, systém správy a řízení, popis safeguardingu, AML rámec a wind-down plán — a ty tenhle dokument nenahrazuje.

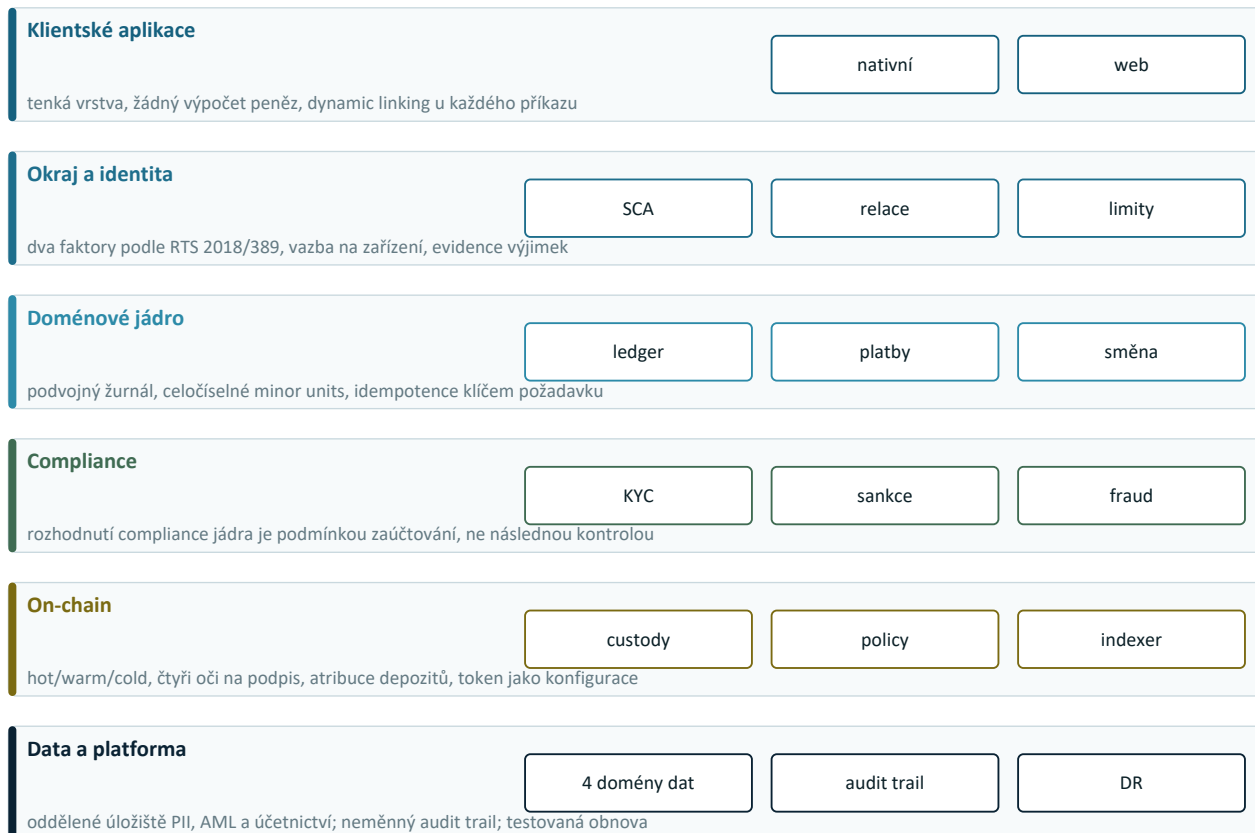
2. Kontext a hranice systému

Systém stojí mezi klientem a čtyřmi světy, které neovládá: bankovními kolejemi, dodavateli compliance, karetním vydavatelem a veřejným blockchainem. Každá z těchto hranic má vlastní režim selhání a vlastní regulační režim — proto vede řez právě tam.



Kontext systému. Šipky značí směr závislosti, ne směr toku peněz.

Vrstvení cílového systému



3. Doménový model a ledger

Jádro systému. Zůstatek přestává být přepisovaný sloupec a stává se odvozeným agregátem nad neměnným podvojným žurnálem.

V cílovém stavu není zůstatek sloupec, který se přepisuje — zůstatek je odvozený agregát nad neměnným podvojným žurnálem, který je jediným zdrojem pravdy o peněžích a zároveň registrem pozic podle MiCA čl. 75. Model je postavený tak, aby celé třídy vad z auditu byly nevyjádřitelné, ne jen opravené: cena nemůže vzniknout mimo kotaci, žurnál nemůže nebalancovat, poplatek nemůže zmizet, hodnota nemůže vzniknout zaokrouhlením a odměna za držení EMT nemá v datovém modelu žádný typ, kterým by se dala zapsat. Peníze jsou celočíselné minor units s škálou danou registrem aktiv (VES 0, fiat 2, tokeny nejméně tolik desetinných míst, kolik hlásí kontrakt), takže float ani asymetrické zaokrouhlení nemají kudy vstoupit. Konkrétní token, jurisdikce ani sazebník nejsou konstanty — jsou to verzované, datované řádky v tabulkách, protože rozhodnutí o licenci a o autorizovaném EMT ještě nepadlo a architektura ho nesmí předjímat. Vše, co je v této oblasti nejdražší doplnit později (podvojnost, idempotence, cenové jádro, škály), se staví v první fázi; safeguarding, on-chain podkniha a karetní zúčtování se na tento základ nasazují až po rozhodnutí o licenci.

3.1 Komponenty

Celkem 14 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Registr aktiv (asset registry)

Fáze 1

Jediné místo, kde je definováno, co je 'peníze'. Tabulka `asset`(`code` PK, `asset_class` ENUM{`fiat`,`emt`,`art`,`crypto_other`,`gas`}, `ledger_scale` smallint NOT NULL, `display_scale` smallint NOT NULL, `rounding_mode` ENUM{`half_even`,`floor`,`ceil`} NOT NULL DEFAULT 'half_even', `functional` bool, `issuer_id`, `redeemable_at_par` bool). Doplnkově `token_contract`(`asset_code`, `chain_id`, `contract_address`, `contract_decimals`, `verified_at`, `valid_from`) a `asset_regulatory_status`(`asset_code`, `valid_from`, `valid_to`, `status` ENUM{`authorised_emt_eu`,`not_authorised_eu`,`out_of_scope`}, `eu_offerable` bool, `source_url`, `decided_by`, `decided_at`) — historizovaná, protože stav podle MiCA se mění a repricing i audit se musí umět vrátit do minulosti. INVARIANTY: CHECK(`display_scale` <= `ledger_scale`); CHECK(`ledger_scale` BETWEEN 0 AND 18); pro `asset_class` IN ('emt','crypto_other') musí platit `ledger_scale` >= max(`contract_decimals`) přes všechny živé kontrakty (vynuceno constraint triggerem při vložení kontraktu — jinak každý on-chain příjem ztrácí dust); EXCLUDE constraint na nepřekrývající se intervaly platnosti u `regulatory_status` a `token_contract`. Redenominace měny se NIKDY neřeší přeskálováním existujících zápisů — zakládá se nové `asset_code` a povinný konverzní žurnál.

Technologie: PostgreSQL 16+, btree_gist pro EXCLUDE, Flyway/Liquibase migrace · **Rozhraní:** Read-only view pro celý systém; zápis jen migrací s čtyřma očima. Žádný kód nikde neobsahuje literál 'XSGD', 'VES' ani číslo 2 jako počet desetinných míst.

Účtová osnova a ledger_account

Fáze 1

`ledger_account`(`id` uuid PK, `code` text UNIQUE, `account_type` ENUM{`asset`,`liability`,`equity`,`income`,`expense`}, `asset_code` FK, `legal_entity_id` FK, `owner_kind` ENUM{`client`,`house`,`counterparty`}, `owner_id`, `safeguarded` bool, `allow_negative` bool, `stripe` smallint, `status` ENUM{`open`,`frozen`,`closed`}). Osnova produktu: AKTIVA 1010 `nostro:bank:{banka}:{asset}` (safeguarding), 1015 `nostro:own:{banka}:{asset}` (vlastní zdroje, fyzicky jiný bankovní účet), 1030 `onchain:{wallet_tier}:{token}`, 1040 `onchain:in_flight:{token}`, 1050 `psp_receivable:{psp}:{asset}`, 1100 `fx_position:{asset}` (obchodní pozice domu), 1200 `client_receivable:{asset}`. ZÁVAZKY 2010 `client:available:{product_account}`, 2020 `client:hold:{product_account}` (blokace, karetní autorizace), 2030 `client:vault:{product_account}:{asset}` (Safe Money), 2040 `client:emt:{product_account}:{token}` (registr pozic dle čl. 75), 2050 `unsettled_incoming:{asset}`, 2090 `clearing:{scheme}:{asset}`, 2100 `intercompany_due_to:{entity}`. VÝNOSY

4010 fee_income:{typ}:{tariff_key}:{asset}, 4020 spread_income:{pair}:{asset}, 4090 rounding_income:{asset}.
 NÁKLADY 5010 fx_revaluation_loss, 5020 network_fee_expense:{chain}, 5090 rounding_expense. VLASTNÍ KAPITÁL
 3020 opening_balance (jen genesis a migrace). INVARIANTY: UNIQUE(id, asset_code) — nutné pro složený cizí klíč z
 postings; CHECK((owner_kind='client') = (owner_id IS NOT NULL)); trigger BEFORE UPDATE OF asset_code,
 account_type, legal_entity_id, allow_negative → RAISE EXCEPTION (tyto atributy jsou po založení neměnné);
 mapovací tabulka product_account_ledger(product_account_id, purpose ENUM{available,hold,vault},
 ledger_account_id) s UNIQUE(product_account_id, purpose) — účet se adresuje identifikátorem, nikdy měnou.

Technologie: PostgreSQL, deny-by-default GRANTy · **Rozhraní:** Zakládání účtů jen přes doménovou službu; osnova je verzovaná v
 repozitáři jako seznam šablon kódů.

Žurnál a zápisy (journal / posting) — jádro ledgeru

Fáze 1

journal(id uuid PK (UUIDv7), seq bigint, legal_entity_id, type journal_type NOT NULL, request_id FK, correlation_id,
 effective_at timestamptz, booking_date date, value_date date, reverses_journal_id FK NULL, metadata jsonb,
 created_by, created_at). posting(journal_id, idx smallint, ledger_account_id, asset_code, direction CHAR(1) CHECK
 IN ('D','C'), amount numeric(38,0) CHECK(amount > 0), signed_amount GENERATED ALWAYS AS (CASE direction
 WHEN 'D' THEN amount ELSE -amount END) STORED, PRIMARY KEY(journal_id, idx)). journal_type je uzavřený
 ENUM: payment_out, payment_in, p2p, transfer_own, fx_trade, vault_move, vault_deposit_fx, vault_withdraw_fx,
 card_auth, card_capture, card_void, onchain_in, onchain_allocate, onchain_out, fee, fx_revaluation,
 safeguarding_topup, safeguarding_sweep, intercompany, reversal, adjustment, opening. INVARIANTY VYNUCENÉ
 DATABÁZÍ: (1) FOREIGN KEY (ledger_account_id, asset_code) REFERENCES ledger_account(id, asset_code) —
 struktura znemožňuje zaúčtovat CZK na USD účet; (2) odložený (DEFERRABLE INITIALLY DEFERRED) constraint
 trigger na COMMIT: pro každý journal_id musí platit SUM(signed_amount) = 0 v KAŽDÉM asset_code zvlášť a
 COUNT(*) >= 2; (3) všechny postingy jednoho žurnálu mají shodný legal_entity_id; (4) CHECK: type IN
 ('fx_trade','vault_deposit_fx','vault_withdraw_fx','transfer_own') → metadata ? 'quote_id'; (5) CHECK: type =
 'adjustment' → metadata ? 'approval_id'; (6) UNIQUE(reverses_journal_id) WHERE NOT NULL — žurnál lze
 stornovat nejvýše jednou; (7) trigger BEFORE UPDATE OR DELETE ON journal, posting → RAISE EXCEPTION, navíc
 REVOKE UPDATE, DELETE od aplikační role; (8) trigger: booking_date nesmí padnout do uzavřeného období.
 Partitioning obou tabulek po booking_date (měsíčně) kvůli 5leté retenci a archivaci odpojením partition.

Technologie: PostgreSQL, deklarativní partitioning, pgaudit · **Rozhraní:** Zápis výhradně přes post_journal(); čtení přes views a
 projekce.

Zůstatky a jejich vynucení (account_balance)

Fáze 1

account_balance(ledger_account_id PK, asset_code, balance numeric(38,0) NOT NULL, allow_negative bool NOT
 NULL (denormalizováno a neměnné), last_journal_seq bigint, version bigint, updated_at). Aktualizuje se
 SYNCHRONNĚ ve stejné transakci jako postingy, výhradně příkazem UPDATE account_balance SET balance = balance
 + :delta, version = version + 1 WHERE ledger_account_id = :id — nikdy se nečte, nerozhoduje v aplikaci a pak
 nezapisuje. KLÍČOVÝ INVARIANT: CHECK(allow_negative OR balance >= 0). Tím je 'peníze nevzniknou z ničeho'
 vlastnost databáze, ne kontrola v UI — kontrola krytí je odmítnutí constraintu, ne předchozí SELECT. Řádek zůstatku
 je zároveň zámek, který serializuje operace nad jedním účtem. Domovní účty s vysokou frekvencí (fee_income,
 spread_income, fx_position, nostro) jsou strippované: fyzicky 64 řádků se sloupцем stripe, výběr podle
 hash(request_id) % 64; každé čtení a každý report MUSÍ agregovat přes stripes (vynuceno tím, že aplikace vidí jen
 view balance_by_account, přímý přístup na tabulku je odepřen).

Technologie: PostgreSQL row-level locking, READ COMMITTED · **Rozhraní:** View v_balance(ledger_account_id, balance) agregující
 stripes; view v_client_balance(product_account_id, available, hold, vault).

Zapisovací brána post_journal()

Fáze 1

Jediná cesta, kterou se do ledgeru zapisuje. SECURITY DEFINER funkce (nebo jediný modul v aplikaci nad REVOKE
 INSERT rolí) s podpisem post_journal(request_id, type, effective_at, value_date, legs jsonb, metadata jsonb) →
 journal_id. Dělá v jedné transakci: (1) validace každé částky — konečná, celé číslo, > 0, ve škále aktiva (větší přesnost

než ledger_scale se ODMÍTÁ, nezaokrouhluje), pod horní mezí per aktivum; (2) kontrola, že jde-li o křížoměnovou operaci, existuje platná, neexpirovaná kotace a částky v nohách přesně odpovídají tomu, co kotace spočítala; (3) SEŘAZENÍ noh podle ledger_account_id vzestupně a teprve pak aplikace zůstatků — deterministické pořadí zámků je jediná ochrana proti deadlocku mezi souběžnou směnou $A \rightarrow B$ a $B \rightarrow A$; (4) INSERT do journal + posting + UPDATE account_balance; (5) INSERT do outbox; (6) uzavření záznamu v idempotenčním registru. Vše commituje najednou nebo nic.

Technologie: PL/pgSQL nebo aplikační modul s odepřenými přímými granty; property testy (žádná posloupnost operací nezmění celkovou hodnotu systému nad rámec zaúčtovaných poplatků) · **Rozhraní:** Interní API doménové vrstvy; aplikační DB role nemá INSERT na journal/posting/account_balance.

Idempotenční registr

Fáze 1

request(request_id uuid PK, client_id, endpoint, request_fingerprint bytea (sha256 kanonizovaného těla + cesty + client_id), state ENUM{in_progress,succeeded,failed}, journal_id NULL, response_status, response_body jsonb, created_at, completed_at, expires_at). Průběh: INSERT ... ON CONFLICT DO NOTHING. Vloženo → požadavek je náš, pokračuje se ve STEJNÉ transakci jako žurnál. Nevloženo → čte se existující řádek: jiný fingerprint = HTTP 409 (stejný klíč, jiné tělo); state='succeeded' = přehraje se uložená odpověď s hlavičkou Idempotent-Replay; state='in_progress' = 409 s pokynem opakovat (nikdy se neblokuje a nikdy se nehádá); state='failed' = přehraje se původní chyba, aby retry semantika neprosakovala. Retence: 90 dní pro endpointy hýbající penězi, 7 dní pro ostatní, poté přesun do request_archive s trvale drženým UNIQUE indexem na request_id (levný, kontroluje se jen na pomalé cestě). Klíč generuje klient (UUIDv4/v7), povinná hlavička Idempotency-Key; pro budoucí PSD2 rozhraní ekvivalent X-Request-ID podle Berlin Group.

Technologie: Stejná databáze jako ledger — atomicita bez 2PC je celý smysl tohoto uspořádání · **Rozhraní:** HTTP: povinná hlavička Idempotency-Key na všech POST/PUT/DELETE měnících stav; odpověď nese journal_id.

Cenové jádro — kotace, sazebník, ekonomický status

Fáze 1

Cena vzniká na jednom místě a nikde jinde. rate_snapshot(id, source, observed_at, published_at) + rate_point(snapshot_id, base, quote, mid_rate numeric(30,12)) — kurz má vždy zdroj a čas platnosti, nikdy to není konstanta v kódu. tariff(tariff_id, key ENUM{hyper,standard}, valid_from, valid_to, spread_bps int, fee_amount numeric, fee_asset, published_at, approved_by) s EXCLUDE constraintem proti překryvu a s CHECK(published_at <= valid_from) — sazebník musí být zveřejněn dřív, než začne platit. asset_economic_status(asset_code, valid_from, valid_to, status ENUM{hyperinflation,normal}, basis text, cumulative_3y_pct, source, source_published_at, decided_by, decided_at) s EXCLUDE proti překryvu — hyperinflace je DATOVANÝ ROZHODNUTÝ FAKT podle kumulativního tříletého kritéria IAS 29, ne živý výpočet z tabulky inflace; jinak by se sazba klientovi přepnula uprostřed dne, až statistický úřad něco publikuje, a obchod by se nedal zpětně přecenit. Pravidlo výběru zůstává produktově beze změny: stačí, aby hyperinflační byla jedna strana páru. fx_quote(quote_id, client_id, sell_asset, buy_asset, fixed_side CHAR(1) {S|B}, mid_rate, rate_snapshot_id, tariff_id, economic_status_ids, spread_bps, client_rate, gross_sell, net_buy, fee_amount, fee_asset, spread_amount, rounding_residual, expires_at (typicky +90 s), created_at). Kotace je jediný výstup, který smí volající provést — nesmí dopočítávat. fixed_side řeší vklad i výběr ze Safe Money jednou formulí místo dvou opačných větvi.

Technologie: PostgreSQL, btree_gist; kurzová služba s vlastním SLA a stářím kotace jako alarmovanou metrikou · **Rozhraní:** quote(sell, buy, amount, fixed_side, client) → fx_quote; post_journal odmítne křížoměnový žurnál bez platného quote_id. Sazebník a důvod sazby jsou součástí kotace a jdou na výpis.

Podkniha Safe Money a strukturální zákaz odměny

Fáze 1

Safe Money není samostatný produkt, je to další závazkový účet klienta ve stejném aktivu: 2030 client:vault:{product_account}:{asset}. Přesun ve stejné měně = žurnál vault_move se dvěma nohama (D client:available / C client:vault). Vklad z jiné měny = žurnál vault_deposit_fx, který je strukturálně TÝž obchod jako směna, jen poslední noha kredituje účet Safe Money místo běžného — proto z něj nelze poplatek vynechat, není kudy. ZÁKAZ ÚROČENÍ (MiCA čl. 50) je vynucen tvarem modelu, ne kontrolou: v ENUMu journal_type neexistuje

žádná hodnota vyjadřující úrok, výnos, staking reward ani odměnu vázanou na dobu držení nebo zůstatek — takový zápis nejde ani vyslovit. Doplňkově noční aserce: pro každý klientský účet Safe Money a EMT účet musí být součet kreditů, jejichž protistranou je výnosový nebo promo účet domu, roven nule. Srovnání kupní síly proti kotvě je čistě prezentační výpočet nad zveřejněnou inflací; nikdy negeneruje žádný posting a v datovém modelu po něm nezbývá stopa v penězích.

Technologie: Tentýž ledger, žádná zvláštní tabulka zůstatků · **Rozhraní:** vault_move(product_account, asset, amount, direction, source_asset, quote_id?) — jediné API; při source_asset <> asset je quote_id povinné.

Životní cyklus transakce a outbox

Fáze 2

To, co v dnešním demu úplně chybí. transaction_lifecycle(transaction_id, kind, state ENUM{initiated,authorized,captured,settled,returned,reversed,rejected}, product_account_id, current_journal_id, updated_at) je PROJEKCE — sloupec state se přepisovat smí, protože není zdrojem pravdy. Každý přechod ale zapisuje append-only řádek transaction_event(transaction_id, seq, from_state, to_state, journal_id, occurred_at, actor) s FK na žurnál, který přechod způsobil; stav bez žurnálu je nepřipustný. Dvoufázové peníze: card_auth / payment hold účtuje D client:available / C client:hold, takže utratitelný zůstatek je prostě zůstatek jiného účtu a kontrola krytí funguje beze změny; capture pak D client:hold / C clearing:{scheme}; expirace či zrušení je storno blokačního žurnálu. outbox(id bigserial, aggregate_id, type, payload jsonb, dedup_key UNIQUE, created_at, published_at, attempts, next_attempt_at) se zapisuje ve stejné transakci jako žurnál a publikuje samostatným workerem — at-least-once doručení plus idempotentní příjemce, žádné distribuované transakce, vícekrokové toky jako sagy s kompenzačními žurnály.

Technologie: Transactional outbox; message broker dle volby, na výběru nezáleží · **Rozhraní:** Události ledger.journal.posted, payment.state_changed; konzumenti dedupují podle event_id.

Uzávěrka a rekondilační stroj

Fáze 2

accounting_period(legal_entity_id, business_date, status ENUM{open,closing,closed,locked}, closed_at, closed_by, sign_off_by). Obchodní datum je INSTITUCIONÁLNÍ (časové pásmo licencované entity, u litevské dcery Europe/Vilnius), uložené na žurnálu jako booking_date; klientovi se z effective_at (timestampz) zobrazuje jeho lokální čas. Dvě pole, dva významy, obě uložená — tím padá dnešní vada, kdy se v Caracasu večerní platba účtovala na další den. Pozdní položka nikdy neotevřívá uzavřený den: dostane booking_date = dnešek, value_date původní a metadata.original_date. Rekondilační běhy (každý má reconciliation_run a své breaks): (1) interní — snapshot zůstatku proti přepočtu ze zápisů, každou noc, jednou měsíčně plný přepočet od nuly a povinně po každé obnově ze zálohy (DORA čl. 12); (2) obrátová předvaha — SUM(signed_amount) = 0 v každém aktivu, průběžně po pěti minutách nad deltou a při uzavěrce; (3) bankovní — nostro proti camt.053, nevysvětlený rozdíl starší dvou pracovních dnů je incident; (4) SAFEGUARDING — per aktivum SUM(všechny klientské závazky včetně hold a Safe Money) <= zůstatek na oddělených safeguarding účtech, denně, podkrytí spouští automatický žurnál safeguarding_topup z vlastních zdrojů plus alarm; (5) on-chain proti indexeru; (6) karetní schéma proti psp_receivable. reconciliation_break(run_id, kind, asset, expected, actual, delta, account_id, first_seen, status, resolution_journal_id) — break se uzavírá VÝHRADNĚ ukázáním na žurnál, který ho vyřešil; 'vyřešeno ručně' není povolený stav.

Technologie: Dávkové joby s repeatable-read snapshotem; SERIALIZABLE jen pro uzavěrku, ne pro provozní zápis · **Rozhraní:** Denní uzavěrkový report, safeguarding attestation pro dohled, exporty pro auditora.

Projekce výpisů

Fáze 2

Výpis se negeneruje ze samostatné tabulky transakcí (dnešní vada 'zůstatek a historie jsou dvě nezávislé pravdy'), ale ani se klientovi neukazují syrové postingy — klient nemá vidět nohu fx_position. statement_line(id, ledger_account_id, journal_id, booking_date, value_date, direction, amount, asset, counterparty_ref, reference_vs, reference_ks, reference_ss, remittance_ref, fee_amount, fee_asset, fx_sell_amount, fx_buy_amount, fx_client_rate, fx_mid_rate, fx_spread_amount, fx_tariff_key, running_balance, UNIQUE(ledger_account_id, journal_id)) je deterministická projekce postingů na KLIENTSKÝCH účtech, obohacená o poplatek materializovaný z

poplatkové nohy téhož žurnálu — poplatek tak je na výpisu samostatně identifikovatelný, což je informační povinnost, ne kosmetika. `statement_period(ledger_account_id, period_start, period_end, opening_balance, closing_balance, total_debits, total_credits, line_count, document_hash, storage_uri, status)` s `CHECK(closing_balance = opening_balance + total_credits - total_debits)` a s vazbou `opening(N) = closing(N-1)`. Výpis se generuje až nad uzavřeným obdobím a je neměnný dokument; oprava se objeví v NÁSLEDUJÍCÍM období jako stornový řádek, nikdy přegenerováním starého výpisu. Druhý typ výpisu nad účty 2040 pokrývá čtvrtletní výpis z registru pozic podle čl. 75 (aktivum, zůstatek, hodnota, provedené převody).

Technologie: Projekce budovaná z outboxu, plně přepočitatelná ze žurnálu · **Rozhraní:** REST/PDF; PDF do WORM úložiště, hash v databázi.

Neměnnost, atestace a WORM archiv

Fáze 2

Vedle REVOKE a triggerů proti UPDATE/DELETE běží dávková kryptografická atestace: každých 60 sekund se nad novými žurnály postaví Merkle strom, kořen se podepíše klíčem v HSM/KMS a uloží do WORM úložiště v jiném účtu, ke kterému provozní administrátoři ledgeru nemají přístup. Tím se prokazuje úplnost a nezměněnost bez toho, aby se každý zápis serializoval na chvost hash řetězu. Přiznaná cena: okno až 60 sekund, ve kterém by manipulace nebyla kryptograficky doložená — vyváženo tím, že zápis je stejně možný jen přes `post_journal` a každý DDL i změna `session_replication_role` je alarmovaná. Retence žurnálů a zápisů 5 let (AMLD čl. 40, od 7/2027 AMLR čl. 77) přes odpojené partitions v neměnném úložišti. DŮLEŽITÉ: v ledgeru nejsou žádné osobní údaje — jen `client_id` a identifikátory účtů. Jméno protistrany, IBAN, zpráva pro příjemce a symboly leží v odděleném úložišti `payment_instruction` s vlastním šifrováním a vlastní retencí, na které `statement_line` jen odkazuje. To je jediný způsob, jak současně splnit pětiletou AML retenci a nárok na výmaz.

Technologie: S3 Object Lock / WORM, KMS s FIPS 140-3 L3, pgaudit · **Rozhraní:** Attestation feed pro interní audit a dohled.

Oddělení právních entit a safeguarding v datech

Fáze 2

Každý `ledger_account` nese `legal_entity_id` a žádný žurnál nesmí míchat entity (vynuceno odloženým constraint triggerem). Pohyb mezi mateřskou singapurskou a dceřinou litevskou společností jsou proto VŽDY dva žurnály, jeden v každé entitě, spojené `correlation_id` a proti sobě postavené na účtech 2100 `intercompany_due_to` / 1210 `intercompany_due_from`, jejichž pár se denně rekonziliuje na nulu. Safeguarding je v datech vyjádřen příznakem `safeguarded` na účtech a invariantem uvedeným u rekonziličního stroje; ledger ale modeluje jen to, co existuje v realitě — oddělený bankovní účet u úvěrové instituce a smluvní trust/segregation ujednání jsou předpoklad, který ledger nevyrobí, jen ho eviduje a hlídá. Klientské prostředky se nikdy nepoužijí na vlastní účet: neexistuje typ žurnálu, kterým by šlo debetovat klientský závazek ve prospěch výnosového nebo vlastního účtu jinak než přes zveřejněný poplatek s kotací nebo přes schválený `adjustment` se čtyřma očima.

Technologie: Tentýž ledger, oddělené schéma per entita jen tehdy, vyžádá-li si to dohled · **Rozhraní:** Denní safeguarding attestation per entita a per aktivum.

On-chain podkniha a registr pozic podle MiCA čl. 75

Fáze 3

Klientská pozice v tokenu je závazkový účet 2040 `client:emt:{product_account}:{token}` — tato tabulka JE registr pozic vyžadovaný čl. 75, ne jeho kopie. Skutečná držba je 1030 `onchain:{hot|warm|cold}:{token}` a 1040 `onchain:in_flight:{token}`. INVARIANT (per token, kontrolovaný průběžně): $SUM(client:emt) + SUM(house\ position) = SUM(onchain:*) + SUM(in_flight)$. Příjem se účtuje DVĚMA žurnály, ne jedním: `onchain_in` (D `onchain:hot` / C 2050 `unsettled_incoming`) hned po zachycení, a `onchain_allocate` (D `unsettled_incoming` / C `client:emt`) až po dosažení potvrzení podle `chain_policy(chain_id, min_confirmations, reorg_depth, finality_seconds)` a po průchodu `travel-rule` a sankčním screeningem. Reorg pak stornuje jen první z nich a klientská pozice se nikdy nepohnula. Gas je náklad v nativním aktivu řetězce (5020 `network_fee_expense`), takže i MATIC/ETH musí být v registru aktiv, přestože je klient nikdy nadržuje. Neznámý odchozí převod z kontrolované adresy bez odpovídajícího žurnálu = incident P1 a circuit breaker.

Technologie: Vlastní indexer nad redundantní RPC infrastrukturou; MPC/HSM custody mimo rozsah této oblasti · **Rozhraní:** Indexer → outbox → allocator; proof of reserves jako Merkle strom závazků proti on-chain důkazu aktiv.

3.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tím kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
Peníze jako numeric(38,0) v minor units, škála výhradně z registru aktiv Zvažováno: bigint — rychlejší, ale u VES na škále 0 po další redenominaci nebo hyperinflaci je hlava v oprotace a záchrana znamená migraci celého ledgeru. DECIMAL s desetinnou čárkou — vrací zpět otázku 'kolik ...	Všechny částky jsou celá čísla v nejmenší jednotce daného aktiva, uložená jako numeric(38,0) společně s asset_code. Škálu určuje asset.ledger_scale (VES 0, CZK/EUR/USD 2, tokeny nejméně tolik, kolik hlásí kontrakt). Žádný float, žádný decimal s pohyblivou přesností, žádné číslo 2 zadrátované v kódu. Dnešní demo drží peníze v IEEE-754 double s round(n,d), který zaokrouhluje nesymetricky vůči znaménku a u odečtů systematicky vychyluje jedním směrem; platba pod půl haléře v něm neodepíše nic a přesto se odešle. Celočíslné minor units tuto celou třídu vad ruší. numeric místo bigint je volba proti přetečení u VES na škále 0 a proti tomu, aby se otázka 'nepřeteče to?' vracela do každého code review.	Agregace jsou o 15–25 % pomalejší než nad bigint; kompenzuje se snapshotem zůstatků a partitioningem. Každé API i každý test musí pracovat s minor units a s škálou z registru — konverze na desetinné číslo je výhradně prezentační krok. Redenominace měny se řeší novým asset_code a konverzním žurnálem, nikdy přeškálováním historie.
Posting nese kladnou částku a směr D/C, ne znaménko Zvažováno: Pouze znaménková částka — méně sloupců, ale ztrácí se rozlišení mezi 'kredit 0' a 'debet 0' a otevírá se cesta k opravám přepisem znaménka.	posting(direction CHAR(1), amount > 0) se znaménkovým generovaným sloupcem jen pro agregaci. CHECK(amount > 0) je triviální a nedovolí nulu ani zápornou nulu; debet/kredit je v řádce explicitně, takže auditor i generátor výpisu čtou záměr, ne jeho odvození. Znaménkový model svádí k tomu, aby se opravovalo 'obrácením znaménka' místo stornem.	Každý dotaz na zůstatek musí použít generovaný signed_amount nebo view; syrový SUM(amount) je vždycky chyba a musí se hlídat code review i lintem SQL.
Bilancování per aktivum vynucené databází, ne aplikací Zvažováno: Kontrola jen v aplikaci — rychlejší, ale první migrace nebo první druhá služba invariant prolomí a nikdo se to nedozví, protože není proti čemu porovnávat.	Kombinace složeného cizího klíče (ledger_account_id, asset_code) → ledger_account(id, asset_code) a odloženého constraint triggeru na COMMIT, který ověří SUM(signed_amount)=0 v každém aktivu zvlášť a COUNT(*)>=2. Cizí klíč strukturálně znemožňuje zaúčtovat CZK na USD účet — to je invariant, který aplikace kontrolovat nemá, protože se na to jednou zapomene. Odložený trigger chytí i zápis, který obejde aplikační bránu (migrace, DBA, budoucí druhá služba). U vícemnového systému musí součet platit v každé měně zvlášť, jinak by 'balancovaná' směna zakryla ztrátu.	Jeden agregační dotaz navíc na žurnál. Při stovkách TPS je to zanedbatelné, u dávkových importů desítek tisíc řádků to je měřitelné a je nutné dávkovat po žurnálech, ne po řádcích.
Jediná zapisovací brána post_journal(), aplikační role bez INSERT na ledger Zvažováno: Repository vrstva v aplikaci bez DB granty — funguje, dokud se nepřidá druhá služba nebo skript; v regulovaném prostředí neobstojí, protože se nedá doložit, že jiná cesta neexistuje.	Zápis do journal, posting a account_balance je odepřen aplikační roli; vše jde přes SECURITY DEFINER funkci, která validuje, seřadí nohy podle account_id a zapisí. Audit ukázal, že cena i pohyby jsou dnes rozprostřené do čtyř funkcí, z nichž si každá vybírá, kterou položku sazebníku respektuje. Jedno hrdlo znamená, že nová obrazovka nemůže přidat další variantu ceny ani zapomenout na protiúčet. Zároveň je to místo, kde se dá vynutit deterministické pořadí zámků.	Brána je jediný bod selhání a zároveň jediné místo, kde se optimalizuje výkon. Musí být pokrytá property testy a její změna vyžaduje čtyři oči. Jakákoli budoucí služba, která by chtěla zapisovat přímo, musí projít stejnou funkcí.
Synchronní zůstatek v těžé transakci s CHECK(balance >= 0), ne asynchronní projekce Zvažováno: Zůstatek jen jako materializovaný pohled přepočítávaný dávkově — levnější zápis, ale kontrola krytí by musela být v aplikaci, čili zpět k lost-update. Event sourcing s projekcemi — stejný problém ...	account_balance se aktualizuje UPDATE ... balance + delta uvnitř těžé transakce; kontrola krytí je odmítnutí check constraintu, ne předchozí SELECT. Vzorec 'přečti zůstatek, rozhodni v kódu, zapiš' je klasický lost-update: dvě souběžné platby oba vidí krytí a obě projdou. Nechat rozhodnout constraint na hodnotě po přičtení je jediné, co je za všech okolností správné. Klient navíc musí po platbě okamžitě vidět správný zůstatek — asynchronní projekce to nedá.	Řádek zůstatku je hot lock. U klientských účtů je to žádoucí (serializuje operace jednoho klienta), u domovních účtů je to skutečné hrdlo — proto striping na 64 řádků a pravidlo, že se nikdy nechte jeden stripe. Reporting se tím komplikuje.

Rozhodnutí	Volba a důvod	Důsledek
READ COMMITTED a deterministické pořadí zámek místo SERIALIZABLE Zvažováno: SERIALIZABLE globálně — jednodušší uvažování, ale retry na každé kolizi a horší chování při špičce. Optimistický zámek přes version sloupec — funguje, ale přesouvá kontrolu krytí zpět do aplikace.	Provozní zápis běží v READ COMMITTED; korektnost drží řádkové zámky nad zůstatky a check constrainty. Nohy žurnálu se před zápisem seřadí podle ledger_account_id. SERIALIZABLE se používá jen v uzávěrkových a rekondilačních dotazech. SERIALIZABLE by pod zátěží generoval serialization failures a nutnost retry logiky u operací hýbajících penězi — což je přesně to místo, kde retry nechceme řešit ad hoc. Deterministické pořadí zámek odstraňuje deadlock mezi směnou A→B a souběžnou B→A, což je u obousměrné směny reálný scénář, ne teoretický.	Nelze se spolehnout na 'přečtu si a bude to platit' — každé rozhodnutí o penězích musí být vyjádřené jako constraint nebo jako podmíněný UPDATE. To je pro vývojáře nezvyk a musí to být napsané v pravidlech pro peněžní kód.
Idempotenční záznam commituje spolu se žurnálem Zvažováno: Idempotence v Redis nebo na API gateway — rychlejší, ale není atomická s zápisem, takže neřeší nic, co potřebujeme řešit.	Řádek v request a postiny jsou v jedné transakci. Kolize klíče s jiným otiskem těla = 409. Neúspěšný požadavek zůstává neúspěšný i při opakování stejného klíče. Jediný způsob, jak dostat exactly-once na hranici ledgeru bez distribuované transakce. Uložení klíče až po commitu žurnálu otevírá okno, ve kterém retry provede druhý pohyb — a přesně to je dnešní vada, kdy dvojklik nebo timeout znamená dvojí odepsání.	Idempotenční registr musí být ve stejné databázi jako ledger — nelze ho vytáhnout do sdílené cache ani do jiné služby. Retence klíčů je bezpečnostní parametr: po expiraci se stejný klíč chová jako nový požadavek, proto 90 dní u peněžních endpointů a trvalý unique index v archivu.
Směna se účtuje přes domovní FX pozici; spread je výnos v nakupovaném aktivu, poplatek v prodávaném Zvažováno: Uznat spread rovnou ve funkční měně (CZK) — vyžadovalo by druhý kurz uvnitř téhož žurnálu a mísilo by dva zdroje kurzu v jednom zápisu. Účtovat směnu jako dva nezávislé žurnály — ztratí se atomičita ...	Jeden žurnál typu fx_trade obsahuje obě měnové nohy. Prodávaná strana: D client:available (hrubá částka + poplatek), C fx_position:{sell} (hrubá částka), C fee_income:fx:{tariff}:{sell} (poplatek). Nakupovaná strana: D fx_position:{buy} (hodnota ve středovém kurzu), C client:available:{buy} (čistá částka po spreadu), C ... Žurnál musí balancovat v každém aktivu zvlášť, takže poplatek ani spread nemají kam zmizet — dnešní stav, kdy se poplatek strhne a nikam nepřipíše a součet obou stran není nula, je v tomto tvaru nevyjádřitelný. Oddělení spreadu od pevného poplatku dává provozovateli přímo čitelný výnos z rozpětí a otevřenou měnovou pozici, kterou lze zajistit — čtete ji ze zůstatku fx_position, nemusíte ji dopočítávat.	Spread se uznává v nakupované měně, takže výnos vzniká v cizích měnách a musí se denně přeceňovat samostatným žurnálem fx_revaluation proti fx_revaluation_gain/loss. Tím se ale oddělí obchodní výsledek od přepočtového, což je účetně správně. Účet fx_position je horké místo — proto striping.
Žádný křížoměnový pohyb bez platné kotace (quote_id) — vynuceno databází Zvažováno: Sdílená funkce pro výpočet ceny bez uložené kotace — nezabrání tomu, aby ji někdo obešel, a znemožňuje zpětně doložit, jakou cenu klient viděl, když ji potvrzoval.	CHECK na journal: typy fx_trade, vault_deposit_fx, vault_withdraw_fx a transfer_own musí mít v metadatech quote_id; post_journal navíc ověří, že částky v nohách přesně odpovídají tomu, co kotace spočítala, a že kotace nevypršela. To je přímá oprava dvou nejdražších nálezu auditu: 'převod na vlastní účet' obcházel celý spread (rozdíl ve výši celého spreadu, tedy 1,5 % z převáděné částky) a vklad do Safe Money z jiné měny obcházel pevný poplatek. Dokud je cena rozprostřená po volajících, každá nová obrazovka přidá další variantu ceny. Když kotace chybí, databáze zápis odmítne — nová obrazovka nemá jak vzniknout špatně.	Každá křížoměnová operace je dvoukroková (kotace, pak provedení) a kotace má expiraci, takže UI musí umět 'kurz vypršel, potvrďte znovu'. Kotace jsou objemná tabulka s krátkou retencí pro nepoužité a dlouhou pro provedené.
Hyperinlace je datovaný rozhodnutí fakt podle IAS 29, ne živý výpočet Zvažováno: Počítat status z tabulky inflace při každém dotazu — jednodušší, ale cena se stane nereprodukovatelnou a sazebník neodpovídá zveřejněnému.	asset_economic_status s intervaly platnosti, zdrojem, kumulativní tříletou inflací a jmenným rozhodnutím. Pricing čte řádek platný k effective_at kotace. Pravidlo 'stačí jedna strana páru' zůstává. Dnešní práh 50 % roční inflace je v kódu přiznaně náhrada za tříleté kumulativní kritérium IAS 29. Kdyby sazba záležela na živém čísle, přepnula by se klientovi uprostřed dne po publikaci statistiky a obchod by se nedal reprodukovat — což znemožňuje reklamaci i přecenění. Sazebník je navíc zveřejňovaný dokument; jeho vstup musí být rozhodnutí s datem, ne vedlejší efekt datového feedu.	Vzniká čtvrtletní rozhodovací proces s doložitelným zápisem a odpovědnou osobou — administrativní zátěž, kterou dohled ale stejně bude chtít vidět. Reklasifikace měny je událost s dopadem na cenu, takže musí mít oznamovací lhůtu klientům.

Rozhodnutí	Volba a důvod	Důsledek
Opravy výhradně stornem a přeúčtováním; adjustment vyžaduje čtyři oči Zvažováno: Editace zápisu s verzí — teoreticky auditovatelné, ale ztrácí se vlastnost, že historie je neměnná, a rekonstrukce zůstatku k libovolnému okamžiku přestane být triviální.	Žádný UPDATE ani DELETE na journal a posting (odepřené granty + trigger). Chybný zápis se ruší úplným zrcadlovým žurnálem typu reversal s vazbou reverses_journal_id a UNIQUE indexem, který dovolí stornovat jednou. Částečná oprava neexistuje — stornuje se celé a zaúčtuje znovu správně. Nové skutečnosti (chargeback, kulance) jsou ... Ledger v bance není záznam o penězích, ledger jsou ty peníze. Částečné opravy jsou noční můra rekonsiliace, protože zůstatek pak nejde poskládat z celých událostí. Úplné storno je navíc snadno testovatelné: součet původního a stornujícího žurnálu je nula na každém účtu.	Výpisy budou obsahovat páry řádků (chybný a stornující) a klient uvidí i chybu — to je informačně správně, ale musí to být v UI vysvětlené. Provoz bude tlačít na 'jen to prosím oprav v databázi'; na to musí být napsaná odpověď a proces, jinak se pravidlo obejde první krizovou noc.
Bez globálně bezmezerové sekvence; úplnost se dokazuje dávkovou Merkle atestací Zvažováno: Hash řetěz na každý žurnál — nejsilnější důkaz, ale serializuje zápis na chvost řetězu. Kompromis 'řetěz per den' jen posouvá totéž hrdlo dovnitř dne.	Žurnály mají UUIDv7 a seq ze sekvence, která smí mít mezery po rollbacku. Každých 60 s se nad novými žurnály postaví Merkle strom, kořen se podepíše v HSM a uloží do WORM. Bezmezerová sekvence vyžaduje UPDATE jednoho čítače pro každý žurnál, což serializuje celý zápis systému do jedné fronty. Za to, co z toho auditor má (možnost říct 'chybí číslo 4711'), je to příliš vysoká cena. Podpis dávek dokazuje úplnost i nezměněnost lépe a bez hrdla.	Musíme umět auditorovi vysvětlit mezery a doložit atestační proceduru — to je jednorázová práce v dokumentaci. Existuje okno až 60 s, kdy manipulace není kryptograficky doložená; vyváženo tím, že zápis je možný jen přes bránu a změny DDL i session_replication_role jsou alarmované.
Zákaz úročení EMT se vynucuje tvarem modelu, ne kontrolou Zvažováno: Povolit obecný typ 'credit_adjustment' a hlídat účet v aplikaci — otevírá přesně tu cestu, kterou regulace zavírá.	V ENUMu journal_type neexistuje žádná hodnota vyjadřující úrok, výnos, odměnu za držení ani staking. Safe Money je prostý závazkový účet. Srovnání kupní síly negeneruje žádný posting. MiCA čl. 50 zakazuje jakoukoli odměnu vázanou na dobu držení nebo zůstatek, včetně nepřímých forem přes slevy a cenotvorbu jiných produktů, a je to jedno z nejsledovanějších ustanovení. Kontrola, kterou lze vypnout nebo obejít novou funkcí, je slabší než absence prostředku, jak věc vůbec vyslovit. Konstanta VAULT_RATE už jednou z produktu odešla po právní rešerši — model má zajistit, aby se nemohla vrátit omylem.	Jakýkoli budoucí loajaltní program se musí navrhnout tak, aby odměna nebyla funkcí zůstatku ani doby držení, a bude vyžadovat nový, právně posouzený typ žurnálu. To je záměrné tření. Srovnání kupní síly musí být v UI i v datech striktně oddělené od pojmu výnos.
Token, jurisdikce i sazebník jsou konfigurace, ne konstanty Zvažováno: Zapéct XSGD jako první token a zbytek přidat později — ušetří pár týdnů teď a stojí přepis ledgeru v okamžiku licenčního rozhodnutí.	asset_code, token_contract (s ověřenými decimals přečtenými z kontraktu), asset_regulatory_status s intervaly platnosti a eu_offerable, legal_entity_id na každém účtu. Nikde v kódu není literál 'XSGD' ani 'USDT'. XSGD ani USDT nejsou v EU autorizované EMT, USDC a EURC ano. Rozhodnutí o tokenu i o licenci ještě nepadlo a horizont je 24–33 měsíců — architektura, která si vybere teď, bude do roka přepisovat datový model, ne konfiguraci. Zároveň je zapotřebí umět token delistovat, aniž by se sáhlo do schématu.	Přidání USDC nebo EURC je migrace dat plus provozní rozhodnutí, ne vývojový úkol. Cenou je, že nic v systému nesmí předpokládat vlastnosti konkrétního tokenu — počet desetinných míst, řetězec ani chování kontraktu (například nestandardní návratové hodnoty u USDT) nesmí být implicitní. Otevření klientské pozice v aktivu, které není v dané jurisdikci a čase nabízetelné, musí ...
V ledgeru nejsou osobní údaje; obchodní datum je institucionální a uložené Zvažováno: Držet vše v ledgeru a řešit výmaz maskováním — porušuje neměnnost a zároveň se to špatně obhazuje před dozorovým úřadem.	Žurnál nese jen client_id a identifikátory účtů. Jméno protistrany, IBAN/SWIFT, symboly a zpráva pro příjemce jsou v odděleném šifrovaném úložišti payment_instruction s vlastní retencí. booking_date se počítá v časovém pásmu licencované entity a ukládá se; effective_at je timestamp a klientovi se z něj zobrazuje jeho lokální čas. Pětiletá AML retence a nárok na výmaz podle GDPR se nedají uspokojit v jednom úložišti — řeší se to architekturou, ne výjimkou. Ledger tak může být neměnný navždy, protože v něm není co mazat. U data platí, že klient v Caracasu a účetnictví v Litvě musí vidět různé věci a obě musí být uloženy, ne dopočítané; dnešní demo tuhle vadu má a projeví se na hraně dne i na hraně měsíce.	Generování výpisu je join přes dvě úložiště s různým režimem přístupu a šifrování, což komplikuje reporting i výkon. Po výmazu osobních údajů zůstane na starém výpisu prázdné jméno protistrany — to je správně a musí to být v podmínkách popsáno.

3.3 Klíčové toky

Směna mezi drženými měnami se spreadem a sazebníkem podle hyperinflation

- 1 Klient na obrazovce směny zadá, že prodává 10 000,00 CZK a chce USD; aplikace volá `quote(sell=CZK, buy=USD, amount=1000000, fixed_side='S')`.
- 2 Cenové jádro načte `rate_snapshot` platný k této chvíli, přečte `asset_economic_status` pro CZK a USD platný k `effective_at`, vyhodnotí pravidlo 'stačí jedna strana páru' → obě normální → `tariff_key='standard'`, a načte řádek `tariff` platný k tomuto okamžiku (`spread_bps`, `fee_amount`, `fee_asset`).
- 3 Kotace spočítá: hrubá prodávaná částka, pevný poplatek převedený do prodávané měny STŘEDOVÝM kurzem (nikdy klientským, jinak by se spread strhl dvakrát), hodnota ve středovém kurzu na nakupované straně, čistá připsaná částka po spreadu, částka spreadu a zaokrouhlovací zbytek. Zaokrouhluje se JEDNOU, na škálu nakupovaného aktiva, deklarovaným režimem. Kotace se uloží s expirací 90 s a vrátí klientovi včetně kurzu, spreadu, poplatku a důvodu sazby.
- 4 Klient potvrdí; aplikace pošle `POST /fx/trades` s hlavičkou `Idempotency-Key` a s `quote_id`.
- 5 Server vloží řádek do request (ON CONFLICT DO NOTHING). Při kolizi klíče a shodném otisku vrátí uloženou odpověď a končí; při kolizi a odlišném otisku vrátí 409.
- 6 `post_journal` ověří, že kotace patří tomuto klientovi, nevypršela a že částky v nohách přesně odpovídají jejímu výpočtu; jinak zápis odmítne.
- 7 Nohy se seřadí podle `ledger_account_id` a v tomto pořadí se aktualizují zůstatky: D `client:available:CZK` (hrubá + poplatek), C `fx_position:CZK` (hrubá), C `fee_income:fx:standard:CZK` (poplatek), D `fx_position:USD` (středová hodnota), C `client:available:USD` (čistá), C `spread_income:USD` (spread), ± `rounding_income/expense` (zbytek).
- 8 `CHECK(balance >= 0)` na korunovém účtu rozhodne o krytí. Nedostatek prostředků není předchozí `SELECT`, ale odmítnutý constraint — dvě souběžné směny se tím nemohou obě protlačit.
- 9 Odložený constraint trigger na `COMMIT` ověří, že součet je nula zvlášť v CZK a zvlášť v USD a že žurnál má alespoň dvě nohy.
- 10 Ve stejné transakci se zapíše `outbox` událost, uzavře se řádek request se stavem `succeeded` a uloženou odpovědí, a vše se commituje najednou.
- 11 Projekce postaví dva řádky `statement_line` (odpis v CZK s vyplněným `fee_amount` a rozpisem kurzu, připsání v USD) — poplatek je na výpisu samostatně identifikovatelný, spread je uveden jako rozdíl proti střednímu kurzu.

Kdyby jednou stranou byl VES (hyperinflační), krok 2 vybere `tariff_key='hyper'` se spreadem bez pevného poplatku a poplatková noha v žurnálu prostě nevznikne. Tarifní klíč se ukládá na kotaci i na řádek výpisu, takže je zpětně doložitelné, proč klient dostal tuto cenu — bez toho nejde vyřídit reklamaci ani prokázat dohledu shodu se zveřejněným sazebníkem.

Vklad do Safe Money z jiné měny (Safe Money je vedené vždy v XSGD)

- 1 Klient chce do Safe Money (vedené v XSGD) vložit 10 000,00 CZK. Aplikace volá stejnou funkci `quote(sell=CZK, buy=USD, fixed_side='S')` — žádná zvláštní cenová větev pro Safe Money neexistuje.
- 2 Kotace vrátí identický rozpis jako u směny: spread podle stavu ekonomiky obou stran a pevný poplatek podle téhož řádku `tariff`. Tím je dnešní vada, kdy Safe Money obcházelo pevný poplatek, strukturálně uzavřená — poplatek není volitelná položka, kterou by si volající mohl vybrat.
- 3 `POST /vault/deposits` s `Idempotency-Key` a `quote_id`; idempotenční registr se chová stejně jako u směny.
- 4 `post_journal` zapíše JEDEN žurnál typu `vault_deposit_fx`: D `client:available:CZK` (hrubá + poplatek), C `fx_position:CZK`, C `fee_income:fx:{tariff}:CZK`, D `fx_position:USD`, C `client:vault:{účet}:USD` (čistá částka po spreadu), C `spread_income:USD`, ± `rounding`.
- 5 Celá operace je atomická: neexistuje stav, ve kterém by peníze odešly z běžného účtu a ještě nedorazily do Safe Money.

- 6 Zůstatek Safe Money je zůstatek závazkového účtu klienta — nenese a nemůže nést žádnou odměnu, protože v modelu neexistuje typ žurnálu, kterým by šla zapsat.
- 7 Výběr ze Safe Money do jiné měny je zrcadlový tok s kotací s `fixed_side='B'`: klient zadá, kolik chce dostat na účet, a kotace dopočítá, kolik se ze Safe Money odepíše. Tím zmizí dnešní vada, kdy vklad násoboval a výběr dělil ve dvou různých větvích a náhled ukazoval opačné číslo, než co se provedlo.

Srovnání udržení kupní síly proti kotvě se počítá výhradně nad zveřejněnou inflací a nikdy negeneruje posting. V datech po něm nezůstane stopa v peněžích — což je vedle formulace v UI druhá, tvrdší záruka, že se nedá prezentovat jako výnos.

Odchozí tuzemská platba s VS/KS/SS včetně blokace a zúčtování

- 1 POST /payments s Idempotency-Key; tělo obsahuje `product_account_id` (nikdy ne měnu jako adresu účtu), částku v minor units, číslo účtu příjemce a symboly.
- 2 Validace na hranici domény: částka je konečná, celočíselná v minor units, > 0 , ve škále aktiva a pod limitem. Vstup s vyšší přesností, než dovoluje `ledger_scale`, se ODMÍTÁ — nezaokrouhluje se. Tím padá dnešní vada, kdy platba pod půl haléře neodepsala nic a přesto se odeslala.
- 3 Osobní údaje příjemce a symboly se ukládají do `payment_instruction` (šifrované, oddělená retence); ledger dostane jen odkaz.
- 4 Žurnál `payment_out` fáze blokace: D client:available / C client:hold. Utratitelný zůstatek klesne, protože je to jiný účet; kontrola krytí je opět check constraint.
- 5 `transaction_lifecycle` přejde do stavu authorized a zapíše se `transaction_event` s FK na tento žurnál.
- 6 Outbox událost odejde do zúčtovacího konektoru; ten publikuje at-least-once, konzument deduplikuje podle `event_id`. Žádná distribuovaná transakce.
- 7 Po přijetí do zúčtování: žurnál `card_capture/payment capture` D client:hold / C clearing:{scheme}:{asset}. Po skutečném zúčtování z banky: D clearing / C nostro:bank (párováno rekonsiliací proti camt.053).
- 8 Nedojde-li k zúčtování nebo je platba vrácena, zapíše se storno žurnálu blokace, nikdy se nepřepisuje stav ani zůstatek.
- 9 Klient dostane na výpisu jeden řádek s `booking_date` v pásmu instituce, `value_date` podle lhůt a poplatkem uvedeným samostatně.

Tady je hlavní kus práce, který v demu vůbec není: blokace, čekající stav, storno, reklamace a protistrana. Rozdíl proti dnešku je v tom, že žádný z těchto stavů není sloupec, který se přepíše — každý je způsobený žurnálem a stav je jen jeho projekce.

Denní uzávěrka a rekonsiliace safeguardingu

- 1 V nastavený čas přejde `accounting_period` pro daný `business_date` do stavu closing; od té chvíle trigger odmítá nové žurnály s tímto `booking_date`.
- 2 Obrátová předvaha: pro každé aktivum se ověří $\text{SUM}(\text{signed_amount})$ přes všechny postingy = 0. Nenulový výsledek je zastavovací stav — uzávěrka nepokračuje a spouští incident.
- 3 Interní rekonsiliace zůstatků: pro každý účet se porovná `account_balance.balance` proti přepočtu ze zápisů. Rozdíl znamená zmrazení účtu a stránkování on-call. Jednou měsíčně a povinně po každé obnově ze zálohy se přepočítává od nuly.
- 4 Safeguarding: pro každé aktivum a každou právní entitu se ověří $\text{SUM}(\text{všechny klientské závazky} - \text{available} + \text{hold} + \text{vault} + \text{emt})$ <= zůstatek na účtech s příznakem safeguarded. Podkrytí spouští automatický žurnál `safeguarding_topup` z účtu vlastních zdrojů plus alarm; nadkrytí nad práh smí být svedeno zpět jen schváleným žurnálem `safeguarding_sweep`.
- 5 Bankovní rekonsiliace: nostro účty proti camt.053, rozdíly do clearing suspense, stárnutí sledované; nevysvětlenný rozdíl starší dvou pracovních dnů je incident.
- 6 On-chain rekonsiliace: součet klientských pozic v tokenu proti skutečné držbě na kontrolovaných adresách. Jakýkoli odchozí převod bez odpovídajícího žurnálu je P1 a spouští circuit breaker.

- 7 Neuzavřené breaky se přenášejí do dalšího dne s evidencí; break se uzavírá výhradně odkazem na žurnál, který ho vyřešil.
- 8 Období přejde do closed se jmenným sign-off. Teprve nad uzavřeným obdobím se generují výpisy a `statement_period` s kontrolou `closing = opening + kredity - debety` a s návazností `opening(N) = closing(N-1)`.
- 9 Merkle attestace dne se podepíše a uloží do WORM; partition s daným měsícem se po uplynutí retenčního okna odpojuje do archivu.

Denní rekonsiliace safeguarding účtu je v praxi nejčastější předmět kontroly u EMI — je proto navržena jako blokujiící krok uzávěrky, ne jako report, který si někdo přečte ráno.

Oprava chybného zaúčtování

- 1 Provoz nebo rekonsiliace identifikuje žurnál, který je věcně chybný (například špatný účet příjemce v interním přeúčtování).
- 2 Nikdy se nesáhá na existující řádky — UPDATE i DELETE jsou odepřené grantem i triggerem, takže pokus skončí výjimkou i pro DBA, který si to rozmyslí za běhu.
- 3 Zapiše se žurnál typu reversal: přesně zrcadlový obraz původního (každá noha se stejnou částkou a opačným směrem), s vyplněným `reverses_journal_id`. UNIQUE index zaručí, že stejný žurnál nelze stornovat dvakrát.
- 4 Storno je vždy úplné. Částečná oprava neexistuje — pokud byla správná polovina operace, stornuje se celá a zaúčtuje se nový, správný žurnál. Rekonsiliace tak vždy pracuje s celými událostmi.
- 5 Je-li důvodem opravy nová skutečnost (chargeback, kulance, doučtování), použije se typ adjustment, který podle CHECK constraintu nesmí vzniknout bez `approval_id` ukazujícího na záznam schválení čtyřma očima.
- 6 Oba žurnály se objeví na výpisu klienta jako pár řádků v období, ve kterém byly zaúčtovány — nikdy se nepřegeneruje již vydaný výpis uzavřeného období.
- 7 Souvisí-li oprava s rekonsiliačním breakem, uzavře se break odkazem na `resolution_journal_id`.

Toto pravidlo je organizačně nejkřehčí bod celého návrhu. První krizová noc přinese tlak na 'jen to prosím oprav přímo v databázi'; proto musí existovat schválený a nacvičený postup a technicky odepřená možnost, ne jen dohoda.

Příchozí stablecoin z on-chain vrstvy

- 1 Indexer zachytí příchozí převod na kontrolovanou adresu a založí událost s tx hashem, blokem, kontraktem a částkou v jednotkách kontraktu.
- 2 Částka se převede do minor units ledgeru podle `asset.ledger_scale`, který je z definice `>= contract_decimals` — proto při převodu nevzniká dust a nic se neztrácí. Neznámý kontrakt nebo aktivum bez platného `token_contract` se neúčtuje, jde do karantény.
- 3 Žurnál `onchain_in`: `D onchain:{tier}:{token} / C unsettled_incoming:{token}`. Klientská pozice se zatím nepohnula.
- 4 Po dosažení `min_confirmations` podle `chain_policy` a po průchodu sankčním screeningem a travel-rule kontrolou se zapiše druhý žurnál `onchain_allocate`: `D unsettled_incoming / C client:emt:{účet}:{token}`.
- 5 Dojde-li k reorgu před alokací, stornuje se pouze první žurnál. Klient nikdy neviděl peníze, které by mu musely být odebrány.
- 6 Není-li aktivum v dané jurisdikci a čase nabízetelné (`asset_regulatory_status.eu_offerable = false`), alokace se neprovede a případ jde na compliance — klientská pozice v neautorizovaném EMT se v EU entitě nezaloží.
- 7 Pozice na účtech 2040 tvoří registr pozic podle MiCA čl. 75; nad ním se nejméně čtvrtletně generuje výpis z registru (aktivum, zůstatek, hodnota, provedené převody) stejnou projekční mašinerií jako běžné výpisy.

Rozdělení příjmu na dva žurnály není formalita — je to jediný způsob, jak oddělit fakt 'transakce je v řetězci' od faktu 'patří tomuto klientovi a je konečná', které mají různý čas a různou reverzibilitu.

3.4 Rizika a opatření

Riziko	Opatření v návrhu
Zvolená škála pro token je menší než počet desetinných míst kontraktu (například ledger na 4 místa proti kontraktu se 6). Každý příjem pak ztrácí dust, výběry se neshodují s on-chain zůstatkem a rekonciliace trvale nesedí o rostoucí zbytek.	CHECK vynucený při registraci kontraktu: <code>asset.ledger_scale >= contract_decimals</code> , přičemž decimals se čte přímo z kontraktu, ne z dokumentace. Zobrazovaná škála (produktově 4 místa u XSGD) je samostatný sloupec <code>display_scale</code> a nikdy se nepoužije k výpočtu. Rekonciliace on-chain proti ledgeru běží průběžně, ne měsíčně.
Domovní účty (<code>fee_income</code> , <code>spread_income</code> , <code>fx_position</code> , <code>nostro</code>) se stanou hrdlem — dotýká se jich každá transakce a řádek zůstatku je zamčený po dobu transakce.	Striping na 64 fyzických řádků s výběrem podle <code>hash(request_id)</code> ; přímý přístup na tabulku zůstatků je odepřen a aplikace vidí jen agregační view, takže nelze omylem přecházet jeden stripe. Zátěžový test musí obsahovat scénář 'všichni klienti směňují současně', ne jen paralelní platby mezi klienty.
Idempotenční klíč expiruje dřív, než dorazí opožděný retry (dávkový import, konektor s dlouhým backoffem), a stejná operace se provede podruhé.	Retence klíčů 90 dní pro všechny endpointy hýbající penězi, poté přesun do archivu s trvale drženým UNIQUE indexem na <code>request_id</code> , který se kontroluje na pomalé cestě. Konektory mají tvrdý strop na dobu retry kratší než retence. Do denní rekonciliace patří detekce dvojic žurnálů se shodnou částkou, účty a časem do několika sekund.
Pravidlo 'opravuje se jen stornem' se pod provozním tlakem obejde ruční úpravou v databázi během incidentu.	UPDATE a DELETE jsou odepřené grantem i triggerem, takže selže i privilegovaná session; změna <code>session_replication_role</code> , vypnutí triggeru a jakékoli DDL na ledgerových tabulkách jsou alarmované do SIEM s okamžitým stránkováním. Existuje nacvičený postup pro nouzové přeúčtování (adjustment se čtyřma očima), aby lidé měli legální cestu, kterou použijí.
Ekonomický status měny se reklasifikuje (VES vystoupí z hyperinlace, nebo naopak) a klienti dostanou jinou cenu bez oznámení, případně se rozejde cena zveřejněná se skutečně účtovanou.	Status i sazebník mají intervaly platnosti s EXCLUDE proti překryvu a CHECK(<code>published_at <= valid_from</code>). Kotace ukládá <code>tariff_id</code> i identifikátor použitého statusu, takže každý obchod lze reprodukovat do posledního haléře. Reklasifikace je čtvrtletní rozhodnutí s oznamovací lhůtou, ne vedlejší efekt datového feedu.
Zaokrouhlovací pravidlo není deklarované a systematicky zvýhodňuje jednu stranu; přes miliony operací vznikne částka, kterou musí někdo doplatit.	Režim zaokrouhlení je sloupec v registru aktiv (výchozí half-even), zaokrouhluje se právě jednou při vzniku kotace a zbytek se účtuje samostatnou nohou na <code>rounding_income/expense</code> . Tím je odchylka viditelná jako číslo v účetnictví, ne skrytá v zůstatcích. Property test: přes libovolnou posloupnost operací se celková hodnota systému nezmění nad rámec zaúčtovaných poplatků, <code>spreadu</code> a zaokrouhlovacích řádků.
Souběžné operace nad stejnou dvojicí účtů v opačném pořadí (směna A→B a B→A) generují deadlocky, které se pod zátěží projeví jako selhané platby.	<code>post_journal</code> řadí nohy podle <code>ledger_account_id</code> vzestupně před aplikací zůstatků — deterministické pořadí zámků je součástí brány, ne odpovědnost volajícího. Deadlocky jsou samostatná metrika s prahem; jakýkoli výskyt je defekt brány, ne provozní jev k přežití.
Rozdíl mezi obchodním datem instituce a lokálním časem klienta se v projekcích rozejde a klient v jiném časovém pásmu vidí platbu ve špatném dni nebo měsíci.	<code>booking_date</code> i <code>effective_at</code> jsou obě uloženy, nikdy dopočítané při čtení; <code>booking_date</code> se počítá v pásmu licencované entity. Testy hraničních případů (23:50 v Caracasu, konec měsíce, přechod letního času) jsou povinnou součástí testovacích sad výpisů a uzávěrky.
Klientské prostředky nejsou v okamžiku insolvence právně oddělené, protože ledger sice vede oddělené účty, ale reálné bankovní uspořádání a smluvní dokumentace tomu neodpovídají.	Příznak safeguarded na účtech je pouze evidencí reality; podmínkou spuštění je smluvně potvrzené trust/segregation ujednání s úvěrovou institucí a fyzicky oddělený bankovní účet od účtu vlastních zdrojů. Denní kontrola krytí je blokující krok uzávěrky a její výsledek se archivuje jako doklad pro dohled.
Žurnál nechtěně smíchá právní entity (singapurská matka a litevská dcera) a knihy licencované entity přestanou být samostatně auditovatelné.	Odložený constraint trigger vyžaduje shodný <code>legal_entity_id</code> u všech noh žurnálu. Mezipodnikové pohyby jsou vždy dvojice žurnálů spojená <code>correlation_id</code> přes účty <code>due_to/due_from</code> , jejichž pár se denně rekonciliuje na nulu a nenulový zůstatek je blokující nález uzávěrky.
Ledger se navrhne kolem dnešního tokenu a po rozhodnutí o autorizovaném EMT (USDC/EURC) se ukáže, že volba je zabezpečena v kódu a schématu.	Aktivum, kontrakt, regulační status i nabízetelnost v jurisdikci jsou řádky v tabulkách s intervaly platnosti. Do definice hotového v F1 patří test, který přidá nové aktivum s jinou škálou a jiným řetězcem výhradně migrací dat a projde celou sadou toků — dokud tenhle test neprojde, není token skutečně konfigurovatelný.
Merkle atestace v šedesátisekundových dávkách nechává okno, ve kterém by manipulace nebyla kryptograficky doložená.	Okno je vědomě přijaté a zdokumentované. Kompenzuje se tím, že zápis je možný jen přes bránu bez přímých grantů, logy jsou v odděleném účtu mimo dosah provozních administrátorů a každá DDL změna či zásah do replikačních rolí spouští okamžitý alarm. Délka dávky je konfigurovatelná a lze ji zkrátit za cenu vyšší zátěže podpisové operace.

Riziko	Opatření v návrhu
Přechod z dnešního demo: seedové zůstatky neodpovídají součtu seedových transakcí, takže neexistuje konzistentní výchozí stav, ze kterého by šlo migrovat.	Nemigruje se nic. Cílový systém začíná prázdný a jakýkoli počáteční stav vzniká výhradně žurnálem typu opening proti účtu 3020 opening_balance — tedy podvojně a doložitelně od prvního dne. Demo zůstává oddělenou prezentační simulací a nikdy se nestane zdrojem dat pro ledger.

4. Služby a jejich hranice

Kde vedou řezy mezi službami a proč právě tam. Hranice se obhazuje poloměrem škody, ne módou.

Cílem je systém, kde je hranice každé služby odůvodnitelná před regulátorem, ne před konferenčním publikem. Řezu podle čtyř kritérií a žádného jiného: (1) hranice důvěry a poloměr škody — co se nesmí dostat k penězům ani ke klíčům, když to někdo prolomí; (2) regulatorní režim — co má vlastní auditní stopu, vlastní retenci, vlastní šifrovací klíče a vlastní přístupovou politiku (KYC data vs. peněžní data, PCI rozsah, MLRO nezávislost); (3) rychlost změny vynucená protistranou — vydavatel karet, blockchain, RPC, travel-rule síť a KYC dodavatel se mění jinak často než účetní kniha; (4) povinnost jednoho zdroje pravdy — co musí ležet v jedné ACID transakci, se nesmí rozříznout sítí. Kritérium „autonomie týmu“ jsem vědomě nepoužil: při 14–25 lidech je dvanáct nasazovacích jednotek způsob, jak neuvést nic do provozu. Proto většina domény zůstává jedním nasazovaným modulárním monolitem Core a samostatnými procesy je jen to, co je samostatnou doménou důvěry. Návrh je fázovaný tak, aby fáze F1 přežila jakékoli rozhodnutí o tokenu i jurisdikci — protože podle auditu XSGD ani USDT nejsou v EU autorizované EMT a to rozhodnutí ještě nepadlo.

4.1 Komponenty

Celkem 16 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Core (modulární monolit) — jedna nasazovací jednotka, vynucené hranice modulů

Fáze 1

Drží moduly Ledger, Payments, Pricing/FX, Party&KYC, Cards a Reference Data. Jedna nasazovací jednotka, ale ne jedno bahno: každý modul má vlastní schéma v Postgresu, vlastní migrace, vlastní veřejné rozhraní jako Kotlin interface a zákaz sáhnout do cizí tabulky (vynuceno ArchUnit testem v CI + oddělenými DB rolemi). Party&KYC má navíc vlastní databázi a vlastní KMS klíč — je to jediný modul, který je fyzicky oddělený už uvnitř monolitu.

Technologie: Kotlin/JVM (Spring Boot nebo Ktor), PostgreSQL 16, Flyway, ArchUnit, testcontainers · **Rozhraní:** Ven jen přes BFF (gRPC/mTLS). Dovnitř mezi moduly volání přes interface, synchronně, v jedné transakci tam, kde to invariant vyžaduje. Žádný modul nevystavuje HTTP.

Ledger (modul v Core, nikdy nedělený)

Fáze 1

Jediný zdroj pravdy o penězích. Podvojně append-only zápisy: každý peněžní pohyb je journal s ≥ 2 postings, součet přesně nula v každé měně zvlášť (deferred DB constraint). Částky celočíselné minor units, měna součástí typu, žádný float, žádné implicitní konverze. Žádný UPDATE ani DELETE na zaúčtovaném řádku — jen storno protizápis. Zůstatek je materializovaný agregát z postings, denně rekonziliován přepočtem od nuly. Vede i clearing/suspense účty, safeguarding účty, FX pozice a účty typu Safe Money.

Technologie: PostgreSQL, generated columns pro kontrolu nuly, partitioning postings po měsících, WORM archiv do S3 Object Lock (retence 5 let, req. 9/26) · **Rozhraní:** postJournal(journal_id, legs[], correlation_id) — idempotentní přes unique constraint na (journal_id); getBalance(account_id, currency); listPostings(account_id, range). Nikdy není dosažitelný z internetu ani z admin plane přímo. Multi-měnový journal je jedna transakce, ne saga.

Payments Orchestrator (modul v Core)

Fáze 1

Vlastní životní cyklus příkazu — jeden stavový automat pro VŠECHNY čtyři peněžní cesty (platba, směna, převod mezi vlastními účty, pohyb v Safe Money) a pro on-chain i karetní leg. Stavů: created → quoted → screening → sca_required → authorized → posted → submitted → settled | rejected | failed | reversed | manual_review. Je to orchestrovaná saga, ne choreografie — protože 'kde je moje platba' musí být čitelné z jednoho místa, jinak je to neodladitelné pro ops i pro dohled. Nedrží zůstatky.

Technologie: Kotlin, stavový automat v DB (žádný stav v paměti), Postgres advisory locks per order, tabulka saga_steps s kompenzacemi
 · **Rozhraní:** createOrder(idempotency_key, type, payload) → order; confirmOrder(order_id, sca_assertion); getOrder(order_id).
 Publikuje události OrderPosted/OrderSettled/OrderReversed přes outbox.

Pricing & FX (modul v Core + sdílená deterministická knihovna)

Fáze 1

Jediné místo, kde vzniká cena. Sazebník podle stavu ekonomiky (hyperinflace: spread bez pevného poplatku; mimo: spread + poplatek), kurzový feed, vydávání kotací s quote_id, TTL a podpisem. Přímo zabíjí nález z auditu, že se sazebník uplatňuje jen v jedné ze čtyř peněžních cest — žádná cesta si cenu nepočítá sama, všechny konzumují kotaci. Čistý výpočet je verzovaná knihovna sdílená mezi serverem a klientem (klient ji smí použít jen k předběžnému zobrazení, závazná je vždy serverová kotace).

Technologie: Kotlin knihovna s property-based testy (směna tam a zpět musí být ztrátová, součet vždy nula), redundantní kurzový feed se sanity gate na skok >X % · **Rozhraní:** quote(from, to, amount, side, channel) → {quote_id, rate, spread, fee, expires_at, tariff_key}; bindQuote(quote_id, order_id). Kotace je jednorázová a vázaná na order — nelze ji uplatnit dvakrát.

Party & KYC (modul v Core, ale vlastní DB a vlastní klíče)

Fáze 1

Klient, jeho identita, KYC případ, doklady, rozhodnutí ověřovacího poskytovatele, právní titul (legal_basis) u každé kategorie údajů, retence, práva subjektu. Ledger ani Payments neznají jméno — znají party_id. Tohle je nejlépe obhajitelný řez celé architektury: jiný právní titul, jiná retence, jiné klíče, jiné přístupové role, jiný auditní režim a povinnost omezit práva subjektu kvůli zákazu tipování (req. 27).

Technologie: PostgreSQL s pgcrypto / column-level encryption přes KMS, dokumenty v S3 s SSE-KMS a per-tenant klíčem, KYC provider integrace (Onfido/Sumsb/Veriff) + povinná nebiometrická větev · **Rozhraní:** getParty(party_id), getKycStatus(party_id) → {status, level, expires_at}. Ven vrací minimalizovaný pohled; celé doklady nikdy neopouštějí modul. Ostatní moduly nesmějí číst jeho tabulky (oddělený DB uživatel).

Identity & Access / SCA (samostatný proces)

Fáze 1

Session, silné ověření klienta podle RTS 2018/389, device binding, registr veřejných klíčů zařízení, dynamic linking challenge, step-up, serverový timeout 5 minut nečinnosti, čítač 5 neúspěšných pokusů, revokace. Je oddělený proto, že je jako jediný dosažitelný před autentizací (jiný threat model), musí přežít výpadek Core (klient se přihlásí a uvidí stav i když ledger stojí) a je to místo, které dohled auditovat bude jistě.

Technologie: Kotlin nebo hotové řešení (Keycloak jako základ + vlastní SCA modul), FIDO2/WebAuthn na webu, hardwarově vázaný klíč v Keystore/Secure Enclave na mobilu, Redis pro čítače (fail-closed při výpadku) · **Rozhraní:** OIDC-like: /token, /sca/challenge, /sca/verify. Challenge se generuje ze serverového příkazu (order_id + částka + měna + identifikátor příjemce + nonce), NIKDY z toho, co pošle klient. Vydává token s claimy channel a aal — server nikdy nevěří klientovi, jaký je.

Compliance (samostatný proces: AML/CFT, screening, monitoring, travel rule)

Fáze 1

Sankční a PEP screening, transakční monitoring, case management, hlášení FIU, travel-rule výměna (IVMS101), ověření vlastnictví self-hosted adresy nad 1 000 EUR, on-chain screening protistran. Oddělený proces proto, že nezávislost MLRO je organizační požadavek, který musí být vidět v architektuře: compliance musí umět zadržet a uvolnit platbu bez nasazení Payments, má vlastní DB, vlastní admin UI a vlastní auditní stopu. Fraud engine je uvnitř jako modul s vlastním schématem, ne další služba.

Technologie: Kotlin/Python, pravidlový engine (Drools nebo vlastní DSL), Chainalysis/TRM/Elliptic pro on-chain, Notabene/TRP pro travel rule, Neo4j nebo Postgres pro grafové vazby · **Rozhraní:** Synchronně na kritické cestě: screen(order) → {allow | hold | deny} s tvrdým timeoutem 800 ms a politikou fail-closed. Asynchronně konzumuje OrderPosted pro post-transaction monitoring. Rozhodnutí ven vždy jen jako jeden neinformativní kód (viz chybová taxonomie).

Reference Data & Product Config (modul v Core, ale pod change controlem)

Fáze 1

Registr aktiv a jurisdikcí — a tím i odpověď na blokátor XSGD/USDT. Záznam: {symbol, chain, contract, decimals, regime: EMT|ART|other, mica_authorized, issuer, whitepaper_ref, freeze_capable, transfer_returns_bool, offered_in[], custody_model, rate_feed}. Dále sazebníkové parametry, inflační snímky se zdrojem a datem, jazykové katalogy, feature flags per jurisdikce. Volba tokenu a jurisdikce je konfigurace pod čtyřma očima, ne konstanta v kódu.

Technologie: Postgres + git-backed konfigurace, lint pravidlo v CI zakazující literály 'XSGD'/'USDT' kdekoli mimo registr · **Rozhraní:** Read-only pro všechny moduly, cache s krátkým TTL. Zápis jen přes admin plane se schvalováním dvou osob a auditním zápisem. Konfigurace je verzovaná v gitu a nasazovaná, ne editovaná v produkci.

BFF / Client API (samostatný proces, jeden na rodinu klientů)

Fáze 1

Jediná internetem dosažitelná plocha pro klienta. Kompozice odpovědí (např. jméno z Party + zůstatek z Ledger), verzování veřejného API, terminace Idempotency-Key, rate limiting per credential, překlad interní chybové taxonomie na veřejnou, lokalizace chybových hlášek. Nulová obchodní logika — jakmile do BFF vteče pravidlo, vzniká druhá pravda.

Technologie: Kotlin, OpenAPI generátor typů pro klienta, Envoy/API gateway před ním, Redis pro idempotency store a limity · **Rozhraní:** REST/JSON, OpenAPI-first, /v1/..., problem+json podle RFC 9457. Dovnitř gRPC/mTLS.

Audit & Evidence Sink (samostatná doména důvěry)

Fáze 1

Append-only, hash-chained auditní stopa: kdo, kdy, co, odkud, s jakým výsledkem, u peněžních operací předchozí i nový stav. Oddělný účet/tenant, write-only credentials z aplikace — kompromitace aplikace nesmí umožnit smazání logů (req. 8 to říká explicitně). Sbírá i evidenci podpisových operací (req. 129) a KYC rozhodnutí.

Technologie: S3 Object Lock (compliance mode) + OpenSearch pro dotazy, podepisování dávek, NTP z důvěryhodného zdroje · **Rozhraní:** Jen zápis, přes jednosměrný kanál. Čtení jen z admin plane s vlastní autorizací. Korelační ID prochází celým požadavkem od BFF až po Chain Gateway.

Admin / Back-office plane (samostatná aplikace, samostatná síť)

Fáze 1

Provoz, compliance case management, ruční opravné zápisy se čtyřma očima, reklamace, uvolnění zadržené platby, manuální rozhodnutí u zaseknutého on-chain příkazu, správa limitů, wind-down operace. Není to route v klientském API — je to jiná aplikace s jinou autentizací, jinou sítí a jinou auditní stopou (least privilege a per-request autorizace, req. 6).

Technologie: Kotlin + jednoduché SSR UI, oddělený VPC, povinné MFA + hardware klíč, session bez výjimek · **Rozhraní:** Vlastní gateway, vlastní IdP, PAM/bastion pro přístup. Každá akce vytváří journal v Ledgeru přes stejné API jako zákaznická operace — žádná SQL do produkce.

Notifications (samostatný proces)

Fáze 1

Push, e-mail, SMS, in-app schránka, šablony ve třech jazycích, oddělení transakčních a marketingových sdělení. Šablony procházejí registrem schváleným compliance — MiCA čl. 50 a 53 zakazují formulace typu 'zhodnocení' nebo 'výnos' u EMT a to se musí vynutit v šabloně, ne v hlavě copywritera. Nikdy neblokuje platbu.

Technologie: Kotlin, APNs/FCM, poskytovatel e-mailu a SMS s EU lokalitou dat · **Rozhraní:** Konzumuje události z outboxu, at-least-once, deduplikace na event_id. Žádný synchronní volající.

Dnešní frontend za portem/adaptérem (přežívající aktivum)

Fáze 1

Obrazovky, komponenty, styly, i18n (284 klíčů ve třech jazycích v ověřené paritě), formátování částek a logika srovnání kupní síly zůstávají. Mezi obrazovky a data se vkládá port (LedgerPort, PaymentsPort, PartyPort) s přesně těmi voláními, které bude vystavovat BFF. Dnes je za portem InMemoryAdapter nad stávajícím zustand storem, zítra HttpAdapter. Obrazovky nikdy nesahají na store přímo.

Technologie: React 18, TanStack Query pro serverový stav, zustand jen pro skutečně klientský stav (jazyk, displayCurrency, assetOrder, toast), Vite · **Rozhraní:** TypeScript interfaci generované ze stejné OpenAPI, kterou implementuje BFF — demo a produkt se nemohou rozejít. Peněžní matematika z klienta mizí; klient zobrazuje kotaci, kterou dostal.

Custody (podpisová doména — vlastní cloud účet, vlastní síť, vlastní IAM)

Fáze 2

Domény klíčů hot/warm/cold, policy engine, whitelist výběrových adres s časovým zámekem 24–48 h, prahy a čtyři oči, Key Compromise Protocol, rolling limity objemu. Nemá odchozí konektivitu do internetu a nemá příchozí z aplikační vrstvy jinak než přes jeden úzký, autentizovaný kanál. Doporučení: nestavět, koupit

(Fireblocks/Copper/Zodia) — vlastní MPC s policy engineem je podle revize odhadů 200+ MD, integrace 60–80 MD.

Technologie: MPC/TSS vendor nebo HSM FIPS 140-3 L3, oddělený AWS/GCP účet, žádné sdílené servisní účty, oddělený seed materiál per doména · **Rozhraní:** requestSigning(intent) → {approval_id}; poll approval. Intent obsahuje dekódovaná data volání, ne hash — blind signing je zakázané pravidlem, ne konvencí.

Chain Gateway (samostatný proces)

Fáze 2

Serializace nonce jako jediný zdroj pravdy per adresa, gas a replace-by-fee, broadcast, politika potvrzení a reorg, redundance RPC (min. dva nezávislí poskytovatelé + vlastní node), indexer příchozích depozitů a jejich atribuce klientům, kvirky tokenů (SafeERC20, nestandardní návratová hodnota USDT, freeze/blacklist emitenta), circuit breaker. Oddělený od Custody kvůli poloměru škody: gateway zpracovává nepřátelská data z řetězce a mluví s cizími RPC, podepisovač nesmí.

Technologie: Go (go-ethereum), Postgres tabulka nonce ↔ tx_hash ↔ stav, watchdog na díru v nonce, Hypernative/Fora pro monitoring, mirror monitoring z nezávislé infrastruktury · **Rozhraní:** submit(order_id, signed_tx) — idempotentní na order_id (jeden order = jeden nonce = jeden tx hash). Publikuje ChainTxConfirmed/ChainTxReplaced/ChainTxStuck. Nikdy nevrací 'hotovo' před dosažením konfirmační politiky.

Cards (modul v Core s vlastním síťovým segmentem a PCI rozsahem)

Fáze 2

Životní cyklus virtuální karty, serverové vynucení limitů a zámku (dnes je to jen klientský stav), autorizační rozhraní na vydavatele, zpracování clearingových souborů, settlement rekongiliace, disputes/chargeback. PAN, CVV a PIN v našem systému nejsou vůbec — držíme jen token vydavatele. Tohle je řez, který drží PCI DSS mimo zbytek systému; kdyby karetní data prosákla do Core, spadne pod PCI všechno.

Technologie: Kotlin, integrace na vydavatelského partnera (Marqeta/Enfuze/Paynetics), oddělený VPC segment, tokenizace · **Rozhraní:** Synchronní autorizace s rozpočtem 2 s, fail-closed. Ledger dostává autorizační hold jako postings; clearing je později převádí na finální zápis, nespárované holdy expirují dávkou.

4.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tím kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
Modulární monolit Core + šest samostatných domén důvěry, ne dvanáct mikroslužeb Zvažováno: Plně mikroslužby od začátku: zamítnuto — při 14–25 lidech spotřebuje 30–40 % kapacity provoz platformy místo produktu a distribuovaná konzistence u peněz je nejdražší chyba, jakou lze udělat. Jeden ...	Ledger, Payments, Pricing, Party&KYC, Cards a Reference Data jsou moduly jedné nasazovací jednotky. Samostatnými procesy jsou jen Auth/SCA, Compliance, Custody, Chain Gateway, Audit sink, Admin plane a BFF. Řez musí být zaplacen. Každý z těchto šesti oddělených procesů platí za sebe jiným threat modelem, jinou sítí, jiným auditním režimem nebo jinou organizační nezávislostí — Custody nesmí být dosažitelný z internetu, Compliance musí být nezávislý na release Payments kvůli MLRO, Audit sink musí přežít kompromitaci aplikace, Auth musí být dosažitelný před přihlášením. Rozříznout Ledger a Payments by naopak nekoupilo nic a ...	Jedna sdílená kódová báze a jeden release pro většinu domény — jeden špatný merge zastaví všechno a nasazení musí být disciplinované (blue/green, migrace kompatibilní dopředu i dozadu). Za to: peněžní invariant drží databáze, ne saga. Hranice modulů se vynucují ArchUnit testem a oddělenými DB rolemi, aby pozdější rozdělení šlo provést bez archeologie.
Ledger je jediný zdroj pravdy, podvojný, append-only, v celočíselných minor units Zvažováno: Zůstatek jako sloupec s auditní tabulkou vedle: zamítnuto, je to přesně dnešní stav a rozcáhá se. Event sourcing celého systému: zamítnuto — je to podvojný účetnictví s horší dohledatelností a ...	Zůstatek není sloupec. Každý pohyb je journal s ≥2 postings, součet nula v každé měně, žádný UPDATE ani DELETE, oprava jen protizápisem. Zůstatek je materializovaný agregát rekongilovaný denním přepočtem od nuly. Audit našel tři cesty, kterými dnes hodnota vzniká nebo mizí (platba pod jeden halír, NaN, levnější konverze přes převod mezi vlastními účty), a to je přímý důsledek toho, že zůstatek a historie jsou dvě nezávislé pravdy nad floaty. Rekonstruovatelnost po obnově a rekongiliace nejdou splnit jinak.	Každá funkce, která chce hnout penězi, musí umět vyjádřit svůj záměr jako vyvážený journal — včetně poplatku, který dnes nikam nepřipisujeme. Přibývají účty, které v UI nikdy nebudou vidět (clearing, suspense, FX pozice, safeguarding, výnosový účet poplatků). Postings rostou rychle: partitioning a archivace do WORM úložiště jsou od začátku, ne později.

Rozhodnutí	Volba a důvod	Důsledek
Peníze se hýbou jen synchronně; události popisují minulost, nikdy ji nezpůsobují Zvažováno: Asynchronní účtování s eventual consistency zůstatků: zamítnuto — klient by viděl zůstatek, ze kterého nemůže zaplatit, a compliance by rozhodoval o už provedené platbě.	Zápis do Ledgeru je synchronní transakce. Žádný peněžní pohyb nevzniká zpracováním zprávy z fronty. Události (OrderPosted, OrderSettled, ChainTxConfirmed) nesou informaci o tom, co se už stalo, a slouží notifikacím, monitoringu, reportingu a rekonciliaci. Když peníze vznikají konzumací zprávy, ztráta nebo duplicita zprávy je ztráta nebo duplicita peněz a jediná obrana je idempotence konzumenta — což je obrana, která funguje, dokud ji někdo nezapomene napsat. Synchronní zápis s DB constraintem selhává hlasitě.	Latence peněžních operací je vázaná na dostupnost Ledgeru; při jeho výpadku nelze platit (ale lze se přihlásit a číst z cache). Kritická cesta má tvrdý rozpočet: quote 200 ms, screening 800 ms, posting 300 ms, celkem pod 2 s. Vyžaduje to disciplínu v tom, co na kritickou cestu smí.
Transakční outbox v Postgresu s pollovacím relayem, NATS JetStream jako sběrnice Zvažováno: Debezium/CDC hned: odloženo. Publikace přímo z aplikačního kódu po commitu: zamítnuto, je to přesně ta díra, kterou outbox řeší. Dual write do fronty i DB: totéž, zamítnuto.	Zápis do domény a zápis události do tabulky outbox v jedné DB transakci. Samostatný relay proces publikuje at-least-once. Konzumenti deduplikují na (consumer, event_id) v tabulce processed_events. Řazení per aggregate_id přes partition key. Je to jediný způsob, jak nemít 'zaučtováno, ale neoznámeno' nebo 'oznámeno, ale nezaúčtováno'. Postgres už v systému je; Kafka + Kafka Connect + Debezium přidávají tři provozní systémy navíc dřív, než je kdo umí provozovat.	Latence doručení má podlahu kolem 200 ms (interval pollingu) — pro notifikace a monitoring nevádí, pro nic na kritické cestě se nepoužívá. Relay je nová věc, kterou je nutné monitorovat: zpoždění, poison message, DLQ, a runbook pro zaseknutý relay. Přechod na Kafku je otevřený, ale až proti doložené potřebě (replay pro analytiku, mnoho nezávislých konzumentů).
Orchestrovaná saga v Payments, s tvrdým pravidlem o nekompenzovatelném on-chain kroku Zvažováno: Choreografie přes události: zamítnuto pro nedohledatelnost. Dvoufázový commit přes služby: zamítnuto, nefunguje přes hranice, kde je jednou stranou blockchain nebo vydavatel karet.	Payments je koordinátor. Kompenzace jsou protizápisy v Ledgeru, nikdy mazání. Rezervace prostředků je skutečný posting na clearing účet, ne 'zámek zůstatku'. Po zařazení on-chain transakce do bloku se saga NIKDY nekompenzuje automaticky — přechází do stavu manual_review a rozhoduje člověk se čtyřma očima. Choreografie rozprostře stav platby do pěti služeb a nikdo neumí odpovědět, kde platba je — což je otázka, kterou položí ops i dohled. A automatická kompenzace on-chain nohy při reorgu je způsob, jak si vytvořit vlastní double-spend proti treasury.	Payments je nejsložitější modul systému a bude to tak i za tři roky. Vzniká fronta manuálních případů, která potřebuje back-office nástroj a lidi — to je provozní náklad, ne jednorázový vývoj. Clearing účty musí být denně rekonziliované, jinak se v nich zaseknou peníze, o kterých nikdo neví.
Cena vzniká jen v Pricing a doručuje se jako vázaná kotace Zvažováno: Jen sdílená knihovna bez služby: zamítnuto — knihovna se forkne a kurzový feed i konfigurace sazebníku stejně potřebují běhový komponent. Cena počítaná v BFF: zamítnuto, obchodní logika v BFF je ...	Žádná cesta si nepočítá spread ani poplatek sama. Pricing vydá quote_id s TTL (30–60 s), Payments ji uplatní jednorázově vůči konkrétnímu order. Čistý výpočet je sdílená verzovaná knihovna, ale závazné číslo přichází ze serveru. Audit ukázal cenovou nekonzistenci: stejná konverze CZK→USD stojí přes 'převod na vlastní účet' o 15 000 CZK méně než přes směnu, protože sazebník se uplatňuje jen v jedné ze čtyř cest. Dokud si každá cesta počítá cenu sama, tenhle nález se bude vracet po každém refactoringu.	Každá peněžní obrazovka má o jedno síťové volání navíc a musí umět stav 'kotace vypršela' (chyba state/quote_expired, ne tichý přepočít). Kotace je stav, který se ukládá a expiruje — další tabulka a další úklidová dávka.
Osobní údaje nikdy neopustí Party&KYC a nikdy nevstoupí do Ledgeru Zvažováno: Denormalizace jména do transakcí kvůli rychlosti výpisu: zamítnuto — je to pohodlné pro dva sprinty a nesplnitelné navždy.	Ledger a Payments znají jen party_id a account_id. Jméno, doklady, adresa, biometrie a rozhodnutí ověřovatele leží ve vlastní databázi s vlastním KMS klíčem a vlastní přístupovou rolí. Skládá je až BFF, na základě per-request autorizace. Jiný právní titul, jiná retence, jiný okruh oprávněných osob a povinnost pseudonymizace jako opatření záměrné ochrany. Navíc práva subjektu se u KYC dat omezují kvůli zákazu tipování — to nejde vynutit, když je jméno rozestě v transakčních tabulkách. A on-chain vrstva nesmí obsahovat osobní údaj vůbec.	Každý výpis a každá notifikace potřebuje join přes hranici — BFF skládá, Notifications dostávají jméno až v okamžiku odeslání, ne v události. Události v outboxu nesou party_id, ne jméno. Reporting a analytika pracují s pseudonymizovanými daty a de-pseudonymizace je samostatně auditovaná operace.

Rozhodnutí	Volba a důvod	Důsledek
Chybová taxonomie s compliance kategorií, která je záměrně neinformativní Zvažováno: Podrobné compliance kódy s tím, že je klientská aplikace 'nezobrazí': zamítnuto — jsou v HTTP odpovědi a kdokoli si je přečte.	RFC 9457 problem+json se stabilním code, retryable příznakem a correlation_id. Kategorie validation/*, auth/*, state/*, compliance/*, dependency/*, internal/*, rate/*. Pro compliance existuje navenek jediný kód compliance/operation_unavailable pro zadržení, zamítnutí, sankční shodu i případ vedoucí k hlášení. Skutečný důvod žije jen v ... Zákaz tipování není poznámka pod čarou — je to trestněprávní hranice. Kdyby klient rozlišil 'kontrolujeme' od 'jsi na sankčním seznamu', aplikace se stane oracle pro obcházení sankcí. Zbytek taxonomie existuje proto, aby klient uměl rozhodnout, co dělat: opakovat se stejným idempotency key, opravit vstup, nebo se zastavit.	Podpora klientů dostane hovory, na které nesmí odpovědět — to potřebuje skript a školení, ne technické řešení. Ladění produkčních incidentů se opírá výhradně o correlation_id, které musí procházet celým řetězcem včetně Chain Gateway. Chybový kód je součástí kontraktu: přidat lze, změnit význam nelze.
Idempotence ve dvou nezávislých vrstvách Zvažováno: Idempotence jen na úrovni DB: zamítnuto, klient by nedostal zpět původní odpověď a nevěděl by, jak dopadl. Idempotence jen v Redisu: zamítnuto, výpadek cache = dvojitá platba.	Na hranici: povinná hlavička Idempotency-Key (UUIDv4 per uživatelský záměr, ne per retry), úložiště (key, user_id, endpoint, body_hash) → (status, response) s TTL 7 dní; stejný klíč a stejné tělo = přehraná odpověď, stejný klíč a jiné tělo = 409 idempotency_key_reuse, běžící požadavek = 409 request_in_progress s Retry-After. V hloubce: ... Klíčové úložiště je optimalizace — Redis může vypadnout, TTL může vypršet, klient může klíč zregenerovat. Databázový constraint je záruka. Jedna vrstva na peníze nestačí.	7 dní místo obvyklých 24 hodin znamená větší úložiště klíčů, ale kryje klienta, který je přes víkend offline a retry pošle až v pondělí. Klient musí klíč generovat na začátku uživatelského záměru a držet ho i přes restart aplikace — to je požadavek na klienta, který se musí napsat do kontraktu, jinak ho nikdo nesplní.
Veřejné API verzované v URL na BFF, interní kontrakty proto s testy jako bránou v CI Zvažováno: Verzování v hlavičce nebo přes content negotiation: funkční, ale hůř se ladí, hůř cachuje a hůř se vysvětluje partnerovi. Žádné verzování a jen aditivní změny: iluze, která vydrží do první změny ...	Veřejně /v1/... s podporou N-2 major verzí a minimálně 12 měsíců, hlavičky Deprecation a Sunset, metriky užití per build aplikace. Interně gRPC bez verze v cestě, kompatibilita pravidly protobufu (nikdy nerecyklovat číslo pole, nikdy neměnit význam), vynuceno buď breaking check a kontraktními testy v CI. Události mají registr schémat; ... Mobilní klient nejde aktualizovat okamžitě — store review a uživatelé, kteří neaktualizují. Server tedy musí umět nejstarší povolený build. Zároveň interní služby se musí smět hýbat bez release mobilu, což jde jen tehdy, když je verzování zastaveno na BFF.	BFF nese překladovou zátěž mezi starým klientským tvarem a novým interním modelem — a ta zátěž roste, dokud se stará verze nevypne. Vypnutí je nutné doopravdy provést, ne jen naplánovat; k tomu slouží politika minimální verze aplikace. Klient musí tolerovat neznámá pole a neznámé hodnoty enumů (fallback na 'unknown'), jinak je každý nový typ platby breaking change — a to musí ...
Rate limiting ve třech vrstvách a přísné oddělení od hodnotových limitů Zvažováno: Jeden globální limit: buď zbytečný, nebo rozbíjí legitimní provoz. Limity jen v aplikaci bez edge: neubrání se objemovému útoku, který spotřebuje aplikační vlákna dřív, než se dostane k logice.	Edge (WAF/CDN) per IP proti objemovým útokům. Gateway per credential (device_id a user_id) token bucket, diferencovaný podle třídy endpointu — čtení štedře, peněžní mutace přísně, autentizace velmi přísně. Doménové limity (5 neúspěšných pokusů, karetní limity, rolling limit odchozího on-chain objemu) NEJSOU rate limity a nepatří do ... Limit na IP nechrání proti útočníkovi s botnetem a zároveň zabije celou kavárnu nebo mobilního operátora s CGNAT. Limit '5 pokusů' z RTS je limit vůči uživateli, ne vůči spojení, a musí přežít rotaci IP. A rolling limit objemu peněz gateway neumí vyjádřit vůbec.	Per-user čítače potřebují sdílené úložiště (Redis), které se stává závislostí na autentizační cestě. Politika je asymetrická: při výpadku Redisu se autentizace utahuje (fail-closed), čtení povoluje (fail-open). To je nutné otestovat chaos testem, protože jinak se to zjistí až v incidentu.
Web zůstává, ale jako kapacitní úroveň — ne jako druhý plnohodnotný klient Zvažováno: Zahodit web a jít jen nativně: zahazuje 5 500 řádků funkčního UI, tři jazyky v paritě a jediný kanál, kterým se dnes produkt ukazuje investorům. Postavit web jako plný klient: nesplnitelné vůči req. ...	Dnešní SPA pokračuje ve třech rolích: investorské demo (beze změny), pozdější webový kanál s omezenou schopností (čtení, nízkohodnotové platby) a referenční implementace kontraktu. Vysokohodnotové operace vyžadují nativní aplikaci. Server vynucuje úroveň přes claim channel a aal v tokenu a nikdy nevěří klientovi, čím je. Device binding s hardwarově vázaným neexportovatelným klíčem, kontrola integrity platformy, detekce rootu, atestace a anti-tampering v prohlížeči prostě nejsou. Předstírat, že jdou, znamená postavit SCA na něčem, co RTS neuzná — a tím přenést odpovědnost za neautorizované transakce na sebe.	Dvě sady schopností v jednom API a dvě sady testů. Uživatel na webu naráží na strop a musí být srozumitelně navigován k aplikaci — to je produktová práce, ne chybová hláška. Zároveň to znamená, že web nesmí být nikdy prezentován jako plnohodnotný bankovní kanál.

Rozhodnutí	Volba a důvod	Důsledek
Safe Money a směna nejsou služby — jsou to typ účtu a typ příkazu Zvažováno: Samostatná Savings/Vault služba: zamítnuto z obou důvodů výše, technického i regulatorního.	Safe Money je účet v Ledgeru s vlastním typem, ne samostatná služba s vlastním zůstatkem. Směna je příkaz se dvěma nohami a kotací ve stejném stavovém automatu jako platba. Vklad do Safe Money z jiné měny je jeden journal se čtyřmi postings plus poplatek, v jedné transakci. Kdyby mělo Safe Money vlastní zůstatek v jiné službě, okamžitě padá podvojný invariant a vzniká saga tam, kde stačila transakce. A samostatná 'spořicí' služba je organizační pozvánka k tomu, aby k ní někdo doplnil výnos — což u EMT zakazuje MiCA čl. 50 a co už jednou z produktu vypadlo (odstraněná konstanta 2,4 % p. a.).	Ledger musí umět typy účtů a pravidla, které pohyby mezi nimi jsou přípustné — to je konfigurace v Ledgeru, nikoli kód v Payments. Zákaz odměny vázané na zůstatek nebo dobu držení se musí testovat: v CI běží kontrola, že v katalogu produktů ani v šablonách zpráv neexistuje pole ani formulace odvozená od doby držení.
Volba tokenu a jurisdikce je konfigurace v registru aktiv, ne konstanta v kódu Zvažováno: Rozhodnout token teď a napsat ho do domény: zamítnuto, rozhodnutí není naše a je právní. Abstraktní 'plugin' architektura pro libovolné aktivum: přestřel, registr s adaptéry na chain stačí.	Registr aktiv s příznaky regime, mica_authorized a offered_in[] je jediné místo, kde je zapsáno, co se komu smí nabídnout. BFF filtruje nabídku podle jurisdikce volajícího, Chain Gateway vybírá adaptér a kvírky podle záznamu, Compliance podle něj volí travel-rule protokol, Pricing kurzový feed. V CI běží lint zakazující literály názvů ... XSGD ani USDT nejsou v EU autorizované EMT a rozhodnutí (přechod na USDC/EURC, omezení mimo EU, nebo trvale jen simulace) ještě nepadlo. Kdyby se produkt postavil na jednom symbolu zabezpečeném v doméně, změna po dokončení custody a on-chain vrstvy zahodí desítky čílovkodní.	Každá obrazovka musí umět prázdnou nebo jinou nabídku aktiv — žádné 'XSGD' natvrdo v textu ani v ikoně. Přibývá offboardingová a migrační dávka pro případ, že se aktivum přestane nabízet (a ta je potřeba tak jako tak, kvůli wind-down plánu a povinnosti odkupu). Registr se stává dokumentem, který uvidí regulátor — takže je pod change controlem se čtyřma očima.

4.3 Klíčové toky

Odchozí tuzemská platba s VS/KS/SS (referenční tok, F1)

- 1 Klient vyplní příkaz; klient vygeneruje Idempotency-Key (UUIDv4) na začátku záměru a drží ho i přes restart aplikace.
- 2 BFF ověří token (channel, aal, platnost, serverový timeout 5 min nečinnosti), aplikuje rate limit třídy 'peněžní mutace' a zapíše idempotency záznam ve stavu in_progress.
- 3 Payments vytvoří order ve stavu created a vyžádá si od Pricing kotaci; kotace se váže na order_id, TTL 60 s.
- 4 Compliance provede synchronní screening (protistrana, částka, vzorec chování) s rozpočtem 800 ms a politikou fail-closed; výsledek allow / hold / deny.
- 5 Při hold nebo deny se order končí a klient dostane výhradně compliance/operation_unavailable — bez rozlišení důvodu; skutečný důvod jde do Compliance a do auditní stopy.
- 6 Payments vrátí stav sca_required; Auth vygeneruje challenge ze SERVEROVÝCH dat příkazu (order_id + částka + měna + identifikátor příjemce + nonce), nikoli z toho, co poslal klient.
- 7 Klient zobrazí částku a příjemce z odpovědi serveru (ne z lokálního formuláře) a podepíše challenge klíčem v Keystore/Secure Enclave odemčeným biometrií.
- 8 Auth ověří podpis a vydá assertion vázanou na order_id; jakákoli změna částky nebo příjemce ji zneplatňuje.
- 9 Payments zavolá Ledger: jeden journal — debet běžný účet klienta, kredit clearing účet odchozích plateb, plus samostatný posting poplatku na výnosový účet. Unique constraint na journal_id garantuje, že opakování nezaúčtuje dvakrát.
- 10 Ve stejné DB transakci vzniká řádek v outboxu s událostí OrderPosted.
- 11 BFF uloží finální odpověď k idempotency klíči a vrátí klientovi order se stavem posted.

- 12 Relay publikuje OrderPosted; Notifications pošlou push, Compliance spustí post-transaction monitoring, reporting aktualizuje výkazy — nic z toho neblokuje klienta.
- 13 Po odeslání do platebního systému a potvrzení settlementu Payments zaúčtuje clearing → nostro a přepne order na settled; při vrácení (return) vzniká protizápis a stav reversed.

Kritická cesta má rozpočet pod 2 s a čtyři fail-closed body: SCA, screening, posting a autorizace tokenu. Poplatek má vlastní posting — dnešní demo poplatek strhává a nikam nepřipisuje, což je přesně ta díra, kterou podvojnost zavírá.

Směna VES → XSGD s hyperinflačním sazebníkem (F1, bez on-chain nohy)

- 1 Klient zvolí pár a částku; klient smí zobrazit orientační číslo ze sdílené pricing knihovny, ale závazná je až serverová kotace.
- 2 Pricing určí sazbu: protože alespoň jedna strana páru je podle inflačního snímku v hyperinflaci, uplatní se tarif 'hyper' — spread bez pevného poplatku. Vrací quote_id, kurz, spread, tariff_key a expires_at.
- 3 Payments založí order typu exchange a naváže kotaci; tentýž stavový automat jako u platby, žádná zvláštní cesta — tím se zavírá cenová nekonzistence mezi čtyřmi peněžními cestami.
- 4 Compliance screening a SCA proběhnou stejně jako u platby (u směny nad prahovou hodnotu; pod ní jen screening).
- 5 Ledger zaúčtuje jeden vícemenový journal: debet VES pozice klienta, kredit FX pozice VES, debet FX pozice XSGD, kredit XSGD pozice klienta. Součet musí být nula v každé měně zvlášť — to je databázový constraint, ne kontrola v kódu.
- 6 Rozdíl mezi středovým kurzem a kurzem klienta se zaúčtuje jako spreadový výnos na vlastní účet — spread se tím stává viditelnou a rekonziliovatelnou položkou, ne rozdílem, který se ztratí v zaokrouhlení.
- 7 Order přechází rovnou na settled (interní směna nemá vnější settlement) a publikuje se OrderSettled.
- 8 UI vedle zůstatku zobrazí srovnání kupní síly proti kotvě — počítané z Reference Data (inflační snímek se zdrojem a datem), označené jako rozdíl podle zveřejněné minulé inflace, nikdy jako výnos, úrok ani předpověď.

Standardní (nehyperinflační) spread je dnes jen převzatá zástupná hodnota — v Reference Data musí být označen jako neschválený a Pricing musí umět tarif odmítnout, dokud klient nedodá vlastní číslo. Sazebník bez schválené hodnoty nesmí jít do produkce tisku.

Odchozí on-chain převod stablecoinu — nejsložitější saga (F2)

- 1 Payments založí order typu chain_withdrawal, vyžádá kotaci a ověří v Reference Data, že aktivum je v jurisdikci klienta vůbec nabízetelné (mica_authorized, offered_in).
- 2 Compliance provede on-chain screening cílové adresy (Chainalysis/TRM), rozhodne, zda je protistrana CASP nebo self-hosted, a u self-hosted nad 1 000 EUR vyžádá důkaz vlastnictví adresy (podpis výzvy klíčem k adrese, EIP-191) — důkaz se ukládá v auditovatelné formě.
- 3 Compliance sestaví travel-rule zprávu (IVMS101) a odešle ji protistraně; při chybějících nebo neúplných údajích se order zastaví, nikoli propustí.
- 4 Chain Gateway přečte stav emitenta pro obě strany (isBlackListed u USDT, ekvivalentní flag u XSGD) — zmrazená adresa vede k odmítnutí, nikdy k nekonečné retry smyčce.
- 5 SCA s dynamic linkingem: do challenge vstupuje order_id, částka, aktivum a cílová adresa; klient podepisuje to, co vidí.
- 6 Ledger zaúčtuje debet klientské pozice → kredit clearing on-chain účtu. Tohle je jediný kompenzovatelný krok celé sagy.
- 7 Custody policy engine ověří whitelist adresy (a její časový zámek 24–48 h), rolling limit objemu a prahy pro čtyři oči; podepisuje se až po schválení a vždy nad dekodovanými daty volání, nikdy nad holým hashem.
- 8 Chain Gateway přidělí nonce ze svého serializeru (jeden zdroj pravdy per adresa, perzistentní tabulka nonce ↔ tx_hash ↔ stav), odešle transakci a hlídá ji; při zaseknutí nad prahem T provede replace-by-fee se stejným nonce.

- 9 Po dosažení konfirmační politiky (počet bloků podle hodnoty) publikuje ChainTxConfirmed; Payments zaúčtuje clearing → externí omnibus účet a přepne order na settled.
- 10 Kompenzace je přípustná POUZE tehdy, když transakce nikdy nebyla zařazena do bloku — odmítnuté podepsání, zamítnutí policy engine, trvale neúspěšný broadcast, zásah circuit breakeru. Pak vzniká protizápis clearing → klient a order končí jako reversed.
- 11 Je-li transakce v bloku a stav je nejednoznačný (reorg, sporná konfirmace), order přechází do manual_review a NIKDY se nekompensuje automaticky. Rozhoduje člověk v back-office se čtyřma očima a rozhodnutí jde do auditní stopy.

Circuit breaker v Chain Gateway smí zastavit výběry sám, bez čekání na člověka; odpauzování je naopak záměrně těžké a vyžaduje dvě osoby. Kvartální test breakeru je součástí programu testování odolnosti, ne dobrovolná aktivita.

Vklad do do Safe Money z jiné měny (F1)

- 1 Klient zadá částku ve zdrojové měně a cílové Safe Money v jiné měně — tedy vklad, který je zároveň směnou.
- 2 Pricing určí tarif podle páru zdrojová měna → měna Safe Money; platí přesně stejná sazba jako na obrazovce směny, aby se spread nedal obejít průchodem přes Safe Money.
- 3 Payments založí order typu vault_deposit a naváže kotaci; SCA se vyžaduje podle prahové hodnoty, screening vždy.
- 4 Ledger zaúčtuje JEDEN journal se čtyřmi postings (debet volný zůstatek zdroj, kredit FX pozice zdroj, debet FX pozice cíl, kredit účet Safe Money cíl) plus posting spreadového výnosu. Žádná saga — je to jedna transakce, právě proto, že směna není samostatná služba.
- 5 Účet Safe Money je jen jiný typ účtu téhož klienta; Ledger má pravidlo, že mezi volným účtem a účtem Safe Money téhož vlastníka lze účtovat, a žádný jiný pohyb tam nevede.
- 6 UI ukáže odloženou částku a vedle ní srovnání kupní síly proti kotvě — nikdy formulaci obsahující výnos, zhodnocení, úrok ani úsporu; katalog šablon a i18n klíčů to kontroluje v CI.
- 7 Výběr ze Safe Money běží stejnou cestou opačně, s tím, že se částka navyšuje o spread tak, aby klient dostal na volný zůstatek přesně to, co zadal.

Toto je konkrétní důvod, proč FX nesmí být samostatná služba: kdyby byla, tenhle jediný journal by se rozpadl na sagu se dvěma kompenzacemi a mezistavem, ve kterém peníze nejsou nikde.

Opakovaný požadavek a duplicita — chování idempotence na hranici (F1)

- 1 Klient odešle příkaz s Idempotency-Key K; spojení spadne po odeslání, ale před přijetím odpovědi. Klient neví, jestli se platba provedla.
- 2 Klient opakuje TÝŽ požadavek s TÝMŽ klíčem K (nikoli s novým — klíč je per záměr, ne per pokus).
- 3 BFF najde záznam pro K: je-li ve stavu completed a hash těla souhlasí, vrátí uloženou původní odpověď s hlavičkou Idempotency-Replayed: true. Klient dostane stejný order_id a stejný stav.
- 4 Je-li záznam ve stavu in_progress, BFF vrátí 409 request_in_progress s Retry-After — nikdy nespustí druhé provedení a nikdy nečeká na dokončení prvního.
- 5 Přejde-li týž klíč s JINÝM tělem, vrátí 409 idempotency_key_reuse — to je klientská chyba a musí být hlasitá, ne tiše přepsaná.
- 6 Selže-li úložiště klíčů (výpadek Redisu) a požadavek přesto projde do Payments, zachytí duplicitu druhá vrstva: unique constraint na journal_id v Ledgeru a na order_id v Chain Gateway. Klient dostane chybu, ale peníze se nepohnou dvakrát.
- 7 Asynchronní strana: konzumenti událostí deduplikují na (consumer, event_id) v tabulce processed_events, protože doručení je at-least-once a nikdy exactly-once.

Explicitně: platba pod hodnotu jednoho minor unitu není tichý no-op ani úspěch, ale chyba validation/amount_below_minor_unit. NaN a nečíselné vstupy nemají projít typovým systémem — částka je celočíselné minor units od hranice API až po databázi.

Karetní autorizace v reálném čase (F2)

- 1 Vydavatel volá naše autorizační rozhraní s rozpočtem 2 s; při překročení nebo výpadku se rozhoduje podle předem dohodnutého stand-in pravidla, ne improvizací.
- 2 Cards ověří stav karty (aktivní / zamčená / zrušená) a limity (obchodník, hotovost, internet) SERVEROVĚ — dnešní demo je drží jen v klientském stavu a limit lze bez omezení eskalovat.
- 3 Compliance provede rychlý screening obchodníka a vzorce; fraud modul může autorizaci zamítnout nebo vyžádat step-up.
- 4 Ledger zaúčtuje autorizační hold: debet běžný účet klienta, kredit karetní clearing účet. Dostupný zůstatek klesá okamžitě.
- 5 Odpověď vydavateli: approve / decline s kódem podle karetní specifikace; naše interní taxonomie se sem nepřenáší.
- 6 Clearingový soubor od vydavatele později převádí hold na finální zápis (clearing → karetní settlement účet); rozdíl mezi autorizovanou a zúčtovanou částkou se dorovnává protizápisem.
- 7 Nespárované holdy expirují dávkou po dohodnutém počtu dnů a vracejí se protizápisem — nikdy se nemažou.
- 8 Rekonciliace vůči settlement výpisu vydavatele běží denně; rozdíl nad prahem zakládá případ v back-office.

PAN, CVV ani PIN v našem systému nikdy nejsou — držíme token vydavatele. Dnešní demo je ukládá do localStorage v otevřené podobě; to je nejen PCI problém, ale i důvod, proč musí karetní modul mít vlastní síťový segment od prvního dne, i když je uvnitř Core.

4.4 Rizika a opatření

Riziko	Opatření v návrhu
Modulární monolit se v praxi rozpadne v bahno — hranice modulů existují jen v dokumentaci a za rok je Ledger volaný z pěti míst přímo SQL dotazem. Pak je pozdější rozdělení nemožné a systém má jednu velkou kritickou cestu bez izolace.	Hranice se vynucují strojově, ne domluvou: ArchUnit test v CI zakazující import napříč moduly mimo veřejné interface, oddělení DB uživatelé a schémata (modul nemá GRANT na cizí tabulky), a code owners per modul. Porušení je červené CI, ne poznámka v code review. Čtvrtletně se měří počet výjimek — rostoucí trend je signál rozdělit modul dřív, ne později.
Fail-closed screening s rozpočtem 800 ms udělá z Compliance jediný bod selhání celého platebního styku — vypadne poskytovatel sankčních dat a nikdo nezaplatí ani rohlík.	Trojstupňová degradace: (1) lokální kopie sankčních seznamů aktualizovaná dávkou, dotazovaná lokálně, takže výpadek dodavatele neblokuje základní kontrolu; (2) definovaný stand-in režim s nižším limitem částky a povinným post-transaction přezkumem, schválený MLRO PŘEDEM a zapsaný v politice — ne rozhodnutý v incidentu; (3) tvrdý strop, nad kterým se nezaplatí nikdy, ani ve stand-in. Režim se testuje čtvrtletně jako součást programu odolnosti.
Saga on-chain převodu skončí ve stavu manual_review častěji, než tým čeká, a fronta manuálních případů zahltlíví lidi, kterých je pět. Peníze zůstanou viset na clearing účtech a nikdo neví kolik.	Denní automatická rekonciliace clearing účtů proti stavu v řetězci a proti vydavateli, s tvrdým alertem nad prahem stárí položky (např. >24 h). Metrika 'objem a stárí na clearing účtech' je provozní SLO, ne report. Back-office nástroj pro hromadné dořešení případů se staví SOUČASNĚ s tokem, ne po něm — v odhadech to musí být položka, jinak se škrtne.
Rozhodnutí o tokenu (XSGD/USDT vs. USDC/EURC vs. mimo EU) se odkládá a mezitím se postaví custody, on-chain vrstva a travel rule na předpokladu, který nakonec neplatí. Zahodí se desítky člověkodní a licenční žádost dostane námitku.	Fázování je postavené tak, že F1 (Ledger, Payments, Pricing, Auth, Party&KYC, BFF, Audit, Admin) přežije jakoukoli variantu — on-chain a custody jsou celé ve F2 a nesmí se začít dřív, než rozhodnutí padne písemně. Registr aktiv + lint zákaz literálů názvů tokenů drží doménu neutrální. Rozhodnutí má vlastní termín a vlastního vlastníka; jeho odklad je eskalace, ne stav.
Kotace s TTL 60 s a stav 'quote_expired' zhorší konverzi a produkt začne tlačit na prodloužení TTL nebo na tichý přepočít. Tím se otevře arbitráž na kurzovém pohybu proti nám.	TTL je parametr v Reference Data pod change controlem, ne konstanta v kódu, a jeho změna vyžaduje doložení dopadu na kurzové riziko. Nikdy tichý přepočít — vypršelá kotace je vždy viditelná chyba s nabídkou nové ceny. U hyperinflačních párů je TTL kratší, protože pohyb je rychlejší; to je explicitní pravidlo, ne výjimka.

Riziko	Opatření v návrhu
Compliance kategorie s jediným neinformativním kódem zhorší podporu a tým časem přidá 'jen pro interní použití' podrobnější kód, který se dostane do HTTP odpovědi. Tím vznikne oracle pro obcházení sankcí a porušení zákazu tipování.	Test v CI, který kontroluje, že odpověď z veřejného API pro kategorii compliance/* obsahuje právě jeden povolený kód a žádné doplňkové pole. Podrobnost je dostupná výhradně v Admin plane a v Audit sinku, oboje za jinou autentizaci. Skript pro podporu a školení jsou součástí dodávky, ne dodatek.
Web jako 'kapacitní úroveň' se v praxi rozjede jako plnohodnotný kanál, protože je hotový a nativní aplikace se zpozdí. Vysokohodnotové platby pak poběží na SCA, které RTS neuzná, a odpovědnost za neautorizované transakce ponese instituce.	Strop není v UI, ale v tokenu: server odmítne operaci nad limit, pokud claim aal a channel neodpovídají, a to je testované kontraktním testem. Prahy jsou v Reference Data pod change controlem se čtyřma očima. Produktově se webový strop komunikuje od začátku, aby jeho zvednutí nebylo 'jen konfigurace', ale viditelné rozhodnutí.
Refactoring dnešního frontendu za port/adaptér se odloží 'až bude backend', a mezitím vznikne dalších pár tisíc řádků obrazovek sahajících přímo dozustand storu. Pak je přepis klienta plná cena, ne rozdíl.	Port se zavádí TEĎ, dřív než existuje jediný serverový endpoint, a jeho dnešní implementací je InMemoryAdapter nad stávajícím storem. Kontrakt se generuje z OpenAPI, kterou píšeme z existujících obrazovek — obrazovky jsou nejlepší dostupná specifikace. Lint pravidlo zakáže import useApp mimo adaptér. Vedlejší přínos: peněžní logika se poprvé dá testovat bez Reactu, což zavírá i nález o nulovém pokrytí testy.
Outbox relay se zasekne (poison message, dlouhá transakce, migrace) a přestanou chodit notifikace i post-transaction monitoring — přičemž peníze se dál hýbou, protože ty jdou synchronně. Zjistí se to až při stížnosti klienta nebo při dohledu.	Zpoždění outboxu je první třídy SLO s alertem na stáří nejstaršího nepublikovaného řádku (práh v minutách, ne hodinách), DLQ s povinným denním přezkumem, a runbook pro zaseknutý relay. Compliance monitoring má navíc nezávislou kontrolu: denní sesouhlasení počtu journalů v Ledgeru proti počtu zpracovaných událostí — rozdíl je incident.
Custody se koupí od dodavatele a tím vznikne kritická závislost třetí strany bez exit strategie; DORA to řeší jako riziko ICT dodavatele u kritické funkce a dohled se na to zeptá.	Registr ICT dodavatelů se smluvními doložkami (auditní právo, hlášení incidentů, lokalita dat, subdodavatelé) a doložená exit strategie: dokumentovaný a NACVIČENÝ postup migrace klíčů k jinému poskytovateli nebo do vlastního HSM, včetně odhadu doby výpadku. Klíčové materiály a registr pozic musí být exportovatelné ve formátu, který nezávisí na dodavateli. Nacvičit alespoň jednou před spuštěním, ne až v incidentu.

5. Identita a silné ověření klienta

Kdo právě mluví se serverem, čím to prokázal a co přesně tím schválil.

Tahle oblast odpovídá na jedinou otázku: kdo právě teď mluví se serverem, čím to prokázal, a co konkrétně tím schválil. Cílový stav je server jako jediná autorita nad identitou, relací i autorizací — klient je kurýr důkazů, nikdy rozhodčí; každá peněžní operace má vlastní autorizační grant kryptograficky vázaný na částku, měnu, protistranu a cenu (kurz, spread, poplatek), takže podpis nelze recyklovat na jinou transakci ani na jinou částku. Vrstva je záměrně postavená tak, aby přežila rozhodnutí, která ještě nepadla: volba tokenu (USDC/EURC vs. dnešní XSGD), jurisdikce (Litva vs. jiná), licenční třída i to, jestli poběžíme pod vlastní licenci nebo jako agent — identita, relace, audit trail a čtyřroční automat jsou na tom všem nezávislé a dají se stavět hned, kdežto SCA a device binding mají tvrdou závislost na rozhodnutí o nativním klientovi. Nejdůležitější a v plánech nejčastěji chybějící část není přihlášení, ale obnova přístupu po ztrátě zařízení: je to jediné místo, kde se z designu stává podvodný vektor, a proto má vlastní službu, vlastní stavový automat, vlastní čtyři oči a vlastní SLA. Poslední zásada, která platí napříč: e-mail ani SMS nejsou v tomto návrhu autentizační ani obnovovací faktor — jsou to oznamovací kanály, takže jejich ztráta nesmí a nebude blokovat návrat klienta k jeho penězům.

5.1 Komponenty

Celkem 15 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Identity Store (registr subjektů)

Fáze 1

Kanonická identita klienta jako entita nezávislá na přihlašovacích prostředcích: subject_id, stav životního cyklu (pending / active / restricted / provisional_recovery / frozen / offboarded), jurisdikční profil, úroveň KYC a její platnost, jazyk (CS/EN/ES) a vazba na osobu jako fyzického člověka (person_id) kvůli vynucení pravidla maker≠checker a kvůli detekci vícenásobných registrací. Neobsahuje KYC data — drží jen referenci do odděleného KYC úložiště a strojově čitelný závěr (úroveň, expirace, důvod omezení). Vystavuje KYC úroveň jako tvrdou podmínku, kterou vyhodnocuje autorizační vrstva u každé peněžní operace — dnešní stav, kdy klient se statusem 'none' provede cokoli, tímto zaniká.

Technologie: PostgreSQL ve vlastním schématu s vlastními přístupovými rolemi, oddělené od produktových a KYC dat; šifrování sloupců s osobními údaji klíčem z KMS. · **Rozhraní:** Interní gRPC/REST (subjects.get, subjects.setStatus), události subject.status_changed a subject.kyc_changed na sběrnici, read-model pro PDP. Navenek nic — žádný veřejný endpoint.

Credential Service (znalostní faktor)

Fáze 1

Uchování a ověření znalostního prvku (heslo pro web, PIN pro mobil) — výhradně serverově. PIN se na zařízení neukládá ani lokálně neověřuje; putuje po kanálu chráněném TLS 1.3 s pinningem uvnitř obálky podepsané klíčem zařízení. Autoritativní čítač neúspěšných pokusů podle RTS čl. 4(3)(b) je vázán na dvojici (subject_id, device_id) i na subject samotný, takže reinstalace ani smazání dat aplikace ho nevynuluje. Politika hesel podle ASVS 5.0 kap. 6, kontrola proti breach listu, žádné bezpečnostní otázky, žádné vynucené rotace.

Technologie: Argon2id (m=64 MiB, t=3, p=1) s per-record solí a peppera v KMS/HSM; konstantní čas odpovědi; rate limit na IP, subject i ASN. · **Rozhraní:** Interní API verify(subject_id, device_id, secret, challenge) → {ok, remaining_attempts, logout_until}; nikdy nevrací rozdíl mezi 'neexistuje' a 'špatné heslo'.

Session Manager

Fáze 1

Vydává a ruší relace, vynucuje serverem hlídání idle timeout max. 5 minut pro přístup k platebnímu účtu podle RTS čl. 4(3)(d) a nezávislý absolutní strop, rotuje identifikátor při každé změně úrovně oprávnění, detekuje znovupoužití refresh tokenu (rodina se okamžitě ruší a jde signál do fraud enginu), udržuje seznam aktivních relací a zařízení s

možností vzdáleného odhlášení a jednorázového 'odhlásit všude'. Klíčové oddělení: relace je právo dívat se, autorizační grant je právo hnout penězi — čerstvá relace nikdy nenahrazuje SCA u platby.

Technologie: Krátkodobý access token (≤ 5 min) vázaný na klíč zařízení stylem DPoP; refresh token rotující a jednorázový; na webu __Host- cookie s HttpOnly/Secure/SameSite=Strict, nikdy localStorage; centrální revokační seznam v Redis se záložním čtením z DB.

Rozhraní: POST /session/refresh, DELETE /session/{id}, GET /session/list; každý požadavek nese proof-of-possession podpis klíčem k_dev nad metodou, URI, časem a hashem access tokenu.

Policy Decision Point — autorizace a role

Fáze 1

Per-request autorizace podle RTS 2024/1774 čl. 21 — ne jen na gateway. Vyhodnocuje, zda daný subjekt/zaměstnanec smí na daném účtu provést danou operaci, s ohledem na roli k účtu (owner, spolumajitel, disponent, jen náhled, zmocněnec), KYC úroveň, stav subjektu, karanténu po obnově, jurisdikční profil a limity. Role klienta a role zaměstnance jsou dvě oddělené domény, které se nikdy nepotkávají v jednom modelu.

Technologie: Policy-as-code (OPA/Rego nebo Cedar) verzované v gitu, testované jednotkovými testy politik, nasazované stejnou change-management branou jako kód. · **Rozhraní:** Sidecar / knihovna volaná z každé služby (PEP): decide(principal, action, resource, context) → {allow|deny, policy_version, reasons}; každé rozhodnutí se loguje s verzí politiky.

Audit & Evidence Store

Fáze 1

Nesmazatelná evidence všeho, co se v této oblasti stalo: každý pokus o SCA a jeho výsledek, každý vydaný a spotřebovaný grant včetně podepsaného payloadu a display_textu, každé rozhodnutí o výjimce s právním základem, každý enrollment a revokace zařízení, každý krok obnovy včetně identity schvalujícího operátora, každé schválení čtyřma očima, každé nahlédnutí zaměstnance do klientských dat. Toto je jediný artefakt, kterým se u sporné transakce obhazuje přenos odpovědnosti podle PSD2 čl. 74 — bez něj ztrátu nese poskytovatel.

Technologie: Oddělený účet/tenant, object-lock (WORM) s retencí 5 let, hash chain nad dávkami podepisovaný klíčem v HSM, synchronizovaný čas z důvěryhodného zdroje. · **Rozhraní:** Append-only zápis přes knihovnu s korelačním ID; čtení jen přes auditní rozhraní s logováním čtení; export pro dohled.

Device Registry (registr zařízení a veřejných klíčů)

Fáze 2

Vazba instance aplikace na konkrétní zařízení jako prvek vlastnictví. Drží veřejné klíče (k_dev pro proof-of-possession relace, k_txn pro podpis transakcí), výsledek ověření atestačního řetězce, model a OS zařízení, stav (provisional / trusted / degraded / revoked), datum enrollmentu a poslední úspěšné použití. Odmítne dvě současně aktivní registrace téhož veřejného klíče z různých zařízení a vynucuje strop na počet aktivních zařízení. Ověření atestace probíhá zde a jen zde: Android Key Attestation proti aktuálnímu trust store (pozor na RKP attestation root povinný od 10. 4. 2026) a Apple App Attest.

Technologie: PostgreSQL + vlastní validátor X.509 řetězců s automaticky obnovovaným trust store a CRL; verdikt Play Integrity a App Attest ověřovaný serverem proti Google/Apple, nikdy nepřebíraný od klienta. · **Rozhraní:** devices.enroll (jen z toku enrollmentu se SCA), devices.list, devices.revoke, devices.attest; události device.enrolled / device.revoked / attestation.failed do fraud enginu.

SCA Orchestrator (jediný vydavatel autorizačních grantů)

Fáze 2

Rozhoduje, zda daný záměr vyžaduje SCA, jaké faktory, a vydává jednorázový autorizační grant. Žádná peněžní služba nesmí zaúčtovat operaci bez platného authorization_id vydaného zde. Vede kompletní evidenci každého pokusu o SCA (úspěšného i neúspěšného) pro doložení dohledu. Vynucuje nezávislost prvků podle RTS čl. 9: podpis klíčem k_dev bez uživatelského ověření = vlastnictví, podpis klíčem k_txn odemčeným BIOMETRIC_STRONG = inherence, serverem ověřený PIN = znalost; kombinace se řídí politikou podle typu operace, ne rozhodnutím klienta.

Technologie: Vlastní služba (SCA se nekupuje jako hotový produkt); ověření podpisů ES256 přes knihovnu s pevným whitelistem algoritmů; stav záměrů v PostgreSQL s TTL 120 s a unikátním nonce. · **Rozhraní:** POST /sca/intents (vytvoří záměr, vrátí kanonický challenge), POST /sca/intents/{id}/verify (přijme podpis, vrátí grant), GET /sca/intents/{id}. Interně authorization.assert(authorization_id, operation_hash) — volá ledger před zaúčtováním.

Intent Canonicalizer (dynamic linking)

Fáze 2

Sestavuje z dat, která má server, jediný kanonický a deterministický objekt, který se podepisuje — a zároveň lokalizovaný text, který MUSÍ být na potvrzovací obrazovce zobrazen doslova a beze změny. Do podpisu vstupuje: verze schématu, intent_id (ULID), typ operace, částka v minor units jako celé číslo, měna, normalizovaný identifikátor příjemce (IBAN bez mezer / číslo účtu+kód banky / on-chain adresa / P2P handle), hash normalizovaného jména příjemce, VS/KS/SS u tuzemské platby, SWIFT u zahraniční, u směny navíc kurz + spread + poplatek + platnost kotace, u vkladu do Safe Money obě nohy operace, dále debetovaný účet, nonce, issued_at/expires_at, device_id a display_text v jazyce klienta. Tím je vyřešená celá dnešní třída chyb: náhled ukazující jiné číslo než se strhne, zahozený IBAN/SWIFT, QR platba, která jen zobrazí toast.

Technologie: COSE_Sign1 nad CBOR s deterministickou serializací (RFC 8949 §4.2), případně JWS s předepsaným pořadím klíčů; podpisy ES256 z hardwarového úložiště. · **Rozhraní:** Interní knihovna sdílená mezi SCA orchestrátorem a všemi peněžními službami; jediná implementace serializace (žádná druhá verze v mobilu ani v back-office).

Recovery & Re-enrollment Service (obnova po ztrátě zařízení)

Fáze 2

Samostatná služba s vlastním stavovým automatem pro nejrizikovější tok celé platformy. Řídí šest cest obnovy seřazených podle síly důkazu (druhé zařízení / obnovovací tajemství / opakované KYC s liveness / eIDAS nebo bankovní identita / ověření videohovor se čtyřma očima / doložený papírový postup), spravuje karanténní stav 'provisional' nového zařízení, cooling-off periody, snížené limity, zúžený seznam povolených operací a povinné oznámení do všech historických kanálů. Vynucuje pravidlo, které je pro ochranu proti převzetí účtu nejdůležitější: obnova vrací přístup, ale po dobu karantény nesmí vzniknout nový cíl platby — výplata jde jen na destinaci, která byla whitelistovaná před zahájením obnovy.

Technologie: Vlastní služba nad PostgreSQL s explicitním stavovým automatem a časovači (Temporal nebo vlastní scheduler s idempotentními kroky); integrace na KYC providera a na poskytovatele identity (BankID/Itsme/EUDI Wallet); záznam videohovoru do WORM úložiště. · **Rozhraní:** POST /recovery/start, /recovery/{id}/prove (per metoda), /recovery/{id}/approve (back-office, maker-checker), GET /recovery/{id}/status; události recovery.started/approved/rejected do fraud engine a do notifikací.

Staff IdP a PAM (identita zaměstnanců)

Fáze 2

Oddělený identity provider pro zaměstnance a administrátory. Povinný phishing-odolný faktor (WebAuthn/FIDO2 hardwarový klíč), žádná cesta přes heslo samotné, žádné SMS OTP. Oddělené účty pro běžnou a administrátorskou práci, just-in-time eskalace s časovým omezením a nahráváním relace, čtvrtletní recertifikace práv. Podpora nemá a nikdy nesmí mít oprávnění resetovat klientovi autentizační prostředek jedním klikem.

Technologie: Keycloak nebo Entra ID / Okta podle cloudové volby; PAM (Teleport nebo cloud-nativní) pro přístup k produkci; YubiKey nebo ekvivalent jako povinný token. · **Rozhraní:** OIDC pro interní nástroje, SCIM pro provisioning, audit události do SIEM.

Maker-Checker Engine (čtyři oči u interních akcí)

Fáze 2

Čtyři oči jako doménový stavový automat, ne jako zaškrtnutí v UI. Každá riziková interní akce je objekt se stavy DRAFTED → PENDING_APPROVAL → APPROVED → EXECUTED / REJECTED / EXPIRED. Vynucuje maker≠checker na úrovni person_id (ne účtu), požaduje u schvalovatele jinou roli, nechává schválení kryptograficky podepsat WebAuthn asercí nad TÝMŽ kanonickým payloadem, jaký používá dynamic linking u klienta, a při jakékoli změně payloadu ruší dosavadní schválení. Pokrývá: ruční opravné zápisy do ledgeru, refundace, zmrazení a odmrazení účtu, override KYC, override limitu, schválení obnovy zařízení cestou R5/R6, změnu sazebníku, změnu SCA politiky a prahů výjimek, přidání adresy do firemního whitelistu, přidělení role zaměstnanci, eskalaci přístupu do produkce.

Technologie: PostgreSQL s optimistickým zamykáním, WebAuthn aserce ukládané jako důkaz, hash payloadu jako klíč schválení. · **Rozhraní:** operations.propose / approve / reject / execute; webhooky do notifikací a do SIEM; break-glass cesta s jedním schvalovatelem, která automaticky zakládá P1 incident a vyžaduje dodatečné schválení do 24 hodin.

Exemption Engine a evidence výjimek ze SCA

Fáze 2

Rozhoduje o uplatnění výjimek podle RTS čl. 10–18 a o každém rozhodnutí vede nesmazatelný záznam. Autoritativní kumulativní čítače na serveru pro výjimku nízkých částek (čl. 16), registr důvěryhodných příjemců (čl. 13 — přidání do seznamu samo vyžaduje SCA a má 24h cooling-off), opakující se platby (čl. 14), převody mezi vlastními účty téhož poskytovatele (čl. 15). Výjimka je právo, ne povinnost: politika se dá vypnout per korridor, měna nebo segment —

pro hyperinflační koridor (VES) je výchozí stav 'žádné výjimky'.

Technologie: Rozhodovací pravidla jako konfigurace s verzí; čítače v transakční DB (ne v cache), rekonzilované nočním přepočtem; property testy na to, že čítač po SCA skutečně padá na nulu. · **Rozhraní:** Interně volané SCA orchestrátorem: `evaluate(intent) → {required | exempt, legal_basis, evidence}; append-only tabulka sca_decisions s retencí 5 let.`

Fraud & Risk Engine (příjem signálů, step-up, TRA)

Fáze 2

Přijímá bezpečnostní signály z klienta (root/jailbreak, selhání atestace, hookovací framework, nahrávání obrazovky, neznámá accessibility služba, změna biometrického zápisu, reinstalace, změna zařízení) i ze serveru (nová registrace zařízení, zahájená obnova, změna kontaktu, zvýšení limitu, nový důvěryhodný příjemce, znovupoužití refresh tokenu, nemožné cestování, neobvyklý příjemce pro daný koridor) a rozhoduje o odezvě: tiché skóre → step-up SCA → cooling-off na konkrétní schopnost → degradace na read-only → zmrazení a kontakt mimo pásmo. Ve fázi 3 sem přibude transaction risk analysis podle čl. 18 včetně měření vlastní míry podvodů a pololetního reportingu.

Technologie: Pravidlový engine nad streamem (Kafka/Redpanda) s deterministickými pravidly ve fázi 2 a modelem až tehdy, kdy budou data; verze modelu součástí každého rozhodnutí. · **Rozhraní:** POST /telemetry/security (z klienta, autentizované), interní `risk.score(intent|event) → {score, action, model_version}; feed do SIEM.`

Mobilní bezpečnostní SDK (iOS + Android)

Fáze 2

Klientská polovina celé vrstvy: generování a používání neexportovatelných klíčů (k_dev bez uživatelského ověření, k_txn s BIOMETRIC_STRONG / .biometryCurrentSet a setInvalidatedByBiometricEnrollment), podpis kanonického payloadu, vykreslení potvrzovací obrazovky výhradně z podepsaného display_textu, ochrana rozhraní (FLAG_SECURE, filtrování dotyků při překrytí, blur při přechodu na pozadí), sběr integritních signálů a jejich odeslání serveru. SDK nikdy nerozhoduje o úspěchu autentizace — jen shromažďuje důkazy.

Technologie: Android: KeyGenParameterSpec se setIsStrongBoxBacked(true) a fallbackem na TEE, BiometricPrompt s CryptoObject, Play Integrity. iOS: kSecAttrTokenIDSecureEnclave, ECC P-256, SecAccessControl, App Attest. Kritická logika v nativním kódu, R8/ProGuard a obfuskace v release. · **Rozhraní:** Nativní API pro aplikaci: `enroll()`, `sign(intent)`, `unlock()`, `securityTelemetry()`; žádné veřejné API vracející boolean 'autentizace OK'.

Notifikační a out-of-band kanál

Fáze 2

Doručuje klientovi bezpečnostní události (přihlášení z nového zařízení, zahájená obnova, změna kontaktu, změna limitu, neúspěšné pokusy, nový důvěryhodný příjemce) a nese kill-switch 'tohle jsem nebyl já', který zmrazí účet a zruší všechny relace a zařízení jedním klepnutím — dostupný z notifikace bez plného přihlášení. Zmrazení je snadné a jednostranné, odmrazení je maker-checker. Push notifikace na zamčené obrazovce nikdy neodhalují částky ani identifikátory. Kanál je vždy jen oznamovací — nikdy nenese autorizaci.

Technologie: APNs/FCM s obsahem doručovaným až po otevření aplikace; e-mail a SMS jako sekundární, nikdy jako nositel odkazu, který cokoli povoluje. · **Rozhraní:** POST /notify (interní), veřejný signed deep-link pouze pro akci 'zmrazit'; tři jazyky ze serveru.

5.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tím kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
ADR-01: Identita, přihlašovací prostředek a zařízení jsou tři oddělené entity Zvažováno: Jeden model 'user' s poli pro klíč a token, jak to dělá většina IdP šablon. Prohrálo, protože do něj nejde přidat druhé zařízení, spoludisponent ani karanténní stav po obnově bez destruktivní migrace ...	Datový model rozdělíme na subject (kdo to je), credential (čím to prokazuje) a device (odkud a s jakým klíčem). Žádná z nich není cizí klíč té druhé v poměru 1:1. Klient smí mít víc zařízení, smí je vyměnit a smí mít víc rolí k víc účtům (rodinný scénář: matka v Caracasu a syn v Madridu na jednom sdíleném účtu). Dnešní demo má jediný boolean authed, což je model, ze kterého se k tomuhle nedá dojít inkrementálně.	Zavazuje nás k tomu, že revokace zařízení není totéž co odhlášení a že smazání přihlašovacího prostředku nemaže identitu — což je nutné kvůli AML retenci. Nevýhoda: složitější dotazy, tři místa, kde se dá udělat chyba v konzistenci, a povinnost udržovat person_id kvůli maker#checker, což je další osobní údaj navíc.

Rozhodnutí	Volba a důvod	Důsledek
ADR-02: SCA orchestrátor stavíme sami, IdP kupujeme Zvažováno: (a) Celý balík od jednoho dodavatele (OneSpan, Entersekt) — rychlejší, ale zamyká nás do dodavatele u nejcitlivější funkce a podle DORA čl. 28–30 vyžaduje exit plán, který u takové komponenty ...	Registraci, hesla, e-mail/telefon verifikaci a zaměstnanecké SSO postavíme nad hotovým IdP (Keycloak nebo Ory Kratos, u zaměstnanců klidně Entra/Okta). Samotné SCA — rozhodnutí o faktorech, challenge, dynamic linking, výjimky, evidence — bude vlastní služba. Žádný běžný IdP neumí dynamic linking podle RTS čl. 5 ani evidenci výjimek podle čl. 3(2). Produkty, které to tvrdí, jsou buď karetní 3-D Secure, nebo obecné MFA, a ani jedno nepokrývá vazbu podpisu na kurz a spread, kterou LargoVerse potřebuje kvůli směně a Safe Money.	Zavazuje nás k tomu, že SCA vrstvu musí umět udržovat vlastní tým — je to trvalý závazek, ne jednorázová integrace, a bude předmětem penetračního testu i dotazů regulátora. Cena: 2–3 člověkoměsíce navíc oproti hotovému řešení a nutnost mít od začátku bezpečnostního inženýra, ne jen backend vývojáře.
ADR-03: Prvek vlastnictví je neexportovatelný klíč v hardwaru s atestací, ne SMS ani e-mail Zvažováno: SMS OTP jako druhý faktor — levné, EBA ho stále uznává, ale v našich koridorech je to nejslabší článek a zároveň nákladová položka rostoucí s objemem. Push-approval bez podpisu — nesplní dynamic ...	Vlastnictví prokazuje podpis klíčem vygenerovaným uvnitř StrongBox/TEE resp. Secure Enclave, jehož původ server ověřil atestačním řetězcem. SMS OTP, e-mailový kód ani magic link nejsou v tomto systému autentizační faktor v žádné roli. SIM swap je v cílových trzích (Venezuela, LatAm, migrantské komunity) běžný a levný útok, e-mailová schránka je typicky první, co útočník převezme. Klíč, který nešel z hardwaru ven, se nedá zkopírovat na útočnickovo zařízení a klonovaná instance aplikace je rozeznatelná.	Zavazuje nás k nativnímu klientovi — dnešní React SPA tuhle vlastnost nemá čím splnit. Zároveň to znamená, že selhání atestace je provozní problém: zařízení bez Google Play Services (v LatAm nezanedbatelný podíl) musí mít definovanou degradační cestu, jinak jim produkt nefunguje. Cena je celá jedna komponenta (mobilní SDK) a QA matice reálných zařízení.
ADR-04: Podepisuje se serverem sestavený kanonický objekt, jehož součástí je i text zobrazený uživateli Zvažováno: Podepisovat jen hash transakce a text nechat na klientovi — jednodušší, ale při sporu nemáme čím doložit, co klient viděl. Podepisovat strukturovaná data bez display_textu a text generovat na ...	Klient nikdy nesestavuje, co podepisuje. Server vytvoří intent, z něj deterministicky serializovaný payload včetně lokalizovaného display_textu, a mobilní SDK vykreslí potvrzovací obrazovku výhradně z tohoto textu. Klasické selhání WYSIWYS je 'zobrazím A, podepíšu hash B'. Když je zobrazovaný text uvnitř podpisu, máme v auditu doložitelné, co přesně klient viděl — ve svém jazyce — a spor o neautorizovanou transakci se dá vůbec rozhodnout. U LargoVerse to navíc řeší produktovou past: podepisuje se i kurz, spread a poplatky, takže se kotace nemůže mezi náhledem a zaúčtováním změnit.	Zavazuje nás k jediné implementaci serializace pro server, iOS i Android — jakákoli druhá kopie je zdroj nedeterminismu a falešně neplatných podpisů. Zavazuje nás také k tomu, že lokalizace potvrzovacích textů je serverová záležitost, takže i18n přetává být čistě klientský problém. Nevýhoda: každá změna produktového textu na potvrzovací obrazovce je změna podepisovaného ...
ADR-05: Biometrie neuvolňuje tajemství, biometrie je podmínka použití klíče — a nikdy neopustí zařízení Zvažováno: Biometrie na serveru (face match při každé platbě) — silnější v teorii, ale je to zpracování zvláštní kategorie údajů s povinným výslovným souhlasem, povinnou nebiometrickou alternativou a od 2. 8. ...	Biometrický údaj se nikdy nepřenáší ani neukládá na server. Inherence se prokazuje tím, že se povedl podpis klíčem, který má setUserAuthenticationRequired(true) s AUTH_BIOMETRIC_STRONG, resp. SecAccessControl s .biometryCurrentSet. Výsledek callbacku onAuthenticationSucceeded nemá pro server žádnou hodnotu. Callback se přehookuje za pár minut na rootnutém zařízení; podpis klíčem, který systém neodemkne bez Class 3 biometrie, ne. Zároveň tím zůstáváme mimo čl. 9 GDPR — na serveru žádná biometrická šablona neexistuje, takže odpadá potřeba výslovného souhlasu i většina povinností AI Actu.	Zavazuje nás k tomu, že změna biometrického zápisu na zařízení (přidání otisku, nový obličej, někdy i větší aktualizace OS) klíč zneplatní a klient je z pohledu systému bez prvku inherence. To je pravidelný provozní jev, ne výjimka — musíme mít nízkotřecí tok pro znovuvytvoření k_txn, jinak nám podpora zahltí. Cena: jeden celý tok navíc a nutnost odlišit ho od skutečné obnovy ...
ADR-06: PIN se ověřuje na serveru, ne na zařízení Zvažováno: PIN derivuje lokální klíč přes Argon2id — plynulejší offline zážitek, ale kontrola se stává klientskou a limit pokusů nevymahatelným. Hybrid s lokálním i serverovým čítačem — zvažován, zamítnut jako ...	Znalostní prvek putuje na server (uvnitř kanálu s pinningem a v obálce podepsané k_dev) a ověřuje se proti Argon2id hashi. Lokální offline ověření PINu neexistuje. Čítač pěti neúspěšných pokusů podle RTS čl. 4(3)(b) musí být autoritativní na serveru a musí přežít reinstalaci aplikace. Lokální ověření dává útočníkovi s odcizeným telefonem neomezené offline pokusy a čítač se resetuje smazáním dat aplikace.	Aplikace bez konektivity neumožní ani přihlášení — což je u produktu cíleného na Venezuelu s nestabilním připojením reálná UX cena. Kompenzujeme tím, že read-only pohled na poslední známé zůstatky je dostupný po biometrickém odemčení lokálně, ale je zřetelně označen jako neaktuální a žádná peněžní operace z něj nejde.

Rozhodnutí	Volba a důvod	Důsledek
ADR-07: Relace a autorizace jsou dvě různé věci s různou životností Zvažováno: Jedna dlouhá relace s 'čerstvostí' jako atributem (step-up podle stáří autentizace) — běžné řešení, jednodušší, ale nesplňuje dynamic linking, protože čerstvost není vázaná na částku a příjemce.	Přihlášení vydá relaci s idle timeoutem 5 minut; každá peněžní operace navíc vyžaduje samostatný, jednorázový autorizační grant ze SCA orchestrátoru s TTL 120 sekund, vázaný na konkrétní intent. RTS čl. 4(3)(d) mluví o přístupu k účtu, čl. 5 o autorizaci transakce — jsou to dva různé požadavky a slévat je do jedné 'session' vede buď k porušení jednoho, nebo k nepoužitelnému produktu. Oddělení navíc znamená, že ukradený access token sám o sobě nepohne penězi.	Zavazuje nás k tomu, že žádná peněžní služba nesmí mít cestu k zaúčtování bez authorization_id — to je invariant, který musí být vynucen v ledgeru (cizí klíč a kontrola hashe operace), ne jen v aplikační vrstvě. Nevýhoda: víc kulatých cest na server a znatelně složitější testování.
ADR-08: Výchozí stav je SCA; výjimka je explicitní, konfigurovatelná a evidovaná Zvažováno: Žádné výjimky vůbec — regulatorně nejbezpečnější, ale u P2P mikroplateb a opakovaných remitencí produkčně neúnosné. Výjimky rovnou včetně TRA — nelze, prahy čl. 18 se odvozují od doložených ...	Exemption engine vrací 'required', pokud pravidlo výslovně nesplní podmínky konkrétního článku RTS. Každé rozhodnutí o výjimce má append-only záznam s právním základem, doloženými podmínkami a verzí politiky. Pro hyperinflační koridor jsou výjimky ve výchozím stavu vypnuté. Výjimka implementovaná jako 'když je to malé, přeskoč SCA' je díra, ne výjimka — a při sporu se bez evidence neobhájí. Zároveň je výjimka obchodní nástroj: pro rodinné remitence do Venezuely je čl. 13 (důvěryhodní příjemci) přesně ta věc, která z produktu udělá použitelný produkt, protože sestra v Caracasu se přidá jednou se SCA a pak už chodí platby bez tření.	Zavazuje nás vést autoritativní kumulativní čítače v transakční databázi (ne v cache) a nočně je rekonciliovat; chyba v čítači je tichý únik peněz bez SCA. Zavazuje nás také k tomu, že přidání důvěryhodného příjemce má vlastní SCA a 24h cooling-off — jinak je z výjimky nejrychlejší cesta k převzetí účtu. Transaction risk analysis podle čl. 18 odkládáme do fáze 3, protože ...
ADR-09: Obnova přístupu není samoobsluha a nikdy nevrací plnou důvěru okamžitě Zvažováno: Okamžitá plná obnova po úspěšném re-KYC — hladké, ale liveness se dnes obchází deepfakem a v kombinaci s uniklým dokladem je to celý útok. Trvalé zablokování a nutnost fyzické návštěvy — bezpečné, ...	Nové zařízení po obnově vstupuje do stavu 'provisional' s úzkou množinou povolených operací a cooling-off periodou 24–72 hodin podle síly použité cesty obnovy. Po dobu karantény nelze vytvořit nový cíl platby ani zvýšit limit; výplata je možná jen na destinaci whitelistované před zahájením obnovy. Obnova je nejčastější podvodný vektor v mobilním bankovníctví a zároveň nejsilnější existující oprávnění v systému — kdo ji zvládne, obejde všechno ostatní. Karanténa mění ekonomiku útoku: útočník musí uspět v obnově a pak ještě přežít 72 hodin, během kterých je skutečný majitel opakovaně informován všemi historickými kanály.	Zavazuje nás k tomu, že legitimní klient s rozbitým telefonem nemůže tři dny poslat peníze rodině — to je reálná bolest, kterou musíme kompenzovat aktivním tlakem na registraci druhého zařízení nebo bezpečnostního klíče už při onboardingu (cesta R1 je okamžitá a bez karantény). Zavazuje nás také k tomu, že karanténní pravidla musí vynucovat PDP, ne UI.
ADR-10: E-mail a telefon nejsou obnovovací faktor Zvažováno: E-mail jako záložní faktor — běžná praxe, ale je to nejsnáze převzatelný kanál a v cílových trzích často sdílený v rámci rodiny. Bezpečnostní otázky — zamítnuty jako veřejně dohledatelné znalosti.	Kontaktní kanály slouží k oznamování a k doručení kill-switchu. Žádná cesta obnovy nezávisí na tom, že klient má přístup do schránky nebo k číslu. Změna kontaktu je naopak sama SCA operace s 24h cooling-off a s oznámením na starý kanál. Otázka 'co když klient ztratil telefon i e-mail' má v drtivé většině návrhů odpověď 'smůla' právě proto, že se e-mail používá jako kotva. Když se kotvou udělá něco, co ztratit nejde — doklad totožnosti, druhé zařízení, obnovovací tajemství, národní eID — je odpověď na tuhle otázku triviální: obnova probíhá úplně stejně.	Zavazuje nás k tomu, že onboarding musí vydat obnovovací tajemství a přesvědčit klienta, aby si ho uložil mimo telefon — což je notoricky špatně přijímaný krok a bude potřebovat kvalitní UX a lokalizaci do tří jazyků. Zavazuje nás také k tomu, že podpora nikdy nesmí měnit kontakt na základě telefonátu, i když klient zní zoufale.
ADR-11: Čtyři oči jsou stav operace podepsaný schvalovatelem, ne příznak v databázi Zvažováno: Čtyři oči jen v back-office UI — levné, ale obejitelné přímým voláním API nebo SQL. Čtyři oči jen u peněžních operací — nedostatečné, protože změna SCA politiky nebo přidělení role je stejně ...	Riziková interní akce je objekt se stavovým automatem; schválení je WebAuthn aserce nad hashem téhož kanonického payloadu, který se použije při provedení. Změna payloadu ruší schválení. Maker≠checker se vynucuje na person_id. Boolean approved_by nemá důkazní hodnotu — administrátor databáze ho přepíše a auditor to ví. Podepsané schválení nad hashem payloadu je doložitelné a znemožňuje klasický podvod 'schválím převod na 100 EUR, provedu na 100 000'.	Zavazuje nás k hardwarovým klíčům pro každého zaměstnance s právem schvalovat a k tomu, že provoz bez druhého člověka se prostě zastaví — s dnešním týmem o jednom vývojáři to není splnitelné vůbec a je to organizační, ne technický blokátor. Cena je také latence provozu: každá ruční oprava trvá minimálně tak dlouho, jak dlouho trvá sehnat druhého člověka.

Rozhodnutí	Volba a důvod	Důsledek
ADR-12: Nativní iOS a Android klient je předpoklad, web je oddělený produkt s vlastním posouzením Zvažováno: PWA s WebAuthn — hardwarově vázané klíče ano, ale bez atestace instance aplikace, bez ochrany obrazovky a bez detekce integrity platformy; jako jediný klient regulatorně neobhajitelné. Hybridní ...	Produkční klient jsou nativní aplikace (nebo React Native s nativními bezpečnostními moduly). Web zůstane buď informační, nebo jako plnohodnotný klient s vlastní vrstvou postavenou na passkeys a s odděleně posouzeným rizikovým profilem a nižšími limity. Secure Enclave, StrongBox, atestace, FLAG_SECURE a ochrana proti overlay nemají na webu ekvivalent. RTS čl. 9(3) požaduje oddělené bezpečné prováděcí prostředí, kontrolu integrity a mitigaci — v prohlížeči nelze splnit ani jedno.	Zavazuje nás k přepisu všech dnešních obrazovek proti serverovému API a k dvojitým vývojovým i QA nákladům; podle vlastního auditu je to druhá největší položka celého plánu a odhady kolem 190 člověkodní jsou podstřelené. Zároveň to určuje pořadí: dokud není nativní klient, nemá smysl stavět SCA orchestrátor v jiné než testovací podobě.
ADR-13: Volba tokenu a jurisdikce se do identitní vrstvy promítá jako politika, ne jako kód Zvažováno: Zapéct dnešní produktové rozhodnutí a refaktorovat později — levnější dnes, ale podle vlastního auditu je právě tohle scénář, který zahodí desítky člověkodní práce ve chvíli, kdy padne regulatorní ...	Subjekt nese jurisdikční profil a účet nese aktivový profil; z nich se odvozuje, které operace vyžadují SCA, jaké limity platí, jestli je nutné ověření kontroly self-hosted adresy a jaké výjimky jsou povolené. Nikde v kódu identitní vrstvy není napsáno XSGD, USDT, USDC ani Litva. Rozhodnutí o autorizovaném EMT a o jurisdikci ještě nepadlo a padnout může jinak, než dnes vypadá. Identitní vrstva je zároveň to jediné, co se dá stavět hned — pokud do ní token zapečeme, zahodíme ji spolu s rozhodnutím.	Zavazuje nás k tomu, že politiky jsou verzované artefakt s vlastními testy a vlastní change-management branou, a že každé autorizační rozhodnutí nese verzi politiky, podle které padlo. Nevýhoda: víc konfigurace znamená víc míst, kde se dá udělat chyba, a nutnost mít testy politik, ne jen testy kódu.

5.3 Klíčové toky

Registrace a onboarding prvního zařízení

- 1 Klient v aplikaci zadá e-mail nebo telefon a heslo/PIN; server založí subject ve stavu pending a odešle ověřovací kód do zadaného kanálu — to je jediné místo, kde e-mail nebo SMS něco ověřuje, a ověřuje jen dosažitelnost kanálu, ne totožnost.
- 2 Mobilní SDK vygeneruje uvnitř StrongBox/Secure Enclave dva neexportovatelné páry klíčů: k_dev bez uživatelského ověření a k_txn s podmínkou BIOMETRIC_STRONG a invalidací při změně biometrického zápisu.
- 3 Aplikace odešle veřejné klíče spolu s atestačním řetězcem (Android Key Attestation) nebo App Attest asercí a s verdiktem Play Integrity; Device Registry celý řetězec ověří proti aktuálnímu trust store a odmítne cokoliv, co nepochází z hardwaru.
- 4 Klient projde KYC u ověřovacího poskytovatele (OCR dokladu, kontrola pravosti, liveness, porovnání obličeje) nebo rovnocennou nebiometrickou cestou (videohovor, bankovní identita, ověřovací platba), a server — ne klient — rozhodne o schválení.
- 5 Server vydá klientovi obnovovací tajemství (jednorázově zobrazený kód) a aplikace ho donutí ho přepsat zpět, aby bylo doloženo, že si ho klient skutečně uložil; zároveň se aktivně nabídne registrace druhého zařízení nebo FIDO2 klíče.
- 6 Subject přechází do stavu active, zařízení do stavu trusted, do Audit Store jde záznam s hashem veřejných klíčů a s výsledkem atestace, a klientovi odchází uvítací notifikace se seznamem toho, co banka nikdy nebude vyžadovat telefonicky.

Enrollment je jediný okamžik, kdy se dá levně vyřešit celý problém obnovy — každý klient, který odejde z onboardingem s druhým zařízením nebo s uloženým obnovovacím tajemstvím, je klient, kterého později nebudeme vracet zpět třídním procesem. Konverzní tlak na tenhle krok je nejlevnější bezpečnostní investice v celém produktu.

Přihlášení se silným ověřením klienta

- 1 Aplikace požádá o challenge; server vygeneruje nonce vázaný na device_id a na účel LOGIN s TTL 120 sekund.
- 2 SDK podepíše challenge klíčem k_dev (prvek vlastnictví) a současně požádá systém o odemčení k_txn biometrií Class 3 a podepíše challenge i tímto klíčem (prvek inherence); pokud klient biometrii nepoužívá, místo druhého podpisu se odešle PIN v obálce podepsané k_dev (prvek znalosti).
- 3 Server ověří oba podpisy proti registrovaným veřejným klíčům, ověří, že zařízení není revokované a že atestační verdikt v posledním okně nepadl, a u PINu inkrementuje nebo nuluje čítač neúspěšných pokusů.

- 4 Při pátém neúspěchu se zařízení i subject dočasně zablokují, klientovi odchází oznámení bezpečným kanálem a událost jde do fraud enginu; blokáce se nedá odklikat z klienta.
- 5 Při úspěchu Session Manager vydá access token s pětiminutovým idle timeoutem vázaný na k_dev a rotující refresh token; identifikátor relace je nový, i kdyby předchozí relace ještě žila.
- 6 Aplikace posílá keep-alive výhradně na skutečnou uživatelskou interakci — ne na pollování zůstatku — a při přechodu do pozadí relaci lokálně zamkne; server relaci zruší po pěti minutách bez interakce bez ohledu na to, co si myslí klient.
- 7 Přihlášení z dosud neviděného zařízení vždy generuje notifikaci s kill-switchem, i když proběhlo korektně.

Dnešní stav — `signIn()` přepne boolean, který se persistuje do `localStorage` a přežije restart prohlížeče — je z pohledu tohoto toku nulový základ; nepřevádí se, nahrazuje se.

Autorizace platebního příkazu s dynamic linkingem

- 1 Klient vyplní příkaz (tuzemská platba s VS/KS/SS, zahraniční s IBAN/SWIFT, P2P, QR nebo převod mezi vlastními účty) a odešle ho jako návrh — server, ne klient, spočítá poplatek podle sazebníku a případný kurz se spreadem.
- 2 Server založí intent, přiřadí mu `intent_id` (které je zároveň idempotency key pro pozdější zaúčtování), a Intent Canonicalizer sestaví podepisovaný objekt: typ operace, částka v minor units, měna, normalizovaný identifikátor příjemce, hash jména příjemce, symboly, poplatek, u směny i kurz, spread a platnost kotace, debetovaný účet, nonce, expirace, `device_id` a lokalizovaný `display_text`.
- 3 Exemption engine rozhodne, zda operace vyžaduje SCA, nebo spadá pod výjimku, a v obou případech založí nesmazatelný záznam s právním základem.
- 4 Aplikace zobrazí potvrzovací obrazovku vykreslenou výhradně z `display_textu` přijatého ze serveru — nikdy z lokálního stavu formuláře — s aktivním filtrováním dotyků při překrytí a s `FLAG_SECURE`.
- 5 Klient potvrdí; SDK vyžádá biometrické odemčení `k_txn` a podepíše celý kanonický objekt; podpis odchází na server.
- 6 SCA orchestrátor ověří podpis, expiraci, nonce a shodu hashe s intentem, vydá jednorázový autorizační grant a předá ho platební službě.
- 7 Ledger zaúčtuje operaci pouze proti platnému grantu, jehož hash operace odpovídá tomu, co se skutečně účtuje; bez grantu neexistuje cesta k zápisu.
- 8 Jakákoli změna částky nebo příjemce — včetně obnovení kotace u směny — ruší intent a vyžaduje nový podpis; recyklace starého podpisu je vyloučená konstrukcí.

U vkladu do Safe Money z jiné měny se podepisuje jedna operace s oběma nohama — zdrojová částka a měna, měna Safe Money, kurz a poplatek — takže klient nikdy nepodepisuje 'pošli 5 000 CZK' a nedozví se až po zaúčtování, kolik VES mu přišlo. U QR se dekodovaný obsah vždy zobrazí k potvrzení a platba se nikdy nezahájí automaticky ze skenu.

Obnova po ztrátě telefonu — klient má druhé zařízení nebo obnovovací tajemství

- 1 Klient na novém telefonu nainstaluje aplikaci a zvolí 'obnovit přístup'; SDK vygeneruje nové páry klíčů a odešle je s atestací, zařízení se založí ve stavu provisional a zatím nemá žádná práva.
- 2 Server okamžitě odešle oznámení do všech historických kanálů (push na stará zařízení, e-mail, SMS) s informací, že byla zahájena obnova, a s kill-switchem, který ji zastaví a zmrazí účet.
- 3 Cesta R1 — druhé registrované zařízení: na starém tabletu nebo druhém telefonu se zobrazí dynamic-linked výzva 'povolit nové zařízení Xiaomi Redmi, Madrid, dnes 14:20', klient ji podepíše klíčem `k_txn` a nové zařízení přechází rovnou do stavu trusted bez karantény.
- 4 Cesta R2 — obnovovací tajemství: klient zadá obnovovací kód a PIN, server oba ověří, a protože jde o dva faktory bez fyzického důkazu, zařízení zůstává v provisional stavu s cooling-off 24 hodin.

- 5 Stará zařízení se revokují až po prvním úspěšném důkazu — ne na začátku — aby zahájení obnovy nemohl útočník použít jako laciný DoS na skutečného majitele.
- 6 Po dobu karantény smí klient sledovat zůstatky a historii, blokovat karty, zmrazit účet a kontaktovat podporu; nesmí platit novému příjemci, zvyšovat limity, přidávat důvěryhodné příjemce, měnit kontakt, registrovat další zařízení ani vybírat kryptoaktiva.
- 7 Po uplynutí karantény bez negativního signálu z fraud engine zařízení přechází do trusted a limity se vrací; při jakémkoli anomálním signálu se karanténa prodlouží a případ jde do ruční revize.

Cesta R1 je jediná, která vrací plný přístup okamžitě — proto se registrace druhého zařízení tlačí při onboardingu a znovu při každé významné změně. Náklad karantény nese produkt, ne bezpečnost: bez ní by obnova byla nejlevnější cesta k převzetí účtu v celém systému.

Obnova, když klient ztratil telefon i přístup k e-mailu (a případně i telefonní číslo)

- 1 Nic v tomto návrhu na e-mail ani na SMS nezávisí, takže se tok neliší začátkem: klient na novém zařízení zahájí obnovu a zařízení se založí jako provisional.
- 2 Cesta R3 — opakované KYC: klient projde znovu ověřením totožnosti u téhož poskytovatele (doklad, liveness, porovnání s uloženým důkazem z původního onboardingu) a k tomu odpoví na znalostní výzvu, kterou nelze uhodnout ze sociálních sítí — má vyjmenovat tři poslední odchozí platby včetně přibližných částek, ne je jen potvrdit.
- 3 Cesta R4 — národní nebo evropská elektronická identita: bankovní identita, eIDAS prostředek nebo EU Digital Identity Wallet, pokud je v jurisdikci klienta dostupná; je to nejsilnější nebiometrická cesta a jediná, která funguje i bez fungujícího dokladu v ruce.
- 4 Cesta R5 — ověřený videohovor: nahrávaný hovor s operátorem, který ověří doklad a živost proti uloženému KYC materiálu a projde skriptem; operátor je maker, jeho nadřazený nezávisle prohlédne záznam a je checker — schválení je podepsané WebAuthn asercí nad hashem případu, ne kliknutí.
- 5 Cesta R6 — poslední instance pro klienta bez dokladu, bez eID a bez druhého zařízení: úředně ověřený podpis na prohlášení nebo návštěva partnerské pobočky, ke které se přidá videohovor a čtrnáctidenní cooling-off; účet je po tu dobu zmrazený, ale prostředky jsou v bezpečí, ne ztracené.
- 6 Ať se použije kterákoli cesta, po dobu karantény platí tvrdé pravidlo: výplata je možná výhradně na destinaci, která byla ve whitelistu už před zahájením obnovy — obnova vrací přístup, ale nikdy nevytváří nový cíl peněz.
- 7 Změna e-mailu a telefonu proběhne až po skončení karantény a je to samostatná SCA operace s vlastním 24h cooling-offem a oznámením na starý kanál, který zůstává aktivní.
- 8 Celý případ je od začátku do konce v Audit Store: kdo obnovu zahájil, z jakého zařízení a IP, jaké důkazy předložil, kdo ji schválil a proti jakému materiálu, plus záznam videohovoru ve WORM úložišti s retencí podle AML.

Toto je odpověď na otázku, kterou většina návrhů nemá: klient ztratil telefon i e-mail a přesto se dostane ke svým penězům, protože ani jedno z toho nebylo faktorem. Cena je ale reálná — R5 a R6 vyžadují personál v provozní době a ve třech jazycích, takže obnova není inženýrská položka, ale trvalá provozní nákladová linka, kterou je nutné mít v rozpočtu od prvního dne.

Znovuvytvoření podpisového klíče po změně biometrie nebo aktualizaci OS

- 1 Klient přidá do telefonu nový otisk nebo obličej; systém tím zneplatní `k_txn`, protože byl vytvořen s invalidací při změně biometrického zápisu.
- 2 Aplikace při dalším pokusu o podpis dostane od systému chybu o neplatném klíči, což je normální stav, ne incident, a nesmí se zobrazit jako 'chyba aplikace'.
- 3 SDK vygeneruje nový `k_txn`, znovu ho nechá atestovat a odešle veřejný klíč na server jako žádost o výměnu — nikoli jako nový enrollment.
- 4 Server tuto výměnu autorizuje kombinací stále platného `k_dev` (vlastnictví, nezměněné) a PINu (znalost), tedy plnohodnotným SCA, a zařízení zůstává trusted.

- 5 Klientovi odchází oznámení 'na tvém zařízení se změnila biometrie, podpisový klíč byl obnoven' s kill-switchem, protože právě tento krok je vektor, kterým útočník s odemčeným telefonem přidá vlastní otisk.
- 6 Fraud engine dostane signál o změně biometrického zápisu; při jeho kombinaci s dalšími anomáliemi (nová IP, cizí země, nedávná změna kontaktu) se místo tiché výměny spustí step-up nebo krátká karanténa.

Tenhle tok v plánech pravidelně chybí a v provozu je to jeden z nejčastějších důvodů kontaktu s podporou — pokud ho nemáme, každá aktualizace OS na části zařízení vygeneruje vlnu klientů, kteří skončí v plném obnovovacím procesu, tedy v tom nejdražším a nejrizikovějším toku, jaký máme.

Uplatnění výjimky ze SCA a její doložení

- 1 Klient posílá 400 CZK sestře, která je v seznamu důvěryhodných příjemců od loňska; intent vzniká standardně a jde do exemption enginu.
- 2 Engine ověří, že příjemce je v registru podle čl. 13, že záznam vznikl se SCA a že od jeho vytvoření uplynul cooling-off, a zároveň ověří, že korridor není označen jako hyperinflační s vypnutými výjimkami.
- 3 Rozhodnutí 'exempt' se zapíše do append-only tabulky s uvedením článku, identifikátoru záznamu ve whitelistu, data jeho vzniku, verze politiky a rizikového skóre v okamžiku rozhodnutí.
- 4 Platba proběhne bez podpisu, ale intent i tak nese authorization_id — jen je vydané na základě výjimky, ne na základě podpisu, takže ledger má pořád jeden jednotný invariant.
- 5 U výjimky nízkých částek podle čl. 16 engine navíc kontroluje autoritativní kumulativní čítač (částka i počet od poslední SCA) a při jeho překročení výjimku odmítne — čítač se nuluje výhradně úspěšným SCA, nikdy uplynutím času ani reinstalací.
- 6 Přidání nového důvěryhodného příjemce je samostatná operace s plným dynamic linkingem, s 24h cooling-offem a s oznámením — protože bez toho by se z výjimky stala nejrychlejší cesta k vyprázdnění účtu.
- 7 Půlročně se z evidence generuje statistika podvodů pro dohled a interní vyhodnocení, jestli konkrétní výjimka nese víc ztrát než užitek; politiku lze vypnout per korridor bez nasazení kódu.

Evidence není administrativní balast — je to celý důkazní materiál při sporu podle PSD2 čl. 74. Pokud nedoložíme, na jakém právním základě jsme SCA neprovedli, nese ztrátu poskytovatel bez ohledu na to, jak transakce ve skutečnosti proběhla.

Interní akce se čtyřma očima — ruční opravný zápis a odmrazení účtu

- 1 Operátor podpory najde v back-office případ (například chybně zaúčtovaný poplatek) a založí návrh operace: typ, účty, částky, důvod, odkaz na ticket; operace vzniká ve stavu DRAFTED a nic neúčtuje.
- 2 Systém sestaví přes tentýž Intent Canonicalizer kanonický payload operace včetně čitelného popisu toho, co se stane — stejná knihovna jako u klientského dynamic linking, žádná druhá implementace.
- 3 Operace přechází do PENDING_APPROVAL a objeví se ve frontě schvalovatelů, kteří mají jinou roli než maker; systém odmítne schválení od téže fyzické osoby podle person_id, i kdyby měla dva účty.
- 4 Schvalovatel si přečte payload a schválí ho WebAuthn asercí ze svého hardwarového klíče nad hashem payloadu; aserce se ukládá jako důkaz, nikoli jako boolean.
- 5 Jakákoli změna payloadu po schválení ho ruší a vrací operaci do DRAFTED; schválení má navíc expiraci 24 hodin.
- 6 Po schválení se operace provede a zapíše do ledgeru s odkazem na maker, checker a hash schváleného payloadu; do Audit Store jde celý řetězec.
- 7 U nejcitlivějších akcí — odmrazení účtu, změna SCA politiky, změna prahů výjimek, přidání adresy do firemního whitelistu, přidělení role — se vyžadují dva schvalovatelé z různých týmů.
- 8 Break-glass s jedním schvalovatelem existuje pro skutečné havárie, ale automaticky zakládá P1 incident, notifikuje CISO a compliance a vyžaduje dodatečné schválení do 24 hodin, jinak se eskaluje na statutární orgán.

Toto je organizačně blokováno, ne technicky: s jedním vývojářem a bez druhé linie obrany se čtyři oči nedají splnit bez ohledu na kvalitu kódu. Nábor druhého seniorního člověka je předpokladem tohoto toku, ne jeho důsledkem.

Detekce a odezva na pokus o převzetí účtu

- 1 Fraud engine přijme kombinaci signálů: přihlášení z nové země, selhaná atestace, znovupoužitý refresh token, žádost o změnu e-mailu a hned poté pokus přidat nového důvěryhodného příjemce.
- 2 Odezva je odstupňovaná a tichá: nejdřív se zvýší skóre a odebere se konkrétní schopnost (přidat příjemce), ne přístup jako celek — tvrdý blok útočníkovi jen ukáže, kterou kontrolu má obejít.
- 3 Na další peněžní operaci se vyžádá step-up SCA s dynamic linkingem, i kdyby jinak spadala pod výjimku; výjimky se pro tento subjekt dočasně vypnou.
- 4 Klientovi odchází oznámení na všechny historické kanály s konkrétním popisem 'někdo se pokouší změnit e-mail na j***@***.com' a s tlačítkem 'tohle jsem nebyl já'.
- 5 Klepnutí na kill-switch zmrazí účet, zruší všechny relace, revokuje všechna zařízení a založí případ; akce je idempotentní, dostupná bez plného přihlášení a záměrně jednosměrná.
- 6 Odmrazení je maker-checker proces s ověřením klienta stejnou laťkou jako obnova zařízení — zmrazit má být triviální, odmrazit má být těžké.
- 7 Celý řetězec signálů, rozhodnutí, verzí pravidel a odezev jde do Audit Store a do SIEM; při naplnění klasifikačních kritérií se spouští DORA lhůta 4 hodin a paralelně GDPR lhůta 72 hodin.
- 8 Proti vishingu platí produktové pravidlo: operátor podpory nemůže provést nic, co se dotýká peněz nebo identity, bez toho, aby klient v aplikaci schválil dynamic-linked výzvu se jménem operátora a popisem požadované akce.

Odezva nesmí být binární i z regulatorního důvodu — připravovaný PSR výslovně řeší dostupnost SCA pro osoby s postižením, takže plošné blokování při detekci accessibility služby je do budoucna neprůchodné a musí být řešeno rizikově.

5.4 Rizika a opatření

Riziko	Opatření v návrhu
Obnova zařízení se stane nejsnazší cestou k převzetí účtu — je to nejsilnější oprávnění v systému a zároveň jediné, které se ze své podstaty musí dát použít bez předchozích faktorů.	Karanténní stav provisional s cooling-off 24–72 hodin podle síly cesty, tvrdý zákaz vytvoření nového cíle platby po dobu karantény, výplata jen na destinaci whitelistovanou před zahájením obnovy, oznámení do všech historických kanálů s kill-switchem, čtyři oči u cest R5/R6 se schválením podepsaným hardwarovým klíčem, a aktivní tlak na registraci druhého zařízení už při onboardingu, protože cesta R1 celý problém obchází.
Atestace selže u legitimních klientů — zařízení bez Google Play Services (v Latinské Americe nezanedbatelný podíl), custom ROM, starší telefony bez StrongBoxu, výpadky nebo rate limity Play Integrity, a od 10. 4. 2026 neaktualizovaný RKP attestation root v našem trust store.	Definovaná degradační politika místo hard failu: fallback z StrongBoxu na TEE s ošetřením StrongBoxUnavailableException, snížené limity a povinné SCA u každé operace místo odmítnutí klienta, alternativní enrollment přes videohovor pro zařízení bez atestace, automatická aktualizace trust store s alertem na blížící se expiraci, a měření podílu odmítnutých zařízení jako produktové metriky, ne jen bezpečnostní.
Nezávislost prvků SCA na jednom víceúčelovém zařízení je napadnutelná — k_dev i k_txn žijí ve stejném TEE a regulátor může namítnout, že kompromitace jednoho kompromituje druhý (RTS čl. 9(1)).	Kompenzační režim podle čl. 9(3) doložený písemně: oddělené prováděcí prostředí (StrongBox/Secure Enclave), vrstvená kontrola integrity vyhodnocovaná na serveru, definovaná mitigace při zjištěné kompromitaci, různé podmínky odemčení obou klíčů, a znalostní prvek ověřovaný výhradně serverově, tedy mimo zařízení. Argumentaci nechat posoudit právníkem na platební služby ještě před podáním licenční žádosti, ne až v řízení.
Pětiminutový idle timeout udělá z produktu v hyperinflačním koridoru s nestabilním připojením nepoužitelnou věc a tlak z produktu ho postupně obejde přes falešný keep-alive.	Přesné vymezení, co je 'přístup k platebnímu účtu' (zůstatky, historie, detaily účtu) a co ne (marketing, nápověda, podpora, blokáce karty); rychlé odemčení biometrií přes k_txn bez plného přihlášení, které je samo SCA-grade; keep-alive výhradně na skutečnou uživatelskou interakci vynucený review pravidlem v kódu; a technická nemožnost prodloužit timeout konfigurací bez schválení čtyřma očima.

Riziko	Opatření v návrhu
Chyba v kumulativních čítačích výjimky nízkých částek nebo v registru důvěryhodných příjemců znamená tichý únik peněz zcela bez SCA, který nikdo nepozoruje, protože se nic nerozbije.	Čítače v transakční databázi pod stejnou transakcí jako zaúčtování, nikdy v cache; nočně rekonziliovaný přepočet z ledgeru; property testy na invariant 'po úspěšném SCA je čítač nula' a 'součet exempted operací od poslední SCA nepřekročí prahy čl. 16'; alert v SIEM na neobvyklý podíl exempted operací na klienta i celkově; a defaultně vypnuté výjimky pro nové koridory.
Změna biometrického zápisu invalidující k_txn vyvolá po plošné aktualizaci OS vlnu klientů, kteří skončí v plném obnovovacím procesu — tedy v nejdražším a nejrizikovějším toku.	Samostatný nízkotřecí tok výměny podpisového klíče autorizovaný stále platným k_dev a PINem, jasně odlišený od obnovy zařízení; chyba systému o neplatném klíči zpracovaná jako očekávaný stav, ne jako pád aplikace; notifikace s kill-switchem, protože přidání vlastního otisku je vektor útočníka s odemčeným telefonem; a sledování objemu těchto událostí jako kapacitní metricky podpory.
Podpora se stane účinnou plochou — sociální inženýrství na operátora je u klientely v tísní (rodina, hyperinflace, urgence) mnohem účinnější než technický útok.	Operátor nemá v systému oprávnění resetovat autentizační prostředek, změnit kontakt ani uvolnit prostředky; každá jeho akce s dopadem na peníze nebo identitu vyžaduje buď maker-checker, nebo schválení klientem přes dynamic-linked výzvu se jménem operátora; skriptované znalostní výzvy, kde klient informace uvádí, nikoli potvrzuje; nahrávané hovory ve WORM; a pravidelný red-team test podpory, ne jen aplikace.
Čtyři oči a oddělení rolí jsou dnes organizačně nespílitelné — tým je fakticky jeden člověk, takže neexistuje maker, checker, druhá ani třetí linie obrany.	Přiznat to jako blokátor, ne jako technický dluh: nábor druhého seniorního vývojáře a compliance role je na kritické cestě identitní vrstvy stejně jako kód. Do té doby stavět maker-checker automat, ale nespouštět žádnou funkci, která by ho obcházela, a v investorském materiálu uvádět fázi F3 jako podmíněnou obsazením rolí.
Nativní klient se odloží, aby se ušetřilo, a SCA se postaví nad dnešní webovou SPA — čímž celá vrstva ztratí právní obhajitelnost, protože device binding, atestace ani ochrana obrazovky se v prohlížeči splnit nedají.	Explicitní architektonická brána: SCA orchestrátor se nasazuje do produkce až s nativním klientem; do té doby existuje jen v testovacím prostředí. Web se od začátku plánuje jako oddělený produkt s passkeys, nižšími limity a vlastním posouzením rizika, ne jako 'zatím to půjde i takhle'.
Zapečení dnešního produktového rozhodnutí (XSGD, Litva) do identitní a autorizační vrstvy — a jeho zahození ve chvíli, kdy padne regulatorní rozhodnutí o autorizovaném EMT nebo o jurisdikci.	Jurisdikční a aktivový profil jako data na subjektu a účtu; pravidla SCA, limity a výjimky jako verzovaná policy-as-code mimo aplikační kód; testy politik jako samostatná sada; a review pravidlo, že v identitní vrstvě nesmí padnout jméno konkrétního tokenu ani jurisdikce.
Závislost na jediném dodavateli KYC, identity providera nebo atestace vytvoří koncentrační riziko, které DORA čl. 28–30 vyžaduje řešit a které u obnovy zařízení znamená, že výpadek dodavatele odřízne klienty od jejich peněz.	Vlastní databáze subjektů, zařízení a klíčů zůstává u nás bez ohledu na dodavatele; KYC provider integrovaný přes vlastní abstrakci se dvěma implementacemi už od návrhu; nejméně dvě nezávislé cesty obnovy, které nesdílejí dodavatele (druhé zařízení a obnovovací tajemství nezávisí na nikom externím); registr informací a exit plán vedený od prvního kontraktu, ne až před podáním žádosti.
Biometrické porovnání obličeje při obnově je zpracování zvláštní kategorie údajů podle čl. 9 GDPR a od 2. 8. 2026 může spadat pod režim vysoce rizikových systémů AI Actu, pokud dodavatel provozuje identifikaci 1:N.	Biometrie na zařízení zůstává mimo tento problém (šablona server nikdy nevidí); pro obnovu explicitní souhlas jako samostatný právní titul, povinná rovnocenná nebiometrická alternativa (eID, videohovor, ověřovací platba), smluvní omezení dodavatele na verifikaci 1:1, DPIA před spuštěním a doložený lidský dohled a logování, pokud by se 1:N někdy použilo.

6. Compliance jako běhová vrstva

AML, sankce, fraud a Travel Rule jako komponenty v kritické cestě peněz, ne jako politiky v dokumentu.

Cílem je, aby compliance nebyl soubor politik v SharePointu, ale běhová vrstva, kterou nelze obejít: žádný pohyb peněz ani kryptoaktiv se nezaúčtuje bez podepsaného rozhodnutí compliance jádra, a každé takové rozhodnutí je zpětně přehratelné z uložených vstupů, verze pravidel a verze sankčních seznamů. Vychází to z konkrétní vady dnešního dema — sazebník platí jen v jedné ze čtyř peněžních cest a KYC status nebrání ničemu; stejný vzorec by u compliance znamenal, že první nová peněžní cesta ji tiše obejde, proto se vynucení dává do ledgeru, ne do obrazovek. Architektura je záměrně tokenově a jurisdikčně agnostická: XSGD/USDT vs. USDC/EURC, Litva vs. jiná jurisdikce a prahy CDD jsou konfigurace rulesetu, ne konstanty v kódu, protože rozhodnutí o licenci a stablecoinu ještě nepadlo a nesmí zahodit rok práce. Kupujeme data a detekční jádra (sankční seznamy, KYC ověření, blockchain analytiku, Travel Rule síť, TM/fraud platformu), stavíme orchestraci, vynucení, rozhodovací deník, evidenci a hlášení — protože to, co se kupuje, je vyměnitelné, a to, co se staví, je přesně ta část, kterou po nás dohled chce doložit. Fázování je řízené tím, co přežije každé rozhodnutí (F1), co jde až po volbě licence a dodavatelů (F2) a co je nutné až k ostrému provozu s cizími penězi (F3).

6.1 Komponenty

Celkem 19 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Compliance Decision Point (compliance-gate)

Fáze 1

Jediné synchronní místo, které pro každý peněžní záměr (platba, převod mezi vlastními účty, směna, vklad/výběr ze Safe Money, on-chain odchozí/příchozí transfer, karetní autorizace, změna limitu, výplata) vrací rozhodnutí ALLOW / STEP_UP / HOLD / DENY s odůvodněním a strojově čitelnou stopou. Vyhodnocuje: KYC stav a úroveň, rizikový profil klienta, sankční zásah na obou stranách, produktové a kanálové limity, restrikce na účtu, fraud skóre, Travel Rule úplnost a jurisdikční pravidla. Nerozhoduje o penězích — vydává verdikt, který ledger vynutí.

Technologie: STAVÍ SE celé (Go nebo Kotlin, stateless, min. 3 repliky ve 2 AZ). KUPUJE SE rozhodovací jádro pravidel jen tam, kde už ho má TM/fraud platforma; vlastní DSL pouze pro tvrdé regulační gate (KYC, sankce, limity), aby nebyly závislé na dostupnosti dodavatele.
· **Rozhraní:** gRPC/HTTP `POST /v1/decisions` (intent, actor, instrument, counterparty, channel, device signals, idempotency key) → decision_id, verdict, reasons[], expires_at, HMAC/podpis. Latencový rozpočet p99 300 ms (z toho screening ≤ 100 ms). Ledger přijímá zápis pouze s platným, nespotřebovaným decision_id vázaným na hash ...

Rozhodovací deník (decision log) a replay

Fáze 1

Neměnný záznam každého volání PDP: snímek vstupů, verze rulesetu, verze každého sankčního a PEP seznamu, verze modelu, výsledek, kdo/co jej přepsal a proč. Je to zároveň důkaz pro dohled, vstup pro ladění falešných poplachů a jediný způsob, jak zpětně obhájit „proč jste tuhle transakci pustili“. Bez něj nelze dělat backtest ani odpovědět na dožádání FIU.

Technologie: STAVÍ SE. Kafka (log) + Postgres/ClickHouse (dotazy) + WORM archiv (S3 Object Lock / Azure immutable blob) s hash-chain a dávkovým podpisem. Splňuje RTS (EU) 2024/1774 čl. 12 a retenci 5 let (AMLR čl. 77), retence parametrická kvůli přechodu z 10 let (zák. 253/2008) na 5.
· **Rozhraní:** Zápis přes append-only API; čtení jen přes replay službu `POST /v1/replay {decision\_id | time\_range, ruleset\_version}` která rozhodnutí deterministicky přehraje. Export do case managementu a do reportingu. Klientské rozhraní k němu nemá přístup vůbec.

Restriční primitiva v ledgeru (hold / freeze / restraint)

Fáze 1

Blokace a zmrazení jako účetní entita, ne boolean na účtu. Typy: soft hold (dočasná blokace částky při STEP_UP nebo šetření), travel-rule hold, sankční freeze (bez lhůty, zrušitelný jen se schválením MLRO a doloženým právním

důvodem), soudní/exekuční příkaz, dormance. Restrikce má vždy rozsah (účet / měna / částka / protistrana), právní důvod, iniciátora, schvalovatele a expiraci. Dostupný a blokový zůstatek jsou dvě různá čísla.

Technologie: STAVÍ SE jako součást ledgeru (Postgres, deferred constraints na nulový součet per měna). Nekupuje se — je to jádro účetní integrity a žádný dodavatel ho nesmí vlastnit. · **Rozhraní:** `POST /v1/restraints` (maker) + `POST /v1/restraints/{id}/approve` (checker), `GET /v1/accounts/{id}/available-balance`. Každé restrikci odpovídají zápisy v podvojném ledgeru (přesun na restraint suspense účet), nikoli příznak. Klientské API vidí pouze „prostředky nejsou k dispozici“ bez důvodu, pokud je důvod AML.

Evidence & retention vault (důkazní trezor)

Fáze 1

Uložení všeho, co musí přežít 5 (resp. 10) let a co se nesmí redigovat: KYC složky, skeny a atributy dokladů, důkazy o provedeném ověření, screeningové zásahy a jejich vyhodnocení, obsah STR/SAR, Travel Rule payloady, korespondence s FIU. Vlastní retenční hodiny pro každou kategorii se samostatným spouštěčem (konec vztahu vs. datum transakce), legal hold pozastavující výmaz, a kryptografické mazání jako doložená technika výmazu.

Technologie: KUPUJE SE úložiště s object-lock (S3/Azure immutable, EU region) a KMS/HSM (FIPS 140-3 L3) pro per-field klíče. STAVÍ SE retenční orchestrátor, klasifikace, legal hold a crypto-shred. Šifrování na úrovni pole u čísla dokladu, adresy a biometrické šablony — FDE nestačí. · **Rozhraní:** `PUT /v1/evidence` (typ, subjekt, právní titul, retenční třída), `POST /v1/legal-holds`, `GET /v1/evidence/{id}` pouze s odůvodněním přístupu, které se loguje. Retenční job maže skutečně, ne příznakem.

Oprávnění, oddělení rolí a maker-checker framework

Fáze 1

Vynucení čtyř očí a SoD na úrovni knihovny, kterou musí použít každá administrativní akce: schválení KYC, ruční opravný zápis, zmrazení a odmrazení, změna limitu nad práh, změna rulesetu, odeslání STR, přístup do KYC složky. Tvrdé pravidlo iniciátor ≠ schvalovatel vynucené na serveru, ne v UI. Just-in-time eskalace s časovým omezením a nahráváním relace pro produkční přístupy.

Technologie: KUPUJE SE IdP (Entra ID / Okta) s MFA a PAM. STAVÍ SE entitlement model, maker-checker knihovna a audit administrátorských akcí. Poznámka: bez obsazených lidí (MLRO, compliance manager, DPO, min. 2 vývojáři) je tato komponenta technicky hotová a procesně nefunkční — je to personální, ne inženýrská blokáce. · **Rozhraní:** `@RequiresApproval(scope, threshold)` dekorátor/middleware → vytvoří pending action, druhý oprávněný uživatel schválí přes back-office; teprve pak se akce provede. Recertifikace práv čtvrtletně, export matice SoD pro dohled.

Registr. politik a pravidel (ruleset registry) se shadow režimem

Fáze 1

Pravidla, prahy, rizikové matice, jurisdikční profily a produktová omezení jsou verzované artefakty se schvalovacím workflow, ne konfigurace v .env a ne kód. Každá verze má autora, schvalovatele, datum účinnosti, dopadovou analýzu ze shadow běhu a možnost okamžitého rollbacku. Ruleset je klíčovaný na (jurisdikce × produkt × aktivum × kanál × riziková třída klienta) — proto je přechod z XSGD na USDC/EURC nebo z LT na jinou jurisdikci změna konfigurace, ne refaktoring.

Technologie: STAVÍ SE. DSL nebo rozhodovací tabulky (GoRules/Zen, Drools, nebo nativní engine TM platformy). Součástí je CI gate: produktová konfigurace se strojově testuje proti MiCA čl. 50 — jakákoli změna, sleva nebo bonus, jejichž vzorec obsahuje zůstatek nebo dobu držení EMT, shodí build; k tomu lexikální lint marketingových ... · **Rozhraní:** Git-backed repozitář rulesetů + `GET /v1/rulesets/{id}` pro PDP; `POST /v1/rulesets/{id}/shadow-run {time\_range}` vrací počet nových/zaniklých alertů proti historii z rozhodovacího deníku. Nasazení jen maker-checker.

Identitní a KYC datový model (compliance core data)

Fáze 1

Kanonický model klienta pro compliance: identifikační atributy, doklady, skutečný majitel, PEP status, daňová rezidence a TIN (kvůli DAC8), účel vztahu, zdroj prostředků, rizikové skóre, historie stavů. U každé kategorie evidovaný právní titul (čl. 6 odst. 1 písm. c pro KYC, písm. b pro vedení účtu, výslovný souhlas pro biometrii) — od něj se odvíjí, zda lze vyhovět výmazu. Dvě datové třídy vynucené typovým systémem: client-visible a compliance-only (risk skóre, alerty, poznámky, existence STR).

Technologie: STAVÍ SE. Postgres se samostatným schématem a vlastním řízením přístupu, pseudonymizace podle EDPB Guidelines 01/2025 (přířazovací tabulka odděleně), logování každého nahlédnutí do KYC složky (kdo, kdy, který klient, důvod). · **Rozhraní:** `GET /v1/customers/{id}/profile?view=client|compliance` — DSAR export smí číst výhradně client-visible view; kompilace selže, pokud se compliance-only pole dostane do klientského DTO. Samostatné schéma/služba, nikdy sloupce v tabulce users.

Back-office / operátorská konzole

Fáze 1

Jediné pracoviště compliance a podpory: vyhledání klienta, KYC fronta, případy, restrikce, ruční opravné zápisy, refundace, revize alertů, generování hlášení. V plánu tato položka chyběla úplně — bez ní skončí provoz u SQL konzole nad produkcí, což je samo o sobě dohledový nález a porušení SoD.

Technologie: STAVÍ SE (je to produkt, ne stránka — 150–250 MD). KUPUJE SE pouze case management jako backend (viz níže), UI zůstává naše, aby se dodavatel dal vyměnit bez rekvalifikace týmu. · **Rozhraní:** Interní web (SSO + MFA), veškeré akce přes maker-checker framework, každé zobrazení citlivého pole logované s důvodem. Žádný přímý přístup do DB pro provozní role.

KYC/KYB orchestrátor a fronta ruční revize

Fáze 2

Řídí průchod ověřením jako stavový automat, ne jako obrazovku: sběr atributů, OCR a kontrola pravosti dokladu, liveness a porovnání obličejů, ověření adresy, kontrola skutečného majitele, sběr daňové rezidence a TIN, rizikové skórování a rozhodnutí. Hraniční a odmítnuté případy padají do fronty ruční revize se SLA, čtyřma očima u schválení nad rizikový práh a doloženým odůvodněním. Samostatný proces odvolání (appeal) s jiným posuzovatelem než ten, kdo zamítl, a s lhůtou a písemným odůvodněním klientovi — u odmítnutí z AML důvodů v tipping-off-safe formulaci.

Technologie: KUPUJE SE ověřovací engine (Sumsub / Veriff / Onfido / IDnow) — a od začátku za dvojicí adaptérů, protože vypnutí jednoho dodavatele nesmí zastavit onboarding; dále eID/eIDAS a bankovní identita jako druhý kanál. STAVÍ SE orchestrace, fronta, odvolání, evidence důkazů a rozhodovací logika. Nebiometrická cesta ... · **Rozhraní:** `POST /v1/onboarding/sessions`, webhooks od dodavatele podepsané a idempotentní, `GET /v1/kyc/{customerId}/level` → tier, který PDP používá jako tvrdou podmínku. Rozhodnutí vždy na našem serveru — dodavatel dodává důkazy a skóre, ne verdikt.

Screening jmen, adres a entit (sankce, PEP, adverse media)

Fáze 2

Kontrola klienta, skutečného majitele, protistrany platby a příjemce zahraničního převodu proti sankčním seznamům EU/OSN/národním (a podle rizikového apetitu i OFAC — s klientelou z Venezuely je to reálná expozice, ne teorie), PEP databázi a adverse media. „Adresa“ má dva významy a oba musí být pokryté: poštovní adresa (geografické restrikce, vysoce rizikové jurisdikce) a bankovní identifikátory (IBAN/BIC z sankcionované banky). Delta re-screening celé báze při každé aktualizaci seznamu, ne jen při onboardingu.

Technologie: KUPUJE SE datová sada (Dow Jones Risk & Compliance / LSEG World-Check; OpenSanctions jako konsolidovaný EU/UN/UK/OFAC zdroj a nezávislá křížová kontrola) a matching engine s nízkou latencí (Neterium, Silent Eight, ComplyAdvantage). STAVÍ SE integrace do PDP, whitelisting falešných shod s expirací, re-screening ... · **Rozhraní:** `POST /v1/screening/check` (jméno, datum narození, země, adresa, typ entity) → hits[] se skóre shody a algoritmem; `POST /v1/screening/{hitId}/disposition` (true positive / false positive / diskontováno) s povinným odůvodněním do evidence. Delta feed konzumovaný přes frontu s SLA na dokončení re-screeningu (cíl: do 24 ...

Screening kryptoadres a rizika protistrany

Fáze 2

Pre-transaction screening každé cílové adresy před odesláním a každé zdrojové adresy před připsáním, v toku peněz, ne v reportu. Typologie: mixéry, sankcionované entity, darknet, ransomware, hazard, rizikové burzy, peel chains. Průběžný re-screening historicky použitých adres. Detekce anonymity-enhancing aktiv a chování — kvůli AMLR čl. 79 od 10. 7. 2027 to musí být připraveno dřív, protože delistace a migrace klientů je měsíce práce.

Technologie: KUPUJE SE (Chainalysis / TRM Labs / Elliptic) — stavět vlastní atribuci adres je nesmysl a dohled ani banka to neužná. STAVÍ SE integrace, cache s TTL, degradační politika při výpadku dodavatele (fail-closed: bez odpovědi se neodesílá) a evidence důkazů o provedeném screeningu. Dodavatel prochází hodnocením podle DORA ... · **Rozhraní:** `POST /v1/chain-screening/address` → risk score, kategorie, expozice; volá se z PDP synchronně před podpisem a asynchronně při detekci příchozího depozitu. Zásah nad práh → automatický HOLD na travel-rule/depozitním suspense účtu a případ.

Transakční monitoring a fraud engine (sdílený feature store, oddělené rulesety)

Fáze 2

Dvě různé úlohy nad jedním datovým základem: AML monitoring (typologie strukturování, smurfing, průtokové účty, mule sítě, nesoulad s deklarovaným profilem, remitenční vzorce specifické pro koridor Venezuela–EU) a fraud/ATO detekce (RTS 2018/389 čl. 2 a 18: neznámé zařízení, kompromitované zařízení, hookovací framework, anomální chování, sociální inženýrství, APP fraud). Sdílejí feature store a case management, ale mají oddělené rulesety, oddělené SLA a oddělené vlastníky — AML alert smí čekat hodiny, fraud rozhodnutí musí padnout v milisekundách.

Technologie: KUPUJE SE platforma (Hawk:AI, Unit21, Feedzai, ComplyAdvantage) včetně case managementu — vlastní transakční monitoring s laděním, analytickým UI a vysvětlitelností je samostatný produkt na 250+ MD a nemá smysl ho stavět. STAVÍ SE feature engineering (znalost našich peněžních cest je naše), enforcement v PDP, příjem ... · **Rozhraní:** Fraud: synchronní volání z PDP se skóre a doporučením (ALLOW / STEP_UP SCA / DENY). AML: asynchronní streaming z ledgeru, generuje alerty do case managementu. Feature store: `GET /v1/features/{customerId}` — velocity okna (1 h / 24 h / 7 d / 30 d), agregáty po měnách, odchylka od profilu.

Case management a workflow šetření

Fáze 2

Jeden inbox pro AML alerty, fraud případy, KYC hraniční případy, sankční zásahy a stížnosti — ne tři systémy. Případ nese: alerty, časovou osu, zapojené transakce a účty, provedené kroky, RFI klientovi, rozhodnutí, schvalovatele, a odkaz na případné STR. Povinná pole pro klasifikaci typu podvodu (kvůli pololetní statistice podle PSD2 čl. 96(6)) se vyplňují při uzavření případu — zpětné doplnění taxonomie do tisíců uzavřených případů není proveditelné.

Technologie: KUPUJE SE společně s TM platformou. STAVÍ SE most do back-office a do evidence, plus vlastní taxonomie výstupů, aby nezávisela na dodavatelské číselníku. · **Rozhraní:** Obousměrná synchronizace s back-office; `POST /v1/cases`, `POST /v1/cases/{id}/close {outcome, fraud\_type, aml\_typology}`; automatické zakládání legal hold při otevření AML případu.

Travel Rule služba (nařízení 2023/1113)

Fáze 2

U každého převodu kryptoaktiv bez prahové hodnoty shromáždit, ověřit, předat a uchovat údaje o plátcí a příjemci; rozlišit protistranu CASP vs. self-hosted; u self-hosted nad 1 000 EUR doložit ověření kontroly adresy klientem. Řídí stavový automat převodu: odeslání dat protistraně → čekání na potvrzení → uvolnění nebo pozastavení, odmítnutí a vrácení při chybějících nebo neúplných údajích. Zpracovává i příchozí stranu: chybějící údaje = definovaný postup (dotaz, pozastavení, vrácení, eskalace, případně STR při opakování).

Technologie: KUPUJE SE členství v síti (Notabene, Sygna, 21 Analytics, TRP/OpenVASP) — protokolová interoperabilita je síťový efekt, který nelze vybudovat. STAVÍ SE adaptér nad protokolem (sít se bude měnit), mapper IVMS101, ověření vlastnictví self-hosted adresy (podpis EIP-191, resp. EIP-1271 pro smart účty, nebo satoshi test) a ... · **Rozhraní:** `POST /v1/travel-rule/outbound` (IVMS101 payload) → status; `POST /v1/travel-rule/inbound` webhook. Prostředky během čekání sedí na oddělitelném travel-rule suspense účtu s vlastním ledgerovým zápisem — nikdy jako příznak „pending“ na klientském zůstatku. Sunrise politika (protistrana v jurisdikci bez travel rule) je ...

Hlášení FIU (STR/SAR) a komunikace s orgány

Fáze 2

Generování, schválení a odeslání oznámení podezřelého obchodu s dodržáním zákazu tipování; evidence odeslaných hlášení odděleně od klientských dat; zpracování dožádání a příkazů k pozastavení. Odeslání STR automaticky zakládá legal hold a nastavuje příznak, který blokuje DSAR export i běžnou klientskou komunikaci o důvodu.

Technologie: STAVÍ SE. Generátor je pár set řádků; hodnota je ve vazbě na case management, v maker-checkeru a v tom, že se STR nikdy nedostane do žádného klientského exportu. Nekupovat — schémata FIU se liší po jurisdikcích a vendor lock zde nic nešetří. · **Rozhraní:** `POST /v1/str/draft` (z případu), maker-checker schválení MLRO, `POST /v1/str/submit` → generátor XML do goAML (litevská FCIS i řada dalších FIU používá goAML; v ČR FAÚ MoneyWeb — proto je formát adaptér, ne pevná součást). Doručení se ukládá do důkazního trezoru.

Perpetual KYC (pKYC) a přehodnocování rizika

Fáze 2

Nahrazuje periodickou revizi „jednou za rok všem“ událostmi: změna adresy nebo země, nový zdroj příjmů, PEP zásah z re-screeningu, překročení objemového pásma, změna vzorce chování, nová jurisdikce protistrany, uplynutí platnosti dokladu, blížící se konec platnosti ověření. Každá událost přepočítá rizikové skóre a případně vyvolá EDD, doplnění dokladů nebo omezení tieru (s předchozím upozorněním klienta a lhůtou).

Technologie: STAVÍ SE nad existující sběrnici; scheduler pro časové spouštěče (platnost dokladu, cyklus revize podle rizikové třídy: vysoké 6–12 měsíců, standardní 24–36). Nekupuje se — je to orchestrace nad komponentami, které už máme. · **Rozhraní:** Konzumuje eventy z ledgeru, screeningu a identitní služby; `POST /v1/risk/reassess {customerId, trigger}` → nový tier + požadované kroky. Snížení tieru se propisuje do PDP okamžitě.

Dohledový a statistický reporting (fraud statistics, MiCA, stížnosti, DORA)

Fáze 3

Pravidelná hlášení, která po licenci nikdo nesmí dělat ručně v Excelu: pololetní statistika podvodů podle PSD2 čl. 96(6) a EBA GL (členěno podle platebního prostředku, kanálu, typu podvodu, SCA/výjimky, ztrát nesených

poskytovatelem a klientem), evidence a hlášení stížností (MiCA čl. 71), notifikace podstatných změn, klasifikace a hlášení závažných ICT incidentů podle DORA (4 h / 24 h / 72 h / 1 měsíc) s předpřipravenými šablonami.

Technologie: STAVÍ SE. Klíčové rozhodnutí je datové, ne nástrojové: taxonomie typu podvodu a použité výjimky ze SCA se musí zaznamenávat u každé transakce od prvního dne, jinak je první pololetní hlášení nesplnitelné bez ručního přeznačení historie. · **Rozhraní:** `GET /v1/reports/{type}?period=` s deterministickým výstupem z rozhodovacího deníku a ledgeru; každý report má verzi datového snímku, aby se dal reprodukovat. Schválení maker-checker před odesláním.

DAC8 / CARF daňové hlášení

Fáze 3

Roční hlášení transakcí klientů poskytovatelem služeb kryptoaktiv podle DAC8 (povinnost sběru dat od 1. 1. 2026, první hlášení za rok 2026). Vyžaduje self-certification daňové rezidence a TIN, validaci formátu TIN podle země, kontrolu rozporu mezi deklarovanou rezidencí a indiciemi (IP, adresa, telefon), agregaci reportovatelných transakcí a XML výstup správcí daně.

Technologie: STAVÍ SE sběr a agregace (musí být v identitním modelu od F1 — dosbírávat daňovou rezidenci u existující báze je kampaň s ~30% neúspěšností). KUPUJE SE generátor a údržba schémat (TaxBit, Ledgible, Fenergo nebo daňový poradce s nástrojem), protože schémata se mění ročně a udržovat je vlastními silami je čistá ztráta. · **Rozhraní:** `GET /v1/dac8/extract?year=` → validovaný XML; `POST /v1/tax/self-certification` volané už v onboardingu. Chybějící nebo neplatné TIN generuje remediation kampaň, ne tichý výpadek v hlášení.

Tuning lab — ladění falešných poplachů a řízení modelového rizika

Fáze 3

Systematické snižování false positive rate bez ztráty zachytu: shadow běh nové verze rulesetu proti historii z rozhodovacího deníku, champion–challenger, above-the-line / below-the-line testování prahů (vzorek z pásma pod prahem se ručně přezkoumá, aby se doložilo, že práh nepropouští), měření podílu alertů uzavřených jako false positive a doby do rozhodnutí. Výstupem je doložitelný cyklus ladění — to je přesně to, co dohled u transakčního monitoringu kontroluje.

Technologie: STAVÍ SE nad rozhodovacím deníkem (proto je deník F1 — bez historie vstupů nelze nic backtestovat). Analytická vrstva ClickHouse/DuckDB + notebooky. Modelová dokumentace a vysvětlitelnost každého automatického zamítnutí kvůli čl. 22 GDPR a informační povinnosti podle čl. 13. · **Rozhraní:** `POST /v1/tuning/shadow {ruleset\_version, period}` → diff alertů, odhad zátěže analytiků, ztracené zachyty; report do schvalovacího workflow rulesetu.

6.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tím kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
ADR-1: Compliance je synchronní brána v kritické cestě peněz, ne dodatečný monitoring Zvažováno: (a) Asynchronní monitoring s post-hoc alerty — o 30–40 % levnější a jednodušší, ale u kryptopřevodů a sankcí neúčinné a dohledově neobhajitelné; (b) kontrola volaná z každé peněžní služby zvlášť — ...	Každý peněžní záměr projde compliance-gate a získá podepsané decision_id; ledger má databázový constraint, který zápis bez platného, dosud nespotřebovaného decision_id odmítne. Dnešní demo dokazuje, proč to jinak nefunguje: sazebník se uplatňuje jen v jedné ze čtyř peněžních cest a KYC status neblokuje žádnou operaci. Jakmile je vynucení v aplikační vrstvě, degraduje s každou novou cestou. U sankčního zásahu a u odchozího on-chain převodu je post-hoc detekce navíc bezcenná — transakce je nevratná. Kontrola musí být tam, kde vzniká účetní zápis, protože to je jediné místo, které nelze ...	Compliance se stává SPOF pro platby: vyžaduje HA (min. 3 repliky, 2 AZ), latencový rozpočet p99 300 ms a explicitní fail-closed/fail-open matici per třídu kontroly. Nutný je degradovaný režim (při výpadku fraud skóringu se sníží limity a vypnou rizikové kanály, ale sankční kontrola nikdy nesmí selhat otevřeně). Provozně to znamená on-call na compliance službě, ne jen na ...
ADR-2: Jeden rozhodovací deník a jedno case management pro AML, fraud i KYC Zvažováno: Specializované best-of-breed nástroje pro každou doménu — lepší jednotlivé funkce, ale integrace tří případových modelů a sjednocení historie stojí víc než rozdíl ve funkcích, a při dohledové ...	Jedna append-only stopa všech compliance rozhodnutí a jeden inbox pro všechny typy případů; oddělené jsou pouze rulesety, SLA a vlastníci. Alert na fraud a alert na praní peněz jsou u remitenčního produktu často tentýž jev viděný ze dvou stran — mule účet je zároveň podvod i praní. Tři oddělené systémy znamenají tři inboxy, tři pravdy o klientovi a nemožnost odpovědět na otázku „co jste o něm věděli“. Backtesting a ladění prahů navíc vyžadují jednu historii vstupů, ne tři.	Vyšší nároky na datový model případu a na řízení přístupu (fraud analytik nesmí vidět STR). Zavazuje k tomu, že TM platforma se vybírá i podle kvality case managementu, ne jen podle detekce. Odměnou je, že tuning lab, dohledový reporting a odpověď na dožádání FIU čtou z jednoho zdroje.

Rozhodnutí	Volba a důvod	Důsledek
ADR-3: Kupujeme data a detekční jádra, stavíme orchestraci, vynucení a evidenci Zvažováno: (a) Postavit vše vlastní — přidává 600+ MD, u screeningu a chain analytiky navíc výsledek, který banka ani dohled neuznají; (b) koupit end-to-end compliance suite od jednoho dodavatele — rychlejší ...	Nakupuje se: sankční a PEP data, matching engine, KYC ověřovací engine, blockchain analytika, TM/fraud platforma s case managementem, Travel Rule síť, DAC8 generátor. Staví se: PDP, rozhodovací deník, restrikce v ledgeru, ruleset registry, identitní model, back-office, FIU generátor, pKYC, reporting. Hranice vede tam, kde je hodnota v datech a síťovém efektu (nekoupitelné vlastní prací) versus tam, kde je hodnota ve znalosti našich peněžních toků a v důkazní stopě (nekoupitelné od dodavatele, protože dohled se ptá nás). Vlastní fuzzy matching jmen nebo vlastní atribuce kryptoadres je jistá cesta k tichému selhání; vlastní vynucení v ledgeru je naopak jediné, co nikdo jiný neudělá správně.	Každý nakupovaný komponent musí být za adaptérem s alespoň teoretickou druhou implementací a projít hodnocením podle DORA čl. 28–30 před podpisem (registr informací, lokalita zpracování, subdodavatelé, exit plán, auditní práva). Vzniká koncentrační riziko: TM platforma je současně detekce i case management. Náklad: vendor minima řádově 60–200 tis. EUR ročně souhrnně, plus ...
ADR-4: Jurisdikce, token a prahy jsou konfigurační rulesetu, ne konstanty v kódu Zvažováno: Napevno zvolit USDC + Litvu a zjednodušit — ušetří 15–20 % úsilí na compliance vrstvě, ale při passportingu do dalších států nebo při změně emitenta se to vrátí jako přepis rozhodovací logiky v době, ...	Ruleset je klíčovaný na (jurisdikce × produkt × aktivum × kanál × riziková třída). Nikde v kódu není literál 'XSGD', 'LT' ani '1000 EUR'. Rozhodnutí o licenčním perimetru a o stablecoinu ještě nepadlo a padnout musí dřív než licenční žádost. XSGD ani USDT nejsou v EU autorizované EMT; přechod na USDC/EURC je pravděpodobný. Zároveň se posouvá regulační osa: AMLR od 10. 7. 2027 mění prahy a zakazuje anonymitu-enhancing aktiva, PSD3/PSR přinesou re-autorizaci. Zapečení kterékoli z těchto hodnot znamená refaktoring pod časovým tlakem.	Vyšší počáteční složitost (rozlišovací klíč všude, testovací matice rostle) a nutnost disciplíny — konfigurace musí být verzovaná a schvalovaná, jinak jsme jen přesunuli problém do YAML. Odměnou je, že změna tokenu nebo jurisdikce je změna konfigurace se shadow během, ne projekt.
ADR-5: Pravidla se nasazují jen přes shadow běh a čtyři oči Zvažováno: Pravidla jako součást kódu s běžným code review — jednodušší, ale změnu prahu pak dělá vývojář v release cyklu, což je pro compliance nepoužitelně pomalé, a analytik nemá způsob, jak sám ověřit dopad.	Změna kteréhokoli prahu, pravidla nebo rizikové matice vyžaduje shadow run proti historii z rozhodovacího deníku, dopadovou analýzu (kolik alertů přibude/ubude, kolik dřívějších záchyťů by nová verze propustila) a schválení druhou osobou; rollback je jednotlivá operace. Nejběžnější způsob, jak se compliance systém rozpadne, není chyba v pravidle, ale nekontrolované doladění prahu pod tlakem fronty alertů. Bez shadow běhu nikdo netuší, co změna udělá, a bez čtyř očí není doložitelné, kdo ji povolil — což je při kontrole první otázka.	Zpomaluje reakci na nově zjištěnou typologii (shadow běh trvá desítky minut až hodiny). Proto je nutná úzká, samostatně schvalovaná „emergency“ cesta pouze pro zpřísnění (nikdy pro uvolnění), s povinným zpětným přezkumem do 24 h. Vyžaduje také, aby rozhodovací deník uchovával vstupy, ne jen výsledky — to je netriviální objem dat (odhad 3–8 GB/měsíc při 100 tis. transakcí ...
ADR-6: Zmrazení a blokáce jsou účetní entita v ledgeru, ne příznak na účtu Zvažováno: Příznak na účtu plus samostatná tabulka blokáce mimo ledger — rychlejší o ~15 MD, ale rekondicace pak nesedí a při auditu nelze doložit, kde blokováné peníze účetně jsou.	Restrikce je záznam s rozsahem, právním důvodem, iniciátorem, schvalovatelem a expirací, kterému odpovídají zápisy v podvojném ledgeru; dostupný zůstatek se počítá, neukládá. Boolean `frozen` na účtu neunesse realitu: zmrazit je potřeba částku, ne účet; zmrazení ze sankcí má jiný režim než dočasné pozastavení kvůli šetření; klient s částečným zmrazením musí dál moci hradit povolené položky. Navíc při odmrazení musí být doložitelné kdo, kdy a na základě čeho — příznak to neunesse.	Složitější výpočet dostupného zůstatku a nutnost pokrýt ho invariantními testy (součet dostupné + blokováno = zůstatek, v každé měně, vždy). Zavazuje k tomu, že každá peněžní cesta čte dostupný zůstatek přes jedno API — pokud si někdo přečte `balance` napřímo, restrikce se obejde.
ADR-7: Tipping-off bezpečnost vynucená typovým systémem, ne procesem Zvažováno: Manuální revize každé odpovědi na žádost subjektu — funguje při deseti klientech, neškáluje a je to jediné selhání od trestněprávního problému.	Dvě datové třídy — client-visible a compliance-only — oddělené na úrovni DTO a schématu. DSAR export, klientské API a notifikace čtou výhradně z client-visible view; pokus dostat compliance-only pole do klientského DTO neprojde kompilací ani CI kontrolou. Zákaz tipování (AMLR čl. 54) je v ČR trestněprávně relevantní a poruší se jedním nedopatřením — poznámkou v exportu, risk skóre v odpovědi API, nebo formulací zamítnutí. Procesní kontrola „analytik zkontroluje export“ selže při prvním objemovém náporu.	Dvojí modelování části entit a zákaz generických „vrať mi celý objekt“ endpointů. Odmítnutí a omezení služby musí mít předschválené neutrální formulace ve všech třech jazycích. Omezení práv subjektu musí být opřeno o konkrétní ustanovení (čl. 23 GDPR) a zdokumentováno pro každý jednotlivý případ — což je funkce v back-office, ne interní politika.

Rozhodnutí	Volba a důvod	Důsledek
ADR-8: Nebiometrická cesta ověření je rovnocenný kanál, ne fallback Zvažováno: Pouze biometrická cesta se souhlasem — levnější, ale právně křehké (klient KYC odmítnout nemůže, takže souhlas není svobodný) a při odvolání souhlasu vzniká neřešitelná situace mezi GDPR a AML ...	Onboarding má od začátku dvě plnohodnotné větve: biometrickou (selfie + liveness + porovnání s dokladem) a nebiometrickou (video-hovor s operátorem, eIDAS/bankovní identita, ověřovací platba z účtu vedeného na stejné jméno). AML předpisy biometrii nevyžadují, jen připouštějí — proto nezakládá právní titul podle čl. 9 GDPR a spoléhat na výslovný souhlas znamená, že odvolání souhlasu musí být bezdůsledné pro službu. Od 2. 8. 2026 navíc u 1:N identifikace nastupuje režim vysoce rizikového systému podle AI Act s povinnostmi provozovatele (lidský dohled, logování, informování osob).	Zdvojnásobuje rozsah onboardingů (odhad +40–60 MD proti jednokanálové variantě) a vyžaduje operátorský tým pro video kanál ve třech jazycích. Zároveň to sníží konverzní ztrátu u klientů s doklady, které OCR nezvládá — u venezuelské klientely reálný přínos, ne jen compliance náklad.
ADR-9: Prostředky čekající na Travel Rule sedí na suspense účtu, ne za příznakem Zvažováno: Držet čekající převody mimo ledger v samostatné tabulce — jednodušší, ale znamená druhou pravdu o penězích, což je přesně chyba, kterou dnešní demo má (zůstatek a historie jako dvě nezávislé pravdy).	Odchozí i příchozí kryptopřevod ve stavu čekání na výměnu údajů je zaúčtován na oddělitelný travel-rule suspense účet; teprve dokončení výměny prostředky uvolní na klientský účet, nebo spustí vrácení. Travel rule v EU nemá práh, takže čekající stav je běžný, ne výjimečný. Příznak „pending“ na klientském zůstatku znemožňuje rekonsiliaci, safeguarding výpočet i odpověď na otázku, komu peníze v daném okamžiku patří. Sunrise issue (protistrana v jurisdikci bez travel rule) navíc vyžaduje explicitní rizikové rozhodnutí a jeho evidenci.	Více účtů v účtové osnově a nutnost stárnutí zůstatků na suspense účtech s alertem (peníze, které tam leží týden, jsou provozní i regulatorní problém). Vyžaduje jasnou politiku, po jaké době se převod vrací odesílateli a jak se to klientovi sděluje bez porušení zákazu tipování.
ADR-10: Každé rozhodnutí musí být deterministicky přehratelné Zvažováno: Ukládat jen výsledek rozhodnutí — o řád levnější na storage, ale znemožňuje backtesting i obhajobu; při první kontrole transakčního monitoringu je odpověď „nevíme, proč to tehdy prošlo“ náletem.	Rozhodnutí = f(snímek vstupů, verze rulesetu, verze každého použitého seznamu, verze modelu). Vše čtyři se ukládají spolu s výsledkem; replay služba musí u libovolného historického decision_id vrátit identický verdikt. Bez toho nelze udělat tři věci, které jsou všechny povinné nebo nevyhnutelné: ladit prahy proti historii, obhájit před dohledem, proč konkrétní transakce prošla (v době, kdy seznam ještě neobsahoval danou entitu), a splnit informační povinnost podle čl. 13 a 22 GDPR ohledně logiky automatizovaného rozhodování.	Sankční a PEP seznamy se musí verzovat a archivovat lokálně, ne jen volat jako API — to je samostatný datový problém (denní snapshoty, desítky GB ročně). Dodavatelé, kteří neumí vrátit verzi seznamu k datu, jsou tím z výběru vyloučeni.
ADR-11: MiCA čl. 50 a čl. 53 jsou strojově kontrolované invarianty v CI Zvažováno: Právní revize textů před každým vydáním — nutná tak jako tak, ale jako jediná kontrola je pomalá, drahá a nepokrývá dynamicky skládané texty a číselné konfigurace.	CI gate, který shodí build, pokud produktová konfigurace obsahuje odměnu, slevu, cashback nebo bonus, jehož vzorec je funkcí zůstatku nebo doby držení EMT; k tomu lexikální lint UI a marketingových textů ve všech třech jazycích na zakázané formulace typu „výnos“, „zhodnocení“, „úrok“, „spoření“, „rendimiento“, „yield“. Zákaz úročení EMT je podle rešerše nejčastější product-killer u peněženkových produktů a nejsledovanější ustanovení ze strany ESMA/EBA. Tým už jednou příslib 2,4 % p. a. odstranil ručně — ruční kontrola se ale neopakuje při každém commitu a produkt má tři jazyky a funkci Safe Money plus „srovnání kupní síly proti inflaci“, tedy dvě místa, kde formulace snadno sklouzne do výnosového jazyka.	Falešně pozitivní nálezy lintu budou obtěžovat copywritery a bude potřeba schvalovaný whitelist výjimek (maker-checker). Srovnání proti inflaci musí mít v API povinné pole s disclaimerem a zakázané názvy polí typu `return`, `yield`, `profit` — což omezuje volnost návrhu API. Cena je nízká (odhad 8–12 MD), přínos je, že regulatorní chyba se zachytí v pull requestu, ne v ...
ADR-12: Daňová rezidence a TIN se sbírají při onboardingu, i když se hlásí až od 2027 Zvažováno: Odložit sběr do doby, kdy hlášení skutečně začne — ušetří 10 MD teď a stojí kampaň za 40+ MD plus odliv klientů později.	Self-certification daňové rezidence a TIN je povinná součást KYC toku od první verze, s validací formátu podle země a kontrolou rozporu proti ostatním indiciím. DAC8 vyžaduje sběr dat od 1. 1. 2026 s prvním hlášením za rok 2026. Dosbírávat TIN u existující klientské báze je remediation kampaň s typicky 20–40 % neúspěšností a s nutností omezit službu neodpovídajícím klientům — což u remitenčního produktu znamená odchod klientů.	Delší onboarding o jednu obrazovku a nutnost vysvětlit klientovi, proč to chceme (informační povinnost podle čl. 13). U klientů s venezuelskou rezidencí a evropskými rodinnými vazbami vzniká netriviální počet případů dvojí rezidence, které potřebují ruční posouzení.

6.3 Klíčové toky

Onboarding, KYC, fronta ruční revize a odvolání

- 1 Klient zahájí registraci; identitní služba založí subjekt ve stavu `unverified` s tierem 0 — PDP v tomto tieru odmítá jakoukoli peněžní operaci, včetně příchozího vkladu (ten se drží na suspense účtu, nepřipisuje se).
- 2 KYC orchestrátor vytvoří relaci u ověřovacího dodavatele a nabídne dvě rovnocenné cesty: biometrickou nebo nebiometrickou (bankovní identita / eIDAS / video-hovor).
- 3 Dodavatel vrátí podepsaným webhookem extrahované atributy, skóre pravosti dokladu, výsledek liveness a důkazy; orchestrátor je ukládá do důkazního trezoru s retenční třídou a právním titulem u každé položky.
- 4 Sbírá se daňová rezidence a TIN (DAC8), účel obchodního vztahu a zdroj prostředků; u vyššího rizika i doklad o zdroji.
- 5 Screening jména, data narození, adresy a — u právnických osob — skutečných majitelů proti sankčním, PEP a adverse media datům; každý zásah dostane dispozici s odůvodněním.
- 6 Rizikové skórování vrátí třídu (nízká / standardní / vysoká / nepřijatelná) podle rulesetu pro danou jurisdikci a produkt; venezuelský koridor a remitenční profil jsou samostatné faktory, ne penalizace.
- 7 Automatické schválení jen pro nízkou a standardní třídu bez zásahů. Vše ostatní jde do fronty ruční revize se SLA (cíl: 90 % do 24 h, 99 % do 72 h) — fronta má prioritizaci, ne FIFO.
- 8 Analytik případ posoudí v back-office; schválení klienta ve vysoké rizikové třídě vyžaduje druhého schvalovatele (maker-checker), zamítnutí vyžaduje strukturovaný důvod z číselníku.
- 9 Rozhodnutí se propíše do tieru a okamžitě do PDP; klient dostane sdělení z předschválené sady formulací — u zamítnutí z AML důvodu neutrální text, který neprozrazuje důvod ani existenci podezření.
- 10 Odvolání: klient jej podá v aplikaci, případ dostane jiný posuzovatel než ten, kdo zamítl (vynuceno frameworkem, ne dohodou), s lhůtou a písemným odůvodněním. Odvolání proti zamítnutí z důvodu sankčního zásahu má samostatnou cestu přes MLRO.

Tři místa, kde se to v praxi láme: (1) fronta bez SLA a bez prioritizace se během první marketingové kampaně nafoukne na týdny a stane se dohledovým nálezem; (2) chybějící odvolání znamená, že každé sporné zamítnutí skončí u dozoru nebo v recenzích; (3) nebiometrická větev dodělaná „potom“ se nedodělá nikdy a produkt zůstane právně na souhlasu podle čl. 9, který klient může kdykoli odvolat.

Runtime rozhodnutí u odchozí platby (nejčastější cesta v systému)

- 1 Klient v aplikaci potvrdí platbu; klient posílá pouze záměr a idempotency key — částku, měnu a příjemce validuje server znovu.
- 2 Platební služba zavolá compliance-gate s intentem, identitou, protistranou, kanálem, zařízením a integritními signály klienta (Play Integrity / App Attest verdikt, root/jailbreak, hookovací framework, accessibility služby).
- 3 PDP paralelně vyhodnotí: KYC tier a jeho platnost, aktivní restrikce na účtu, sankční screening jména a IBAN/BIC příjemce (rozpočet ≤ 100 ms), limity (per-transakce, denní, měsíční, per-kanál), fraud skóre z feature store a rizikový profil.
- 4 Verdikt: ALLOW → decision_id; STEP_UP → vyžádání SCA nebo dodatečného ověření; HOLD → částka se přesune na šetřicí suspense účet a založí se případ; DENY → odmítnutí s klientovi sdělitelným důvodem (a interním důvodem odděleně v compliance-only třídě).
- 5 Při ALLOW platební služba zapíše do ledgeru; databázový constraint ověří, že decision_id je platné, dosud nespotřebované a jeho hash odpovídá skutečně účtované částce a příjemci — jinak transakce selže.
- 6 Rozhodnutí i vstupy jdou do rozhodovacího deníku spolu s verzí rulesetu a verzemi seznamů.
- 7 AML monitoring dostane událost asynchronně a vyhodnotí ji proti profilu a typologiím; případný alert vznikne řádově v minutách, ne v kritické cestě.
- 8 Při výpadku fraud skóringu PDP přejde do degradovaného režimu: sníží limity, vypne rizikové kanály a označí transakce k post-hoc přezkumu — ale sankční kontrola nikdy nedegraduje, při její nedostupnosti se platby v dotčené třídě zastaví.

Latencový rozpočet je architektonické omezení, ne cíl: pokud screening nezvládne p99 pod 100 ms, jde do kritické cesty jen sankční kontrola nad lokálně replikovaným seznamem a zbytek se řeší asynchronně. To je legitimní volba, ale musí být vědomá a zdokumentovaná — ne důsledek toho, že to bylo pomalé.

Odchozí převod kryptoaktiv s Travel Rule a screeningem

- 1 Klient zadá výběr na externí adresu; PDP nejprve ověří tier, restrikce a limity.
- 2 Chain-screening cílové adresy (Chainalysis/TRM/Elliptic): sankční zásah → okamžité DENY a případ; vysoké risk skóre → HOLD a eskalace na analytika. Při nedostupnosti dodavatele se neodesílá (fail-closed).
- 3 Klasifikace protistrany: adresa patřící CASP (řeší se přes travel-rule síť) vs. self-hosted. U self-hosted nad 1 000 EUR se vyžaduje doložené ověření kontroly adresy klientem — podpis challenge klíčem k adrese (EIP-191, u smart účtů EIP-1271) nebo mikroplatba; důkaz jde do trezoru.
- 4 U adres nově přidávaných klientem platí čekací doba 24–48 h vynucená policy enginem na serveru (ne v UI) a notifikace klientovi druhým kanálem — rozdíl mezi „útočník vybral vše okamžitě“ a „měli jsme den to zastavit“.
- 5 Sestaví se IVMS101 payload s údaji o plátcích a příjemcích a odešle se přes travel-rule síť; prostředky se zaúčtují na travel-rule suspense účet.
- 6 Čeká se na potvrzení protistrany. Potvrzeno → uvolnění do podpisové fronty. Odmítnuto nebo timeout → definovaný postup: dotaz, vrácení klientovi, nebo eskalace; při opakovaných neúplných údajích od téže protistrany vzniká případ.
- 7 Sunrise scénář (protistrana v jurisdikci bez travel rule): rozhodnutí podle konfigurovaného rizikového apetitu, vždy s evidencí — nikdy implicitní propuštění.
- 8 Podpis transakce prochází signing policy (prahová pásma, iniciátor ≠ schvalovatel, clear signing s ověřením calldata mimo hlavní UI); po odeslání se čeká na finalitu podle výše částky, teprve pak konečné zaúčtování.
- 9 Travel-rule údaje se ukládají do trezoru na 5 let a nikdy nevstupují do on-chain metadat, memo polí ani kontraktů.

Zápis osobního údaje na veřejný řetězec je jediná chyba v celém návrhu, která je fyzicky neopravitelná — proto to patří do code review checklistu a do DPIA, ne do provozní kontroly.

Sankční zásah → zmrazení → hlášení

- 1 Zásah přijde jednou ze tří cest: pre-transaction screening, delta re-screening po aktualizaci seznamu, nebo chain-screening adresy.
- 2 Systém automaticky založí restrikci typu `sanctions\_freeze` na dotčené prostředky — bez lhůty, bez možnosti automatického vypršení — a zablokuje všechny odchozí operace klienta.
- 3 Vzniká případ nejvyšší priority s okamžitou notifikací MLRO (nikoli e-mail: pager/telefon, protože sankční lhůty jsou hodinové).
- 4 Analytik ověří, zda jde o skutečnou shodu (jméno, datum narození, země, další identifikátory) nebo falešný pozitiv; rozhodnutí je vždy maker-checker, u true positive schvaluje MLRO.
- 5 True positive: zmrazení zůstává, podává se hlášení příslušnému orgánu ve lhůtě podle unijních restriktivních opatření, zakládá se legal hold na veškerá data klienta, aktivuje se tipping-off režim (klientovi se sděluje jen to, že prostředky nejsou k dispozici).
- 6 False positive: restrikce se uvolní s odůvodněním, subjekt se zapíše do whitelistu s expirací a s vazbou na konkrétní verzi seznamu — whitelist bez expirace je způsob, jak se za rok propustit skutečný zásah.
- 7 Odmrazení je vždy samostatná maker-checker akce s doloženým právním důvodem (výmaz ze seznamu, rozhodnutí orgánu); systém nikdy neodmrazuje sám.
- 8 Celý průběh — včetně časových razítek každého kroku — se ukládá do trezoru jako důkaz dodržení lhůt.

S klientelou z Venezuely je nutné vedle EU/OSN seznamů vědomě rozhodnout o vztahu k OFAC (sekundární sankce, USD/USDC koridor, Circle jako single point of freeze). To není technické rozhodnutí — je to otázka, jestli je cílový trh vůbec obsluhovatelný, a musí padnout

před stavbou, ne po ní.

Alert → případ → oznámení podezřelého obchodu (STR) na FIU

- 1 AML monitoring vygeneruje alert (typologie: strukturování pod prahem, průtokový účet, nesoulad s deklarovaným profilem, mule vzorec, neobvyklá kombinace koridorů).
- 2 Alerty se korelují do případu podle klienta a časového okna — deset alertů z jedné kampaně je jeden případ, ne deset.
- 3 Analytik případ šetří v back-office: časová osa, zapojené účty, protistrany, historie KYC, dřívější případy; může vyžádat doplňující informace od klienta (RFI) v neutrální formulaci.
- 4 Při rozhodnutí podat STR se automaticky založí legal hold (výmaz dat se pozastaví) a nastaví se tipping-off příznak, který blokuje DSAR export, marketing a jakoukoli klientskou komunikaci o důvodu.
- 5 Návrh STR se generuje z případu; obsah schvaluje MLRO (maker-checker), odeslání do goAML XML; doručení jde do trezoru.
- 6 Rozhodnutí, zda vztah ukončit nebo pokračovat pod zvýšeným monitoringem, je samostatné a dokumentované — automatický offboarding po STR není správně a v některých případech je v rozporu s pokyny FIU.
- 7 Případ zůstává otevřený pro navazující dožádání; příkaz k pozastavení transakce od FIU se implementuje jako restrikce se samostatným typem a vlastní lhůtou.
- 8 Uzavření případu vyžaduje vyplnění klasifikace (AML typologie, u fraud případů typ podvodu podle taxonomie EBA) — bez toho případ nelze zavřít, protože z těchto polí se generuje pololetní statistika.

Poslední krok je největší skrytá past celého návrhu: klasifikační pole vypadají jako administrativní zátěž a vždycky se odkládají. Bez nich je první pololetní hlášení podvodů nesplnitelné jinak než ručním přeznačením tisíců uzavřených případů.

Ladění falešných poplachů (tuning cycle)

- 1 Měsíčně se z rozhodovacího deníku a case managementu spočítá: false positive rate per pravidlo, medián doby do rozhodnutí, podíl alertů uzavřených bez šetření, počet záchytů vedoucích k STR.
- 2 Pravidla s FP rate nad prahem (typicky > 95 % u AML alertů znamená, že pravidlo nefunguje) jdou do revize.
- 3 Analytik navrhne novou verzi rulesetu; tuning lab ji přehraje proti historickým vstupům za posledních 6–12 měsíců.
- 4 Výstup shadow běhu: kolik alertů přibude, kolik ubude, a hlavně které dřívější skutečné záchyty (potvrzené true positive nebo STR) by nová verze propustila — to je jediné číslo, které rozhoduje.
- 5 Below-the-line testování: náhodný vzorek transakcí těsně pod novým prahem se ručně přezkoumá, aby se doložilo, že práh nepropouští systematicky.
- 6 Návrh se schvaluje maker-checker (analytik navrhuje, MLRO nebo compliance manager schvaluje) s přiloženou dopadovou analýzou.
- 7 Nasazení s možností okamžitého rollbacku; prvních 14 dní běží stará i nová verze paralelně (champion–challenger) a rozdíly se sledují.
- 8 Celý cyklus se archivuje — doložený a opakovaný proces ladění je přesně to, co dohled u transakčního monitoringu kontroluje; systém bez historie ladění působí jako systém, který nikdo nesleduje.

Zpřísnění může jít zrychlenou cestou (emergency change) při nově zjištěné typologii, uvolnění nikdy. Asymetrie je záměrná.

Průběžné přehodnocení rizika (perpetual KYC)

- 1 Události ze všech vrstev jdou na sběrnici: změna adresy nebo země, nová protistrana v rizikové jurisdikci, překročení objemového pásma, PEP zásah z delta re-screeningu, blíží se konec platnosti dokladu, změna vzorce chování oproti profilu, uzavřený fraud případ.
- 2 pKYC engine přepočítá rizikové skóre a porovná s aktuální třídou klienta.
- 3 Zvýšení třídy vyvolá požadované kroky: doplnění dokladu o zdroji prostředků, EDD dotazník, ověření skutečného majitele, případně dočasné snížení tieru — vždy s předchozím upozorněním klienta a lhůtou, ne s tichým odříznutím.
- 4 Snížení tieru se propisuje do PDP okamžitě a projeví se na limitech; klient vidí, co má doplnit, a do kdy.
- 5 Časové spouštěče doplňují událostní: vysoké riziko revize po 6–12 měsících, standardní po 24–36, expirace dokladu s předstihem 60 dní.
- 6 Nedoplnění ve lhůtě vede k odstupňovanému omezení (nejprve odchozí operace, pak vše kromě výběru vlastních prostředků) a případně k ukončení vztahu podle definovaného offboarding procesu.

Roční plošná revize všech klientů je verze, kterou nikdo nezládne udělat včas a která zároveň nezachytí nic mezi revizemi. Událostní model je levnější v provozu a lepší v záchytu, ale vyžaduje, aby sběrnice existovala od začátku — dodatečné napojení je drahé.

6.4 Rizika a opatření

Riziko	Opatření v návrhu
Compliance-gate je nový SPOF: jeho výpadek zastaví všechny platby, a naopak tlak na dostupnost povede k tichému zavedení fail-open.	Explicitní, schválená a testovaná matice fail-closed/fail-open per třída kontroly: sankce a KYC vždy fail-closed, fraud skóring a adverse media fail-open s povinným post-hoc doběhem do 24 h. Degradovaný režim se sníženými limity jako první reakce, ne vypnutí kontroly. Chaos testy výpadku každého dodavatele čtvrtletně; nedostupnost sankčního screeningu je klasifikovaný ICT incident podle DORA, ne provozní drobnost.
Záplava falešných poplachů: fronta alertů přeroste kapacitu analytiků, backlog se stane dohledovým nálezem a pod tlakem se prahy tiše uvolní.	Prahy se od začátku kalibrují proti shadow běhu na simulovaných i pilotních datech, ne odhadem. Kapacitní model (alertů/den × minut/alert × analytiků) je vstupem do rozhodnutí o nasazení pravidla, ne dodatečné zjištění. Uvolnění prahu jde vždy přes maker-checker a shadow běh; zpřísnění může zrychleně. Fázový rollout se zastropovanými zůstatky drží objem alertů v mezích kapacity, dokud není ladění zaběhnuté.
Bez obsazených lidí je maker-checker technicky hotový a procesně mrtvý — dnešní tým je fakticky jednočlenný a čtyři oči nelze simulovat.	Nábor MLRO (litevský daňový rezident), compliance managera na úrovni vedení a nezávislého DPO se plánuje jako kritická cesta 6–9 měsíců elapsed, ne jako 45 člověkodní. Do doby obsazení se rizikové operace tvrdě zastupují na úrovni, kde jeden schvalovatel stačí, a to se přizná v licenční dokumentaci. Framework se staví i tak — jinak se dodělává do systému, který už drží cizí peníze.
Prozrazení podezření (tipping-off) přes DSAR export, chybovou hlášku, notifikaci nebo formulaci zamítnutí — v ČR trestněprávně relevantní.	Oddělení datových tříd vynucené typovým systémem a CI kontrolou, ne revizí. Předschválené neutrální formulace odmítnutí a omezení služby ve všech třech jazycích. DSAR workflow s povinným krokem kontroly proti case managementu a s dokumentovaným omezením práv podle čl. 23 GDPR pro každý jednotlivý případ. Penetrační test zaměřený i na tento únik informací, ne jen na technické zranitelnosti.
Sunrise issue u Travel Rule: protistrany bez podpory protokolu způsobí, že významná část převodů uvázne nebo se bude muset vracet, což se projeví jako nefunkční produkt.	Volba sítě s největším pokrytím v cílových koridorech je výběrové kritérium číslo jedna, ne cena. Adaptér nad protokolem umožní přidat druhou síť. Explicitní sunrise politika s rizikovým apetitem schváleným MLRO. Stárnutí zůstatků na travel-rule suspense účtech s alertem a s automatickým vrácením po definované lhůtě.
Koncentrace u jednoho dodavatele (TM platforma je současně detekce i case management; chain analytika je jediný zdroj atribuce adres) — výpadek nebo ukončení smlouvy ohrozí provoz i licenci.	Hodnocení podle DORA čl. 28–30 před podpisem, povinné klauzule podle čl. 30 (auditní práva, lokalita dat, exit strategie s testovanou migrací), zápis do registru informací. Rozhodovací deník a evidence zůstávají u nás, takže výměna dodavatele nezničí historii. Exit plán se testuje, ne píše — jednou ročně zkušební export dat z dodavatele a ověření použitelnosti.

Riziko	Opatření v návrhu
Rozpor mezi AML retencí a GDPR: buď se drží vše „pro jistotu“ 10 let (porušení čl. 5 odst. 1 písm. e), nebo se maže dřív (AML sankce).	Parametrická retence per kategorie s vlastním spouštěčem, oddělený AML trezor s vlastním režimem přístupu, legal hold jako první třída, skutečné mazání jobem (ne příznak deleted). Přejchod z desetileté národní lhůty na harmonizovanou pětiletou podle AMLR čl. 77 od 10. 7. 2027 musí být změna konfigurace, ne přepis kódu.
Automatizované AML/fraud rozhodování bez vysvětlitelnosti naráží na čl. 22 GDPR a na informační povinnost podle čl. 13 — a při stížnosti klienta nelze doložit, proč byl odmítnut.	Každý verdikt nese strukturované reasons[]; modely s neprůhledným výstupem se používají jako jeden faktor, nikdy jako samostatný důvod zamítnutí. U každého automatického zamítnutí je dostupná lidská revize (odvolání). Informační povinnost popisuje existenci a logiku scoringu konkrétně, ne obecnou frází.
Chybějící sběr klasifikačních dat od prvního dne (typ podvodu, použitá výjimka ze SCA, AML typologie, TIN) znemožní první dohledová a daňová hlášení.	Povinná pole vynucená schématem už ve F1, i když se hlásí až ve F3. Jednou za kvartál zkušební vygenerování všech budoucích hlášení nad reálnými daty — chybějící pole se odhalí, dokud je báze malá. Toto je nejlevnější opatření v celém seznamu a nejdražší opomenutí.
Screening selže tiše: transliterace španělských, arabských a cyrilických jmen, přezdívk, chybějící datum narození, adresní varianty — falešně negativní zásah se nikdy neprojeví jako chyba.	Nekupovat pouze matching engine, ale i pravidelné testování jeho účinnosti: kontrolní sada známých entit (včetně variant zápisu) se použije proti produkčnímu screeningu měsíčně; nezachycení kontrolní entity je incident. Křížová kontrola dvou nezávislých seznamových zdrojů u sankcí. Nikdy nestavět vlastní fuzzy matching.
Rozsah: EMI + CASP + custody + karty + FX + hyperinflační produkt současně znamená, že compliance vrstva musí pokrýt šest různých regulačních režimů najednou — a žádná z fází se nikdy nedokončí.	Rozhodovací sprint před stavbou: pokud padne rozhodnutí nedržet vlastní custody nebo jít jako agent/distributor pod cizí licenci, odpadá Travel Rule vlastní implementace, chain screening a značná část F2 — řádově 150–250 MD a jedna licenční třída. Compliance architektura je na to připravená (ADR-4), ale rozhodnutí musí padnout dřív, než se napíše první adaptér.
Produktová logika sklouzne k výnosovému jazyku: „Safe Money“, „srovnání kupní síly“ a hyperinflační příběh jsou tři místa, kde formulace nebo cenová konfigurace poruší MiCA čl. 50 nebo 53.	Strojový invariant v CI nad produktovou konfigurací a lexikální lint textů ve všech třech jazycích (ADR-11), plus povinné disclaimer pole v API srovnání a zákaz názvů polí typu return/yield/profit. Právní revize textů zůstává, ale jako druhá linie — první zachycení musí být v pull requestu.

7. Blockchainová vrstva

Úschova klíčů, podpisová politika, atribuce depozitů a token-agnostická integrace.

Cílem této vrstvy je, aby aplikace mohla přijímat, držet a odesílat stablecoin jménem klientů tak, že (a) ztráta libovolné jedné komponenty — serveru, cloudu, člověka, RPC providera, dodavatele custody — nevede ke ztrátě klientských aktiv, a (b) volba konkrétního tokenu a řetězce je řádek v registru, ne vlastnost kódu. To druhé není estetika: audit ukázal, že XSGD ani USDT nejsou v EU autorizované EMT, takže produkt dnes stojí na aktivu, které bude muset vyměnit, a dnešní demo má symboly zabezčené přímo v typovém systému (`src/domain/types.ts:1 `Currency` union, :15 `STABLECOINS = ['XSGD','USDT']`). Statistika roku 2025 (76 % odcizených prostředků z kompromitace klíčů a podpisových procesů, nikoli z chyb v kontraktech) určuje pořadí priorit: první je nezávislé ověření obsahu transakce a segregace klíčů, teprve pak kryptografie. Vrstva je proto navržena kolem jednoho invariantu — nikdo, ani člověk, ani služba, nikdy nepodepisuje data, která sám nezkonstruoval z odsouhlaseného záměru — a kolem jednoho tvrdého účetního pravidla: on-chain hodnota se stává disponibilní až po finalitě řetězce, nikdy dřív. Vůči MiCA čl. 75 je bezpečnostní architektura přímo finanční expozicí, protože odpovědnost za ztrátu klientských aktiv je objektivní a omezená jen tržní hodnotou ztraceného aktiva.

7.1 Komponenty

Celkem 17 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Registr aktiv a řetězců (Asset & Chain Registry)

Fáze 1

Jediný zdroj pravdy o tom, co je dané aktivum: řetězec, adresa kontraktu, decimals, sémantická třída tokenu (vrací bool / nevrací, fee-on-transfer, nutný reset approve na nulu, podpora EIP-2612), typ freeze adaptéru, adresa proxy admina a hash známé implementace, regulační status podle MiCA a povolené jurisdikce, potvrzovací politika, pegová reference a sada oracle zdrojů, expoziční limity. Žádný symbol tokenu se nesmí vyskytnout nikde v kódu jako konstanta ani jako člen typu.

Technologie: Postgres s append-only historií verzí, konfigurace validovaná JSON Schema v CI, podepsaná offline klíčem, načítaná službami s ověřením podpisu při startu i za běhu · **Rozhraní:** `resolveAsset(asset_id) → AssetSpec; listOfferable(jurisdiction, client_class) → [asset_id]`; každý záznam má verzi a hash, který se povinně loguje u každé transakce a u každého podpisu. Změna registru prochází stejným režimem jako změna podpisové politiky: čtyři oči + 24h timelock + podpis HSM klíčem.

Ledgerový záměr a outbox (Transaction Intent + Outbox)

Fáze 1

Převádí obchodní požadavek (výběr, sweep, doplnění hot) na kanonický, neměnný záměr s idempotenčním klíčem a rezervuje prostředky podvojným zápisem ještě před tím, než se cokoli dostane k síti. Je to hranice mezi účetnictvím a řetězcem: on-chain vrstva nikdy nesáhá do zůstatků, pracuje výhradně se záměry.

Technologie: Postgres, celočíselné minor units, účty jako řádky (`client_id, asset_id`) — nikdy enum měn · **Rozhraní:** `createIntent(idempotency_key, client_id, asset_id, amount_minor, destination) → intent` s kanonickým hashem; outbox tabulka čtená broadcasterem ve stejné DB transakcí jako zápis do postings (transactional outbox, žádné dvoufázové commity)

Adaptér poskytovatele úschovy (Custody Provider Adapter)

Fáze 1

Izoluje zbytek systému od toho, kdo klíče fakticky drží. Stejně rozhraní obsluhuje nakoupenou custody (Fireblocks / Copper / Taurus / Zodia), vlastní MPC cluster i cold multisig. Bez této vrstvy je výměna dodavatele přepsáním půlky backendu — a exit strategie pro kritického ICT dodavatele je podle DORA čl. 28–30 povinná, ne volitelná.

Technologie: gRPC služba, per-provider implementace, kontraktní testy proti sandboxu každého providera v CI · **Rozhraní:** `deriveAddress(scope, index) → address; requestSignature(intent_hash, unsigned_tx, policy_context) → signature | rejected; getVaultBalances(); subscribeToVaultEvents()`. Rozhraní je záměrně úzké — adaptér nikdy nepřijme surová calldata bez odpovídajícího `intent_hash`.

Neměnný auditní log podpisových operací (WORM)

Fáze 1

Zaznamenává každé volání podpisu, každou změnu politiky, každou změnu allowlistu, každý přístup ke klíčovému materiálu a každou odeslanou transakci: identita iniciátora a všech schvalovatelů, verze politiky, verze registru aktiv, hash podepisovaných dat, výsledek screeningu. Musí přežít kompromitaci samotné aplikace — proto jiný účet, jiný tenant, jiné oprávnění.

Technologie: S3 Object Lock / Azure immutable blob v odděleném účtu, hash chain, čas z důvěryhodného zdroje, retence 5 let podle AML/MiCA · **Rozhraní:** append(event) bez možnosti update a delete; čtení pro compliance a forenziku; hash chain přes dávky s periodickým kotvením

Policy engine (schvalovací a limitní stroj)

Fáze 2

Rozhoduje, zda a za jakých podmínek se záměr smí podepsat. Vyhodnocuje pásma částek, rolling limity per adresa / per hodinu / per den / globálně, časová okna, čtyři oči s tvrdě vynuceným pravidlem iniciátor ≠ schvalovatel, zámek nových adres, chování (nová adresa + maximální částka + mimo pracovní dobu = automatický hold bez ohledu na schválení) a regulatorní bránu z registru aktiv. Běží mimo aplikaci, s vlastním úložištěm a vlastním adresářem identit.

Technologie: Samostatná služba, vlastní Postgres, politika jako verzovaná data (ne kód), WebAuthn s hardwarovým klíčem pro schvalovatele, oddělený IdP od klientské aplikace · **Rozhraní:** evaluate(canonical_intent) → {auto | needs_approvals(n, roles) | hold | deny(reason)}; approve(intent_hash, approver_identity, webauthn_assertion). Schvaluje se hash kanonického záměru, nikdy calldata.

Podpisová vrstva hot/warm — MPC/TSS nad HSM

Fáze 2

Prahové podepisování ECDSA pro provozní adresy. Klíč nikdy neexistuje celý; shares vznikají distribuovaným generováním a žijí uvnitř validovaných modulů v nezávislých doménách selhání. Adresa je stabilní napříč rotací podílů — to je hlavní důvod volby proti multisigu.

Technologie: Nakoupená MPC platforma (F2) nebo vlastní CGGMP21/DKLS23-třída knihovna s verifiable secret sharing (F3), podíly v AWS CloudHSM / Azure Managed HSM / on-prem Thales, každý v jiném providerovi; FIPS 140-3 Level 3 jako kořen důvěry, entropie výhradně z TRNG uvnitř modulu · **Rozhraní:** Volá se výhradně přes Custody Adapter; přijímá (intent_hash, unsigned_tx) a odmítá cokoli, co neodpovídá záměru schválenému policy engine

Cold multisig a estate hardwarových podepisovačů

Fáze 2

Drží většinu rezerv a všechna administrativní oprávnění (pauser, upgrader, vlastnictví forwarderů, změny signerů). Pravidla vynucená on-chain, takže je ověří auditor i dohled bez důvěry v naši infrastrukturu. Práh 4-ze-7, každý signer na vyhrazeném hardwarovém zařízení používaném výhradně k této činnosti.

Technologie: Safe smart account, Ledger/Trezor v enterprise režimu, EIP-712 typed data + ERC-7730 deskriptory pro clear signing včetně vlastního deskriptoru pro náš forwarder · **Rozhraní:** Safe (nebo ekvivalent) s timelockem na administrativní funkce; podpisy se pořizují na air-gapped stanicích proti vlastní verzované kopii podpisového rozhraní se SRI, nikdy proti veřejně hostovanému front-endu

Broadcaster (nonce serializer, gas manager, RBF)

Fáze 2

Jediný zdroj pravdy o nonce každé odesílací adresy, sestavení a eskalace poplatků, opakované odesílání a rušení. Nonce je současně idempotenční token vůči síti: stejný záměr, stejný nonce, stejný payload dá stejnou transakci, takže duplicitní odeslání je na síti no-op.

Technologie: Nonce z DB sekvence přidělený v téže transakci jako zápis do outboxu; eth_getTransactionCount se používá jen k rekonciliaci při startu a při přepnutí RPC, neshoda znamená zastavit a alertovat; pool více odesílacích adres místo souběhu na jedné; maxFeePerGas = baseFee × 1,125^k + tip pro cílové okno k bloků, s tvrdým ... · **Rozhraní:** submit(intent) → tx_hash; watchdog eskaluje; cancel(nonce) jako explicitní operátorská akce. Tabulka onchain_tx(intent_id, from, nonce, tx_hash[], gas_params, status, replaced_by) je perzistentní a přežívá restart.

Indexer a kanonický řetězec

Fáze 2

Vlastní pohled na řetězec. Ukládá kanonický řetězec jako posloupnost (výška, block_hash, parent_hash), každý event klíčuje trojicí (block_hash, tx_hash, log_index) a spravuje životní cyklus seen → confirmed → finalized → reorged. Je zdrojem pravdy o depozitech; webhooky dodavatelů slouží jen jako urychlení, nikdy jako pravda.

Technologie: Vlastní full node (Reth/Nethermind + Lighthouse) jako referenční zdroj + ≥2 nezávislé komerční RPC providery; sleduje se block tag `safe` a `finalized`, ne jen počet potvrzení · **Rozhraní:** Publikuje doménové události `deposit_seen` / `deposit_finalized` / `deposit_reorged` do ledgeru, idempotentně a s deduplikací podle event ID

Služba depozitních adres a CREATE2 forwarder

Fáze 2

Přiděluje každému klientovi vlastní depozitní adresu pro dvojici (aktivum, řetězec) a zajišťuje sweep na klientskou omnibus adresu. Adresa se odvozuje deterministicky, kontrakt se nasazuje až v okamžiku, kdy na adresu něco dorazí.

Technologie: CREATE2 se saltem `H(client_id, asset_id, chain_id, verze)`; cílová adresa je součástí init code, takže odvozená adresa sama zavazuje k cíli — kompromitovaný deployer nemůže na téže adrese nasadit forwarder mířící jinam. Minimální immutable kontrakt bez admin funkcí, externě auditovaný. · **Rozhraní:** `getDepositAddress(client_id, asset_id, chain_id) → address` (deterministicky, opakovaně stejná); `sweep(address) → intent`. Mapování adresa ↔ klient existuje výhradně off-chain a šifrovaně; on-chain se nikdy nezapisuje nic identifikujícího klienta.

Adaptér emitenta: freeze/blacklist a proxy watcher

Fáze 2

Před každým odchodem i příchozím pohybem zjišťuje, zda emitent některou stranu neomezil, a hlídá, že se kontrakt pod nohama nezměnil. Stav „zmrazeno emitentem“ je plnohodnotný, terminální stav v ledgeru i v UI — nikdy se z něj nestává retry smyčka.

Technologie: Adaptérové třídy vybírané registrem; při události `Upgraded` se automaticky pozastaví odchodí pohyby daného aktiva a porovná se bytecode hash nové implementace proti známé hodnotě v registru — odblokuje až člověk po diff review · **Rozhraní:** `isRestricted(asset_id, address) → bool` (implementace podle registru: USDT `isBlackListed`, USDC `isBlackListed`, XSGD ekvivalentní flag); watcher odebírá události blacklistu, Pause, `Upgraded(address)`, změn rolí a vlastnictví

Monitor pegu

Fáze 2

Nezávisle na emitentovi sleduje, zda aktivum drží paritu, a mechanicky omezuje expozici při odchylce.

Technologie: Minimálně tři nezávislé zdroje (order book mid z dvou burz, on-chain DEX TWAP, odkupní kotace emitenta, je-li dostupná), medián s odmítnutím odlehklých hodnot; nikdy jediný oracle · **Rozhraní:** `getPegDeviation(asset_id) → bps`; pásma z registru spouštějí akce: >50 bps po 15 minut alert a rozšíření spreadu, >200 bps automatické pozastavení konverzí do aktiva (konverze ven zůstávají), >500 bps nebo pozastavení odkupu u emitenta plný halt aktiva

Brána screeningu a travel rule

Fáze 2

Sankční a rizikový screening obou stran každého pohybu v transakční cestě (ne v reportingu) a výměna údajů o původci a příjemci podle TFR (EU) 2023/1113. Ukládá důkaz o provedeném screeningu v auditovatelné formě, protože právě ten dohled požaduje.

Technologie: Chainalysis / TRM / Elliptic pro screening, TR síť (Notabene / Sygna / TRP) pro IVMS101; ověření kontroly self-hosted adresy nad 1 000 EUR podpisem challenge podle EIP-191; travel-rule údaje nikdy do calldata ani do on-chain metadat · **Rozhraní:** `screen(address, direction, amount) → {clear | review(score) | sanctions_hit}` s TTL cache a povinným záznamem (provider, verze pravidel, čas, skóre, rozhodnutí, rozhodující osoba); `travelRule.resolveCounterparty(address) → {casp(id) | self_hosted}`; nightly re-screening celého adresáře a všech protistran za posledních ...

On-chain monitor a circuit breaker

Fáze 2

Nezávislé sledování všech vlastních adres a kontraktů s automatickou reakcí, ne s alertem do Slacku. Detekuje odchodí transfer bez odpovídajícího záměru v ledgeru, jakýkoli Approval event, změnu implementace nebo vlastnictví, pohyb mimo časové okno a překročení rolling limitu.

Technologie: Komerční detekční vrstva (Hypernative / Hexagate / OpenZeppelin Defender) plus vlastní pravidla; mirror monitoring z jiného cloudu a jiného RPC, aby výpadek hlavní infrastruktury monitoring neumlčel; čtvrtletní testování breakeru · **Rozhraní:** Pauser role s nízkým prahem (pozastavit snadno, odpauzovat těžko — odpauzování vyžaduje cold multisig); circuit breaker zastavuje výběry a v krajním případě spouští evakuaci na předem připravené adresy bez čekání na člověka

Rekonciliace a proof of reserves

Fáze 2

Průběžně, ne měsíčně, porovnává součet klientských zůstatků v ledgeru se skutečnými on-chain zůstatky na kontrolovaných adresách a páruje každou on-chain transakci se záznamem. Jakýkoli odchozí převod bez odpovídajícího záměru je incident nejvyšší priority.

Technologie: Samostatná služba čtoucí ledger read-only a řetězec z vlastního nodu; MiCA čl. 75 registr pozic klientů je odvozený pohled nad postings · **Rozhraní:** reconcile(asset_id) každých N minut → {ok | drift(amount)}; kanonický seznam kontrolovaných adres s prokázanou kontrolou (podpis zprávy klíčem, obnovovaný ročně); publikovatelný proof of reserves jako Merkle strom závazků plus on-chain důkaz aktiv

RPC federace a vlastní node estate

Fáze 2

Zajišťuje, že aplikace nemá jediný pohled na řetězec. Kritická čtení (zůstatky, potvrzení, finalita) se cross-checkují mezi zdroji; neshoda je alert a zastavení připsování, ne tichý výběr většiny.

Technologie: Vlastní full node jako referenční pravda, dva komerční provideri jako redundance; odesílání transakcí veřejným mempoolu i privátním relayem tam, kde hrozí front-running · **Rozhraní:** call(method, params, quorum_policy) → výsledek nebo divergence_alert; automatický failover s rekonziliací nonce a pending transakcí při přepnutí

Hardened podpisové prostředí

Fáze 2

Fyzická a softwarová izolace strojů, na kterých lidé podepisují. Bybit i Radiant začaly kompromitací vývojářské strany, ne kryptografie — nejlepší HSM nepomůže, když podvržené UI podstrčí jinou transakci.

Technologie: Vyhrazené hardened stanice, pinnované závislosti a lockfile, reprodukovatelné buildy s podepsanými artefakty a ověřením podpisu při deploy, oddělený verifikační přístroj pro nezávislý přepočítání hashe transakce · **Rozhraní:** Vlastní verzovaná kopie podpisového rozhraní se subsources integrity, žádné načítání JS z CDN třetích stran, žádná pošta, žádné prohlížení webu, žádné otevírání příloh na těchto strojích

7.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tím kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
ADR-01: Custody se v první a druhé fázi kupuje, nestaví Zvažováno: Nekustodiální model — klient drží klíče sám, my děláme fiat, platby a směnu, krypto jen jako on/off-ramp u licencovaného partnera. Toto je jediná varianta, která ruší odpovědnost podle čl. 75 úplně a ...	Klientská kryptoaktiva drží kvalifikovaný externí custodian s MiCA autorizací (nebo v procesu), přístupovaný výhradně přes vlastní Custody Provider Adapter. Vlastní MPC cluster se staví až tehdy, když padne kterákoli ze tří spouštěcích podmínek definovaných níže. Auditní odhad jen pro blockchainové mezery je 80 + 45 + 70 + 35 + 40 + 50 + 25 ≈ 345 člověkodní, a to je jednorázová stavba. Ustálený provoz vlastní custody stojí řádově 3 FTE bezpečnostního a SRE profilu, cloudové HSM ve dvou regionech, roční CCSS/pentest/TLPT a pojistné — dohromady v řádu 0,7–0,9 mil. EUR ročně (plánovací odhad, který je nutné nahradit reálnými nabídkami). Dodavatel účtuje typicky v desítkách ...	Custodian se stává kritickým ICT dodavatelem podle DORA čl. 28–30: musí být v registru informací, smlouva musí obsahovat práva na audit, lokaci dat a součinnost při incidentech, a musí existovat otestovaná exit strategie. Koncentrační riziko je reálné a nezmizí — proto je adaptér povinný od F1 a druhý poskytovatel je položka v F3. Zásadní upozornění, které se často podceňuje: ...
ADR-02: Hybridní klíčový model — MPC/TSS nad HSM pro hot a warm, multisig 4-ze-7 pro cold a pro oprávnění Zvažováno: Čistý multisig na všechno — prohrál na chain-agnosticitě, gasu a na tom, že rotace signerů je viditelná a pomalá operace. Čisté HSM s jedním klíčem uvnitř modulu — nejjednodušší provozně, ale kdokoli ...	Provozní podepisování prahovým MPC/TSS s podíly uloženými v HSM validovaných podle FIPS 140-3 Level 3, rozproštěnými do nezávislých domén selhání (dva různé cloudové providery plus jeden on-prem modul). Cold rezervy a všechna administrativní oprávnění na smart-contract multisigu s prahem 4-ze-7 a hardwarovými podepisovači. HSM není ... MPC vyhrálo pro hot a warm ze tří konkrétních důvodů. Za prvé stabilita adresy: rotace podílů nemění adresu, což je zásadní, protože na naše adresy jsou navázány whitelisty protistran, depozitní odvození a smluvní přílohy — u multisigu je každá změna signerů on-chain transakce a u části protistran administrativní proces. Za druhé chain-agnosticita: registr aktiv musí umět i řetězce, kde Safe neexistuje (XSGD je ...	Za MPC se platí tím, že pravidla podepisování jsou vynucená mimo řetězec — v našem policy engine. Kdo ovládne policy engine, obejde je, protože on-chain tam žádná druhá brána není. Z toho plynou dvě povinné protiváhy: (a) většina hodnoty musí ležet tam, kde pravidla vynucuje řetězec, tedy v cold multisigu, a (b) hot zůstatek musí být sám o sobě stropem ztráty (viz ADR-03). ...

Rozhodnutí	Volba a důvod	Důsledek
ADR-03: Podíly hot/warm/cold se odvozují z odtoku, nejsou paušál, a hot strop je vynucen zůstatkem Zvažováno: Jedna omnibus adresa se softwarovými limity — prohrála, protože limity jsou pak jen v naší databázi a jediná kompromitace je bez stropu. Fixní procenta bez vazby na odtok — prohrála, protože buď ...	Hot = max(p99 denního čistého odtoku za posledních 30 dní, minimální provozní float), zastropováno na min(2 % aktiv v úschově, absolutní strop v EUR). Warm ≈ 8–10 %, dostatečné na doplnění hot v rámci dne. Cold ≥ 88 %. Sweep z depozitních adres jde přímo do cold, nikdy přes hot. Doplnění hot z warm dávkově dvakrát denně plus na vyžádání ... Paušální „1–2 %“ je bezcenné číslo, dokud nevíte, kolik denně odtéká — u remitenčního produktu s výplatními špičkami může být p99 odtoku násobkem průměru a příliš nízký hot znamená, že se výběry zastaví, což je z pohledu klienta výpadek služby. Naopak příliš vysoký hot je přímá expozice. Klíčová vlastnost návrhu je, že hot zůstatek je jediný bezpečnostní strop, který nezávisí na tom, jestli je náš policy engine ...	Provoz musí umět žít s tím, že velký výběr počká na plánované doplnění warm — to je produktové rozhodnutí, které patří do smluvních podmínek a do UI, ne do improvizace v 03:00. Zároveň to znamená, že treasury potřebuje predikci odtoku, ne jen jeho měření. On-chain segregace podle MiCA čl. 75 odst. 7 přidává další dimenzi: klientská a firemní aktiva mají oddělené adresy v každé ...
ADR-04: Disponibilní je až finalizované — žádné připsování před finalitou Zvažováno: Připsování na 12 potvrzeních jako Binance — prohrálo, protože přínos (2,4 min místo 12,8 min) je pro remitenční produkt zanedbatelný, zatímco cena je reorg handler, který musí umět odebrat už ...	Příchozí depozit se po dosažení `safe` zapíše podvojně proti účtu „nepotvrzené vklady“: klient částku vidí ve stavu „potvrzuje se“, ale nemůže s ní disponovat. Na klientský disponibilní účet se převede až po dosažení `finalized` (2 epochy, ≈ 12,8 minuty na Ethereum). Reorg tedy nikdy nesahá na disponibilní zůstatek. Burzovní praxe (12–20 potvrzení) je vědomé připsování před finalitou proti riziku a existuje proto, že burzy soutěží o vteřiny při obchodování. Náš produkt nesoutěží o vteřiny — soutěží se SWIFTem, kde alternativa trvá dva dny. Za 13 minut latence dostaneme zdarma celou třídu odstraněných problémů: žádné klawbacky proti utracenému zůstatku, žádné záporné zůstatky po reorgu, žádná otázka „kdo nese ztrátu, když ...	Klient čeká. To musí být v UI vysvětlené a nesmí to vypadat jako chyba. U L2 je to horší: „finalita“ na L2 není finalita na L1, a u optimistických rollupů je L1 settlement v řádu dnů. Důsledek pro registr aktiv: každý řetězec má vlastní politiku a u L2 se buď akceptuje L2 finalita s tvrdým expozičním limitem a explicitním rizikovým rozpočtem, nebo se L2 pro velké částky ...
ADR-05: Atribuce depozitů přes per-klientskou adresu odvozenou CREATE2, s cílem zabezčením v odvození Zvažováno: Omnibus adresa s párováním podle částky — prohrála na atribuci a na AML. EOA per klient s gas top-upem — prohrála na dvojnásobku transakcí a na uvíznutém prachu. EIP-7702 — odložena; může se stát ...	Každý klient dostane pro dvojici (aktivum, řetězec) vlastní depozitní adresu, odvozenou deterministicky přes CREATE2 se saltem H(client_id, asset_id, chain_id, verze). Kontrakt je minimální immutable forwarder bez administrativních funkcí, nasazovaný líně až v okamžiku prvního sweepu, a cílová adresa je součástí init code — takže z ... Na EVM neexistuje memo ani destination tag, takže omnibus adresa nedává žádnou spolehlivou atribuci — museli bychom klienty párovat podle částky a času, což je pro AML nepoužitelné a pro klienta nespolehlivé. Zbývají tři cesty. EOA per klient vyžaduje před každým sweepem poslat na adresu ETH na gas (dvě transakce místo jedné) a nechává tisíce adres s uvíznutým prachem. EIP-7702 delegace umožní sponzorovaný sweep bez ...	Porušujeme vlastní pravidlo nenásazovat žádný vlastní kontrakt — a platíme za to externím auditem (řádově 20–40 tis. EUR a 4–8 týdnů), invariant a fuzz testy ve Foundry, testnetovým a shadow nasazením a vlastním ERC-7730 deskriptorem, aby hardwarové peněženky uměly interakci s forwarderem dekodovaně zobrazit. Druhý důsledek je ochrana údajů: depozitní adresa přiřazená ...
ADR-06: Schvaluje se záměr, calldata staví podepisovač — anti blind-signing v strojové formě Zvažováno: Simulace transakce (Tenderly/Blockaid) jako hlavní obrana — zůstává jako doplňková vrstva hostovaná mimo hlavní front-end, ale prohrála jako hlavní obrana, protože simuluje to, co jí někdo předloží, ...	Kanonický záměr (klient, aktivum, částka v minor units, cíl, řetězec) je jediný, co kdy vidí schvalovatel, a schvaluje jeho hash. Podepisová služba nezávisle sestaví calldata ze stejného záměru a podepíše jen tehdy, když hash calldata, kterou sama postavila, odpovídá schválenému záměru. Surová calldata z vnějšku se nikdy nepodepisuje. Pro ... Toto je jediný opatření, které by zastavilo Bybit (podvržený front-end Safe po kompromitaci vývojářského stroje změnil transakci na delegatcall měnící implementaci), WazirX (nesoulad mezi zobrazeným a podepsaným) i Radiant (malware podstrčil transferOwnership do Ledgeru, který Safe transakce neparsuje). Ve všech třech případech byl multisig i cold storage formálně v pořádku a útok prošel skrz to, co člověk viděl. ...	Podepisová služba musí umět sestavit calldata pro každou sémantickou třídu tokenu a pro každou operaci, kterou systém provádí. To je záměrné omezení: co neumí sestavit, to systém neumí udělat — a to je vlastnost, ne chyba. Ad hoc on-chain operace (interakce s novým kontraktem, nouzový zásah) proto vyžadují buď rozšíření podepisové služby přes normální change management, nebo ...

Rozhodnutí	Volba a důvod	Důsledek
ADR-07: Aktivum je řádek v registru, ne člen typu — a je to testovatelné akceptační kritérium Zvažováno: Feature flag na úrovni aplikace („podporujeme USDC místo XSGD“) — prohrál, protože neřeší ledger, adresy, sémantiku ani regulatorní bránu a jen odkládá přepis. Podpora právě jednoho aktiva s tím, že ...	V backendu neexistuje žádný typ ani konstanta obsahující symbol tokenu. Účty jsou dvojice (client_id, asset_id), aktiva jsou řádky v registru, chování tokenu je vybráno sémantickou třídou z registru přes TokenAdapter, produktová logika (spread, sazebník, hyperinflační režim) se řídí atributem měny, ne rovností na symbol, a regulatorní ... Dnešní demo má opak: `Currency` je union obsahující `XSGD` a `USD` (src/domain/types.ts:1), `STABLECOINS` je pole literálů (:15), kurz VES↔XSGD existuje ve dvou nezávislých definicích, které se potkávají zhruba na páté platné číslici. Když padne rozhodnutí přejít na USDC/EURC — a ono padnout musí, protože XSGD ani USDT nejsou v EU autorizované EMT — znamená to v tomto tvaru přepis domény, obrazovek, textů i testů. ...	Registr se stává bezpečnostně kritickou konfigurací a musí být chráněný jako podpisová politika: verzovaný, podepsaný, měněný čtyřma očima s 24h timelockem, s hashem logovaným u každé transakce. Špatný řádek v registru (jiná adresa kontraktu, jiné decimals) je stejně nebezpečný jako chyba v kódu — proto validace schématem v CI a povinný testnetový průchod před aktivací nového ...
ADR-08: Nonce je idempotenční token vůči síti, přidělováný databází, nikdy RPC Zvažováno: Nonce z RPC s optimistickým retry — prohrál na závodech mezi nody a při restartu. Jedna odesílací adresa s globálním zámekem — prohrála na propustnosti, protože při výplatní špičce se fronta ...	Nonce se přiděluje z databázové sekvence v téže transakci, ve které vzniká záznam v outboxu. Tabulka onchain_tx váže intent → odesílací adresa → nonce → seznam tx hashů → stav a přežívá restart. eth_getTransactionCount slouží výhradně k rekonsiliaci při startu a při přepnutí RPC; neshoda znamená zastavit odesílání a alertovat, nikdy ... Stejný záměr, stejný nonce a stejný payload dají bajtově identickou transakci se stejným hashem — síť ji deduplikuje sama. Idempotence odchozích plateb tím přestává být otázkou naší logiky a stává se vlastností protokolu. Opačný přístup, kdy se nonce bere z RPC, má dvě selhání: pending versus latest se mezi nody liší, takže dva různí provideri dají různá čísla, a při restartu služby vzniká závod, jehož výsledkem je ...	Databáze se stává kritickou cestou pro odesílání — bez ní se neodesílá nic, což je správně, ale klade to tvrdé nároky na její dostupnost a na PIR. Watchdog musí eskalovat poplatky přes replace-by-fee s navýšením obou polí (maxFeePerGas i maxPriorityFeePerGas) nejméně o 10 %, jinak geth náhradu odmítne; jen zvýšení typu nestačí. Zároveň musí existovat tvrdý absolutní strop v ...
ADR-09: V custody cestě nevzniká žádný allowance — a proto je jakýkoli Approval event incident Zvažováno: Neomezené allowance kvůli úspoře gasu — prohrálo triviálně, v roce 2024 tímto vzorcem oteklo přes 100 mil. USD. Přesné allowance s měsíčním auditem — zůstává jako záložní režim pro případ, kdy se ...	Všechny naše pohyby jsou přímé transfery z vlastních adres a sweepy z forwarderů; nikde se neuděluje allowance. Pokud by kdy byl nutný (interakce s likviditním protokolem), pak výhradně přesná částka, jednorázově, s revokací ve stejné dávce, a přednostně přes EIP-2612 permit s deadline. Monitoring má natvrdo pravidlo: naše adresy ... Zapomenutý neomezený allowance na kontrakt, který je později kompromitován nebo upgradován, znamená vyprázdnění zůstatku bez jakékoli další interakce z naší strany. Klasická obrana (nikdy type(uint256).max, periodický audit allowance) je nutná, ale je reaktivní. Když se allowance v našem návrhu nevyskytuje vůbec, mění se detekce z „je tenhle allowance v pořádku?“ na binární invariant, který nevyžaduje úsudek. ...	Kdykoli produkt sáhne po něčem, co allowance potřebuje (DEX, likviditní pool, agregátor), rozhodnutí se dostane před bezpečnostní review, protože zruší invariant. To je záměrné tření. Zároveň platí, že u tokenů vyžadujících reset na nulu (USDT) se používá forceApprove sémantika a nikdy přímý přepis nenulového allowance na jiné nenulové.
ADR-10: Emitent je protistrana s vlastním rizikem, ne infrastruktura Zvažováno: Ignorovat freeze a řešit ho reaktivně — prohrálo, protože bez preflight kontroly aplikace opakovaně posílá transakce, které revertnou nebo projdou s uvízlými prostředky, a klientovi lže. Jediný ...	Ledger nese u každé pozice stav omezení (liquid / frozen_by_issuer / quarantine / legal_hold). Před každým pohybem se čte freeze predikát pro obě strany přes adaptér vybraný registrem. Události blacklistu, pauzy a zejména Upgraded na proxy tokenu se monitorují; Upgraded automaticky pozastaví odchozí pohyby daného aktiva do doby, než ... XSGD i USDT (a stejně tak USDC) jsou centrálně kontrolované upgradovatelné kontrakty s funkcí zmrazení adresy — Tether v roce 2025 zablokoval přes 4 000 adres a 1,26 mld. USD. Předpoklad, že kód kontraktu je neměnný, je prostě nepravdivý: proxy lze upgradovat kdykoli a bez našeho souhlasu. Zmrazení hlavní omnibus adresy zastaví výběry všech klientů najednou, takže to není okrajový scénář, ale scénář kontinuity ...	Stav „zmrazeno emitentem“ musí být plnohodnotný, terminální stav v ledgeru, v API i v UI — klient uvidí zůstatek a pravdivé sdělení, že s ním nelze nakládat, a systém se do něj nezacyklí retry smyčkou. Provozně to znamená mít předem otestovaný kontakt na emitenta a připravený formát žádosti o zmrazení (u kompromitace se počítá v minutách), právní runbook pro zmrazení klientské ...

Rozhodnutí	Volba a důvod	Důsledek
ADR-11: Screening a travel rule jsou fail-closed a v transakční cestě, zásah končí v karanténě, ne vrácením Zvažováno: Screening v batch reportingu po transakci — prohrál, protože po odeslání už není co zastavit. Fail-open při výpadku providera — prohrál na poměru rizik. Automatické vrácení zadržených prostředků — ...	Screening obou stran běží synchronně v cestě transakce, ne v reportingu. Nedostupnost poskytovatele znamená pozastavení pohybů, ne jejich propuštění. Sankční zásah je tvrdý blok bez možnosti přehlasování skóre. Příchozí prostředky se zásahem se připisují do karanténního účtu (klient vidí „zadrženo k prověření“) a nikdy se automaticky ... Převod na sankcionovanou adresu je porušení unijních restriktivních opatření nezávisle na úmyslu a pro mladý fintech je typicky existenční — banka ukončí vztah, dohled zahájí řízení. Automatické vrácení prostředků na adresu, která zásah vyvolala, je samo o sobě převodem na sankcionovanou adresu, tedy druhé porušení. Fail-open je lákavý, protože fail-closed znamená výpadek při výpadku dodavatele; ale výpadek je ...	Poskytovatel analytiky je kritický ICT dodavatel podle DORA čl. 28–30 se vším, co k tomu patří, a jeho výpadek je náš výpadek — proto sekundární poskytovatel v F3 a cache s TTL, která pokryje krátké výpadky u nízkorizikových, nedávno prověřených adres. Travel rule podle TFR (EU) 2023/1113 platí bez jakéhokoli prahu, takže se týká každého převodu; u self-hosted adres nad 1 000 ...
ADR-12: Žádný vlastní most, cross-chain jen nativní emisí nebo mechanismem emitenta Zvažováno: Wrapped varianta přes zavedený most — prohrála, protože wrapped token po hacku mostu ztrácí krytí i cenu bez ohledu na kvalitu našeho zabezpečení, a je to historicky nejnákladnější jednotlivá ...	Nikdy nestavíme vlastní most a nepoužíváme mosty třetích stran s validátorským multisigem. Multi-chain se řeší tím, že aktivum je nativně emitované na cílovém řetězci (registr to eviduje jako samostatné asset_id), případně mechanismem burn-and-mint samotného emitenta typu CCTP. Bridge hacky tvoří od roku 2022 přes 69 % všech odcizených prostředků v DeFi, kumulativně přes 2,8 mld. USD — Ronin 600 mil. (kompromitováno 5 z 9 klíčů), Wormhole 326 mil., Nomad 190 mil., Multichain přes 100 mil. Vzorec je vždy stejný: nízkoprahový validátorský multisig. Přitom to není potřeba: XSGD je nativně na Ethereum, Polygonu, Arbitrum, Avalanche, XRPL, Hedeře a Zilliqa, USDC je nativně prakticky všude, kam ...	Registr aktiv musí umět, že „stejný token na jiném řetězci“ je jiné asset_id s vlastní adresou, vlastní potvrzovací politikou a vlastními limity — nikoli tentýž záznam s jiným chain_id. Účetně to znamená oddělené účty a explicitní treasury operaci při přesunu likvidity mezi řetězci, ne transparentní bridging. To je záměrně méně pohodlné.

7.3 Klíčové toky

Klientský výběr stablecoinu na externí adresu

- 1 Klient v aplikaci zvolí aktivum (asset_id z registru), částku a cílovou adresu z vlastního adresáře nebo zadá novou.
- 2 Backend ověří stav KYC jako tvrdou podmínku na serveru, produktovou způsobilost z registru (mica_status daného aktiva proti jurisdikci klienta) a disponibilní zůstatek počítaný z postings, nikdy z přepisovaného sloupce.
- 3 Ledger založí záměr s idempotenčním klíčem a podvojným zápisem rezervuje prostředky z klientského účtu na účet „ve výběru“; od této chvíle je dvojitá utracení vyloučené účetně, ne kontrolou.
- 4 Validace adresy: kontrolní součet EIP-55 a porovnání celého řetězce znaků; adresa vizuálně podobná dříve použité vyvolá varování a druhé potvrzení kvůli address poisoning.
- 5 Je-li adresa v klientově adresáři nová, aktivuje se 24h zámek s potvrzením druhým kanálem a notifikací na všechny kontakty klienta; výběr se do vypršení zámku vůbec nezařadí a zámek vynucuje policy engine na serveru, nikoli UI.
- 6 Screening cílové adresy u poskytovatele analytiky, synchronně a fail-closed; sankční zásah znamená tvrdý blok, případ pro compliance a hlášení FIU, prostředky zůstávají rezervované do rozhodnutí.
- 7 Travel rule: zjistí se, zda protistrana je CASP nebo self-hosted adresa; u CASP proběhne výměna IVMS101 přes TR síť ještě před odesláním, u self-hosted nad 1 000 EUR musí existovat doložené ověření kontroly adresy klientem podepsanou challenge podle EIP-191.
- 8 Freeze preflight přes adaptér z registru pro obě strany; je-li kterákoli omezená, záměr končí ve stavu blocked_by_issuer s pravdivou zprávou klientovi a bez jakékoli retry smyčky.
- 9 Policy engine vyhodnotí kanonický záměr proti verzované politice: pásma částky, rolling limity, časové okno, chování; výsledkem je automatické schválení, požadavek na N schvalovatelů, hold nebo zamítnutí s důvodem.

- 10 Schvalovatelé v odděleném rozhraní vidí dekodovaný záměr — kdo, komu, kolik, jaké aktivum, jaký řetězec — a potvrzují hash kanonického záměru pomocí WebAuthn na hardwarovém klíči; pravidlo iniciátor ≠ schvalovatel je vynuceno v datech.
- 11 Podle pásma se vybere zóna: malé částky z hot, střední z warm, velké nikoli přímo z cold klientovi, ale plánovaným doplněním warm a následným výběrem z warm.
- 12 Broadcaster přidělí odesílací adresu z poolu a nonce z databázové sekvence v téže transakci jako zápis onchain_tx, sestaví calldata pomocí TokenAdapteru vybraného sémantickou třídou z registru a spočítá poplatky jako $\text{baseFee} \times 1,125^k + \text{tip}$ pro cílové okno k bloků, s tvrdým EUR stropem.
- 13 Podpisová služba nezávisle sestaví calldata ze stejného záměru a porovná její hash se schváleným; teprve při shodě požádá custody adaptér o podpis. Cokoli jiného odmítne — surová calldata se nikdy nepodepisuje.
- 14 Odeslání proběhne přes nejméně dvě nezávislé RPC cesty; tx hash se připsí k nonce. Opakované odeslání téhož záměru se stejným nonce a payloadem je bajtově identická transakce, tedy no-op na úrovni sítě.
- 15 Watchdog hlídá zařazení; není-li transakce zařazena do stanoveného času, provede se replace-by-fee s navýšením obou poplatkových polí nejméně o 10 % (prakticky +12,5 %) až do stropu. Při dosažení stropu následuje alert a lidské rozhodnutí, nikdy tiché vzdání.
- 16 Po dosažení `finalized` ledger přeúčtuje z účtu „ve výběru“ a záměr se uzavře; skutečně odeslaná částka se ověří změnou zůstatku na řetězci, ne parametrem transakce.
- 17 Klient dostane notifikaci s tx hashem; WORM log obsahuje iniciátora, všechny schvalovatele, verzi politiky, hash záznamu registru aktiva, důkaz screeningu a hash podepsaných dat.

Kroky 6–8 jsou jediné, které mohou skončit blokem z regulačních důvodů, a všechny tři musí být fail-closed. Krok 13 je jádro obrany proti vzorci, který stál Bybit 1,5 mld. USD.

Příchozí depozit a jeho atribuce klientovi

- 1 Klient si vyžádá depozitní adresu pro dvojici (aktivum, řetězec); služba ji odvodí deterministicky přes CREATE2 se saltem $H(\text{client_id}, \text{asset_id}, \text{chain_id}, \text{verze})$, s cílovou omnibus adresou zabezpečenou v init code. Kontrakt se zatím nenasazuje.
- 2 Mapování adresa ↔ klient se ukládá výhradně off-chain a šifrovaně; on-chain nevzniká žádný údaj identifikující klienta (EDPB Guidelines 02/2025 — hash ani šifrovaný údaj nepřestává být osobním údajem a technická nemožnost výmazu není omluva).
- 3 Indexer sleduje Transfer události kontraktu z registru na množinu odvozených adres, souběžně z vlastního full nodu a nejméně dvou nezávislých komerčních RPC.
- 4 Nový event se uloží se stavem seen a klíčem (block_hash, tx_hash, log_index); odpovědi zdrojů se cross-checkují a jakákoli neshoda znamená alert a pozastavení připsování, nikoli tiché hlasování většinou.
- 5 Screening zdrojové adresy; zásah znamená připsání do karanténního účtu se stavem „zadrženo k prověření“ pro klienta, nikdy automatické vrácení odesílateli.
- 6 Kontrola travel rule u příchozích od CASP; chybějící nebo neúplné údaje vedou k holdu podle politiky, ne k tichému připsání.
- 7 Po dosažení `safe` se provede provizorní podvojný zápis proti účtu „nepotvrzené vklady“; klient částku vidí, ale nemůže s ní disponovat.
- 8 Po dosažení `finalized` (2 epochy, ≈ 12,8 minuty) se prostředky převedou na disponibilní clientský účet. Připsaná částka se určí měřenou změnou zůstatku on-chain, ne parametrem transakce — kvůli tokenům s poplatkem při převodu a rebasingu.
- 9 Sweep: forwarder se líně nasadí a v jedné transakci přepoše zůstatek na clientskou omnibus cold adresu; gas platí vyhrazená firemní gas adresa, nikdy clientské prostředky, protože jinak by se porušila segregace podle MiCA čl. 75.
- 10 Rekonceiliace v pravidelném intervalu porovná součet clientských zůstatků v ledgeru se skutečným on-chain zůstatkem omnibus adres; odchylka nad práh je incident, odchozí transakce bez odpovídajícího záměru je incident nejvyšší priority.

Na EVM neexistuje memo ani destination tag, takže per-klientská adresa je jediná spolehlivá atribuce. Krok 8 je důvod, proč se reorg nikdy nedotkne disponibilních prostředků.

Reorg a odebrání provizorního připsání

- 1 Indexer zjistí, že `block_hash` ve výšce `H` neodpovídá uložené hodnotě kanonického řetězce.
- 2 Postup se zastaví, všechny eventy ve výškách $\geq H$ se označí jako `pending_reorg` a spustí se re-derivace z nového kanonického řetězce.
- 3 Eventy, které v novém řetězci existují se stejným (`tx_hash`, `log_index`), se vrátí do stavu `seen` a postupují normálně.
- 4 Eventy, které v novém řetězci zmizely, generují kompenzační podvojný zápis proti účtu „nepotvrzené vklady“ — nikdy proti disponibilnímu klientskému zůstatku, protože tam se před finalitou nic nedostalo.
- 5 Pokud reorg vyřadil naši vlastní odchozí transakci, nonce se uvolní a broadcaster odešle znovu se stejným nonce a stejným payloadem; ledger se nemění, protože výběr se uzavírá až po finalitě.
- 6 Reorg hlubší než definovaný počet bloků automaticky pozastaví připsování i odesílání a vyžádá si lidské rozhodnutí; každý reorg se loguje jako událost s dopadem na účetnictví.

Celý tok je jednoduchý právě proto, že platí ADR-04. Kdybychom přisouvali na 12 potvrzeních, musel by tento tok umět odebrat prostředky, které klient mezitím utratil — a to je problém, který nemá dobré řešení.

Doplnění hot z warm a sweep do cold

- 1 Treasury služba porovnává hot zůstatek s prahem odvozeným z p99 denního odtoku za posledních 30 dní a s absolutním stropem.
- 2 Při poklesu pod dolní práh vzniká záměr na doplnění z warm; jde standardní schvalovací cestou se čtyřma očima, ale s vyšším limitem než klientský výběr, protože cíl je naše vlastní, dlouhodobě whitelistovaná adresa.
- 3 Doplnění probíhá dávkově dvakrát denně v definovaném okně; ad hoc doplnění mimo okno vyžaduje dodatečného schvalovatele a automaticky zakládá provozní záznam.
- 4 Při překročení horního stropu hot vzniká záměr na sweep přebytku do cold; sweep je jednosměrný a nevyžaduje cold podpis, protože jde o vklad, ne výběr.
- 5 Doplnění warm z cold se plánuje s 24h předstihem, podepisuje se 4-ze-7 na hardwarových zařízeních v air-gapped prostředí proti vlastní verzované kopii podpisového rozhraní, a nikdy se nespouští jako reakce na aktuální odtok.
- 6 Depozitní sweepty z forwarderů míří vždy přímo do cold omnibus adresy, nikdy přes hot — hot nikdy nedrží víc, než je jeho strop, a to je jediná hranice ztráty, která nezávisí na poctivosti našeho policy engine.

Zákaz reaktivního doplňování warm z cold je záměrný: útočník schopný vyvolat vysoký odtok by jinak uměl vytáhnout cold prostředky do teplejší zóny.

Emitent zmrazí adresu nebo upgraduje kontrakt

- 1 Watcher zachytí událost blacklistu, pauzy nebo `Upgraded(address)` na proxy kontraktu tokenu z registru.
- 2 U `Upgraded` se okamžitě a automaticky pozastaví odchozí pohyby daného aktiva; bytecode hash nové implementace se porovná s hodnotou uloženou v registru.
- 3 Člověk provede diff review nové implementace; do jeho rozhodnutí zůstávají pohyby pozastavené. Odblokování vyžaduje aktualizaci registru, tedy čtyři oči a timelock.
- 4 U zmrazení klientské adresy se pozice v ledgeru přepne do stavu `frozen_by_issuer`; klient v aplikaci vidí zůstatek i pravdivé sdělení, že s ním emitent zakázal nakládat, spolu s kontaktem na řešení. Systém se nepokouší o žádné opakované odeslání.
- 5 Zakládá se compliance případ; podle důvodu zmrazení se posuzuje hlášení FIU a informování dohledu.

- 6 U zmrazení naší vlastní omnibus adresy se aktivuje runbook kontinuity: okamžitá eskalace na emitenta předem otestovaným kanálem, pozastavení výběrů v daném aktivu, komunikace klientům, a posouzení, zda jde o závažný ICT incident s notificační lhůtou podle DORA.
- 7 Souběžně běží monitor pegu; při odchylce nad 50 bps po 15 minut alert a rozšíření spreadu, nad 200 bps automatické pozastavení konverzí do aktiva při zachování konverzí ven, nad 500 bps nebo při pozastavení odkupu u emitenta plný halt aktiva a aktivace treasury runbooku.

Zmrazení omnibus adresy je scénář kontinuity provozu, ne okrajová situace — Tether v roce 2025 zablokoval přes 4 000 adres. Bez limitu expozice na jednoho emitenta je to událost, která zastaví celý produkt najednou.

Podezření na kompromitaci klíče (Key Compromise Protocol)

- 1 Spouštěčem je kterákoli z definovaných událostí: odchozí transfer z kontrolované adresy bez odpovídajícího záměru v ledgeru, Approval event z naší adresy, odchylka rekondiliace nad práh, neshoda mezi RPC zdroji, nebo lidské podezření.
- 2 Circuit breaker se aktivuje automaticky, bez čekání na to, až se někdo přihlásí: pozastaví výběry, zastropuje objemy. Pauser role má nízký práh — pozastavit musí být snadné, odpauzování vyžaduje cold multisig.
- 3 On-call podle jmenného rozpisu potvrdí incident a určí rozsah (která zóna, které klíče, které adresy).
- 4 Evakuace zbývajících prostředků na předem připravené, nikdy nepoužité evakuační adresy vytvořené během původní key ceremony a předem whitelistované; cílový čas zahájení je v řádu jednotek minut, ne hodin.
- 5 Souběžně odchází žádost emitentovi o zmrazení adresy útočníka předem otestovaným kanálem a v předem připraveném formátu — u stablecoinu je to jediné opatření, které umí ztrátu skutečně vrátit, a jeho okno se počítá v minutách.
- 6 MPC podíly se okamžitě re-sharují na nový kворum (adresa se nemění); u multisigu se kompromitovaný signer odvolává on-chain přes timelock a do jeho vypršení platí zvýšený práh.
- 7 Klasifikace incidentu a notificační řetězec: prvotní oznámení dohledu do 4 hodin od klasifikace jako závažného, průběžná zpráva do 72 hodin, závěrečná zpráva s kořenovou příčinou do 1 měsíce; souběžně se posuzuje ohlašovací povinnost podle GDPR.
- 8 Forenzika z WORM logu: co přesně bylo podepsáno, kým schváleno, proti jaké verzi politiky a jakému záznamu registru — bez toho nelze uzavřít závěrečnou zprávu ani uplatnit pojistné plnění.

Celý postup se nacvičuje nejméně jednou ročně včetně skutečného odeslání na evakuační adresu z dust zůstatku. Nenacvičený KCP je dokument, ne obrana.

Výměna tokenu XSGD → USDC jako změna konfigurace

- 1 Padne právní rozhodnutí (XSGD ani USDT nejsou v EU autorizované EMT, USDC a EURC ano).
- 2 Do registru přibude řádek pro USDC: chain_id, adresa kontraktu, decimals 6, sémantická třída (vrací bool, podporuje EIP-2612, freeze adaptér typu usdc), adresa proxy admina a hash známé implementace, mica_status authorized, potvrzovací politika, pegová pásma a expoziční limity.
- 3 Řádek XSGD se přepne na nabídku vypnuto pro EU jurisdikce; existující zůstatky zůstávají plně disponibilní k výběru a převodu, protože zákaz se týká nabízení, ne držby, kterou klient už má.
- 4 Ledger nevyžaduje žádnou migraci: účty jsou dvojice (client_id, asset_id), takže účty v USDC vznikají samy. Žádný typ ani enum se nemění.
- 5 Custody: založí se nová omnibus adresa a nové depozitní odvození; protože salt obsahuje asset_id, adresy se s XSGD nekříží a nemůže dojít k záměně.
- 6 Treasury provede řízenou konverzi firemní pozice. Klientské pozice se nekonvertují bez pokynu klienta — konverze cizího majetku bez pokynu je nepřípustná bez ohledu na to, jak dobře je míněná.

- 7 Produktová logika zůstává beze změny: spread a sazebník se řídí atributem inflačního režimu protistranné měny, ne rovností na symbol tokenu.
- 8 Rozsah změny kódu je nulový, pokud sémantická třída USDC už existuje; jedna nová implementace TokenAdapteru, pokud ne. Akceptačním kritériem je, že shadow asset v testovacím prostředí s odlišnou sémantikou projde celou testovací sadou bez jedině změny kódu.

Tento tok je zároveň test, jestli je ADR-07 skutečně dodržené. Pokud se ukáže, že migrace vyžaduje zásahy do domény, ledgeru nebo obrazovek, abstrakce se během vývoje rozpadla a je nutné ji opravit dřív, než se rozhodnutí o tokenu skutečně provede.

7.4 Rizika a opatření

Riziko	Opatření v návrhu
Kompromitace vývojářské strany a podvržení toho, co podepisující vidí — vzorec Bybit (1,5 mld. USD), WazirX (230 mil.) a Radiant (53 mil.). Multisig, cold storage i hardwarové peněženky jsou proti tomuto útoku samy o sobě bezcenné.	Schvaluje se hash kanonického záměru, calldata staví podpisová služba nezávisle a podepíše jen při shodě (ADR-06). K tomu clear signing s EIP-712 a vlastními ERC-7730 deskriptory, nezávislý verifikační přístroj přepočítávající hash jiným kanálem, tvrdé pravidlo nepodepsat nic, co zařízení neumí dekodované zobrazit, vyhrazené hardened podpisové stanice bez pošty a bez prohlížení webu, pinnované závislosti se SRI, reprodukovatelné buildy a vlastní verzovaná kopie podpisového rozhraní místo veřejně hostované instance.
Kompromitace policy enginu obchází celý MPC model, protože u MPC nejsou pravidla vynucená on-chain.	Většina hodnoty leží v cold multisigu, kde pravidla vynucuje řetězec. Hot zůstatek je sám o sobě stropem ztráty, udržovaný sweepem. Policy engine běží jako samostatná služba s vlastním úložištěm, vlastním adresářem identit a WebAuthn na hardwarových klíších; změna politiky prochází čtyřma očima a 24h timelockem a je zaznamenána ve WORM logu mimo dosah provozních administrátorů.
Implementační chyba v MPC protokolu umožňující extrakci klíče — historicky doložené u starších GG18/GG20 implementací.	Nepsat vlastní protokol. Pinovat na auditovanou knihovnu třídy CGGMP21/DKLS23 s verifiable secret sharing a autentizovaným kanálem mezi stranami, periodický key refresh, sledování bezpečnostních oznámení dodavatele jako součást vulnerability managementu. V F1/F2 se toto riziko z velké části přenáší na nakoupenou custody platformu, což je další argument pro ADR-01.
Koncentrační riziko na jediném poskytovateli custody — jeho výpadek, ztráta autorizace nebo insolvence zmrází veškerá klientská aktiva a je to nález podle DORA čl. 28–30.	Custody Provider Adapter povinně od F1, takže dodavatel je vyměnitelný bez přepisu backendu. Dodavatel v registru informací, smlouva s právy na audit, lokací dat a součinností při incidentech, zdokumentovaná a otestovaná exit strategie, a v F3 druhý poskytovatel pro rozdělení expozice. Cold multisig, jehož signery kontrolujeme my, drží většinu hodnoty i v modelu s nakoupenou custody.
Nákup custody nepřenáší odpovědnost — podle MICA čl. 75 zůstává objektivní odpovědnost za ztrátu klientských aktiv nám a je omezená jen tržní hodnotou ztraceného aktiva.	Explicitně to přiznat ve smlouvách i v investorském materiálu, nastavit smluvní odpovědnost dodavatele a pojistné krytí tak, aby pokrývaly reálnou expozici, a držet custody policy, registr pozic po klientech a čtvrtletní výpisy jako vlastní povinnost, kterou nelze outsourcovat. Bezpečnostní architektura se rozpočtuje jako finanční expozice, ne jako IT náklad.
Zaseknutá nonce fronta zastaví všechny výběry a projeví se jako výpadek služby; naopak závod při restartu může vést k duplicitnímu odeslání.	Nonce z databázové sekvence přidělený v téže transakci jako outbox zápis, perzistentní tabulka nonce ↔ tx hash ↔ stav přežívající restart, eth_getTransactionCount jen k rekonciliaci s tvrdým zastavením při neshodě, watchdog s replace-by-fee navyšujícím obě poplatková pole nejméně o 10 %, tvrdý EUR strop s alertem místo tichého vzdání, cancel transakce jako explicitní operátorská akce, pool odesílacích adres místo souběhu na jedné.
Kompromitovaný nebo lhoutí RPC endpoint může tvrdit, že transakce proběhla, nebo ukázat jiný zůstatek — a systém připiše neexistující vklad.	Vlastní full node jako referenční pravda plus nejméně dva nezávislé komerční providery; cross-check kritických čtení s alertem a pozastavením připsování při neshodě, nikoli tichým hlasováním; automatický failover s rekonciliací nonce a pending transakcí; mirror monitoring z jiného cloudu, aby výpadek hlavní infrastruktury monitoring neumlčel.
Upgrade proxy kontraktu tokenu změni chování, na kterém aplikace stojí, kdykoli a bez našeho souhlasu.	Proxy watcher sledující událost Upgraded; automatické pozastavení odchozích pohybů daného aktiva, porovnání bytecode hashe nové implementace s hodnotou v registru a odblokování až po lidském diff review přes změnu registru se čtyřma očima a timelockem. Předpoklad neměnnosti kontraktu se v návrhu nevyskytuje nikde.

Riziko	Opatření v návrhu
Depeg stablecoinu — reálný scénář USDC v březnu 2023 s propadem na ~0,87 USD kvůli 3,3 mld. USD uvízlým v jedné bance; postihuje i autorizovaného emitenta.	Nezávislý monitoring ze tří zdrojů s mediánem a odmítnutím odlehklých hodnot, pásma 50/200/500 bps s automatickou reakcí (rozšíření spreadu, pozastavení konverzí do aktiva, plný halt), limit na podíl klientských aktiv u jednoho emitenta, sledování attestací rezerv a bankovních protistran, předem připravená likviditní záloha a nacvičená krizová komunikace. V UI povinná disclosure rizika emitenta a depegu a absolutní zákaz prezentovat stablecoin jako ekvivalent koruny nebo dolaru.
Prezentace srovnání kupní síly jako výnosu — MiCA čl. 50 zakazuje jakoukoli odměnu vázanou na dobu držení EMT, a to je nejsledovanější ustanovení u peněžkových produktů.	Zákaz je vynucen produktově i technicky: v ledgeru nesmí existovat žádný mechanismus připisující hodnotu v závislosti na čase držení, srovnání proti inflaci je čistě informační výpočet nad kotvou bez jakéhokoli účetního dopadu, a marketingové formulace typu zhodnocení, výnos nebo úspory se blokují v lokalizačních textech i v review. Tým už jednou hranici respektoval odstraněním slibu 2,4 % p. a. — pravidlo je nutné zafixovat, aby se nevrátilo jinou formulací.
Depozitní adresa přiřazená klientovi je osobní údaj a cokoli zapsaného do veřejného řetězce je fyzicky nesmazatelné — jediná chyba v celém návrhu, která nemá nápravu.	On-chain se nikdy nezapíše nic identifikujícího klienta; mapování adresa ↔ klient existuje výhradně off-chain a šifrovaně s definovanou retencí; údaje travel rule se přenášejí TR sítí, nikdy v calldata ani v transakčních metadatech. Toto je architektonické rozhodnutí, ne kontrola v nápravě, a patří do DPIA.
Výpadek poskytovatele screeningu při fail-closed režimu zastaví pohyby; při fail-open by prošla sankční transakce.	Vědomě volíme fail-closed a přijímáme provozní výpadek jako menší zlo než regulatorní porušení. Zmírnění: cache rozhodnutí s TTL pro nízkorizikové, nedávno prověřené adresy, sekundární poskytovatel v F3, a poskytovatel v registru ICT dodavatelů s SLA a exit strategií podle DORA. Prostředky se zásahem končí v karanténě a nikdy se automaticky nevracejí, protože vrácení na sankcionovanou adresu je samo o sobě druhé porušení.
Abstrakce registru aktiv se během vývoje rozpadne návratem podmínek typu if (asset == 'XSGD') a migrace tokenů se stane přepisem — přesně to, čemu se celý návrh vyhýbá.	Shadow asset v testovacím prostředí s odlišnou sémantikou (nevrací bool, poplatek při převodu, jiná decimals) jako trvalá součást CI; testovací sada musí projít bez změny kódu. Statická kontrola v CI zakazující literály symbolů tokenů mimo registr. Code review s explicitní položkou v checklistu. Bez tohoto tření je tvrzení „konfigurace, ne přepis“ jen záměr.
Čtyřroční princip nelze zavést bez lidí — dnešní jednočlenný tým ho technicky ani procesně neunes, a přesto je předpokladem celé podpisové politiky.	Obsazení rolí je vstupní podmínka fáze F2, ne její výsledek: minimálně sedm nezávislých držitelů podílů pro cold multisig s prahem 4-ze-7, oddělené role pauser ≠ upgrader ≠ owner, schvalovatel mimo IT (treasury nebo compliance) pro nejvyšší pásmo. Do doby obsazení nesmí systém držet skutečná klientská aktiva. Toto je nejtvrdší závislost celého plánu a je personální, ne technická.
Nasazení vlastního forwarder kontraktu porušuje pravidlo nenasazovat nic vlastního a vytváří novou třídu rizika.	Kontrakt je minimální, immutable, bez administrativních funkcí, s cílem zapečeným v init code. Slither/Semgrep/Mythril jako gate v CI, manuální audit renomované firmy, invariant a fuzz testy ve Foundry, testnet a shadow nasazení, vlastní ERC-7730 deskriptor. A tvrdé pravidlo, které z toho neplyne oslabení: nikdy nestavět vlastní most, protože bridge hacky tvoří přes 69 % odcizených prostředků v DeFi.

8. Data, úložiště a soukromí

Tři neslučitelné požadavky najednou: rekonstruovatelné peníze, mazatelné osobní údaje, nesmazatelná AML složka.

Datová vrstva má unést tři vzájemně neslučitelné požadavky najednou: peníze musí být rekonstruovatelné do posledního halěře a nikdy přepsané, osobní údaje musí jít na požádání zničit, a AML složka musí přežít 5–10 let bez redakce. Neřeším to výjimkou ani politikou, ale fyzickým rozdělením dat do čtyř nezávislých domén (produktová a účetní data, PII trezor, AML trezor, audit trail), které spolu komunikují jen přes neprůhledné tokeny — nikdy přes jméno, IBAN nebo číslo dokladu. Výmaz se pak nedělá mazáním řádků napříč systémy, ale zničením klíče konkrétního klienta v PII trezoru: co zbyde v ledgeru, zálohách a WORM archivu, je pseudonym bez přiřazovací tabulky. Blockchainová vrstva je z pohledu dat čistě výpočetní — on-chain nejde ani jeden bajt odvozený od klienta, protože podle EDPB Guidelines 02/2025 je to jediná chyba v celém návrhu, kterou už nelze napravit. Volba tokenu, řetězce, jurisdikce a retenčních lhůt je řádek v tabulce, ne konstanta v kódu, protože AMLR mění lhůtu 10 → 5 let k 10. 7. 2027 a MiCA status tokenů se mění průběžně.

8.1 Komponenty

Celkem 17 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Ledger DB (účetní jádro)

Fáze 1

Jediný zdroj pravdy o penězích. Podvojně zápisy: tabulka postings, každá operace ≥ 2 řádky, součet přesně 0 v každé měně/aktivu zvlášť, vynuceno deferred constraint na úrovni transaction_id. Částky jako BIGINT v minor units (VES a hyperinflační měny: scale uložený u aktiva, ne globální konstanta 2). Zůstatek je materializovaný agregát, nikdy sloupec, který se přepisuje. Žádné UPDATE/DELETE — jen storno protizápisem. Nese subject_token, nikdy jméno.

Technologie: PostgreSQL 17 (managed, EU region), aplikační role bez UPDATE/DELETE grantu na postings, partitioning po měsících, pgaudit. TigerBeetle až pokud F3 překročí $\sim 2\,000$ postingů/s. · **Rozhraní:** gRPC/HTTP příkazy postTransaction(idempotency_key, legs[]), readBalance(account_id, at_time); logická replika pro reporting; outbox tabulka pro události ven.

Produktová DB (účty, karty, platby, trezory, KYC stav)

Fáze 1

Stav produktu bez osobních údajů: účty a jejich měny, virtuální karty a limity, příkazy k platbě (VS/KS/SS, IBAN/SWIFT jen jako token), Safe Money, stav KYC (jen enum a datum, ne doklady), jazyk klienta, nastavení. Každý sloupec má v katalogu přiřazený data_class a legal_basis; sloupec bez třídy neprojde noční kontrolou schématu.

Technologie: PostgreSQL 17, samostatný cluster a samostatný cloud účet od ledgeru, TLS verify-full, CMK šifrování svazků. · **Rozhraní:** REST/gRPC pro aplikační služby; CDC (logical decoding) do analytiky; odkaz na PII trezor přes subject_token a counterparty_token.

PII trezor (vault service + vlastní DB)

Fáze 1

Jediné místo, kde existuje jméno, datum narození, adresa, e-mail, telefon, číslo a typ dokladu, IBAN protistrany a blockchainová adresa klienta. Vydává neprůhledné tokeny (UUIDv7) a jen ty putují do zbytku systému. Šifruje po polích AES-256-GCM klíčem konkrétního klienta, AAD = tabulka||sloupec||subject_token, aby nešlo přenést ciphertext mezi řádky. Drží slepý index (HMAC-SHA256 zkrácený na 4 bajty, záměrné kolize) pro vyhledání podle e-mailu, telefonu a čísla dokladu bez dešifrování celé tabulky.

Technologie: Samostatná služba (Go/Rust) + PostgreSQL, vlastní cloud účet, vlastní KMS KEK s dual control, síťově dosažitelná jen z aplikační vrstvy přes mTLS, žádný přímý DB přístup pro vývojáře. Build vlastní, ne Skyflow/VGS — viz rozhodnutí. · **Rozhraní:** tokenize(field, value) → token, detokenize(token, purpose, reason) → hodnota (každé volání do audit trailu), lookupByBlindIndex(field, value) → kandidátní tokeny, shred(subject_token).

Audit trail (neměnný důkazní log)

Fáze 1

Kdo, kdy, co, odkud, s jakým výsledkem, u peněžních operací před/po. Řetězený hash: entry_hash = SHA-256(kanonický JSON || prev_hash). Zapisuje se výhradně přes append-only API, aplikační role nemá UPDATE/DELETE, produkční účet nemá credentials do WORM účtu. Payload obsahuje jen tokeny, nikdy hodnotu osobního údaje — proto se z něj nikdy nemaže a nemusí.

Technologie: PostgreSQL append-only tabulka + „sealer“ každých 5 min: Merkle root segmentu, podpis ECDSA P-256 klíčem v HSM (aplikace ten klíč nemá), kvalifikované časové razítko RFC 3161 od eIDAS TSA, uložení pečeti do S3 Object Lock (compliance mode, 10 let) v odděleném účtu. · **Rozhraní:** append(event) — synchronní, s návratem entry_hash; verifyRange(from,to) → OK/first_broken_index; getSealsForAuditor(period) → pečeti + Merkle důkazy.

Hierarchie klíčů a KMS/HSM

Fáze 1

Root of trust a celý životní cyklus klíčů. Čtyři úrovně: root KEK v HSM (nikdy neopustí modul) → doménové KEK (vault, aml, ledger-at-rest, backup, logs, analytics-salt, chain-signing — každý s jiným IAM) → per-subject DEK → per-object DEK. Oddělení rolí: kdo spravuje klíč, nemá přístup k datům, a naopak; vynuceno hranicí cloud účtů, ne politikou na papíře.

Technologie: AWS CloudHSM nebo Azure Managed HSM (FIPS 140-3 Level 3) jako root — ~2–5 tis. EUR/měsíc za HA pár, to je fixní cena vstupu; provozní KEK v KMS, DEK jako řádky, ne jako KMS klíče (100 tis. klientů × 1 USD/klíč/měsíc = neúnosné). · **Rozhraní:** Envelope API wrap/unwrap; cache dešifrovaných DEK jen v paměti vault služby, TTL max. 5 min, invalidace broadcastem při shred.

Shred store (klíčový materiál pro kryptografický výmaz)

Fáze 1

Malá tabulka subject_token → shred_secret (32 B). DEK klienta = HKDF(HSM_KEK_cohort, subject_token, salt = shred_secret). Zničení shred_secret zničí DEK navždy. Tento store má záměrně jinou zálohovací politiku než zbytek: PITR max. 24 h, žádné logické dumpy, žádné dlouhodobé snapshoty — aby okno, ve kterém by obnova ze zálohy mohla „vzkřísit“ smazaný klíč, bylo maximálně jeden den.

Technologie: PostgreSQL v účtu PII trezoru s vypnutými dlouhodobými zálohami, doplněno tombstone journalem ve WORM. · **Rozhraní:** deriveDek(subject_token), destroy(subject_token) → shred_receipt (podepsané, jde do audit trailu).

Katalog dat a strojově čitelný ROPA

Fáze 1

Registr datových tříd: pro každou tabulku/sloupec/objektový prefix drží data_class, legal_basis, retenci, umístění (region + poskytovatel), příjemce a odpovědnou roli. Z něj se generuje záznam o činnostech zpracování podle čl. 30 i DORA Register of Information a z něj čerpá mazačí i DSAR orchestrátor. Sloupec, který v katalogu není, shodí CI — to je jediný způsob, jak zabránit tomu, aby ROPA po roce neodpovídala realitě.

Technologie: Verzované YAML v gitu, validace v CI, materializace do produktové DB. · **Rozhraní:** YAML v repu → generovaná tabulka + kontrolní job proti information_schema; export do šablon ČNB a ÚOOÚ.

Registr aktiv a referenčních dat

Fáze 1

Token, řetězec, jurisdikce a sazebník jako data. Tabulka asset(code, chain_id, contract_address, decimals, issuer, regulatory_status, mica_authorized, valid_from) — XSGD, USDT, USDC, EURC jsou řádky, ne konstanty; přepnutí na autorizovaný EMT je migrace dat a produktové politiky, ne přepis ledgeru. Vedle toho pricing_version (spread, poplatek, režim hyperinlace) a reference_index(index_code, period, value, source, published_at, retrieved_at) pro zveřejněnou inflaci.

Technologie: Produktová DB + WORM snapshot každé verze sazebníku a každého zobrazeného srovnání kupní síly (disclosure_snapshot) pro obranu proti stížnosti. · **Rozhraní:** Read-only pro aplikaci; zápis jen přes schvalovací workflow se čtyřma očima; každý posting nese asset_id a pricing_version_id, aby šla transakce po pěti letech vysvětlit.

Zálohy, DR a testovaná obnova

Fáze 1

Zálohy jsou provozní nástroj, ne archiv — proto krátké. PITR 35 dní, snapshoty 90 dní, uložené v jiném cloud účtu s Object Lock proti ransomwaru, šifrované vlastním backup KEK, který produkční role nemůže použít k dešifrování. Dlouhodobé uchování dělá účelový AML archiv, ne zálohy, protože v záloze nejde selektivně smazat jednoho klienta.

Technologie: Managed PITR + logické dumpy pg_dump do S3 Object Lock; obnova do izolovaného účtu, nikdy do produkce. · **Rozhraní:** restore(target_env, point_in_time) → pipeline, která povinně v pořadí: obnoví data, přehraje tombstone journal, spustí rekonsiliaci, teprve pak otevře síť; report do audit trailu.

Úložiště KYC dokumentů

Fáze 2

Skeny a fotky dokladů, selfie s liveness, důkazy o původu prostředků. Každý objekt šifrovaný vlastním per-object DEK odvozeným z klientova DEK. Object Lock v governance módu do doby platnosti AML retence. Nikdy nevrací objekt přímo klientské aplikaci — jen krátkodobý podepsaný odkaz vydaný po autorizaci a zalogovaný jménem konkrétního operátora včetně důvodu.

Technologie: S3-compatible v EU regionu (AWS S3 eu-central-1) s Object Lock, SSE-KMS s vlastním CMK nad aplikačním šifrováním, cross-region replikace jen do eu-west-1. · **Rozhraní:** putDocument(subject_token, doc_type, bytes), getPresignedUrl(doc_id, actor, reason, ttl=300s), listByCase(case_id).

AML trezor (case management, screening, travel rule)

Fáze 2

Oddělená doména s vlastní retencí, vlastní KEK a vlastním okruhem rolí: CDD/EDD složky, screeningové zásahy, transakční monitoring alerty, SAR/STR a komunikace s FAÚ, travel-rule záznamy (jméno a adresa/číslo dokladu obou stran). Toto je jediné místo, které přežije žádost o výmaz — a jediné, kde po výmazu ještě existuje mapování token → osoba. Vlastní legal_hold tabulka, která pozastavuje jakýkoli mazací job.

Technologie: PostgreSQL v samostatném účtu, přístup jen přes PAM s JIT eskalací a nahráváním relace, MFA povinně, exporty zakázané technicky (žádné COPY TO, žádný síťový egress). · **Rozhraní:** Uzavřené API pro compliance konzoli; pro DSAR workflow jen boolean dotaz hasOpenInvestigation(subject_token) bez detailu (zákaz tipování, AMLR čl. 54).

Tombstone journal (žurnál výmazů)

Fáze 2

Append-only seznam všeho, co bylo kdy smazáno nebo kryptograficky zničeno (subject_token, data_class, čas, důvod, id zničeného klíče). Povinně se přehrává jako PRVNÍ krok každé obnovy ze zálohy, dřív než se obnovený systém pustí do provozu. Bez něj by restore z týden staré zálohy vrátil k životu data, která klient nechal smazat.

Technologie: S3 Object Lock (compliance mode) v odděleném účtu, JSONL, podepsané dávky stejným mechanismem jako audit pečeti. · **Rozhraní:** append(tombstone); replay(target_env, since) → počet aplikovaných výmazů + report; je součástí runbooku obnovy a testuje se čtvrtletně.

Retenční a mazací orchestrátor

Fáze 2

Parametrická retence jako data, ne jako kód. Tabulka retention_policy(data_class, legal_basis, trigger_event, duration, jurisdiction, valid_from, valid_to, source_ref) — přechod AMLR 10 → 5 let k 10. 7. 2027 je vložený řádek s valid_from, ne nasazení. Noční job maže po dávkách skutečně (DELETE + přepis, ne deleted=true), respektuje legal_hold, běží nejdřív v dry-run a rozdíl reportuje DPO. Metrika rows_overdue_for_deletion s alertem, pokud > 0 déle než 24 h.

Technologie: Job v aplikačním jazyce + tabulky v produktové DB; každý výmaz zapisuje do audit trailu i do tombstone journalu. · **Rozhraní:** planRetention(dry_run), executeRetention(batch), placeLegalHold(scope, reason, until), listOverdue() pro DPO dashboard.

DSAR / erasure orchestrátor

Fáze 2

Řídí celý životní cyklus žádosti subjektu údajů: ověření totožnosti bez sběru nových údajů (re-autentizace v aplikaci se SCA), sestavení datové mapy klienta z katalogu, kontrola právních titulů po kategoriích, kontrola proti AML (tipping-off), kontrola legal hold, provedení, doložení a odpověď do 1 měsíce. Vydává podepsaný erasure certificate.

Technologie: Workflow služba (Temporal nebo prostý state machine v Postgresu) — musí být trvanlivá a auditovatelná, protože kroky trvají dny a část je manuální. · **Rozhraní:** openRequest(type: access|erasure|portability|objection), getPlan(request_id) → co se smaže / co zůstane a proč, execute(request_id, approver), certificate(request_id).

Analytická vrstva s pseudonymizací

Fáze 2

Analytici a produkt nikdy nesahají na produkční data. CDC z read repliky prochází transformační službou v samostatném účtu, která má přístup ke KMS klíči analytické soli, ale ne ke KEK trezoru. Nahradí subject_token za

apid = HMAC-SHA256(salt_analytics, subject_token) zkrácený na 128 bitů, zahodí všechny vault tokeny, věk převede do pásem, adresu zobecní na NUTS2. Dataset zůstává osobním údajem (EDPB 01/2025) — má vlastní retenci 25 měsíců, řízení přístupu a je v ROPA.

Technologie: Debezium → transformace → ClickHouse nebo Postgres v EU. Vědomě se vyhýbám nástrojům, jejichž control plane nejde provozovat výhradně v EU. · **Rozhraní:** dbt modely nad pseudonymizovaným schématem; žádný přímý přístup k produkčním DB; přístup k soli má jen ingest služba.

Logy, telemetrie a SIEM

Fáze 2

Logy jsou nejčastější únik PII v produktech tohoto typu. Pipeline má povinnou redakční fázi (regex na IBAN, e-mail, telefon, číslo dokladu, PAN, JWT) a skener, který při zásahu neposílá záznam dál a zvedne alert na tým, který ho vypustil. Do logu smí jít jen tokeny a correlation_id. Vlastní retence: 12 měsíců hot, 24 měsíců cold; přístupový log ke KYC složkám 5 let jako samostatná třída.

Technologie: OpenTelemetry, Grafana Loki nebo vendor s EU-only regionem a DPA; SIEM s korelací cloud audit logu, KMS logu, IdP a WAF. · **Rozhraní:** OTLP z aplikací → kolektor s redakcí → Loki/OpenSearch v EU + forward do SIEM; SIEM pravidla mj. na nesouhlas součtu ledgeru a hromadné detokenizace.

On-chain indexer a adresní store

Fáze 2

Sleduje příchozí platby a stav odchozích, drží mapování depozitní adresa ↔ subject_token, nonce a stav transakcí. Adresa je osobní údaj, proto tento store patří do důvěrové zóny trezoru, má vlastní retenci a při výmazu se z něj mapování maže. Jedna depozitní adresa na klienta a řetězec, po uzavření vztahu se nikdy nepoužije znovu.

Technologie: PostgreSQL v zóně trezoru + vlastní RPC uzly/poskytovatel v EU; statická kontrola v CI, že do calldata/memo nemůže proniknout hodnota odvozená od klienta. · **Rozhraní:** onDeposit(address, tx_hash, amount, confirmations) → připsání do ledgeru přes idempotentní příkaz; buildWithdrawal(subject_token, asset, amount) — jediná cesta k podpisu, s whitelistem povolených polí.

8.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tým kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
Jeden databázový engine (PostgreSQL), izolace nasazením, ne exotikou Zvažováno: TigerBeetle pro ledger — vynikající výkon a vestavěná neměnnost, ale žádné SQL pro reporting, žádné joins s produktovými daty, a stejně by bylo potřeba druhé úložiště; odkládám na F3 a jen pokud ...	Všechny relační domény běží na PostgreSQL 17, ale ve fyzicky oddělených clusterech, v oddělených cloud účtech, s oddělenými credentials a oddělenými KMS klíči. Izolace se dělá hranicí účtu a IAM, ne volbou jiné technologie. Tým 14–25 lidí neužívá čtyři různé databázové provozy. Jeden engine znamená jednu sadu záloh, jeden monitoring, jednu migrační cestu, jeden model oprávnění. Riziko „jedna DB pro všechno“ neřeším jiným enginem, ale tím, že kompromitace aplikačního účtu nedává přístup k trezoru ani k logům.	Nese to fixní cenu: čtyři cluster s replikou místo jednoho, řádově 3–6 tis. EUR/měsíc na startu místo 1 tis. Zároveň se zavazujeme držet se vanilla Postgresu bez proprietárních rozšíření, aby zůstala použitelná exit strategie podle DORA čl. 30.
Vlastní PII trezor místo nákupu tokenizační služby Zvažováno: SaaS trezor by ušetřil vývoj a přinesl hotové certifikace, ale u většiny poskytovatelů je control plane mimo EU a výmaz závisí na jejich API a jejich zálohách — tedy přesně na věci, kterou musíme ...	Trezor si stavíme sami jako malou službu nad Postgresem a KMS. Skyflow, Very Good Security ani obdobné SaaS nepoužíváme pro primární úložiště. Trezor je jediné místo, kde smí existovat jméno a doklad. Dát ho externímu zpracovateli znamená, že nejcitlivější doména celého systému je závislá na cizím control plane, cizí lokalitě a cizím exit riziku — a přesně tuhle závislost DORA čl. 28–30 nutí dokumentovat, testovat a mít z ní cestu ven. Samotná služba je přitom malá: šifrování polí, slepý index, tokenizace, shred. Odhad 4–6 člověkoměsíců včetně testů.	Bereme na sebe odpovědnost za kryptografickou správnost (AAD, nonce management, konstantní čas u slepého indexu) a za penetrační test právě této služby. Nemáme certifikaci třetí strany jako marketingový argument. Na druhou stranu můžeme kdykoli doložit, kde přesně data leží.

Rozhodnutí	Volba a důvod	Důsledek
Výmaz se provádí zničením klíče (crypto-shredding), ne mazáním řádků napříč systémy Zvažováno: Per-subject KMS klíč (nejčistší, ale cenově vyloučený). Fyzické přepisování dat ve všech kopiích (neproveditelné u WORM a Pitr). Anonymizace místo výmazu (laťka EDPB Guidelines 02/2026 je vysoká a u ...	Každý klient má vlastní DEK odvozený z HSM KEK a z jeho shred_secret. Osobní údaje ve všech doménách jsou šifrované tímto klíčem. Výmaz = tvrdý DELETE v trezoru + zničení shred_secret + zápis do tombstone journalu. Rozstřílet výmaz do dvaceti systémů, jejich replik, WORM objektů a záloh je neproveditelné a hlavně nedokazatelné. Zničení jednoho klíče je jediná operace, kterou lze provést atomicky a doložit. RTS 2024/1774 čl. 6–9 i praxe dozoru kryptografické mazání uznávají, pokud doložíme, že bez klíče už data nejsou identifikovatelná.	Vzniká jediné kritické místo: dokud existuje shred_secret nebo jeho kopie, výmaz neproběhl. Proto má shred store jinou zálohovací politiku (Pitr 24 h, žádné dumpy) a proto je přehrání tombstone journalu povinný a testovaný krok každé obnovy. Zbytkové riziko: obnova ze zálohy starší než výmaz vrátí zašifrovaný záznam do stavu čitelnosti na dobu, než doběhne replay. Toto riziko ...
Ledger a audit trail se nikdy nemazou; osobní údaje se do nich nedostanou Zvažováno: Šifrovat PII přímo v ledgeru stejným subject DEK — funguje kryptograficky, ale znamená, že v peněžním systému leží zvláštní kategorie dat, což zbytečně zvyšuje jeho klasifikaci a rozsah PCI/AML ...	V postings a v audit.event nejsou žádné přímé identifikátory — jen subject_token, account_id, částka, aktivum, čas. Výmaz se jich proto vůbec netýká. Ledger musí být rekonstruovatelný a součet nula musí platit i pět let zpětně; smazání jednoho řádku rozbije rozvahu. Audit trail je hash řetěz — smazání položky rozbije důkaz o všem, co následuje. Jediné řešení je nedávat do nich nic, co by kdy bylo potřeba smazat.	Reporting a podpora nemohou dělat join na jméno. Bude opakovaně přicházet požadavek „přidej do reportu jméno klienta“ — to je governance rozhodnutí, které musí být explicitně a trvale zamítnuté, jinak celý model spadne. Kdo potřebuje jméno, volá detokenize s uvedeným důvodem a to volání je vidět v audit trailu.
Neměnnost audit trailu se dokazuje kvalifikovaným časovým razítkem a WORM, ne kotvením do veřejného blockchainu Zvažováno: Kotvení do veřejného řetězce (GDPR riziko, gas náklady, nulový regulační přínos). Azure Confidential Ledger / AWS QLDB (vendor lock-in a u QLDB ukončená podpora). Jen hash řetěz bez externí pečeti ...	Každých 5 minut Merkle root segmentu, podpis HSM klíčem, kvalifikované časové razítko podle eIDAS od EU TSA, uložení do S3 Object Lock v compliance módu v odděleném účtu s 10letou retencí. Žádné kotvení hashů na Ethereum. EDPB Guidelines 02/2025 v2.0 říká, že hash osobního údaje zůstává osobním údajem. Merkle root nad dávkou by šel obhájit, ale ta obhajoba není ověřená a její cena při chybě je nevratná. Přitom veřejné kotvení nepřidává nic, co by ČNB, ÚOOÚ nebo auditor požadovali — kvalifikované razítko má v EU vyšší důkazní váhu než transakce na veřejném řetězci.	Vzdáváme se veřejné ověřitelnosti třetí stranou. Auditor musí důvěřovat tomu, že jsme mu vydali kompletní sadu pečeti — proto pečeti chodí do účtu, do kterého produkce nemá credentials, a proto je verifikační job nezávislý. Náklad razítek je řádově jednotky EUR měsíčně, náklad WORM úložiště desítky EUR.
Primární i záložní data výhradně v EU; Singapur nedostane řádková data Zvažováno: Spoléhat na DPF u amerických dodavatelů (levnější, ale s existenčním právním rizikem). Multi-region včetně SG pro latenci (produkt cílí na EU klienty a jejich rodiny; latence není důvod).	Produkce v eu-central-1 (Frankfurt), DR v eu-west-1 (Irsko). Žádná služba, jejíž control plane nebo metadata nelze uzamknout do EU, nevstupuje do kritické cesty. Mateřská společnost v Singapuru dostává jen agregované manažerské reporty bez řádkové granularity. Kasační opravný prostředek Latombe (C-703/25 P) u SDEU není rozhodnutý a SDEU už dva předchozí rámce zrušil. Postavit onboarding na dodavatele, jehož legalita závisí na nerozhodnutém sporu, je provozní hazard — pád DPF by znamenal okamžité zastavení onboardingu.	Vylučuje to část dodavatelů (zejména analytické a support nástroje bez EU-only režimu) a někdy to znamená dražší nebo slabší variantu. Vzdálený přístup zaměstnance ze Singapuru do produkce je předání podle kap. V — řeší se SCC + TIA, PAM bránou hostovanou v EU, JIT eskalací, nahráváním relace a technickým zákazem stahování. Toto se eviduje v ROPA i v DORA registru informací.
Retence je konfigurace v datech, ne konstanta v kódu Zvažováno: Konstanta v kódu (levnější dnes, dražší za rok). Externí policy engine typu OPA (přidává další runtime závislost pro věc, která je tabulka o dvaceti řádcích).	Tabulka retention_policy s platností od–do a odkazem na právní zdroj. Řádky pro AMLR čl. 77 (5 let) jsou v tabulce už dnes s valid_from = 2027-07-10, řádky pro zákon 253/2008 Sb. (10 let) mají valid_to = 2027-07-09. Lhůta se mění během života produktu a bude se měnit znovu (AMLA, národní odchylky, PSD3). Přepisovat kód při každé změně je zdroj chyb a znamená nasazení do produkce kvůli právní změně.	Mazací job musí umět vyhodnotit, která politika platila v okamžiku vzniku záznamu a která platí teď — a musí být jasně rozhodnuto, že se aplikuje ta kratší platná. To je netriviální logika, kterou je nutné pokrýt testy, jinak se jednoho dne smaže něco, co mělo zůstat.
On-chain nejde nic odvozeného od klienta — vynuceno kódem, ne dokumentem Zvažováno: Salted hash reference v memo (EDPB výslovně říká, že hash zůstává osobním údajem — vyloučeno). Permissioned řetězec (řeší předávání do třetích zemí, ale nepomůže s tím, že smazat to stejně nejde).	Jediná cesta k podpisu vede přes builder transakcí, který má whitelist povolených volání (ERC-20 transfer s adresou a částkou) a prázdný memo/data prostor. V CI běží statická kontrola a test, který se pokusí protlačit hodnotu z uživatelského vstupu do calldata a musí selhat. Podle EDPB je to jediné místo v celém návrhu, kde je chyba nenapravitelná — zapsaný osobní údaj na veřejném řetězci nelze odstranit ani na příkaz dozoru a vede k příkazu ukončit zpracování.	Ztrácíme možnost používat on-chain reference (např. ID platby v memo) pro párování; párování se dělá výhradně off-chain přes adresu a tx_hash v indexeru. To je mírně pracnější a vyžaduje jednu depozitní adresu na klienta a řetězec.

Rozhodnutí	Volba a důvod	Důsledek
Blockchainová adresa klienta je osobní údaj a patří do trezoru Zvažováno: Držet adresy v produktové DB jako běžný sloupec (jednodušší, ale nesprávná klasifikace celé domény).	Mapování adresa ↔ klient leží šifrované v PII trezoru; indexer, který adresy nutně potřebuje v plaintextu pro párování z RPC, běží v důvěrové zóně trezoru s vlastní retencí a při výmazu se z něj mapování maže. Adresa je jednoznačný identifikátor spojený s konkrétní osobou. Nechat ji v produktové DB by znamenalo, že produktová DB je PII store a celý model tokenizace ztrácí smysl.	Indexer je provozně náročnější (jiná síťová zóna, přísnější přístup) a jeho výpadek zdrží připsování vkladů. Zbytkové riziko po výmazu: on-chain historie adresy zůstane veřejná a externí chain-analysis ji může spojit s osobou z jiných zdrojů — to nedokážeme odstranit a uvádíme to v DPIA i v informační povinnosti.
Dlouhodobé uchování dělá účelový archiv, ne zálohy Zvažováno: Dlouhé zálohy s dokumentovanou nemožností výmazu (běžná praxe, ale u dozoru neobhajitelná u tak citlivé kategorie).	Zálohy mají krátkou životnost (PITR 35 dní, snapshoty 90 dní). AML retence 5–10 let se plní tím, že AML trezor a KYC úložiště samy o sobě jsou trvalá úložiště s Object Lock, ne tím, že bychom drželi desetileté zálohy. V záloze nelze selektivně smazat jednoho klienta. Desetiletá záloha produkční databáze je desetiletá kopie všech osobních údajů včetně těch, které měly být dávno smazané — to je přímé porušení čl. 5 odst. 1 písm. e) GDPR a při kontrole se to najde okamžitě.	Ztrácíme možnost obnovit stav systému k datu před rokem. Pokud to někdy bude potřeba pro forenzní účely, musí se to vyřešit legal holdem předem, ne nálezem v archivu. Tohle je nutné vysvětlit vedení, protože intuíce říká „zálohy mít radši déle“.
Biometrická šablona se neukládá Zvažováno: Ukládat šablonu se samostatným klíčem a samostatnou retencí (technicky proveditelné, ale přidává právní titul, DPIA kapitolu, AI Act povinnosti provozovatele a nejcitlivější možnou kategorii dat).	Od KYC poskytovatele přebíráme jen výsledek ověření, skóre, čas a referenci na jeho záznam. Šablonu obličeje ani hlasu neukládáme a smluvně požadujeme její zničení po ověření. Nabízíme rovnocennou nebiometrickou alternativu (bankovní identita, ověřovací platba, videohovor). Šablona je zvláštní kategorie podle čl. 9 GDPR, jejímž jediným reálným titulem je výslovný souhlas, který lze odvolat — a odvolání by narazilo na AML retenci. Od 2. 8. 2026 navíc identifikace 1:N spadá do režimu vysoce rizikových systémů AI Actu. Neuložením šablony celá tato větev problémů mizí.	Nemůžeme dělat vlastní opakované ověření proti dříve pořízené šabloně (např. při reaktivaci účtu) — musí se ověřovat znovu u poskytovatele, což stojí poplatek za každé ověření. Přijímáme to.
Testovací a vývojová prostředí dostávají výhradně syntetická data Zvažováno: Maskovaná kopie produkce (rychlejší, ale maskování transakčních dat prakticky nikdy neobstojí proti reidentifikaci podle částky a času).	Generátor syntetických dat je součástí repozitáře, generuje z profilu schématu, používá vyhrazené testovací rozsahy IBAN a fiktivní zůstatky včetně hraničních případů (VES v hyperinflaci, částky pod nejmenší jednotkou, NaN vstupy). Kopie produkce do stagingu je technicky znemožněná — staging nemá síťovou ani IAM cestu k produkčním zálohám. Produkční data ve stagingu jsou podle rešerše nejčastější nález u fintech kontrol a zároveň porušení čl. 5 a 32 GDPR i RTS 2024/1774 čl. 16.	Reprodukce produkčního bugu je pracnější — musí se popsat jako datový scénář a doplnit do generátoru. Dlouhodobě se to vyplácí, protože z toho vzniká regresní sada.

8.3 Klíčové toky

Klient požádá o výmaz — co se přesně stane

- 1 Žádost přijde kanálem v aplikaci nebo e-mailem na adresu DPO; orchestrátor založí request se lhůtou 1 měsíc (prodloužitelnou o 2) a od té chvíle běží časovač viditelný na dashboardu.
- 2 Ověření totožnosti bez sběru nových údajů: klient se re-autentizuje v aplikaci se silným ověřením. U e-mailové žádosti se posílá odkaz do aplikace — nikdy se nevyžaduje zaslání kopie dokladu, to by bylo další zpracování navíc.
- 3 Orchestrátor sestaví datovou mapu klienta: z katalogu dat vytáhne všechny třídy, kde může existovat záznam vázaný na subject_token, a dotáže se každého systému (trezor, produktová DB, ledger, KYC úložiště, AML trezor, indexer, analytika, logy, podpora, externí zpracovatelé).
- 4 Kontrola stavu vztahu: pokud má klient nenulový zůstatek, otevřené Safe Money, aktivní kartu nebo nevypořádaný příkaz, výmaz se neprovádí — nejprve musí proběhnout uzavření vztahu a výplata prostředků. Klientovi se to sdělí jako podmínka, ne jako odmítnutí.

- 5 Kontrola tipping-off: orchestrátor volá `hasOpenInvestigation(subject_token)` do AML trezoru a dostane jen ano/ne bez detailu. Při „ano“ se práva omezí podle čl. 23 GDPR, do spisu se zapíše konkrétní právní ustanovení, důvod a datum přezkumu, a klientovi odchází právně schválená standardní odpověď, ze které nelze usoudit, že podezření existuje. Nikdy se neodpovídá individuálně formulovaným textem, protože rozdíl ve formulaci je sám o sobě prozrazením.
- 6 Kontrola legal hold: probíhá-li šetření FAÚ, soudní spor nebo dožádání orgánů činných v trestním řízení, výmaz se pozastaví, důvod a předpokládané trvání se zapíše.
- 7 Rozřazení podle právního titulu, který je u každé datové třídy uložen jako sloupec, ne odvozený z úvahy: titul souhlas (marketing, volitelná analytika, případná biometrie) se maže vždy a bezpodmínečně; titul plnění smlouvy se maže po uzavření vztahu; titul právní povinnost podle AML se nemaže a klientovi se to výslovně sdělí s odkazem na čl. 17 odst. 3 písm. b) GDPR; titul oprávněný zájem se posuzuje individuálně.
- 8 Plán výmazu se předloží ke schválení (čtyři oči: operátor + DPO nebo jeho zástupce). Plán říká po kategoriích, co se smaže a co zůstane a proč — a stejný text je základem odpovědi klientovi.
- 9 Provedení, krok 1 — PII trezor: řádky klienta se tvrdě smažou (DELETE, ne příznak), slepé indexy se smažou, tabulka se vakuuje.
- 10 Provedení, krok 2 — zničení klíče: v shred store se zničí `shred_secret` klienta a zápis se doprovodí podepsanou stvrzenkou. Tím přestává existovat DEK a všechno, co jím bylo zašifrováno — pole v trezoru, skeny dokladů pod Object Lockem, obsah starých záloh — se stává nečitelným, i tam, kam se fyzicky nedá sáhnout.
- 11 Provedení, krok 3 — invalidace cache: vault služba dostane broadcast, který zahodí dešifrovaný DEK ze všech instancí. Erasure certificate se vydává až po potvrzení od všech instancí, jinak by mohl existovat běžící proces, který ještě klíč drží.
- 12 Provedení, krok 4 — produktová DB, indexer, analytika, logy: mažou se zbytkové vazby (push tokeny, identifikátory zařízení, IP v provozních logech, mapování depozitní adresa ↔ klient v indexeru, řádek `subject_token` → apid v analytice, event-level záznamy). Agregáty v analytice zůstávají, protože už neobsahují vazbu na osobu.
- 13 Provedení, krok 5 — externí zpracovatelé: podle registru dodavatelů se volají jejich erasure API nebo se zakládají tikety s SLA na potvrzení (KYC poskytovatel, e-mailová a SMS brána, push provider, helpdesk). Nepotvrzený zpracovatel je otevřený bod žádosti a eskaluje se.
- 14 Co se nemaže a proč: řádky v ledgeru zůstávají pod tokenem, protože účetní a AML povinnost trvá a smazání by rozbilo součet nula; audit trail zůstává celý, protože je hash řetěz a protože v něm žádný osobní údaj není; AML složka, screeningové zásahy a travel-rule záznamy zůstávají po celou retenční dobu; samotný erasure certificate zůstává jako důkaz splnění povinnosti.
- 15 On-chain se nemaže nic, protože tam nikdy nic nebylo. Depozitní adresa klienta se označí jako retired a nikdy se nepoužije znovu; její on-chain historie zůstává veřejná a to se klientovi v odpovědi výslovně říká.
- 16 Zápis do tombstone journalu ve WORM: `subject_token`, seznam datových tříd, id zničeného klíče, čas, schvalovatel. Tento zápis je to, co zajistí, že obnova ze zálohy výmaz nezvrátí.
- 17 Vydání erasure certificate: podepsaný dokument se seznamem systémů, počtů smazaných řádků, id zničených klíčů, potvrzení zpracovatelů, a se seznamem odmítnutých položek včetně právního důvodu. Ukládá se do audit trailu a drží se stejně dlouho jako AML složka.
- 18 Odpověď klientovi ve lhůtě, po kategoriích: smazáno / uchováno s uvedením právního důvodu a data, kdy uchování skončí / omezeno. Klient se zároveň poučí o právu podat stížnost u ÚOOÚ.
- 19 Konec AML retence (5, resp. 10 let od ukončení vztahu): naplánovaný job zničí AML DEK a smaže AML složku. Teprve tímto okamžikem přestává existovat kdokoli, kdo umí token přiřadit k osobě. Současně proběhne test reidentifikace podle EDPB Guidelines 02/2026 nad zbylými transakčními daty — tam, kde kombinace částky, času a protistrany umožňuje vyčlenění, se řádky nahradí denními agregáty po měnách tak, aby zůstal zachován účetní součet nula, ale zmizela klientská granularita.

Klíčová věta pro klienta i pro dozor zní: během AML retence data NEJSOU anonymní a netváříme se, že jsou — držíme je na základě právní povinnosti a říkáme to. Anonymními se stávají až zničením AML klíče. Kdo tvrdí, že tokenizace sama o sobě splnila výmaz, lže si do kapsy.

Onboarding a KYC — kam se co zapíše

- 1 Klient zadá jméno, datum narození, adresu, kontakt. Aplikace nic z toho neukládá u sebe — volá `vault.tokenize` a dál pracuje jen s tokeny.

- 2 Vault vygeneruje `shred_secret`, odvodí subject DEK z HSM KEK, zašifruje každé pole zvlášť s AAD = `tabulka||sloupec||subject_token` a založí slepé indexy pro e-mail, telefon a číslo dokladu.
- 3 Produktová DB založí zákazníka pouze se `subject_token`, jazykem, stavem KYC a rizikovým pásmem. Ledger založí účty v CZK/EUR/USD a peněženské účty pro aktiva podle registru asset — bez jediného osobního údaje.
- 4 KYC poskytovatel provede ověření dokladu a liveness. Vracíme si výsledek, skóre, čas a jeho referenci; biometrickou šablonu nepřebíráme a smluvně požadujeme její zničení.
- 5 Sken dokladu (pokud je pro daný rizikový profil skutečně nutný) se ukládá do objektového úložiště, zašifrovaný per-object klíčem odvozeným z klientova DEK, s Object Lock nastaveným na aktuálně platnou retenční lhůtu z `retention_policy`.
- 6 AML trezor založí CDD složku s vlastním klíčem a vlastní retenční hodinou spuštěnou až ukončením vztahu — nikoli založením účtu.
- 7 Audit trail dostane události: `subject_created`, `kyc_verified`, `document_stored`, každou s tokeny, nikdy s hodnotami.
- 8 Do analytiky se přes CDC dostane jen `apid`, pásmo věku, region NUTS2 a stav — transformační služba nemá přístup ke KEK trezoru, takže ani omylem nemůže poslat dál jméno.

Rozhodující je, že aplikační služby nikdy nedostanou plaintext samy od sebe — musí explicitně zavolat `detokenize` s uvedeným účelem a důvodem, a to volání je vidět. Tím se hromadné stahování KYC složek stane detekovatelnou anomálií, ne neviditelným `SELECTem`.

Platba nebo směna — zápis a jeho důkaz

- 1 Klient odešle příkaz; aplikace vygeneruje Idempotency-Key (UUIDv4) a pošle ho s požadavkem.
- 2 Payment service ověří klíč proti tabulce idempotency (unique constraint na klíč, uložený hash těla); při shodě vrátí původní odpověď, při stejném klíči a jiném těle vrátí 409.
- 3 V jedné DB transakci se zapíše: postiny do ledgeru (odepsání ze zdrojového účtu, připsání na cílový, poplatek na výnosový účet, spread na spreadový účet — součet přesně nula v každém aktivu zvlášť), řádek do outboxu a řádek do audit trailu se stavem před a po.
- 4 Směna nese odkaz na `pricing_version_id`, takže je po letech doložitelné, jaký spread a jaký režim (hyperinlace vs. běžný sazebník) v tom okamžiku platil a proč byl poplatek nula nebo pevný.
- 5 Vklad do Safe Money z jiné měny se účtuje jako dvě spárované operace pod jedním `transaction_id`: směna a vklad — nikdy jako jeden zápis s implicitní konverzí, protože pak nejde vysvětlit, kde vznikl rozdíl.
- 6 Do produktové DB jde příkaz s `VS/KS/SS` a s `counterparty_token`; jméno a IBAN protistrany leží v trezoru, protože i protistrana je subjekt údajů.
- 7 Worker čte outbox a odesílá ven (do banky, do sítě, jako webhook). Konzumace je deduplikovaná podle event ID; asynchronní kroky mají kompenzační zápis, ne dvoufázový commit.
- 8 Sealer po 5 minutách zapečetí segment audit trailu a uloží pečeť s kvalifikovaným časovým razítkem do WORM účtu.
- 9 Noční job přepočte zůstatky z nuly ze všech postingů a porovná je s materializovanými agregáty; rozdíl v jakékoli měně je alert nejvyšší priority do SIEM.

Toto je přímá oprava dnešního stavu simulace, kde je zůstatek float v `localStorage` a pole transakcí se s ním nikde neporovnává. Rozhodnutí o typu (celočíselné minor units, scale u aktiva) je nutné udělat v F1 — dodatečná migrace floatových zůstatků na celá čísla je nejdražší oprava v celém seznamu.

Retenční job a legal hold

- 1 Denně v noci job načte `retention_policy` platnou k dnešnímu dni pro každou datovou třídu, včetně jurisdikce klienta.

- 2 Pro každou třídu spočítá množinu záznamů, u nichž od spouštěcí události (ukončení vztahu, datum transakce, odvolání souhlasu) uplynula lhůta.
- 3 Odečte vše, na čem leží legal hold, a vše, kde běží omezení podle čl. 23.
- 4 Spustí se nejprve v dry-run a rozdíl oproti včerejšku se pošle DPO; teprve po schválení režimu se maže ostře, v dávkách, s brzdou na počet řádků za minutu, aby se nezahltil ledger cluster.
- 5 Mazání je skutečné: DELETE + VACUUM, u objektů odstranění po vypršení Object Locku, u polí šifrovaných klientským klíčem zničení klíče, pokud už žádná třída klienta klíč nepotřebuje.
- 6 Každý výmaz jde do audit trailu i do tombstone journalu.
- 7 Metrika rows_overdue_for_deletion se exportuje do dashboardu; hodnota > 0 déle než 24 h je incident, protože znamená, že držíme data bez titulu.

Nejtěžší část není mazání, ale správné určení spouštěče. Retence KYC složky běží od ukončení vztahu, retence transakce od transakce — to jsou dvě různé hodiny nad daty téhož klienta a v praxi se to nejčastěji plete.

Obnova ze zálohy a důkaz, že po ní data sedí

- 1 Obnova se nikdy nedělá do produkce, vždy do izolovaného účtu bez síťové cesty ven — RTS 2024/1774 to vyžaduje a je to zároveň jediný způsob, jak test nesmete provoz.
- 2 Krok 1: obnoví se ledger cluster do zvoleného bodu v čase (PITR z WAL archivu).
- 3 Krok 2: PŘED otevřením jakéhokoli přístupu se přehraje tombstone journal od data zálohy do současnosti — všechny výmazy provedené mezitím se aplikují znovu. Teprve po úspěšném replay smí systém přijmout první požadavek. Tento krok je v runbooku první, ne poslední.
- 4 Krok 3: rekonciliace — přepočít všech zůstatků z nuly a porovnání s materializovanými agregáty, kontrola součtu nula v každé měně a aktivu, kontrola, že počet postingů odpovídá počtu v audit trailu.
- 5 Krok 4: verifikace hash řetězu audit trailu od začátku, ověření podpisů a časových razítek všech pečeti proti WORM kopii.
- 6 Krok 5: vzorek 100 náhodných KYC objektů se pokusí dešifrovat; objekty patřící smazaným klientům MUSÍ selhat — to je pozitivní test kryptografického mazání, ne chyba.
- 7 Krok 6: protokol o obnově s časy, výsledky kontrol a odchylkami jde do audit trailu a je to dokument, který si vyžádá dozor.
- 8 Cíle: ledger RPO 0 pro potvrzené transakce (synchronní replika v druhé AZ + WAL archiv), RTO 30 minut při výpadku AZ, 4 hodiny při výpadku regionu. PII trezor RPO 5 minut, RTO 4 hodiny. KYC úložiště RPO 15 minut, RTO 8 hodin. Audit trail RPO 0 (zápis průchozí do WORM), RTO 24 hodin. Analytika RPO 24 hodin, RTO 72 hodin.
- 9 Frekvence: úplný test obnovy čtvrtletně, jednou ročně scénář ztráty celého regionu a jednou ročně obnova k jinému poskytovateli jako důkaz exit strategie podle DORA čl. 30.

Netestovaná záloha se rovná žádné záloze a DORA to vysloveně kontroluje. Krok s tombstone journalem je přitom to, co většina týmů vynechá — a přesně on rozhoduje o tom, jestli je náš výmaz skutečný, nebo jen dočasný.

Rotace klíčů a mimořádná rotace při kompromitaci

- 1 Root KEK v HSM: rotace jednou za 3 roky, key ceremony s dual control, split knowledge a písemným protokolem; starý root zůstává jen pro odbalení, nikdy pro nové šifrování.
- 2 Doménové KEK: rotace ročně, přebalí se všechny per-subject DEK. Měřeno: 100 tis. klientů × ~2 ms = pod 4 minuty, běží online po dávkách.
- 3 Per-subject DEK se nerotuje — jeho hodnota je právě v tom, že je jeden a jde zničit; rotace by vytvořila druhou kopii, kterou by bylo nutné také zničit.

- 4 TLS certifikáty: automatizované ACME, 90 dní; identity ve service mesh 24 hodin.
- 5 Aplikační tajemství (DB hesla, API klíče, webhook secrecy): 30–90 dní, dynamické krátkodobé DB credentials z Vaultu, žádné tajemství v gitu ani v .env na disku, pre-commit i CI skener.
- 6 Analytická sůl se záměrně nerotuje (rotace by rozbila longitudinální analýzy) — místo toho je izolovaná v jiném KMS klíči v jiném účtu a toto rozhodnutí je zapsané v DPIA.
- 7 Mimořádná rotace: playbook s definovaným pořadím (nejprve odejmout přístup, pak rotovat, pak přešifrovat, pak vyhodnotit, co bylo kompromitovaným klíčem dostupné) a s nacičeným časem — u vault KEK cíl 4 hodiny od rozhodnutí.

Nejčastější chyba není chybějící rotace, ale to, že se rotuje klíč a nikdo neví, co všechno jím bylo zašifrováno. Proto má každý ciphertext v hlavičce id klíče a verzi schématu — bez toho je rotace hádání.

Přístup zaměstnance k osobním údajům klienta

- 1 Operátor podpory vidí v konzoli jen tokeny, částky a stavy. Jméno klienta nevidí, dokud ho nepotřebuje.
- 2 Kliknutí na „zobrazit identitu“ vyžaduje vyplnění důvodu z číselníku plus volný text a odkaz na tiket. Bez toho volání neprojde.
- 3 Vault ověří roli, účel a rozsah, dešifruje pole a vrátí je s TTL v UI; současně zapíše do audit trailu kdo, kdy, kterého klienta, které pole a s jakým důvodem.
- 4 Přístup ke KYC skenu je vyšší úroveň: JIT eskalace přes PAM, schválení druhou osobou, časově omezené okno, nahrávaná relace, zákaz stahování.
- 5 SIEM sleduje anomálie: víc než N detokenizací za hodinu, přístup mimo pracovní dobu, přístup ke klientovi bez otevřeného tiketu, sekvenční procházení tokenů. Zásah vyvolá alert a automatické dočasné omezení role.
- 6 Čtvrtletní recertifikace přístupových práv; odchod zaměstnance = okamžitá revokace ve všech účtech, kontrolovaná skriptem, ne pamětí.
- 7 Vzdálený přístup ze Singapuru prochází stejnou cestou plus je označen jako předání podle kap. V a reportuje se odděleně.

Toto je zároveň jediná obrana proti insiderovi. Model bez tokenizace tuhle kontrolu neumí postavit — když je jméno v produkční tabulce, každý SELECT je legitimní a nikdo nepozná rozdíl mezi prací a krádeží.

8.4 Rizika a opatření

Riziko	Opatření v návrhu
Obnova ze zálohy starší než výmaz vzkřísí data, která už měla být zničena. Toto je nejpravděpodobnější způsob, jak celý model vymazu tiše selže.	Tombstone journal ve WORM účtu, jehož přehrání je první krok obnovy a je součástí automatizované pipeline, ne lidského uvážení. Shred store má PITR jen 24 h a žádné logické dumpy, takže okno vzkříšení klíče je maximálně jeden den. Čtvrtletní test obnovy obsahuje pozitivní kontrolu: vzorek objektů smazaných klientů MUSÍ selhat při dešifrování. Zbytkové riziko se popisuje v DPIA jako přijaté.
Dešifrovaný DEK zůstane v cache nebo v paměti procesu po zničení klíče a data jsou dál čitelná.	TTL cache maximálně 5 minut, broadcast invalidace při shred, a erasure certificate se vydává až po potvrzení od všech instancí vault služby. Vault běží jen v malém počtu instancí právě proto, aby tato invalidace byla proveditelná a ověřitelná.
Osobní údaje se dostanou do logů, Kafka topiků, error trackerů nebo analytiky. V praxi je to nejčastější reálný únik u aplikací tohoto typu a děje se to postupně a nepozorovaně.	Povinná redakční fáze v log pipeline s regexem na IBAN, e-mail, telefon, číslo dokladu a PAN, která záznam zadrží a upozorní tým, který ho vypustil. Topic retention 7 dní a payload jen s tokeny. Čtvrtletní audit datové mapy proti skutečnému obsahu úložišť vzorkováním. Test v CI, který selže, pokud se do logovacího volání dostane objekt s polem označeným v katalogu jako PII.

Riziko	Opatření v návrhu
Slepý index umožní korelaci: kdo získá dump trezoru, může podle shodných indexů spojovat záznamy a při znalosti hodnoty ověřit její přítomnost.	Index zkrácený na 4 bajty se záměrnými kolizemi — vyhledání vrací kandidátní množinu, která se teprve dešifruje a filtruje. Indexový klíč je v jiném KMS klíči než DEK a nikdy se neexportuje. Porovnání v konstantním čase. Přijímáme mírně pomalejší vyhledávání jako cenu.
Neměnnost ledgeru se obejde migrací nebo superuserem — někdo „opraví“ zůstatek přímo v databázi a nikdo to nepozná.	Aplikační role nemá UPDATE ani DELETE grant na postings; superuser credentials existují jen v break-glass trezoru s alertem při použití. Všechny DDL i DML mimo aplikaci jdou do pgaudit a do SIEM. Noční přepoččet zůstatků z nuly odhalí jakýkoli zásah do dat, i ten, který nešel přes aplikaci. Migrace dotýkající se peněžních tabulek vyžadují čtyři oči.
Chybně přiřazený právní titul u datové třídy — např. KYC vedené na souhlas. Klient souhlas odvolá, vznikne povinnost výmazu, kterou nelze splnit kvůli AML retenci, a z toho není cesta ven.	legal_basis je NOT NULL sloupec v katalogu a v datovém modelu; noční konformitní kontrola shodí build, pokud existuje sloupec bez třídy nebo třída bez politiky. V onboardingu není žádný checkbox typu „souhlasím se zpracováním osobních údajů“ — souhlas je vyhrazený výhradně marketingu a volitelné analytice a je oddělitelný. Právní revize titulů jednou ročně a při každé nové datové třídě.
Koncentrační riziko jediného poskytovatele cloudu podle DORA čl. 28–30; závislost, ze které neexistuje otestovaná cesta ven.	Držíme se vanilla PostgreSQL a S3 API bez proprietárních funkcí v kritické cestě. Exit strategie je dokumentovaná a jednou ročně se testuje obnovou ledgeru a trezoru k druhému poskytovateli. Cena tohoto rozhodnutí je nižší výkon a víc vlastní provozní práce oproti Auroře — přijímáme to vědomě.
Zrušení EU-US Data Privacy Framework rozhodnutím SDEU ve věci C-703/25 P zablokuje dodavatele v kritické cestě onboardingu.	Primární i záložní úložiště výhradně v EU regionech, včetně replik, CDN, logů, monitoringu a nástrojů podpory. Žádný dodavatel v kritické cestě, jehož control plane nelze uzamknout do EU. Standardní smluvní doložky a posouzení dopadu předání podepsané předem jako záložní mechanismus, ne až po rozsudku. U KYC poskytovatele je EU-only zpracování podmínkou výběru.
Analytický dataset považovaný za anonymní ve skutečnosti umožňuje reidentifikaci kombinací částky, času a protistrany — a my na základě omylu neplníme žádnou povinnost.	Dataset je od začátku klasifikován jako osobní údaj podle EDPB Guidelines 01/2025 a má vlastní retenci 25 měsíců, řízení přístupu a záznam v ROPA. Test reidentifikace podle EDPB Guidelines 02/2026 se opakuje ročně a při každém přidání nového atributu, protože dostupnost pomocných datasetů roste.
Výpadek HSM zablokuje veškeré operace s osobními údaji — onboarding, podporu i KYC.	HA pár HSM ve dvou zónách, cache DEK udrží čtení v běhu po dobu TTL, onboarding se zastaví řízeně s jasným chybovým stavem místo tichého selhání. RTO pro HSM 1 hodina, dokumentované v BIA. Ledger a platby na HSM nezávisí, takže výpadek nezastaví peníze.
Tlak na „přidání jména do reportu“ postupně rozpustí celý model tokenizace. Přejde to jako drobná žádost z byznysu a bude se opakovat.	Zákaz přímých identifikátorů mimo trezor je zapsán jako architektonické rozhodnutí s vlastníkem a je předmětem code review. Kdo potřebuje identitu, volá detokenize s důvodem a to volání je vidět v audit trailu — tedy identita je dostupná, ale ne zdarma a ne tiše. Výjimku smí povolit jen DPO, písemně a s dobou platnosti.
Klient se domnívá, že po výmazu jsou jeho data pryč, zatímco AML trezor je drží dalších 5 až 10 let. Nesoulad mezi očekáváním a realitou je zdroj stížností u ÚOOÚ i tehdy, když je postup správný.	Odpověď na žádost je strukturovaná po kategoriích s konkrétním datem, kdy které uchování skončí, a s odkazem na právní ustanovení. Stejná informace je v informační povinnosti při onboardingu, ne až v odpovědi na stížnost. Erasure certificate se klientovi na vyžádání poskytne.
Zápis čehokoli odvozeného od klienta na veřejný řetězec — jediná nenapravitelná chyba v celém návrhu.	Builder transakcí s whitelistem polí jako jediná cesta k podpisu, statická kontrola a negativní test v CI, policy engine, který odmítne transakci s neznámou calldata. Explicitní položka v code review checklistu u čehokoli, co se dotýká podepisování, a samostatná kapitola v DPIA.
Přechod AMLR k 10. 7. 2027 (10 → 5 let) se neprovede včas a data se drží bez titulu, nebo naopak předčasně a chybí AML podklady.	Retenční politika je tabulka s valid_from a valid_to; řádky pro obě období jsou vloženy už dnes s odkazem na zdroj. Mazací job vyhodnocuje politiku platnou k dnešnímu dni a aplikuje kratší platnou lhůtu; přechod je pokrytý testy s posunutým časem, aby se chování ověřilo dřív, než nastane.

9. Platforma a provoz

Oddělení prostředí, ověřitelná cesta od commitu k běžícímu artefaktu a schopnost odpovědět, koho incident zasáhl.

Platforma má být fyzická odpověď na tři věci, které dnes v LargoVerse neexistují vůbec: oddělení prostředí a identit, ověřitelná cesta od commitu k běžícímu artefaktu a schopnost odpovědět na otázku "kolik klientů to zasáhlo" do třiceti minut. Cílový stav je jeden primární region v EU (AWS eu-central-1) s teplou zálohou v eu-west-1, čtrnáct oddělených AWS účtů, veškerá infrastruktura v Terraformu, GitOps nasazení přes Argo CD a admission control, který odmítne spustit nepodepsaný image — takže regulátorovi lze doložit řetězec commit → build → SBOM → podpis → digest v produkci bez ručního dohledávání. Druhá polovina návrhu je provoz, ne technologie: pojmenovaný člověk s pravomocí klasifikovat incident, časová osa generovaná z incidentního kanálu, čtyři paralelní ohlašovací lhůty v jednom runbooku (DORA 4 h, GDPR 72 h, MiCA klient, PSD2 fraud) a týdenní automatizovaný test obnovy do izolovaného účtu, protože netestovaná záloha je podle DORA čl. 12 samostatný nález. Vědomě stavím tak, aby fáze F1 přežila každé dosud neučiněné rozhodnutí — volbu tokenu, jurisdikci i to, jestli licence bude EMI, CASP nebo obojí; nic ve fázi F1 nezávisí na tom, jestli emitujeme přes USDC, EURC nebo přes partnerskou EMI. Nákladově je to platforma, jejíž cena není řízena provozem (10 tx/s je výpočetně nic), ale compliance podlahou: HSM, log archiv, SIEM, DR region a tři prostředí stojí zhruba 25–40 tis. EUR měsíčně dřív, než přijde první klient.

9.1 Komponenty

Celkem 22 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Landing zone — AWS Organizations a struktura účtů

Fáze 1

Nese hranici izolace. Účet je jednotka blast radiusu, ne VPC. Struktura: management, log-archive, security-tooling, network-hub, shared-services (CI runnery, registry), dev, test, sandbox, staging, prod-app, prod-ledger, prod-keys, backup-vault, restore-test. Účet prod-ledger drží Aurora s postings a nemá žádnou cestu do internetu; prod-keys drží CloudHSM cluster a nemá v sobě žádnou aplikační workload. Účet backup-vault je vlastněn jinou sadou identit než produkce a produkční role do něj nemají mazací oprávnění — to je konkrétní protiransomware a protiinsider kontrola, ne politika.

Technologie: AWS Organizations + Control Tower baseline přepsaný Terraformem, IAM Identity Center napojený na Entra ID / Okta jako jediný zdroj identity, SCP a RCP v kódu · **Rozhraní:** SCP na úrovni OU: deny opuštění organizace, deny vypnutí CloudTrail/Config/GuardDuty, deny všech regionů mimo eu-central-1/eu-west-1 (kromě globálních služeb), deny smazání KMS klíče bez MFA, deny public S3 a public AMI sharing. Cross-account přístup výhradně přes IAM role s podmínkou na zdrojový účet a ExternalId; ...

Síťová páteř a segmentace

Fáze 1

Rozděluje síť podle kritičnosti dat a vynucuje explicitní pravidla toku podle RTS 2024/1774 čl. 13. Pět zón: edge (CloudFront + WAF), ingress (interní ALB, VPC origin, žádné veřejné IP na aplikačních subnetech), aplikační (EKS privátní subnety), datová (Aurora, ElastiCache — routing tabulka bez NAT i bez IGW), klíčová (CloudHSM ENI v dedikovaném subnetu, security group povoluje pouze signer service). Management plane je samostatný účet bez routy k produkčním datům. Egress je default-deny: veškerý odchozí provoz jde přes centrální egress VPC s AWS Network Firewall a FQDN allowlistem — Ethereum RPC endpointy, KYC provider, SEPA brána, sankční screening, OTLP kolektor a nic víc.

Technologie: AWS VPC, Transit Gateway, Network Firewall (Suricata pravidla), VPC endpointy, Route 53 Resolver DNS Firewall s logováním dotazů do SIEM · **Rozhraní:** Transit Gateway s route tabulkami per zóna; peering mezi prod-app a prod-ledger pouze na portu Postgresu a pouze ze security group ledger služby; VPC endpointy (PrivateLink) pro S3, KMS, Secrets Manager, ECR, STS, aby tento provoz vůbec neopustil páteř AWS.

Běhové prostředí aplikací

Fáze 1

Tři EKS clustery (non-prod, staging, prod), každý ve svém účtu. Karpenter pro škálování, spot instance výhradně pro CI a dávkové úlohy — nikdy pro ledger, signer ani platební API. Ledger běží jako StatefulSet s PodDisruptionBudget a topologií přes tři AZ. Namespace signer má vlastní node group na dedikovaných instancích, bez sdílení jádra s ostatními workloady.

Technologie: EKS 1.31+, Karpenter, Argo CD, Argo Rollouts (canary), Kyverno pro admission · **Rozhraní:** Argo CD app-of-apps, Helm charty renderované Kustomize; produkční sync je manuální s dvěma schvalovateli, non-prod má auto-sync se selfHeal, takže drift v nižších prostředích neexistuje.

Prostředí a jejich oddělení

Fáze 1

Pět prostředí s odlišným účelem a odlišnou datovou politikou. dev — efemérní namespace per vývojář, syntetická data, testnet. test — vytvářeno a ničeno pipeline pro každý běh integračních testů. sandbox — stabilní veřejné prostředí pro partnery a investorské demo, Sepolia testnet, mock KYC, mock SEPA; sem se stěhuje dnešní Cloudflare Pages demo a je natvrdo označeno jako nikoli produkce. staging — plná parita s produkcí ve verzích a konfiguraci, cca 20 % kapacity, napojení na sandboxy skutečných dodavatelů. prod. Šesté, dočasné prostředí restore-test se vytváří automaticky každý týden pro obnovu zálohy a po ověření se ničí. Produkční data nesmí opustit prod ani v anonymizované formě; testovací data vyrábí deterministický generátor (IBANy z testovacích rozsahů s platným checksumem, fiktivní doklady, nasazený ledger).

Technologie: Terraform workspace per prostředí, oddělené AWS účty, oddělené Vault clustery, oddělené KMS klíče — žádný credential ani klíč není sdílený napříč prostředím · **Rozhraní:** Oddělení rolí podle PCI DSS 6.4.2 a RTS čl. 16: autor změny nemá oprávnění nasadit ji do produkce, nasazuje výhradně identita pipeline; schvalovatel je jiná osoba než autor a u změn dotýkajících se peněžní logiky se vyžaduje čtyřochův princip explicitně kódovaný v CODEOWNERS.

Infrastruktura jako kód a policy as code

Fáze 1

Veškerá infrastruktura vzniká Terraformem; ruční zásah v konzoli je incident, ne postup. Stav v S3 s SSE-KMS a zámek v DynamoDB, per účet a prostředí. Nad plánem běží politiky: žádná security group s 0.0.0.0/0 na jiném než 443, žádná RDS bez šifrování a bez deletion protection, žádný S3 bucket bez blokáce veřejného přístupu, žádný IAM policy s Action:* Resource:*. Noční detekce driftu proti reálnému stavu s alertem na rozdíl.

Technologie: Terraform (state v S3+DynamoDB), Checkov + tfsec + Conftest, driftctl; OpenBao/OpenTofu evidované jako výstupní varianta pro případ eskalace BUSL licence · **Rozhraní:** GitHub PR → terraform plan jako komentář → OPA/Checkov gate → schválení → apply z pipeline identity přes OIDC (žádné statické AWS klíče v CI vůbec).

CI/CD pipeline s branami

Fáze 1

Jediná cesta kódu do produkce. Pořadí bran: lint → typecheck → unit testy včetně vlastnostních testů peněžních invariantů (dnes v repozitáři neexistuje jediný test — tohle je nejdražší dluh, který se doplňuje) → mutační testování na modulu ledger → SCA → SAST → sken tajemství → reprodukovatelný build OCI image → SBOM → podpis a provenance → push do ECR s immutable tagy → deploy test → integrační a kontraktní testy → deploy staging → DAST + zátěžový test k6 na trojnásobku očekávané špičky → schvalovací brána se záznamem změny → produkce canary 5 % → automatický rollback při vyhoření SLO → 100 %.

Technologie: GitHub Actions + ARC, Semgrep + CodeQL, gitleaks + GitHub push protection, k6, OWASP ZAP baseline · **Rozhraní:** GitHub Actions s efemérními self-hosted runnery (Actions Runner Controller na EKS v shared-services), OIDC federace do AWS bez dlouhodobých klíčů; trunk-based vývoj, feature flagy přes self-hostovaný flagd — žádný SaaS flag provider v peněžní cestě.

Podepisování artefaktů a admission control

Fáze 1

Uzavírá řetězec důkazů. Každý image se podepisuje cosignem klíčem v AWS KMS (vlastní identita, ne keyless přes veřejný Fulcio), k němu se připojuje SBOM attestation a SLSA v1.0 provenance z GitHub Actions. Kyverno v produkčním clusteru vynucuje verifyImages: bez platného podpisu našim klíčem, bez SBOM attestace a bez provenance se pod nespustí. Tím je fyzicky nemožné, aby v produkci běželo něco, co neprošlo pipeline — což je přesně to, co dnes chybí, kdy se nasazuje ručně přes wrangler s --commit-dirty=true a k nasazenému artefaktu

neexistuje ověřitelný commit.

Technologie: cosign + AWS KMS asymetrický klíč, Syft (CycloneDX 1.6), GitHub Artifact Attestations, Kyverno, self-hosted Rekor ·

Rozhraní: Evidenční tabulka v log-archive účtu: commit SHA → build ID → image digest → Argo CD sync revision → digest běžícího podu, plus transparentní log (Rekor, self-hosted). Na dotaz dohledu "co přesně běželo 14. dubna v 15:20" se odpovídá dotazem, ne archeologií.

Správa aplikačních tajemství a rotace

Fáze 1

HashiCorp Vault, jeden cluster na prostředí (3 uzly, Raft, auto-unseal přes KMS). Dynamické krátkodobé Postgres credentials s TTL 1 h — aplikace nikdy nedostane statické heslo do databáze. Transit engine pro aplikační šifrování, PKI engine pro interní certifikáty. Tajemství se do podů dostávají přes CSI driver, ne jako Kubernetes Secret v etcd. Kryptoperiody písemně: TLS veřejné 90 dní (ACM automaticky), workload certifikáty 24 h, DB credentials 1 h, API klíče dodavatelů 90 dní, webhook secrecy 90 dní s překryvem dvou platných, KEK ročně, MPC shares proaktivně re-sharing čtvrtletně bez změny adresy, signeři cold multisigu do 24 h po odchodu člověka.

Technologie: Vault Community (auto-unseal KMS), Vault Secrets Operator / CSI, 1Password Business pro nevyhnutelná lidská tajemství, break-glass root credentials v zapečetěné obálce ve fyzickém trezoru s dvoučlenným přístupem a čtvrtletní kontrolou · **Rozhraní:** Jeden příkaz `rotate-all --class=<třída>` provede mimořádnou rotaci celé třídy tajemství; čtvrtletně se testuje ve stagingu a měří se doba do plné rotace. Bez tohoto testu je postup mimořádné rotace jen dokument.

SBOM a kontrola závislostí

Fáze 1

SBOM při buildu je bezcenný, pokud se znovu nevyhodnocuje. Syft generuje CycloneDX 1.6 pro každý image i pro zdroj; SBOMy jdou do self-hostovaného Dependency-Track, který je průběžně přehodnocuje proti novým CVE a NVD/OSV feedům. Na dotaz "která běžící verze je zasažena CVE-2026-XXXX" odpovídá v minutách — to je předpoklad pro čtyřhodinovou lhůtu i pro patch management podle RTS čl. 10. SLA na záplatu: kritická (CVSS ≥ 9 nebo v KEV) 48 h v produkci, vysoká 7 dní, střední 30 dní, nízká 90 dní; výjimka jen s kompenzačním opatřením a datem expirace. VEX (OpenVEX) se publikuje i konzumuje, jinak se backlog CVE zaplní falešnými nálezy a SLA se stane fikcí.

Technologie: Syft, Dependency-Track (self-hosted), Renovate s auto-merge pouze pro patch-level dev závislosti po plné CI, AWS CodeArtifact, Chainguard/distroless base images · **Rozhraní:** Vlastní registry proxy (AWS CodeArtifact) před npmjs a Docker Hub — jednak nezávislost na dostupnosti veřejných registrů, jednak sedmidenní karanténa nových verzí balíčků proti typosquattingu a kompromitaci maintainera. `ignore-scripts=true` s explicitním allowlistem (dnes esbuild a fsevents), Node verze připnutá v ...

Telemetrie — metriky, logy, trasování

Fáze 1

Jedna instrumentace (OpenTelemetry SDK), jedna OTLP roura, tři backendy. Trasování se vzorkuje 100 % na peněžních cestách (platba, směna, Safe Money, on-chain podpis) a tail-based 5 % jinde; trace ID je zároveň korelační ID, které prochází celým požadavkem a objevuje se i v audit trailu a v incidentní zprávě — RTS čl. 12 to vyžaduje explicitně. Nad technickými metrikami stojí byznysové invarianty jako první třída: `ledger_imbalance_by_currency` musí být identicky nula v každé měně zvlášť; rekondilační job přepočítává zůstatky z postings po pětiminutových oknech a jednou denně od nuly. Jakákoli nenulová hodnota je okamžitá stránka bez ohledu na SLO.

Technologie: OpenTelemetry, Prometheus + Mimir (metriky, 13 měsíců), Loki (provozní logy, 30 dní, mazatelné), Tempo (trasy, 14 dní), Grafana — vše self-hosted na S3 backendu · **Rozhraní:** OTel Collector jako DaemonSet (scrubbing PII a tajemství na kolektoru, ne až v backendu) + gateway deployment v observability namespace; backend v účtu security-tooling, kam produkční role nemají zápis do retenční politiky.

Neměnný audit trail a log archive

Fáze 1

Oddělený od provozních logů, protože má jiný účel a jinou retenci. Vše, co se dotýká peněz, klíčů, oprávnění a konfigurace, jde přes Kinesis Firehose do S3 v účtu log-archive s Object Lock v režimu Compliance. Retence 10 let pro transakční a KYC záznamy (AML), 12 měsíců pro bezpečnostní telemetrii. Každá dávka nese hash řetězce navazující na předchozí, denní Merkle root se podepisuje asymetrickým KMS klíčem a kopie se ukládá k druhému poskytovateli. Produkční ani administrátorské role nemají oprávnění zapisovat ani mazat v tomto účtu — kompromitace aplikace nesmí umožnit smazání logů. U peněžní operace se loguje předchozí i nový stav, nikdy ne obsah tajemství, celý PAN ani plný IBAN.

Technologie: S3 Object Lock Compliance, Kinesis Firehose, CloudTrail Lake, KMS asymetrický podpis denního rootu · **Rozhraní:** Zdroje: aplikační audit událostí, CloudTrail organizační trail, EKS audit log, VPC Flow Logs, DNS query logy, RDS audit, CloudHSM audit, Vault audit device, IdP logy, WAF logy. Čas ze společného zdroje (AWS Time Sync / chrony), protože časová razítka v hlášení dohledu musí obstát.

Registr informací a řízení dodavatelů

Fáze 1

Registr podle prováděcího nařízení 2024/2956 je udržován jako data v Gitu (YAML), validovaná v CI proti ITS schématu a exportovaná do předepsaného formátu — ne jako tabulka, kterou někdo jednou ročně dohledává. Každý záznam: LEI poskytovatele, podporovaná funkce, posouzení kritičnosti, nahraditelnost, odkaz na exit plán, checklist povinných ustanovení podle čl. 30, lokace dat a řetězec subdodavatelů (řetězec je část, kterou většina institucí nezvládne). Kritičtí dodavatelé s alternativou: KYC/AML (iDenfy jako litevský primární + Sumsb jako záloha), sankční screening (ComplyAdvantage), SEPA/BaaS partner, karetní issuer (Enfuce), blockchain RPC (Alchemy + Infura + vlastní uzel jako rozhodčí — vlastní uzel je to, co brání jednomu RPC poskytovateli lhát nám o stavu řetězce), chain analytics (Chainalysis/Elliptic pro travel rule), custody technologie.

Technologie: YAML v Gitu + validační schéma, generátor exportu do ITS formátu, generátor egress allowlistu do Terraformu ·

Rozhraní: Technický zámek, který drží registr pravdivý: FQDN allowlist v Network Firewallu se generuje z registru. Nový SaaS nelze v produkci zavolat, dokud pro něj neexistuje validní záznam. Compliance záznam je zdrojem konfigurace firewallu, ne jeho popisem. Ročně game day "dodavatel mimo provoz" pro dva nejkritičtější (RPC a ...

Kapacita, náklady a FinOps

Fáze 1

Model roku 1: 50 tis. uživatelů, 5 plateb měsíčně, tedy ~250 tis. transakcí měsíčně a špička kolem 10 tx/s. Výpočetně nic — cenu žene compliance podlaha. Odhad měsíčně: EKS control plane 3× 73 USD; produkční uzly ~600 USD; Aurora prod 2× r7g.xlarge ~1 050 USD + storage/IO ~250 USD; Aurora Global sekundár ~525 USD; CloudHSM 2 moduly ~2 100 USD (největší pevná položka a nesmlouvatelná pro FIPS 140-3 L3); KMS ~150 USD; síť (TGW, NAT, Network Firewall) ~700 USD; S3/Glacier/Object Lock ~200 USD a roste; self-hosted observabilita ~800 USD; SIEM Elastic ~2 500–3 500 EUR. AWS celkem ~7–8 tis. USD měsíčně před spuštěním, 12–18 tis. USD v provozu. K tomu SaaS: GitHub Enterprise ~525 USD, PagerDuty ~500 USD, Teleport, Semgrep/Snyk ~1 000 USD, Fireblocks 8–15 tis. USD měsíčně pokud se nestaví vlastní MPC, KYC 1–2,5 EUR za ověření, Chainalysis od ~25–50 tis. USD ročně. Reálný run rate platformy a dodavatelů při spuštění 25–40 tis. EUR měsíčně, bez lidí.

Technologie: AWS Budgets + Cost Anomaly Detection, Kubecost, k6, tagovací politika v Terraformu · **Rozhraní:** Povinné tagy vynucené SCP a Kyverno; rozpočty per prostředí s alertem na 80/100/120 %; měsíční FinOps review. Savings Plans až po třech měsících stabilního baseline — nezamykat se dřív, než se architektura usadí. Kapacitní testování v CI proti stagingu na trojnásobku špičky; změřený (nikoli odhadnutý) strop tx/s ...

Sandbox a nástupce dnešního investorského dema

Fáze 1

Dnešní stav — jednosouborový AES-GCM build na Cloudflare Pages za sdíleným heslem a Cloudflare Access — se převádí do sandbox prostředí platformy: identita per osoba místo sdíleného hesla, Sepolia testnet, mock KYC a mock SEPA, syntetická data, viditelné a nezaměnitelné označení, že jde o simulaci bez licence. Zachovávám Cloudflare Access, protože je už postavený a zároveň nám dává druhého poskytovatele na edge. Sdílené heslo v cleartextu ve složce synchronizované do OneDrive zaniká.

Technologie: Cloudflare Access (identita), CloudFront + S3 nebo Cloudflare Pages pro statický frontend, sandbox API v EKS non-prod ·

Rozhraní: Stejná pipeline jako ostatní prostředí — sandbox se nasazuje podepsaným artefaktem, ne ručním wrangler deploy s --commit-dirty=true.

Zero trust přístupová vrstva pro lidi

Fáze 2

Žádný SSH, žádný bastion se stálými přihlašovacími údaji, žádné trvalé produkční oprávnění. Přístup k produkční databázi a Kubernetes běží přes Teleport s krátkodobými certifikáty (TTL 8 h), nahráváním relací a per-session schválením. Eskalace na roli s přístupem k peněžním datům je JIT: požadavek se zdůvodněním, schválení druhou osobou v Slacku, automatické vypršení za 4 hodiny. MFA je výhradně FIDO2/WebAuthn — TOTP se nepřipouští ani jako záloha, protože phishing-resistant je jediná forma, která obstojí proti scénáři, který stál Bybit 1,5 mld. USD. Čtvrtletní recertifikace přístupů generovaná z IdP do ticketu vlastníkov role.

Technologie: Teleport Enterprise (session recording je požadavek RTS čl. 21, ne komfort), Entra ID / Okta, YubiKey pro celý tým, Jamf/Intune pro device trust · **Rozhraní:** IdP (Entra ID / Okta) → IAM Identity Center pro AWS konzoli a CLI; Teleport pro DB, k8s a interní nástroje; AWS SSM Session Manager pro nouzový přístup k instancím s logováním do log-archive. Interní webová rozhraní (Grafana, Argo CD, Dependency-Track) za Cloudflare Access jako PEP — navazuje na to, co je v repozitáři ...

Service mesh a per-request autorizace

Fáze 2

Vynucuje, že mTLS a autorizace nejsou na gatewayi, ale u každého volání. Istio v ambient módu dává mTLS mezi všemi službami bez sidecar overheadu; waypoint proxy nasazují jen do namespace ledger, payments a signer, kde potřebují L7 AuthorizationPolicy a ext_authz do OPA. Konkrétní politika: služba payments smí volat ledger pouze metody PostTransaction a GetBalance, nikoli administrativní; signer service smí být volána pouze z payments-orchestrator a pouze s tokenem obsahujícím schválení policy enginu.

Technologie: Istio ambient mesh, OPA (Rego), SPIRE · **Rozhraní:** SPIFFE identity per workload, certifikáty s TTL 24 h automaticky rotované; OPA jako externí authorizer s politikami ve stejném repozitáři jako kód a testy politik v CI.

Správa kryptografických klíčů

Fáze 2

Dvě úrovně. AWS KMS s customer-managed klíči pro envelope encryption všeho v klidu (Aurora, S3, EBS, zálohy), klíčové politiky pinované na konkrétní role, deletion window 30 dní a SCP vyžadující MFA pro smazání. AWS CloudHSM cluster (2× hsm2m.medium, FIPS 140-3 Level 3) v účtu prod-keys jako kořen důvěry pro on-chain podpisové shares a pro KEK šifrující citlivá pole ledgeru. Klíče nikdy neopustí hranici modulu; entropie z hardwarového TRNG uvnitř, nikdy z aplikačního RNG. Key ceremony s protokolem, dual control a split knowledge pro operace s root klíči.

Technologie: AWS CloudHSM (2 moduly minimum — jeden modul je single point of failure a nález při auditu), AWS KMS, Azure Managed HSM pro jeden MPC share jako pojistka proti výpadku jednoho poskytovatele · **Rozhraní:** PKCS#11 z signer service, která běží na dedikovaných uzlech; každá podpisová operace zapisuje záznam mimo modul do WORM úložiště v log-archive.

SIEM a detekce jako kód

Fáze 2

Konzumuje audit trail a bezpečnostní telemetrii, vyhodnocuje detekční pravidla, generuje alerty. Pravidla žijí v Gitu jako kód a nasazují se pipeline — detekce je změna a podléhá stejnému change managementu jako aplikace. Konkrétní detekce navázané na tento produkt, ne generické: nesouhlas součtu ledgeru; pokus o UPDATE nebo DELETE na zaúčtovaném postingu; ztráta kvora CloudHSM; odchozí on-chain transakce nad limit nebo mimo whitelist; zmrazení naší adresy emitentem tokenu; změna implementace proxy kontraktu tokenu; přístup ke klíčovému materiálu mimo pracovní dobu; eskalace oprávnění; deaktivace SCP nebo guardrailu; hromadný export dat z KYC schématu; neobvyklý objem nebo směr plateb do zemí s hyperinflací.

Technologie: Elastic Security na Elastic Cloud v AWS eu-central-1, pravidla v Sigma/EQL v repozitáři, GuardDuty a Security Hub jako doplňkové zdroje · **Rozhraní:** Alerty do PagerDuty s předvyplněným kontextem (trace ID, dotčené účty, odhad počtu klientů); čtvrtletní ladění proti false positives s metrikou signal-to-noise, protože nevyladený SIEM se přestane číst a to je horší než žádný.

Alerting a služební pohotovost

Fáze 2

Nejdřív SLO, teprve z nich alerty. SLO: dostupnost platebního API 99,9 % (43 min/měsíc), p99 čtení zůstatku 800 ms, p99 odeslání platby 2,5 s, stáří směnného kurzu < 30 s, připsání on-chain vkladu do 25 min po finalitě, rozhodnutí KYC do 24 h. Stránkuje se na burn rate ve dvou oknech (2 % za 1 h, 5 % za 6 h); vše ostatní je ticket. K tomu tvrdý seznam okamžitých stránek nezávislý na SLO: nenulový ledger imbalance, ztráta kvora HSM, neočekávaný odliv z hot peněženky, selhání zálohy dvakrát po sobě, selhání testu obnovy, nález tajemství ve veřejném místě.

Technologie: PagerDuty (auditovatelné, kdo a kdy potvrdil — vstup do incidentní zprávy), Slack s botem, který zakládá incidentní kanál a časově razítkuje každý krok · **Rozhraní:** Primární + sekundární rotace ze 6–8 inženýrů, týdenní směny. Při týmu 14–25 lidí nelze provozovat plnohodnotný follow-the-sun; návrh proto posouvá jádro podpory na 12:00–22:00 CET, protože cílová klientela je v UTC-4 a špička je večer středoevropského času. Noc pokrývá tenká rotace s tvrdým cílem pod 2 stránky týdně ...

Zálohy, obnova a DR

Fáze 2

Aurora PostgreSQL v prod-ledger: synchronní commit přes tři AZ (RPO 0 v rámci regionu), Aurora Global Database do eu-west-1 s replikačním zpožděním pod 1 s (mezirregionální RPO ≈ 1 s, cíl RTO při neplánovaném failoveru pod 15 min). PITR 35 dní. Denní logický dump do účtu backup-vault s S3 Object Lock, měsíční archivní dump do Glacier Deep Archive s desetiletou retencí kvůli AML. AWS Backup Vault Lock v režimu Compliance — jednou nastavená retenční nejde zkrátit ani rootem. RTO/RPO tabulka per funkce: platby a ledger RTO 1 h / RPO ≈ 0 , karetní limity RTO 4 h, KYC onboarding RTO 8 h / RPO 15 min, reporting RTO 24 h.

Technologie: Aurora Global Database, AWS Backup + Vault Lock (Compliance), S3 Object Lock, Glacier Deep Archive, druhá kopie u nezávislého poskytovatele (Azure Blob immutable) · **Rozhraní:** Týdně automaticky: obnova snapshotu do efemérního účtu restore-test, spuštění rekoncele (součet postings = zůstatky, v každé měně zvlášť), checksum diff, podepsaný protokol do log-archive, zničení účtu. Čtvrtletně DR game day s reálným přepnutím regionu a měřením času byznysem. Ročně plná ztráta primárního regionu. ...

Incident management a strojní podpora hlášení do 4 hodin

Fáze 2

Nejpodceňovanější součást celého návrhu. Klasifikační služba přijme fakta o incidentu (počet zasažených klientů, doba výpadku, geografický rozsah, ztráta dat, dopad na kritickou funkci, ekonomický dopad), vyhodnotí je proti kritériím delegovaného nařízení 2024/1772 a vrátí verdikt závažný ano/ne s časovým razítkem a jménem rozhodující osoby. Lhůta 4 h běží od klasifikace, nejpozději 24 h od zjištění. Klíčová konstrukční podmínka: audit stream musí být navržený tak, aby jediný dotaz nad oknem incidentu vrátil distinct client_id dotčené selhávající cestou. Kdo neumí odpovědět na "kolik klientů" do 30 minut, nestihne podat hlášení do 4 hodin — a je to otázka datového modelu, ne procesu.

Technologie: Incident tracker (Jira Service Management nebo incident.io), Slack bot pro časovou osu, generátor šablon jako služba, PagerDuty jako zdroj potvrzovacích časů · **Rozhraní:** Generátor hlášení plní šablonu podle prováděcího nařízení 2025/301 z incidentního záznamu; člověk kontroluje a odesílá do Lietuvos bankas. Runbook má čtyři paralelní větve s pojmenovanými vlastníky: DORA 4 h/72 h/1 měsíc → NCA, GDPR 72 h → dozorový úřad, MiCA čl. 75 informování klienta, PSD2 hlášení podvodů. ...

Podpisová doména on-chain (signer enclave)

Fáze 3

Provozně nejcitlivější komponenta platformy, protože 76 % ztrát roku 2025 bylo kompromitací klíčů a podpisových procesů, ne chybami v kontraktech. Tři oddělené domény: hot (automatické podpisy, do 1–2 % aktiv, tvrdý denní i per-transakční limit), warm (MPC/HSM s policy enginem a lidským schválením), cold (air-gapped, většina rezerv). Samostatný klíčový materiál — žádné odvození ze společného seedu, samostatné síťové segmenty, samostatné servisní účty. Policy engine běží mimo podpisové UI: whitelist adres se zpožděním 24–48 h, čtyřroční princip nad limitem, simulace transakce (Tenderly/Blockaid) hostovaná mimo hlavní frontend, tvrdé pravidlo, že podpis, kde hardware zařízení neumí zobrazit dekodovaná data, se neprovede. Self-hostovaná verzovaná kopie Safe UI se subresource integrity, nikdy veřejný hostovaný frontend.

Technologie: MPC/TSS pro hot a warm (shares rozprostřené mezi AWS CloudHSM, Azure Managed HSM a TEE), Safe multisig s vysokým prahem a hardware peněženkami pro cold, EIP-712 + ERC-7730 clear signing · **Rozhraní:** Volání pouze z payments-orchestrator přes mTLS s tokenem nesoucím schválení policy enginu; každý podpis do WORM auditu; kontinuální on-chain monitoring s circuit breakerem, který zastaví odchozí toky při detekci anomálie nebo změny implementace proxy kontraktu tokenu.

9.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tým kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
AWS jako primární cloud, eu-central-1 primární a eu-west-1 jako teplá záloha Zvažováno: Azure (levnější Sentinel, Managed HSM, EU Data Boundary) — prohrálo na zralosti Object Lock ekvivalentu a na tom, že celý tým dnes nemá Azure zkušenost. GCP — nejslabší nabídka v oblasti neměnného ...	Frankfurt jako primární region se třemi AZ, Irsko jako warm standby. Žádná klientská data mimo EU, ani v singapurské mateřské společnosti. CloudHSM s FIPS 140-3 Level 3, KMS custom key store, Object Lock v Compliance režimu a Backup Vault Lock jsou dnes na AWS nejzralejší kombinace pro to, co DORA a RTS 2024/1774 vyžadují. Frankfurt je nejbližší velký region k litevské dceřince a k evropské klientele; Irsko je dostatečně nezávislá failure doména. Držení dat výhradně v EU eliminuje závislost na EU-US Data Privacy Framework, jehož kasační opravný ...	Zavazuje nás ke koncentraci u jednoho poskytovatele, což je podle DORA čl. 29 samostatné riziko, které musí být v registru popsán a mitigován. Latence pro Venezuelu a LATAM je ~180–220 ms na API; frontend to řeší CloudFront edge cachí, ale peněžní zápisy tuto latenci ponesou a UX to musí unést. Přesun do Azure nebo GCP by trval měsíce, ne týdny — proto stavím na ...
Izolace na úrovni AWS účtů, ne na úrovni VPC v jednom účtu Zvažováno: Jeden účet s VPC per prostředí — levnější a rychlejší, ale sdílená IAM hranice znamená, že jedna nadměrně široká politika propojí produkci s testem; přesně to je typ nálezu, který u dohledu prochází ...	Čtrnáct účtů v AWS Organizations, kde je účet jednotkou blast radiusu. Ledger, klíče a zálohy mají vlastní účty s vlastní sadou identit. IAM chyba v jednom účtu nemá jak dosáhnout do druhého; SCP na úrovni OU je tvrdší hranice než jakákoli IAM politika uvnitř účtu. Požadavek RTS čl. 13 na izolaci systémů podporujících kritické funkce se takto plní strukturálně, ne konfigurací. Zároveň to čistě odděluje náklady per prostředí, což potřebujeme pro FinOps.	Vyšší počáteční složitost — cross-account role, sdílené VPC endpointy, centralizované logování, sdílené AMI a image. Bez Terraformu je to neudržitelné, takže IaC přestává být volba a stává se podmínkou. Přidává zhruba 2–3 týdny práce na začátku a trvale asi 0,3 FTE na správu landing zone.
EKS jako běhové prostředí místo serverless nebo ECS Zvažováno: AWS Lambda + Step Functions — nižší provozní zátěž, ale podpis artefaktu a per-pod identita se řeší hůř a vendor lock-in ničí exit plán. ECS Fargate — kompromis, chybí ekosystém policy nástrojů ...	Tři EKS clustery s Karpenterem; aplikace jako OCI kontejnery. Potřebujeme mesh s per-request autorizací, admission control ověřující podpisy, dedikované uzly pro signer service a přenositelnost mezi cloudy jako součást exit strategie podle DORA čl. 28. Lambda ani ECS nedají první tři věci bez obcházení, a Lambda navíc špatně snáší dlouhou běžící rekonciliace a sekvenční nonce management pro on-chain podpisy.	Kubernetes je trvalá provozní daň — upgrady čtvrtletně, CVE v ekosystému, potřeba někoho, kdo tomu opravdu rozumí. Počítám 0,5–1 FTE platform engineer trvale. Výměnou dostáváme, že admission policy (nespuštění nepodepsaný image) je vynutitelná v jednom místě, což je nejsilnější supply-chain kontrola, jakou máme.
cosign s vlastním KMS klíčem místo keyless podepisování Zvažováno: Keyless cosign — odmítnuto z důvodu závislosti a nemožnosti zařadit do registru. Notary v2 — menší ekosystém nástrojů. Žádné podepisování — dnešní stav, kde k nasazenému artefaktu neexistuje ...	Podpisy artefaktů klíčem v AWS KMS, transparentní log Rekord self-hosted, SLSA v1.0 provenance z GitHub Actions. Keyless (Fulcio + veřejný Rekord) je elegantní, ale váže důvěryhodnost našich produkčních artefaktů na veřejnou infrastrukturu Sigstore, kterou nemůžeme mít v registru informací jako řízeného dodavatele a jejíž výpadek by zablokoval nasazení. Vlastní KMS klíč znamená, že podpisová identita je naše, auditovatelná a rotovatelná podle naší kryptopolitiky.	Musíme spravovat životní cyklus podpisového klíče včetně rotace a odvolání, a provozovat vlastní Rekord. Přidává jednu komponentu k údržbě. Naopak dává, že při dotazu dohledu na integritu dodavatelského řetězce ukazujeme vlastní klíč s vlastní politikou, ne odkaz na veřejnou službu.
CloudHSM jako kořen důvěry vedle KMS, ne KMS samotné Zvažováno: Pouze KMS — levnější, ale KMS není určený pro secp256k1 podpisové workflow s policy enginem a nedá exkluzivní kontrolu nad modulem. Fireblocks jako plná custody služba — provozně nejjednodušší, 8–15 ...	AWS KMS s CMK pro veškeré šifrování v klidu; samostatný CloudHSM cluster (2 moduly) v odděleném účtu pro on-chain podpisové shares a pro KEK citlivých polí ledgeru. KMS je pro data at rest naprosto dostatečné a levné. Ale u on-chain klíčů potřebujeme jednovlastnický, exkluzivně kontrolovaný modul, kde lze doložit celý životní cyklus klíče uvnitř FIPS 140-3 L3 hranice, key ceremony s dual control a auditní stopu každé podpisové operace — to je požadavek pro custody due diligence, pro pojistitele (Lloyd's upisuje prakticky jen MPC/HSM architektury) i pro MiCA čl. 75.	Nejdražší pevná položka rozpočtu, ~2 100 USD měsíčně jen za dva moduly, a nezanedbatelná provozní složitost (kvorum, backup karty, PKCS#11 integrace, ceremonie). Dva moduly jsou minimum — jeden je single point of failure a nález při auditu. Zavazuje nás k tomu, že signer service je oddělená služba na dedikovaných uzlech, ne knihovna v monolitu.
HashiCorp Vault místo AWS Secrets Manager Zvažováno: AWS Secrets Manager + Parameter Store — provozně triviální, ale dynamické DB credentials řeší jen částečně a vytváří další vazbu na AWS proti exit plánu. Sealed Secrets / SOPS v Gitu — nepřipouštím, ...	Vault Community, jeden cluster na prostředí, auto-unseal přes KMS, Raft storage. Potřebujeme tři věci, které Secrets Manager nedá: dynamické Postgres credentials s hodinovým TTL (žádné statické heslo do databáze nikdy neexistuje), Transit engine pro aplikační šifrování bez toho, aby aplikace držela klíč, a interní PKI pro mTLS. K tomu jeden audit device pro všechna tajemství napříč prostředí a cloudy, což při možném přesunu MPC share do Azure přestává být teoretické.	Provozujeme stavovou službu, která je kritickou závislostí — když je Vault dole, nová pody nenastartují. Vyžaduje to HA setup, testovaný unseal postup a disaster recovery plán pro samotný Vault. BUSL licence je právní riziko; OpenBao (fork pod Linux Foundation) je evidovaná výstupní varianta a API kompatibilita se testuje jednou ročně, aby přechod nebyl teoretický.

Rozhodnutí	Volba a důvod	Důsledek
Dva oddělené logovací proudy — provozní a evidenční Zvažováno: Jeden proud do SIEM s dlouhou retencí — dražší o řád a v rozporu s GDPR minimalizací. Jen CloudTrail jako audit — nepokrývá aplikační peněžní události, které jsou přesně to, co dohled chce vidět.	Provozní logy do Loki (30 dní, mazatelné, vzorkované, PII odstraněné na kolektoru). Evidenční audit trail do odděleného účtu log-archive, S3 Object Lock Compliance, hash chain, 10 let. Jsou to dvě různé věci s protichůdnými požadavky. Provozní log chci levný, hodně objemný a smazatelný (GDPR minimalizace). Evidenční trail chci neměnný, podepsaný, mimo dosah administrátora a s desetiletou retencí (AMLR čl. 77 zakazuje redakci záznamů). Kdo je slije do jednoho, buď platí compliance retenci za debug logy, nebo si mazacím jobem zničí důkazní materiál.	Aplikace musí explicitně rozlišovat, co je audit událost a co je log — to je designové rozhodnutí v kódu, ne konfigurace infrastruktury, a musí být hotové dřív než první produkční release. Vzniká riziko, že se na něco zapomene; řeší se tím, že audit událost je typ v doménovém modelu a chybějící audit u mutující peněžní operace je selhání testu.
Self-hosted observabilita (LGTM), ale komerční SIEM Zvažováno: Grafana Cloud na všechno — o 0,5 FTE levnější provozně, ale přidává dalšího dodavatele s přístupem k finanční telemetrii. Microsoft Sentinel — cenově atraktivní (~2 EUR/GB) a byl by první volbou, ...	Grafana + Mimir + Loki + Tempo na vlastním S3 backendu v účtu security-tooling; Elastic Security na Elastic Cloud v eu-central-1 jako SIEM. Telemetrie je velký objem, obsahuje pseudonymizovaná finanční data a její self-hosting je předvídatelně nákladný. SIEM je naopak o kvalitě detekčních pravidel, které nechceme psát od nuly — vendor je udržuje a to je hodnota, kterou při týmu 14–25 lidí neumíme replikovat. Rozdělení tedy nekopíruje technologii, ale to, kde je naše přidaná hodnota.	Self-hosted LGTM stojí zhruba 0,5 FTE navíc a je to skrytá položka, kterou lidé v rozpočtech zapomínají. Elastic je zároveň zpracovatel osobních údajů a kritický dodavatel — musí být v registru informací s DPA, EU lokací a exit plánem. Detekce jsou psané jako Sigma/EQL v Gitu, takže migrace na jiný SIEM je práce na týdny, ne na kvartály.
Warm standby v druhém regionu, ne active-active Zvažováno: Multi-region active-active — zamítnuto pro složitost. Pouze zálohy bez druhého regionu (cold standby) — RTO v řádu hodin až dnů, což u platební funkce neobstojí v BIA. Pilot light (jen data, žádná ...)	Aurora Global Database s teplou replikou v eu-west-1, aplikační vrstva připravená ale škálovaná na nulu, přepnutí řízené runbookem. Active-active pro podvojný ledger znamená buď distribuovaný konsensus se zápisovou latencí přes region, nebo sharding klientů po regionech s ohromnou složitostí rekonceiliace. U 10 tx/s je to neúměrné. Warm standby dá RTO pod 15 minut a RPO pod sekundu, což pro platební instituci naší velikosti bohatě stačí a je to obhajitelné v business impact analýze.	Přepnutí není bezobslužné — vyžaduje rozhodnutí člověka a asi 10–15 minut práce podle runbooku. Runbook proto musí být nacvičený čtvrtletně, jinak je RTO 15 minut fikce. Sekundární region stojí ~600 USD měsíčně za to, že většinu času nic nedělá; to je cena za provozní odolnost, ne plýtvání.
Registr informací je zdroj konfigurace firewallu, ne jeho popis Zvažováno: Registr jako excel udržovaný compliance oddělením — standardní praxe, ale rozchází se s realitou během jednoho kvartálu. Registr generovaný automaticky z cloudové inventarizace — nepokrývá SaaS mimo ...	Registr podle prováděcího nařízení 2024/2956 se udržuje jako validovaná data v Gitu a generuje se z něj FQDN allowlist pro AWS Network Firewall. Compliance dokumenty, které nemají technický důsledek, zastarají do tří měsíců. Když je registr vstupem do egress pravidel, nelze v produkci zavolat dodavatele, který v registru není — registr se udržuje sám, protože jinak nic nefunguje. To je jediný způsob, jak si troufám tvrdit, že registr předložený dohledu odpovídá skutečnosti.	Přidání nového dodavatele je pomalejší — vyžaduje PR s posouzením kritičnosti, nahraditelnosti a exit plánu, schválené compliance rolí. Vývojáři si na to budou stěžovat. Je to záměr: rychlost přidávání SaaS závislosti je v regulované instituci antipattern, ne feature.
Vlastní registry proxy se sedmidenní karanténou nových verzí balíčků Zvažováno: Přímý npmjs s `npm ci` a lockfile — dnešní stav; lockfile chrání proti změně existující verze, ne proti kompromitované nové verzi, kterou Renovate ochotně navrhne. Socket.dev / Snyk supply-chain ...	AWS CodeArtifact jako jediný upstream pro npm a kontejnerové base images; nová verze balíčku se zpřístupní až po 7 dnech od publikace, s možností výjimky pro bezpečnostní záplaty. Dnešní repozitář má 126 balíčků, všechny přímo z registry.npmjs.org. Naprostá většina útoků na npm ekosystém je odhalena během několika dní od publikace kompromitované verze. Sedmidenní zpoždění je nejlevnější existující obrana proti celé této třídě útoků a nestojí nic než trpělivost.	Nemůžeme okamžitě přijmout nově vydanou verzi, což občas zdrží upgrade. Bezpečnostní záplaty mají výjimkovou cestu se jmenovitým schválením. Přidává jednu infrastrukturní komponentu a závislost na CodeArtifact pro build.
PagerDuty místo self-hostovaného on-call nástroje Zvažováno: Grafana Cloud IRM — srovnatelné, vázalo by nás na Grafana Cloud, kterou jinak nepoužíváme. Opsgenie — Atlassian ho ukončuje a migruje do JSM, nechci stavět na produktu na konci životního cyklu. ...	PagerDuty pro zhruba 12 responderů, ~500 USD měsíčně. Potřebujeme auditovatelný záznam, kdo a v kolik hodin alert potvrdil a eskaloval — to je přímý vstup do časové osy incidentní zprávy podle DORA čl. 19. Grafana OnCall v OSS variantě byl ukončen, self-hosting alertovacího systému je navíc ironický single point of failure (stránkový systém nesmí spadnout se zbytkem platformy).	Další dodavatel v registru, byť nekritický pro poskytování služby. Fixní náklad, který roste s týmem. Musí být nakonfigurován tak, aby fungoval i při totálním výpadku naší platformy — tedy nezávislý kanál a mobilní aplikace, ne webhook z našeho Grafany jako jediná cesta.

Rozhodnutí	Volba a důvod	Důsledek
AWS Shield Advanced odložen s definovaným spouštěčem Zvažováno: Zapnout od začátku — bezpečnější, ale 36 tis. USD ročně před prvním klientem se v runway 24–33 měsíců projeví. Cloudflare jako plná edge ochrana — levnější, ale znamenalo by to nechat Cloudflare v ...	Rok 1 pouze CloudFront + AWS WAF se spravovanými sadami pravidel a rate limitingem; Shield Advanced (3 000 USD měsíčně) se zapíná při splnění spouštěče. 3 000 USD měsíčně je 10 % rozpočtu platformy za ochranu, kterou v beta a sandbox fázi nepotřebujeme. Standardní Shield a WAF pokryjí objemové útoky na CloudFront vrstvě.	Nemáme DDoS response team ani finanční ochranu proti scale-out nákladům při útoku. Spouštěč je explicitní a napsaný: první veřejná produkční platba klienta, nebo první zaznamenaný L7 útok nad 10 tis. požadavků za sekundu, nebo smluvní požadavek bankovního partnera — podle toho, co nastane dříve. Bez pojmenovaného spouštěče by se odklad tiše změnil na trvalý stav.
Klasifikace incidentu jako služba s jmenovitou odpovědností, ne jako proces v dokumentu Zvažováno: Ruční klasifikace podle checklistu — funguje, dokud incident nepřijde v neděli ve tři ráno. Outsourcing na compliance poradce — nezvládne čtyřhodinovou lhůtu, protože nemá přístup k datům.	Interní nástroj vyhodnocující kritéria delegovaného nařízení 2024/1772 nad daty z audit streamu, s pojmenovaným klasifikátorem a jeho zástupcem dosažitelnými 24/7. Čtyřhodinová lhůta začíná běžet klasifikací, a v praxi se prohrává dvěma způsoby: nikdo neví, kdo má pravomoc rozhodnout, nebo nikdo neumí do půl hodiny zjistit počet zasažených klientů. Obojí je řešitelné předem a obojí je levné, pokud se to udělá při návrhu datového modelu, a extrémně drahé, pokud se to řeší až při prvním incidentu.	Audit stream musí nést atribuci klienta u každé operace, což zvyšuje jeho objem i citlivost a vyžaduje pseudonymizaci (client_id, nikdy jméno). Klasifikátor je role s reálnou odpovědností — musí být obsazen člověkem s mandátem, typicky CTO nebo Head of Risk, ne rotujícím inženýrem.
Vlastní Ethereum uzel jako rozhodčí vedle dvou komerčních RPC poskytovatelů Zvažováno: Jediný RPC poskytovatel — nejlevnější a nejrizikovější; přesně ten typ jednobodové závislosti, kterou dohled označí. Tři komerční poskytovatelé s hlasováním — lepší než jeden, ale všichni tři mohou ...	Alchemy + Infura jako primární a sekundární RPC, k tomu vlastní full node (Geth/Nethermind + Lighthouse) v prod účtu; při neshodě o stavu se nedůvěřuje ani jednomu komerčnímu a operace se pozastaví. Dva komerční RPC poskytovatelé chrání před výpadkem, ale ne před tím, že nám poskytovatel vrátí nesprávný stav — ať už chybou, nebo kompromitací. U systému, který na základě on-chain stavu přisuzuje klientům peníze, je nezávislé ověření podmínkou. Zároveň to je konkrétní mitigace koncentračního rizika podle DORA čl. 29 pro kritickou závislost.	Vlastní archive-lite node stojí ~400–600 USD měsíčně na compute a storage a vyžaduje údržbu při hard forkech. Přidává provozní úlohu, kterou musí někdo umět. Výměnou dostáváme, že žádný jednotlivý dodavatel nemůže způsobit nesprávné připsání prostředků.

9.3 Klíčové toky

Změna peněžní logiky od commitu do produkce

- 1 Vývojář otevře PR na trunk; CODEOWNERS vyžaduje pro adresáře ledger/, payments/ a exchange/ schválení dvou osob, z nichž ani jedna není autor.
- 2 CI spustí lint, typecheck, unit testy včetně vlastnostních testů invariantů (součet postings v každé měně = 0, žádná posloupnost operací nezmění celkovou hodnotu nad rámec vybraných poplatků, idempotentní opakování má stejný efekt jako jedno provedení) a mutační testování na modulu ledger.
- 3 Paralelně běží SCA proti Dependency-Track, SAST (Semgrep + CodeQL), sken tajemství (gitleaks) a Terraform policy gate; jakýkoli kritický nález PR zablokuje bez možnosti obejít.
- 4 Po merge se sestaví reprodukovatelný OCI image s pinovaným digestem base image a SOURCE_DATE_EPOCH; vygeneruje se SBOM v CycloneDX 1.6.
- 5 cosign podepíše image klíčem v KMS, připojí SBOM attestation a SLSA v1.0 provenance; artefakt jde do ECR s immutable tagem a záznam commit→build→digest se zapíše do evidenční tabulky v log-archive.
- 6 Argo CD nasadí do test prostředí; proběhnou integrační a kontraktní testy proti mockům dodavatelů a proti Sepolia testnetu.
- 7 Nasazení do stagingu; DAST baseline a zátěžový test k6 na trojnásobku očekávané špičky s kontrolou, že p99 latence a chybovost drží SLO.
- 8 Schvalovací brána: záznam změny s plánem návratu, schválený jinou osobou než autorem; u změn peněžní logiky navíc schválení risk role. Bez záznamu změny brána nepustí.

- 9 Kyverno v produkčním clusteru ověří podpis, SBOM attestaci a provenance — nepodepsaný nebo neúplný artefakt se nespustí bez ohledu na to, co říká Argo CD.
- 10 Argo Rollouts pustí canary na 5 % provozu; automatická analýza SLO burn rate po 15 minutách rozhodne o postupu nebo automatickém rollbacku.
- 11 Postupné rozšíření na 100 %; digest běžícího podu se doplní do evidenční tabulky, čímž je řetězec commit → build → SBOM → podpis → nasazení → běžící instance uzavřený a dotazovatelný.

Dnešní stav je opakem: žádné testy, žádné CI, ruční `npm run build:secure && wrangler pages deploy --commit-dirty=true`, takže k nasazenému artefaktu neexistuje ověřitelný commit. Vlastnostní testy peněžních invariantů jsou z celého řetězce to jediné, co nelze koupit ani nakonfigurovat — musí se napsat a je to nejdražší položka fáze F1.

Nouzová změna (emergency change) mimo standardní bránu

- 1 Incident velitel vyhlásí potřebu nouzové změny a otevře break-glass roli, která je časově omezená na 4 hodiny a vyžaduje potvrzení druhé osoby.
- 2 Pipeline běží ve zkrácené podobě: unit testy, sken tajemství, build, podpis — tyto kroky se nikdy nevynechávají, protože nepodepsaný artefakt by neprošel admission controle a obejít Kyverno by znamenalo vypnout jedinou funkční supply-chain kontrolu.
- 3 Vynechávají se pouze DAST, zátěžový test a staging soak; toto vynechání se automaticky zaznamená do change recordu jako přijaté riziko.
- 4 Nasazení jde přímo na canary 25 % s kratším analytickým oknem a s člověkem sledujícím metriky v reálném čase.
- 5 Do 24 hodin proběhne dodatečné schválení nouzové změny risk rolí, doplnění chybějících testů a rozhodnutí, zda změna zůstává nebo se vrací.
- 6 Nouzová změna automaticky zakládá post-incident review, i když nedošlo k výpadku.

RTS 2024/1774 čl. 17 vyžaduje oddělený proces nouzové změny s dodatečným schválením. Kritické je, že se nevynechává podpis — jinak se break-glass stane trvalou zadní cestou do produkce.

Plánovaná i mimořádná rotace tajemství a klíčů

- 1 Plánovaná rotace běží automaticky podle kryptoperiod: Vault vydává DB credentials s TTL 1 h a ty se prostě nechají vypršet; workload certifikáty rotuje Istio každých 24 h; veřejné TLS obnovuje ACM.
- 2 Tajemství dodavatelů (API klíče, webhook secrecy) rotuje job každých 90 dní metodou dvou platných hodnot — nové se vytvoří, obě běží 24 h, staré se odvolá; bez překryvu by rotace znamenala výpadek integrace.
- 3 KEK v CloudHSM se rotuje ročně; datové klíče se přešifrují envelope postupem na pozadí bez odstávky, protože se mění pouze zabalený DEK, ne šifrovaná data.
- 4 MPC shares procházejí proaktivním re-sharingem čtvrtletně; adresa se nemění, takže operace je pro klienty i pro ledger neviditelná.
- 5 Mimořádná rotace při podezření na kompromitaci: jediný příkaz `rotate-all --class=<třída>` odvolá a znovu vydá celou třídu; runbook definuje pořadí tříd tak, aby se systém během rotace nezablokoval (nejdřív aplikační tajemství, pak DB, nakonec certifikáty).
- 6 Signeři cold multisigu se rotují do 24 hodin od odchodu člověka z týmu; to je on-chain transakce s ceremonií a čtyřma očima.
- 7 Čtvrtletně se celá mimořádná rotace nacvičí ve stagingu a změří se doba do plné rotace; číslo se zapisuje jako evidence pro ICT audit.

Dnešní stav — jedno sdílené heslo, které je zároveň vývojovým přístupovým kódem a leží v cleartextu ve složce synchronizované do OneDrive — zaniká hned v F1. Statické nerotované tajemství je podle auditu nejčastější příčina eskalace incidentu na 'major'.

ICT incident od detekce po hlášení do 4 hodin

- 1 Detekce: SIEM pravidlo, SLO burn rate alert nebo tvrdý invariantní alert (např. ledger_imbalance $\neq$ 0) vyvolá stránku v PagerDuty; časové razítko detekce je od této chvíle fixní a nepřepisovatelné.
- 2 On-call potvrdí do 5 minut, otevře incidentní kanál (bot jej založí automaticky a od této chvíle časově razítkuje každou zprávu) a jmenuje incident velitele.
- 3 Do 30 minut se z audit streamu vytáhne rozsah dopadu: distinct client_id dotčené selhávající cestou, doba nedostupnosti, zasažené měny a geografie, ztráta či poškození dat, dopad na kritické funkce. Toto je jediný krok, který nesnese improvizaci — buď je datový model připravený, nebo lhůta padá.
- 4 Klasifikátor (jmenovaná osoba nebo její zástupce) spustí klasifikační nástroj, ten vyhodnotí kritéria delegovaného nařízení 2024/1772 a vrátí verdikt s razítkem a jménem. Od okamžiku klasifikace jako závažný běží 4 hodiny.
- 5 Souběžně se rozjíždí zmírnění dopadu — pokud jde o on-chain nebo peněžní tok, aktivuje se circuit breaker a odchozí operace se pozastaví; klasifikace a hlášení běží nezávisle na tom, jestli je incident vyřešený.
- 6 Generátor hlášení naplní šablonu podle prováděcího nařízení 2025/301 z incidentního záznamu; compliance role zkontroluje a odešle do Lietuvos bankas. Nejpozději do 24 hodin od zjištění i tehdy, pokud klasifikace proběhla později.
- 7 Paralelní větve runbooku se spouštějí ze stejného incidentu: GDPR 72 h k dozorovému úřadu, pokud jsou dotčeny osobní údaje; informování klientů podle MiCA čl. 75, pokud došlo ke ztrátě kryptoaktiv; hlášení podvodu podle PSD2, pokud jde o neautorizované transakce. Každá větev má jmenovaného vlastníka.
- 8 Do 72 hodin průběžná zpráva, do 1 měsíce závěrečná zpráva s root cause — obojí čerpá z časové osy incidentního kanálu a z neměnného audit trailu, ne z paměti účastníků.
- 9 Post-incident review bez hledání viníka, s konkrétními akcemi, termíny a vlastníky; akce se zakládají jako tickety a jejich plnění se reportuje na úroveň statutárního orgánu.

Čtvrtletně se celý tok nacvičí s fiktivním incidentem a měří se čas do konceptu hlášení. Cíl je koncept do 2 hodin, aby zbývala rezerva na kontrolu. Bez nacvičení je čtyřhodinová lhůta jen číslo v dokumentu.

Týdenní test obnovy ledgeru a čtvrtletní DR game day

- 1 Automatický job každou neděli vytvoří efemérní účet restore-test s vlastní VPC bez konektivity do produkce.
- 2 Do něj se obnoví poslední snapshot Aurora z účtu backup-vault; obnova probíhá na systémech fyzicky i logicky oddělených od zdrojových, jak vyžaduje RTS.
- 3 Spustí se rekongilace: přepočítá zůstatků ze všech postings od nuly a porovnání proti materializovaným zůstatkům, zvláště v každé měně; k tomu kontrola integrity hash chainu audit trailu za odpovídající období.
- 4 Změří se skutečná doba obnovy a porovná se s deklarovaným RTO; odchylka nad 20 % je ticket, ne poznámka.
- 5 Výsledek se podepíše a uloží do log-archive jako evidence; účet se zničí. Selhání testu dvakrát po sobě je okamžitá stránka.
- 6 Čtvrtletně navíc DR game day: řízené přepnutí na eu-west-1 podle runbooku, s byznysem měřícím skutečný RTO a s ověřením, že po přepnutí sedí zůstatky a že se nezdvojily žádné operace.
- 7 Ročně plný test ztráty primárního regionu včetně obnovy Vaultu, KMS grantů a přístupu ke klíčovému materiálu — to je část, kterou většina institucí netestuje a která při reálném výpadku selže první.

Rekongilace po obnově není volitelný krok — DORA čl. 12 odst. 5 ji vyžaduje explicitně a je to zároveň jediný způsob, jak zjistit, že záloha je konzistentní, a ne jen obnovitelná.

Připojení nového dodavatele do produkce

- 1 Vlastník integrace otevře PR do registru dodavatelů s vyplněným záznamem: LEI, podporovaná funkce, posouzení kritičnosti (podporuje kritickou nebo důležitou funkci ano/ne), nahraditelnost, lokace dat, řetězec subdodavatelů a odkaz na exit plán.

- 2 CI validuje záznam proti schématu prováděcího nařízení 2024/2956; neúplný záznam PR zablokuje.
- 3 Compliance a risk role posoudí smlouvu proti checklistu čl. 30 DORA — právo na audit a přístup, lokace zpracování, součinnost při incidentech, SLA, výpovědní podmínky; u dodavatele kritické funkce navíc dokumentovaná a otestovaná exit strategie a posouzení koncentračního rizika.
- 4 Pokud dodavatel zpracovává osobní údaje, přidává se DPA a záznam do evidence činností zpracování; u předání mimo EU navíc posouzení dopadu předání.
- 5 Po schválení merge vygeneruje Terraform nové FQDN pravidlo v Network Firewallu a nový secret slot ve Vaultu; teprve tímto okamžikem je dodavatel technicky dosažitelný z produkce.
- 6 Integrace se nejprve nasadí do sandboxu proti testovacímu prostředí dodavatele, pak do stagingu, pak do produkce standardní pipeline.
- 7 U dodavatelů podporujících kritickou funkci se jednou ročně provede game day 'dodavatel mimo provoz' a ověří se, že fallback (druhý KYC provider, druhý RPC, vlastní uzel) skutečně funguje.

Zásadní je pořadí: registr je vstupem do konfigurace sítě, ne jejím popisem. Tím se stává technicky nemožným mít v produkci volaného dodavatele, který v registru chybí — a to je jediná verze registru, o které se dá tvrdit, že odpovídá skutečnosti.

9.4 Rizika a opatření

Riziko	Opatření v návrhu
Koncentrace u AWS. Většina kritických funkcí závisí na jednom poskytovateli, což je podle DORA čl. 29 samostatné riziko koncentrace a při dohledu předvídatelný nález.	Stavět na přenositelných primitivech (Kubernetes, PostgreSQL, OCI, OpenTelemetry, Terraform) a proprietární AWS služby držet mimo aplikační vrstvu. Exit plán s odhadem 4–6 měsíců a rozpočtem, ne s větou 'lze migrovat'. Reálně provozované opory u jiných poskytovatelů, aby exit nebyl teoretický: DNS a edge na Cloudflare, druhá kopie záloh v Azure Blob s immutable politikou, jeden MPC share v Azure Managed HSM, status page mimo AWS. Ročně zkoušet obnovu ledgeru ze sekundární kopie mimo AWS.
Čtyřhodinová lhůta se prohraje na datech, ne na procesu. Odpověď na otázku 'kolik klientů to zasáhlo' bude vyžadovat hodiny ad hoc dotazů.	Atribuce klienta u každé auditní události od prvního dne, uložená tak, aby jeden dotaz nad časovým oknem a nad identifikátorem selhávající cesty vrátil distinct client_id do 30 sekund. Předpřipravené dotazy jako součást runbooku. Čtvrtletní nácvik s měřením času do konceptu hlášení; když číslo přesáhne 2 hodiny, je to defekt datového modelu a řeší se jako defekt.
Nepřetržitá pohotovost při týmu 14–25 lidí. Rotace se vyčerpá, kvalita reakce klesne a v nejhorší chvíli nebude nikdo, kdo klasifikuje incident.	Tvrdý strop 2 stránky týdně na osobu jako měřený SLI provozu, ne jako přání; každá stránka nad limit vyvolá revizi alertu. Jádru podpory posunuté na 12:00–22:00 CET podle geografie klientely (LATAM), noc pokrytá tenkou rotací pouze s tvrdým seznamem stránek. Pravidla odpočinku a kompenzace písemně. Klasifikátor incidentu má vždy zástupce a je to seniorní role s mandátem, ne rotující inženýr. Při růstu nad 25 lidí zvážit externí NOC pouze na triáž, nikdy na klasifikaci.
Self-hosted observabilita a Vault jsou skryté FTE náklady. V rozpočtu vypadají levně, v realitě spotřebují 0,5–1 inženýra a při jeho odchodu se stanou neudržovanými.	Explicitně rozpočtovat 1 FTE platform engineer na EKS + LGTM + Vault a mít pro každou z těchto komponent alespoň dva lidi se skutečnou znalostí (bus factor 2 jako podmínka, ne cíl). Předem definovaný ústupový plán: pokud v F2 nebude kapacita, migrovat telemetrii do Grafana Cloud EU a tajemství do AWS Secrets Manager, s odhadem 3 týdnů práce a cenovým dopadem přibližně +1 500 EUR měsíčně.
Kompromitace podpisové cesty on-chain. Přesně tento vektor stál Bybit 1,5 mld. USD — multisig byl formálně v pořádku, ale podepisující viděli podvrženou transakci.	Policy engine mimo podpisové UI, clear signing s EIP-712 a ERC-7730 jako tvrdá podmínka (nezobrazitelná data = žádný podpis), nezávislý verifikační kanál pro calldata hash na izolovaném zařízení a jiným kanálem, simulace transakce hostovaná mimo hlavní frontend, self-hostovaná verzovaná kopie Safe UI se subresource integrity. Whitelist adres se zpožděním 24–48 h a limity hot penězanky na 1–2 % aktiv, aby nejhorší možný scénář byl provozní ztráta, ne ztráta klientských prostředků.

Riziko	Opatření v návrhu
Kompromitace vývojářského stroje jako vstup do produkce. Radiant Capital i Bybit začaly na koncovém zařízení, ne v cloudu.	Spravovaná zařízení s EDR, FIDO2 bez alternativy, žádné dlouhodobé cloudové credentials na laptotech (výhradně krátkodobé tokeny přes IdP), oddělené účty pro běžnou a administrátorskou práci, podepisování commitů, branch protection a povinný review. Nejsilnější kontrolou je ale to, že nasazuje výhradně identita pipeline — kompromitovaný vývojář může navrhnout kód, ale nemůže ho sám dostat do produkce.
SIEM a logy obsahují pseudonymizovaná finanční a osobní data. Dodavatel SIEM se stává zpracovatelem s přístupem k citlivé telemetrii a zároveň dalším kritickým dodavatelem.	Scrubbing PII a tajemství na OTel kolektoru, tedy dřív, než data opustí náš perimetr; do SIEM jdou pseudonymní identifikátory, nikdy jména, plné IBANy ani PAN. DPA, lokace zpracování v EU, záznam v registru informací s posouzením kritičnosti a exit plánem. Detekční pravidla v neutrálním formátu (Sigma) v našem repozitáři, aby migrace na jiný SIEM byla otázka týdnů.
Sandbox nebo investorské demo se začne chovat jako produkce — někdo do něj zadá reálná data nebo ho někdo prezentuje jako compliant systém.	Trvalý vizuální i textový disclaimer v sandboxu, technicky vynucené odmítnutí produkčních formátů dat (validátor, který odmítne skutečný IBAN nebo skutečné rodné číslo), oddělený účet bez cesty k produkčním datům, testnet místo mainnetu. V každém investorském materiálu explicitně odlišit dnešní simulaci od cílové architektury — audit na toto riziko výslovně upozorňuje.
Kompromitace npm ekosystému. Dnes 126 balíčků přímo z veřejného registru; jedna kompromitovaná verze v tranzitivní závislosti se dostane do buildu.	Registry proxy se sedmidenní karanténou nových verzí, ignore-scripts s explicitním allowlistem, pinované digesty base images, SBOM průběžně přehodnocovaný v Dependency-Track, Renovate s auto-merge jen pro patch-level dev závislosti po plné CI, a jmenovaný schvalovatel pro každou novou přímou závislost. Admission control jako poslední pojistka: nepodepsaný artefakt se nespustí bez ohledu na to, co je v něm.
Náklady utečou dřív, než přijde příjem. Compliance podlaha 25–40 tis. EUR měsíčně proti runwayi 24–33 měsíců je významná část rozpočtu.	Fázování podle F1/F2/F3 s tím, že drahé položky (CloudHSM ~2 100 USD, SIEM ~3 000 EUR, DR region ~600 USD, Shield Advanced 3 000 USD) se zapínají až s pojmenovaným spouštěčem, ne s kalendářem. Rozpočty per prostředím s alertem na 80 %, měsíční FinOps review, Savings Plans až po třech měsících stabilního baseline. Non-prod prostředí se v noci a o víkendech škálují na nulu, což u dev a test ušetří zhruba 60 % compute.
Jediný CloudHSM cluster nebo ztráta klíčového materiálu. Ztráta klíčů je jediná neobnovitelná ztráta v celé platformě — záloha databáze ji nezachrání.	Minimálně dva HSM moduly v clusteru napříč AZ. Recovery kit cold multisigu jako Shamir shares s kvorem 3 z 5 ve třech geograficky oddělených trezorech (Vilnius, Frankfurt, mateřská společnost), roční ceremonie s protokolem a skutečným ověřením, že shares fungují. MPC shares rozprostřené mezi různé cloudy a hardwarová prostředí, aby výpadek jednoho poskytovatele nezmrazil prostředky. Backup HSM karty s dual control a split knowledge.
Licenční změny u klíčových nástrojů (Terraform a Vault pod BUSL) mohou u regulované entity vyvolat právní i rozpočtové překvapení.	OpenTofu a OpenBao evidované jako otestované výstupní varianty, ne jako teoretická možnost — jednou ročně se ověří API kompatibilita na kopii stavu a konfigurace, s dokumentovaným výsledkem. Vyhýbat se funkcím, které jsou pouze v Enterprise variantách, dokud pro ně není zaplacený a rozpočtovaný důvod.
Detekční pravidla a alerty se nevyhladí, tým je přestane číst a SIEM se stane drahým archivem.	Metrika signal-to-noise jako čtvrtletně reportovaný ukazatel; každé pravidlo, které za kvartál vygenerovalo jen falešné popluchy, se buď opraví, nebo vypne s odůvodněním. Stránkuje se pouze na symptomy a na tvrdý seznam invariantů; příčinné alerty jsou tickety. Detekce jsou kód a prochází stejným review jako aplikace.
Prostředí se rozejdou. Staging přestane být parita produkce a testy v něm přestanou vypovídat.	Stejně Terraform moduly pro staging i produkci s jediným rozdílem v proměnných velikosti; Argo CD auto-sync se selfHeal v non-prod, takže drift se opraví sám; noční detekce driftu s alertem. Verze všech komponent (Kubernetes, Postgres, mesh, runtime) jsou v jednom souboru a staging je vždy na stejné nebo novější verzi než produkce, nikdy na starší.
Zálohy v jednom účtu a jedné doméně selhání proti ransomware nebo zlomyslnému insiderovi.	AWS Backup Vault Lock v režimu Compliance — jednou nastavená retence nejde zkrátit ani rootem účtu. Zálohy v odděleném účtu, ke kterému produkční role nemají mazací oprávnění. Druhá kopie u nezávislého poskytovatele s immutable politikou. Alert na jakýkoli pokus o změnu retenční politiky nebo o smazání snapshotu, stránkující okamžitě bez ohledu na denní dobu.

10. Klientské aplikace

Tenká nedůvěryhodná prezentační vrstva, která nesmí spočítat ani korunu.

Cílový klient je tenká, nedůvěryhodná prezentační vrstva nad serverem, který je jediným držitelem pravdy o penězích: klient nesmí spočítat zůstatek, spread ani poplatek, smí je jen zobrazit tak, jak je dostal, a kryptograficky potvrdit, že přesně tohle uživatel viděl. Veškerá hodnota, kterou klient přidává, leží ve třech věcech — v důkazu vlastnictví zařízení (klíč v StrongBoxu/Secure Enclave, který nikdy neopustí hardware), v dynamic linkingu podle RTS 2018/389 čl. 5 (podpis vázaný na částku a příjemce z odpovědi serveru, ne z formuláře) a v tom, že spolehlivě dojde platbu i když spojení spadne mezi podpisem a potvrzením. Tři platformy jsou tři samostatné implementace UI, ale jen jedna implementace kontraktu: OpenAPI schéma, ICU katalog tří jazyků, designové tokeny a zlaté formátovací vektory jsou sdílené artefakty, ne sdílený kód. Web není druhořadý kanál — pro cílovou klientelu v hyperinflační zemi s levným Androidem, malým úložištěm a drahými daty je to primární vstup, a proto je postavený jako instalovatelná PWA s úzkým, ale skutečným rozsahem operací. Dnešní React demo se nezahazuje: jeho i18n katalog, formátovací pravidla, designové tokeny a jedenáct obrazovek jsou zadání a testovací vektory pro nativní tým a přímý základ webového klienta, zatímco jeho stavová vrstva (700 řádků klientské peněžní logiky v localStorage) se stane referenční specifikací pro backend a v klientovi zanikne.

10.1 Komponenty

Celkem 17 komponent, seřazené podle fáze. Štítek vpravo říká, **kdy se komponenta staví**, ne pořadí v seznamu: **Fáze 1** = staví se hned, přežije každé budoucí rozhodnutí · **Fáze 2** = až po rozhodnutí o licenci · **Fáze 3** = až před ostrým provozem.

Kontraktní balík (@largo/contract)

Fáze 1

Jediný zdroj pravdy sdílený všemi třemi klienty: OpenAPI 3.1 schéma API, JSON schéma podepsané produktové konfigurace, číselník chybových kódů, číselník stavů platby a zlaté testovací vektory formátování (hodnota × měna × jazyk → očekávaný řetězec). Negeneruje UI ani logiku, generuje typy a testy.

Technologie: OpenAPI 3.1, JSON Schema, Spectral lint v CI, Style Dictionary pro tokeny · **Rozhraní:** Git tag + npm/SPM/Maven artefakt; generátory: openapi-typescript pro web, OpenAPI Generator (Swift, Kotlin) pro nativní; vektory jako JSON, které spouští testy na všech třech platformách.

Lokalizační katalog (@largo/i18n)

Fáze 1

CS/EN/ES texty v ICU MessageFormat s plurály a select formami, klíče jako jediná identita, žádný tichý fallback mezi jazyky. Přebírá 284 hotových klíčů z dnešního src/i18n/{cs,en,es}.ts a doplňuje plurálové kategorie, které dnešní řešení neumí vůbec (čeština má one/few/many/other).

Technologie: ICU MessageFormat, Lokalise/Crowdin, formatjs (web), stringsdict (iOS), Android plurals · **Rozhraní:** XLIFF/ARB export do překladatelského nástroje, build-time kompilace do .strings (iOS), strings.xml (Android) a runtime katalogu (web); CI selže při chybějícím klíči v kterémkoli jazyce.

Formátovací a parsovací vrstva částek

Fáze 1

Zobrazení a čtení částek podle locale a podle měny, s peněžními hodnotami držených výhradně jako celá čísla v minor units. Řeší dnešní chybu v src/screens/Payments.tsx:171 — Number(amount.replace(',','')) na vstupu '1.234,56' ve španělštině vrátí 1.234, tedy platbu o tři řády menší, než uživatel zadal.

Technologie: Intl.NumberFormat (web), NumberFormatter (iOS), NumberFormat + BigDecimal (Android); nikdy style:'currency' — XSGD/USDC nejsou ISO 4217 a CLDR pro ně nedá konzistentní výsledek · **Rozhraní:** format(minorUnits, currency, lang) → String; parse(text, currency, lang) → minorUnits | ParseError. Chování je definované zlatými vektory v kontraktním balíku, ne implementací.

Designové tokeny a UI kit

Fáze 1

Barvy, typografie, poloměry, odstupy a stavy komponent v jednom zdroji, generované do tří cílů. Součástí je kontrastní audit — dnešní `src/styles/tokens.css` nebyl proti WCAG kontrolován a tlumený text na světlém pozadí typicky nedosahuje 4,5:1.

Technologie: Style Dictionary, Figma Tokens (až bude přístup k souboru — dnes máme jen prototypové odkazy) · **Rozhraní:** `tokens.json` → CSS custom properties, Swift Color extension, Compose LargoTheme; vizuální regresní snapshoty na všech třech platformách

Webový klient (PWA)

Fáze 1

Plnohodnotný přehled, historie, výpisy, správa karet bez zvýšení limitů, tuzemské platby na známé příjemce, směna do limitu. Instalovatelná, offline read-only. Primární kanál pro cílovou zemi, kde je stažení nativní aplikace ze storu drahé nebo nedostupné. Přímé pokračování dnešního React kódu.

Technologie: React 18 + TypeScript + Vite 6 (dnešní stack), TanStack Query, React Router s reálnými URL místo MemoryRouter, WebAuthn/passkeys · **Rozhraní:** REST/JSON přes fetch s DPoP hlavičkou; WebAuthn pro device binding a podpis; service worker jen pro app shell a read cache, nikdy pro API odpovědi s částkami

Stavová a synchronizační vrstva

Fáze 1

Server-authoritative cache. Klient nikdy nemodifikuje read model lokálně — nemá optimistický zápis zůstatku. Delta synchronizace kurzorem, každá zobrazená hodnota nese značku `asOf`, kterou UI ukáže, jakmile je starší než 60 sekund bez spojení.

Technologie: TanStack Query (web), Repository + Flow nad Room (Android), Observation + GRDB (iOS) · **Rozhraní:** GET `/ledger/entries?since=<cursor>` → {entries, cursor, hasMore}; ETag na kolekce; SSE nebo push pro invalidaci

Přístupnostní vrstva (EAA)

Fáze 1

Zajišťuje soulad se směrnicí (EU) 2019/882 přes EN 301 549 v3.2.1 / WCAG 2.2 AA. Musí být zabudována od první obrazovky, ne dolepena — zejména proto, že se přímo sráží s bezpečnostními opatřeními (randomizovaná PIN klávesnice vs. screen reader, blokáce accessibility služeb vs. nevidomí uživatelé, 5minutový timeout vs. WCAG 2.2.1).

Technologie: axe-core v CI (web), Espresso Accessibility Checks + Accessibility Scanner (Android), XCUITest performAccessibilityAudit() (iOS), plus jeden externí audit s reálnými uživateli před vydáním · **Rozhraní:** Sémantika komponent v UI kitu (role, label, hint, live region); povinný Prohlášení o přístupnosti + kanál zpětné vazby v profilu

Nativní iOS klient

Fáze 2

Plný rozsah operací včetně těch, které web nesmí: onboarding a device binding, zvýšení limitů karty, výběr kryptoaktiva na novou adresu, přidání příjemce nad denní limit, změna bezpečnostních nastavení.

Technologie: Swift 6, SwiftUI (UIKit tam, kde SwiftUI nedává kontrolu nad překryvy), deployment target iOS 16 · **Rozhraní:** Volá API přes SecurityKit (pinning, App Attest assertion); podpis transakcí přes klíč v Secure Enclave

Nativní Android klient

Fáze 2

Totéž co iOS klient, plus nese největší část bezpečnostní práce, protože Android je platforma, kde reálné bankovní trojany žijí (overlay, accessibility abuse, root).

Technologie: Kotlin 2.x, Jetpack Compose, single-activity, minSdk 29 (Android 10), targetSdk aktuální · **Rozhraní:** Volá API přes SecurityKit (pinning, Play Integrity token); podpis přes klíč v StrongBoxu s fallbackem na TEE

SecurityKit — nativní bezpečnostní modul

Fáze 2

Device binding, generování a životní cyklus klíčů, vzdálená atestace, certificate pinning, detekce rootu/jailbreaku, detekce hookovacích frameworků a emulátoru, detekce překrytí a accessibility služeb, ochrana obrazovky. Sbírá signály a posílá je na server jako skóre; nikdy sám nerozhoduje o povolení operace.

Technologie: iOS: Secure Enclave, App Attest, DeviceCheck, ptrace(PT_DENY_ATTACH), dyld image scan. Android: KeyGenParameterSpec se setIsStrongBoxBacked, Key Attestation, Play Integrity API, kontroly v C/C++ přes JNI (ne v Kotlinu, ten se

patchuje triviálně) · **Rozhraní:** Interní API pro aplikaci: `bind()`, `sign(displayBlock)`, `integritySignals()`, `pinnedSession()`; ven jen hlavičky X-Device-Attestation a X-Device-Signals

Podpisová vrstva a dynamic linking

Fáze 2

Realizuje RTS 2018/389 čl. 5: podepisuje kanonický `displayBlock`, který server vydal pro konkrétní intent a který je 1:1 vykreslen na potvrzovací obrazovce. Tím se odstraňuje klasické WYSIWYS selhání 'zobrazím A, podepíšu B'.

Technologie: Android `BiometricPrompt` s `CryptoObject` nad klíčem s `setUserAuthenticationParameters(0, AUTH_BIOMETRIC_STRONG)` a `setInvalidatedByBiometricEnrollment(true)`; iOS `SecKeyCreateSignature` nad `SecAccessControl.biometryCurrentSet`; web `WebAuthn` s `challenge = SHA-256(displayBlock)` · **Rozhraní:** `POST /payments/intents` → `{intentId, displayBlock, challengeExpiresAt}`; podpis = ECDSA P-256 nad `SHA-256(displayBlock)`; `POST /payments/{id}/confirm` se `signature + keyId + attestation assertion`

Síťová vrstva a idempotence

Fáze 2

Jediná cesta ven z aplikace. Drží pinovanou TLS relaci, přidává atestační a DPoP hlavičky, generuje a perzistuje `Idempotency-Key` ještě před odesláním, implementuje backoff a — což je důležitější než retry — přechod na stavový dotaz, když odpověď nedorazí.

Technologie: `URLSession` + vlastní `URLSessionDelegate` (iOS), `OkHttp` + `CertificatePinner` (Android), `fetch` + `Network Security Config` ekvivalent na serveru (web) · **Rozhraní:** `Idempotency-Key`: `UUIDv7` zapsaný do lokální šifrované DB před prvním pokusem; `Retry-After` respektován; 426 `Upgrade Required` vede na obrazovku vynucené aktualizace

Šifrované lokální úložiště

Fáze 2

Odděluje tři třídy dat: autentizační materiál (nikdy na disk v čitelné podobě), transakční cache (šifrovaná, mazatelná), preference (nešifrované, bez osobních údajů). Řeší i to, co se dnes dělá špatně — `zustand` persist ukládá celý stav včetně zůstatků a KYC do `localStorage`.

Technologie: iOS: `Keychain` s `kSecAttrAccessibleWhenUnlockedThisDeviceOnly` + `SQLite` s `NSFileProtectionComplete` a `isExcludedFromBackup`. Android: `EncryptedSharedPreferences` + `Room` se `SQLCipher`, klíč z `Keystore`, `allowBackup=false` a prázdná `dataExtractionRules`. Web: `access token` jen v paměti modulu, `refresh` v `__Host-HttpOnly Secure` ... · **Rozhraní:** `secureStore.put/get/wipe()`; `wipe()` se volá při `logoutu`, změně biometrického zápisu, selhání atestace a při reinstalaci

Podepsaná runtime konfigurace (pins, tarify, verze, killswitch)

Fáze 2

Umožňuje měnit `certificate piny`, minimální verzi klienta, sazebník, seznam podporovaných měn a `stablecoinů` a zapnout/vypnout funkce bez vydání nové verze. Přímou odpovídá požadavku, že volba tokenu a jurisdikce je konfigurace, ne konstanta — dnes je v `src/domain/types.ts` zabezpečena jako `STABLECOINS = ['XSGD', 'USDT']`.

Technologie: `Ed25519 detached signature`, bootstrap konfigurace zabezpečena v buildu jako záchrana při prázdné cache · **Rozhraní:** `GET /config` → JSON podepsaný `Ed25519` klíčem, jehož veřejná část je v binárce; `pole version` je monotónní (anti-rollback), `notBefore/notAfter` povinné; cache v šifrované DB

Orchestrátor platebního toku

Fáze 2

Stavový automat platby na klientovi: `draft` → `intent` → `potvrzení` → `podpis` → `confirm` → sledování stavu. Drží `pendingConfirm` záznamy a při studeném startu je odsmiřuje proti serveru. Jediné místo, kde je popsáno, co se smí opakovat a co ne.

Technologie: Explicitní FSM (`XState` na webu, `sealed class / enum` s přechody nativně), nikdy ad-hoc `booleany` v komponentě · **Rozhraní:** `Stavy`: `draft`, `intentCreated`, `awaitingUser`, `signed`, `confirmSent`, `processing`, `settled`, `rejected`, `expired`, `unknownNeedsReconcile`

Telemetrie bezpečnostních událostí

Fáze 2

Posílá serveru signály, které `fraud engine` potřebuje k rozhodnutí podle RTS čl. 2 a 18: verdikt atestace, `root/hook skóre`, aktivní nahrávání obrazovky, neznámá `accessibility` služba, změna biometrického zápisu, reinstalace, nové zařízení, úroveň `hardwaru klíče` (`StrongBox` vs. `TEE`). Neobsahuje osobní ani autentizační údaje.

Technologie: Vlastní endpoint, nikdy třetí strana; `crash reporting` (`Sentry`) se `scrubbingem` a bez `breadcrumb` z platebních obrazovek · **Rozhraní:** Batchované `POST /telemetry/security` a inline hlavička `X-Device-Signals` u operací s finančním dopadem

Klientská CI/CD a odolnostní pipeline

Fáze 3

Reprodukovatelné buildy, obfuskace, SBOM, SCA sken s blokující politikou, mapování MASTG testů na CI joby, podpis a distribuce, správa store review cyklů. Nese i ohlašovací povinnost CRA, která pro aktivně zneužívané zranitelnosti platí od 11. 9. 2026.

Technologie: R8/ProGuard s pravidly na odstranění log volání, strip symbolů a žádný DWARF v iOS release, Trivy/Snyk, fastlane, Gradle Managed Devices pro matici zařízení · **Rozhraní:** Artefakty: SBOM (CycloneDX) na každé vydání, mapa požadavek → MASTG-TEST-xxxx → výsledek, retence pro auditora

10.2 Architektonická rozhodnutí

Formát ADR: co se zvolilo, proč, a co to zavazuje do budoucna — včetně nevýhod, které tým kupujeme.

Rozhodnutí	Volba a důvod	Důsledek
ADR-C1: Nativní iOS + nativní Android + samostatný web, nikoli jedna multiplatformní codebase Zvažováno: Kotlin Multiplatform byla nejvážnější alternativa a je nejméně špatná — sdílí doménu, nikoli UI, a bezpečnostní vrstva zůstává nativní. Prohrála na náboru (tým 14–25 lidí najde Swift a Kotlin ...	Swift/SwiftUI, Kotlin/Compose a React/TypeScript jako tři samostatné aplikace. Sdílí se kontrakt (OpenAPI, ICU katalog, designové tokeny, zlaté vektory), nikoli běhový kód. Ze 33 klientských požadavků je osm nejtvrdějších — device binding (RTS čl. 7), biometrie s kryptografickou vazbou (čl. 8), StrongBox/Secure Enclave, root detekce a atestace (čl. 9(3)), anti-hook, ochrana obrazovky, overlay — čistě nativní API. V React Native i Flutteru se všechny dělají nativními moduly, takže Swift a Kotlin píšete tak jako tak, jen s mostem navíc a s vlastní útočnou plochou. Flutter má navíc vlastní ...	Dvojnásobek UI práce a dvě QA matice — podle vlastního auditu 350–450 MD místo optimistických 190. Každá nová obrazovka se dělá třikrát, každý regulační text se ověřuje třikrát. Zavazuje k udržování kontraktního balíku jako skutečné brány (nesmí existovat endpoint, který zná jen jedna platforma) a k disciplíně, že rozdíl mezi platformami je vždy vědomé rozhodnutí zapsané v ...
ADR-C2: Server je jediná autorita nad penězi; klient nepočítá ani jednu peněžní hodnotu Zvažováno: Ponechat výpočet na klientovi a na serveru ho jen ověřit (server-side validation) — zamítnuto, protože pak existují dvě implementace sazebníku, které se rozejdou, a klient bude uživateli tvrdit ...	Klient nesmí spočítat zůstatek, kurz, spread, poplatek ani výsledek směny. Všechny tyto hodnoty přicházejí ze serveru jako hotová čísla se svojí měnou a se svým popisem. Klient je zobrazí a podepíše. Dnešní store (src/store/useApp.ts) dělá pravý opak: exchangeAny počítá spread a poplatek, vaultMove přepočítává kurz při vkladu z jiné měny, pay ověřuje krytí. To je pro demo správně a pro produkt neobhajitelné — klientský kód je plně pod kontrolou útočníka a nesmí být vstupem do žádného finančního rozhodnutí. Zároveň je to jediný způsob, jak dostat dynamic linking podle RTS čl. 5 doopravdy: podepisovaná částka musí ...	Každá obrazovka, která dnes reaguje okamžitě, potřebuje síťové kolo — vybráním měny ve směně se volá /quotes, změnou částky se volá /quotes znovu (debounced na 400 ms). To je horší UX a v Caracasu na pomalé síti citelně horší. Kompenzuje se tím, že se u zadávání zobrazuje indikativní odhad z posledního quote a viditelným popisem 'orientační', a závazné číslo se dorovná v ...
ADR-C3: Peníze jako celá čísla v minor units, nikdy jako float Zvažováno: Decimal (Swift Decimal, Java BigDecimal, decimal.js) — správně, ale na webu přidává závislost a stejně se serializuje jako řetězec; navíc svádí k tomu, že se na klientovi zase začne počítat. Celé ...	Peněžní hodnota se v celém klientovi přenáší, ukládá a porovnává jako celé číslo v nejmenší jednotce měny plus kód měny plus exponent (CZK 3712964 / exp 2, VES 4500 / exp 0, XSGD 12500000 / exp 4). Na float se převádí až v okamžiku formátování, a to jen na výstup. Dnešní kód používá number a pomocnou funkci round(n, decimals), která opakovaně opravuje binární chyby. V demu to nikoho nezabolí; v ledgeru regulované instituce je rozdíl haléře mezi tím, co ukázal klient, a tím, co zaúčtoval server, nález při rekonsiliaci a v horším případě podepsaná částka, která neodpovídá zaúčtované. Navíc XSGD má čtyři desetinná místa a VES nula — jeden globální round(x, 2) je pro obě špatně.	Zavazuje k tomu, že exponent měny je součástí konfigurace ze serveru, ne konstanta v kódu (VES může být redenominována, nový stablecoin může mít šest desetinných míst). Znamená to vlastní typ Money na všech třech platformách a zákaz aritmetiky nad ním kdekoli jinde než v testech. Vstupní pole musí pracovat nad řetězcem čísla a exponentem, ne nad Double.

Rozhodnutí	Volba a důvod	Důsledek
ADR-C4: Offline je read-only; platba se offline nezadáva ani nefrontuje Zvažováno: Offline fronta s podpisem nad lokálně známými údaji — zamítnuto jako přímý nesoulad s RTS čl. 5 a jako kurzové riziko. Offline potvrzování přes SMS/USSD kanál — reálná varianta pro cílový trh, ale je ...	Bez spojení se zobrazí poslední načtená data s viditelnou značkou 'aktuální k HH:MM' a tlumeným rámečkem. Platební a směnné obrazovky se nedají otevřít, zobrazí se stav 'bez připojení' s vysvětlením. Neexistuje fronta 'odešli, až budeš online'. Bez spojení nelze získat intent, nelze získat displayBlock a nelze získat platnou quote. Podpis vytvořený offline by byl vázán na kurz a sazebník, které v okamžiku odeslání už neplatí, a nesplnil by dynamic linking. Fronta odložených plateb je navíc v hyperinflační měně přímo nebezpečná — kurz VES se mezi zadáním a odesláním pohne měřitelně.	Uživatel ve slabé síti nemůže platbu 'připravit dopředu'. Kompenzuje se rychlostí: intent se vytváří až po potvrzovacím tlačítku, ne při otevření formuláře, takže síť je potřeba jen v posledních dvou krocích, a šablony příjemců jsou lokálně cachované, takže se offline dá formulář alespoň vyplnit do draftu. Zavazuje k tomu, že draft je čistě lokální a nikdy se nestane platbou ...
ADR-C5: Dynamic linking přes serverem vydaný displayBlock, který se vykresluje 1:1 Zvažováno: Klient sestaví text sám z polí odpovědi — zamítnuto, protože pak je formát textu klientský a útočník s kontrolou nad klientem podepíše jinou strukturu, než jakou server očekává. Podepsat jen ...	Server pro každý intent vydá displayBlock — kanonický UTF-8 text se strukturovanými řádky (částka k odepsání, částka k připsání, kurz, sazba, poplatek, jméno příjemce, maskovaný IBAN, symboly, intentId, nonce, platnost). Klient tento blok vykreslí na potvrzovací obrazovku doslova a podepíše SHA-256(displayBlock). Nesmí zobrazit nic ze ... RTS čl. 5(1) žádá, aby byl autentizační kód kryptograficky specifický pro částku a příjemce, a čl. 5(2) žádá integritu a důvěrnost zobrazovaných údajů. Nejčastější reálné selhání je 'zobrazím text A, podepíšu hash B' — displayBlock ho odstraňuje konstrukčně, protože zobrazený text a podepsaný vstup jsou tatáž bajtová sekvence. Sekundární efekt: server ví přesně, co uživatel viděl, což je při reklamaci jediný důkaz, ...	Potvrzovací obrazovka nesmí být svobodná v layoutu — pořadí a znění řádků určuje server. Změna v prezentaci potvrzení je změna backendu, ne frontendu, a musí projít verzováním displayBlock formátu. Lokalizace displayBlocku je na serveru, takže server musí znát jazyk uživatele (proto je jazyk vlastnost účtu, ne lokální nastavení). Klient smí přidat vizuální rámování a ikony, ...
ADR-C6: Idempotence a stavový dotaz místo slepého retry Zvažováno: Spolehnout se na to, že uživatel platbu najde v historii — zamítnuto, protože historie se aktualizuje asynchronně a uživatel v nejistotě platbu zopakuje ručně. At-most-once bez idempotence (nikdy ...	Idempotency-Key (UUIDv7) se generuje a zapisuje do šifrované lokální DB PŘED prvním odesláním confirm. Při jakékoli nejistotě (timeout, ztráta spojení, zabití aplikace) se neopakuje confirm, ale volá se GET /payments/intents/{id}, jehož odpověď je autoritativní. Server drží idempotenci minimálně 24 hodin. Ztráta spojení mezi podpisem a odpovědí je jediný okamžik celého toku, kdy klient nemůže vědět, jestli peníze odešly. Slepý retry je nejhorší možná reakce — v kombinaci s částečně zpracovaným requestem vede k duplicitní platbě, a to je pro klienta v hyperinflační zemi, který posílá rodně měsíční příjem, existenční problém. Stavový dotaz převádí neurčitost na jednu ze čtyř známých odpovědí.	Zavazuje backend k tomu, že intent má dotazovatelný stav po celou dobu své existence a že idempotency okno je delší než nejhorší reálný výpadek uživatele. Klient musí mít při studeném startu odsmiřovací krok, který projde pendingConfirm záznamy dřív, než pustí uživatele na dashboard — a musí mít UI pro stav 'čeká na potvrzení stavu', což je obrazovka, na kterou se v plánech ...
ADR-C7: Certificate pinning na SPKI se dvěma piny, rotací s 90denním předstihem a nezávislým záchranným kanálem Zvažováno: Nepinovat vůbec a spolehnout se na systémový trust store — zamítnuto, protože firemní MDM i malware instalující root CA jsou reálný a běžný vektor a absence pinningu je u banky standardní závažný ...	Pinuje se SHA-256 hash SPKI (ne certifikátu) — vždy dva piny: aktivní klíč a záložní klíč držený offline v HSM, který nikdy nebyl použit. Pin set přichází v podepsané konfiguraci s notBefore/notAfter a monotónní verzí; v binárce je bootstrap pin set s platností 12 měsíců. Navíc existuje rescue endpoint na jiné doméně, s jinou CA a ... Pinning bez rotační strategie je nejistější způsob, jak si vypnout celou instalovanou bázi. Pinování celého certifikátu vyřadí aplikaci při každé obnově; pinování bez záložního klíče vyřadí ji při každé výměně klíče; pinning bez záchranného kanálu znamená, že jediná cesta z chybné rotace je vynucený update ze storu, tedy dva až sedm dní úplného výpadku plateb — a to je incident hlásitelný podle DORA.	Rotační postup je provozní procedura, ne úkol vývojáře: nový klíč se do pins.json přidá minimálně 90 dní před nasazením certifikátu; přepnutí certifikátu se provede až když telemetrie ukazuje pokrytí nové verze konfigurace nad 99,5 %; starý pin se odstraní po dalších 90 dnech. To znamená, že plánování certifikátů má horizont šest měsíců a nedá se to udělat 'rychle'. Rescue ...

Rozhodnutí	Volba a důvod	Důsledek
ADR-C8: Root a jailbreak jako riziková veličina se stupňovanou odpovědí, nikdy jako binární zavření aplikace Zvažováno: Tvrdé zablokování na rootnutém zařízení — zamítnuto (viz výše, a navíc generuje supportní zátěž bez bezpečnostního přínosu). Ignorovat root a spolehnout se jen na serverovou autorizaci — zamítnuto ...	Klient sbírá desítky nezávislých signálů a posílá je jako skóre; verdikt vydává server. Politika: MEETS_STRONG_INTEGRITY nebo MEETS_DEVICE_INTEGRITY → plné limity; MEETS_BASIC_INTEGRITY → read-only plus platby do nízkého limitu na dříve použité příjemce; žádná integrita → read-only bez plateb a nabídka webového klienta. Reakce je vždy ... RTS čl. 9(3)(c) žádá mitigaci, ne zablokování. 'Zavři aplikaci při detekci' útočníkovi přesně ukáže, kterou kontrolu patchovat, a legitimních uživatelů s rootnutým zařízením je nezanedbatelné množství — v cílové zemi s levnými telefony a šedým trhem podstatně víc než v ČR. Vyhodnocení musí být na serveru, protože klientský boolean se přepíše jedním Frida skriptem.	Vyžaduje fraud engine schopný přijmout a vážit signály, tedy závislost na backendu, kterou nelze obejít. Vyžaduje také definovanou degradační politiku pro výpadek Play Integrity (rate limity jsou reálné): cachovaný verdikt platí 15 minut, při nedostupnosti Google API se použije poslední známý verdikt po dobu 24 hodin a operace nad limit se odloží — nikdy hard fail, který by ...
ADR-C9: Ochrana obrazovky globálně na Androidu, kompenzačně na iOS, s nahrazením ztracené funkce Zvažováno: Selektivní FLAG_SECURE jen na obrazovkách se zůstatky — zamítnuto, protože seznam citlivých obrazovek se v čase rozpadá a jednou se na novou obrazovku zapomene. Nedělat nic na iOS — zamítnuto, ...	Android: FLAG_SECURE na celé přihlášené Activity, nastavené v onCreate a nikdy nevytápné; Window.setHideOverlayWindows(true) na potvrzovací obrazovce; od API 35 registerScreenCaptureCallback → při aktivním nahrávání se zůstatky zakryjí a potvrzení platby se zablokuje úplně. iOS: překryv na sceneWillResignActive (jinak zůstane zůstatek v ... Nejrozšířenější reálný scénář podvodu na cílové klientele je vishing se sdílením obrazovky: útočník uživatele přiměje spustit screen sharing a přečte si zůstatky, čísla účtů i potvrzovací údaje. FLAG_SECURE na část okna aplikovat nelze, takže selektivní nasazení znamená, že vždy někde zůstane díra. iOS veřejné API pro blokaci screenshotu nemá — tam se dá jen detekovat a reagovat.	Uživatel si nemůže udělat screenshot výpisu, což je funkce, kterou lidé reálně používají (posílají potvrzení rodině). Bez náhrady to generuje stížnosti a obcházení přes druhý telefon. Proto je 'Sdílet potvrzení' jako serverem podepsané PDF povinná součást dodávky, ne nice-to-have. FLAG_SECURE lze na rootnutém zařízení obejít (DisableFlagSecure modul), takže se to musí ...
ADR-C10: Ochrana proti překrytí a zneužití accessibility bez vyřazení uživatelů s postižením Zvažováno: Zablokovat platbu při jakékoli aktivní accessibility službě — jednodušší, běžné v praxi, a v EU po EAA neudržitelné. Spoléhat jen na FLAG_WINDOW_IS_OBSCURED bez whitelistu — nechyť accessibility ...	setFilterTouchesWhenObscured(true) na potvrzovací tlačítko a na PIN pad — zakrytý dotek se zahodí a zobrazí se vysvětlení. Accessibility služby se nezakazují: udržuje se whitelist známých legitimních služeb podle package a podpisového certifikátu (TalkBack, Switch Access, Voice Access, komerční čtečky); neznámá služba s právem čist obsah ... Overlay plus accessibility abuse je hlavní vektor bankovních trojanů na Androidu — falešný překryv sebere PIN a accessibility služba platbu sama potvrdí. Zároveň je bez accessibility služby aplikace pro nevidomého uživatele nepoužitelná, a plošné blokování by bylo přímé porušení směrnice (EU) 2019/882, která je pro bankovní služby závazná od 28. 6. 2025. Tenhle konflikt je reálný a musí být rozhodnut vědomě, ne ...	Whitelist je živý artefakt, který někdo musí udržovat (nové čtečky, nové verze, změny podpisů), a jeho zastarání se projeví jako step-up u uživatele, který za nic nemůže. Proto musí být whitelist součástí podepsané runtime konfigurace, ne binárky, a musí existovat rychlá cesta, jak do něj službu doplnit. Navazující rozhodnutí: randomizovaná PIN klávesnice se nabízí pouze ...
ADR-C11: Web je plnohodnotný kanál s úzkým rozsahem operací, ne mobilní aplikace v prohlížeči Zvažováno: Web jen jako marketing a read-only přehled — zamítnuto, protože zahazuje primární kanál cílového trhu. Web s plným rozsahem — zamítnuto, protože by se rizikový profil celé instituce srovnal s ...	Web umí: přehled, historii, výpisy, tuzemské platby na dříve použité příjemce do denního limitu, směnu do limitu, zamknutí karty. Neumí: první registraci a device binding, zvýšení limitů, výběr kryptoaktiva na novou adresu, přidání nového příjemce nad limit, změnu bezpečnostních nastavení. Device binding a podpis přes WebAuthn s ... Na webu neexistuje ekvivalent App Attest ani Play Integrity, DOM je pro XSS otevřený a WYSIWYS je proto strukturálně slabší — útočník s XSS může přepsat zobrazený displayBlock, i když nemůže podepsat jiný. Zároveň je web pro cílovou klientelu důležitější než v ČR: levný Android s plným úložištěm, drahá data a nedostupný nebo nepoužitelný obchod s aplikacemi jsou v Caracasu běžná realita, takže 'stáhněte si appku' ...	Rozsah operací se stává součástí konfigurace a musí být vynucen serverem podle typu klienta (X-Client hlavička je jen indikace, autorita je vázaná na typ přihlašovacího prostředku). Znamená to, že některé úkony uživatel prostě nemůže udělat bez telefonu, a to musí být v UI vysvětleno předem, ne až po vyplnění formuláře. Zavazuje k PCI DSS 4.0.1 req. 6.4.3 a 11.6.1, pokud se na ...

Rozhodnutí	Volba a důvod	Důsledek
ADR-C12: Dvouúrovňové vynucení verze klienta — jiný práh pro čtení a jiný pro platby Zvažováno: OTA aktualizace obcházející store (CodePush) — zamítnuto v ADR-C1 z bezpečnostních důvodů. Jeden práh — zamítnuto výše. Žádné vynucení a spolehnutí na automatické aktualizace — zamítnuto, protože ...	Server vrací dvě minimální verze: minVersion (pod ní aplikace nefunguje vůbec) a minPaymentVersion (pod ní jde jen číst). Klient posílá X-Client: ios/2.14.3 (build 4412); server odmítá per-endpoint s 426 Upgrade Required a strukturovaným lokalizovaným tělem. Android: In-App Updates v režimu IMMEDIATE; iOS: blokující obrazovka s odkazem ... Bez vynucení zůstávají zranitelné verze v terénu roky a mitigace podle RTS čl. 9(3)(c) je nedoložitelná. Jednouúrovňové vynucení je ale příliš tvrdé — vyhodit uživatele z aplikace kvůli změně v platebním toku znamená, že si nemůže ani zkontrolovat zůstatek, což generuje panické volání na support. Dva prahy oddělují 'tuhle verzi už nechceme pouštět k penězům' od 'tuhle verzi vypínáme'.	minSdkVersion 29 a iOS deployment target 16 na startu; v roce 2027 zvednout Android na 31 kvůli setHiddenWindows a lepšímu pokrytí StrongBoxu — každé zvednutí odrážne část cílové báze, což je u trhu s levnými telefony citelnější než v EU, a musí to být rozhodnutí s daty o instalované bázi. iOS vynucený update systémově neexistuje, takže blokující obrazovka je jediná páka ...
ADR-C13: Přístupnost podle EAA se řeší v UI kitu a v CI, ne jako revize před vydáním Zvažováno: Externí audit jednou ročně bez CI kontrol — zamítnuto, protože nálezy přijdou po vydání a opravují se v panice. Cílit jen na WCAG 2.1 AA (což EN 301 549 dnes vyžaduje) — zamítnuto, protože 2.2 ...	Cílem je WCAG 2.2 AA přes EN 301 549 v3.2.1 jako technická presumpce shody se směrnicí (EU) 2019/882. Sémantika (role, popisky, hinty, live regions) je vlastností komponent v UI kitu, takže obrazovka ji dostane zdarma. V CI běží axe-core (web), Espresso Accessibility Checks (Android) a XCUITest performAccessibilityAudit (iOS) jako ... EAA je pro bankovní služby pro spotřebitele závazná od 28. 6. 2025, tedy dřív, než tenhle produkt vůbec vznikne — nejde o budoucí povinnost, jde o vstupní podmínku. Dolepovat přístupnost po dokončení UI je nejdražší možná cesta a u finanční aplikace se to projeví jako přepis komponent, ne jako doplnění atributů.	Konkrétní dopady, které mění návrh: částky nesmí být v pevných jednotkách, protože rozhraní musí být použitelné při 200% zvětšení textu (test na Largest Accessibility Size je součástí definice hotovéhoho); cílová velikost dotyku minimálně 24x24 CSS px podle WCAG 2.2, prakticky 44x44; přeskládání aktiv, které je dnes v src/components/ReorderList.tsx čistě ukazovací gesto, musí ...
ADR-C14: Dnešní React kód pokračuje jako webový klient a jako zadání pro nativní tým; stavová vrstva se nepřenáší Zvažováno: Začít web od nuly na Next.js kvůli SSR a lepšímu SEO — zamítnuto, protože přihlášená část se stejně nerenderuje na serveru, přidalo by to serverovou vrstvu s přístupem k session a zahodilo by hotový ...	Přenáší se: i18n katalog (284 klíčů × 3 jazyky), formátovací pravidla ze src/lib/format.ts jako specifikace plus zlaté vektory, designové tokeny ze src/styles/tokens.css, komponentní kit ze src/components/ui.tsx a jedenáct obrazovek jako běžící referenční prototyp. Nepřenáší se: src/store/useApp.ts, zustand persist do localStorage, float ... Nejcennější věc v repozitáři nejsou obrazovky, ale tři kompletní jazykové sady a rozhodnutá pravidla zobrazení částek — kód měny za číslem, per-měnová desetinná místa, VES na nula míst. To jsou desítky rozhodnutí, která by se jinak dělala znovu a v každé platformě jinak. Naopak stavová vrstva je přesně ta část, kterou ADR-C2 zakazuje: 700 řádků, kde klient rozhoduje o penězích, a persist, který ukládá zůstatky a KYC ...	Referenční prototyp musí zůstat spustitelný a musí být jasně označen jako simulace, jinak se z něj stane zdroj nedorozumění ('vždyť to takhle funguje'). Zavazuje k tomu, že se nejdřív udělá migrace i18n na ICU (dnešní translate() dělá jen replaceAll nad {placeholders} a plurály neumí vůbec) a že se opraví konkrétní věci, které se jinak přenesou i do produktu: locale-aware ...

10.3 Klíčové toky

Platba s dynamic linkingem — šťastná cesta

1. Uživatel otevře formulář, vybere zdrojový účet, vyplní příjemce (tuzemsky číslo účtu a VS/KS/SS, zahraničně IBAN a SWIFT, u P2P kontakt) a částku; klient validuje jen formát — mod-97 nad IBAN, délky symbolů podle konvence ČNB, částku parsuje podle locale do minor units.
2. Klient si průběžně tahá orientační quote (debounce 400 ms) a zobrazuje odhad poplatku a kurzu s viditelným popiskem 'orientační'; závazné číslo ještě neexistuje.
3. Uživatel klepne na Pokračovat; teprve teď klient volá POST /payments/intents s Idempotency-Key, atestačním tokenem a podpisem device-bound klíčem (DPOp).
4. Server vytvoří intent, zamkne kurz, spočítá poplatek podle sazebníku (hyperinflační vs. standardní podle toho, jestli je některá strana v hyperinflaci) a vrátí intentId, displayBlock, challenge a časy platnosti kurzu a challenge.

- 5 Klient vykreslí potvrzovací obrazovku výhradně z `displayBlocku`, doslova a v pořadí, které určil server; nad ním běží odpočet platnosti kurzu.
- 6 Uživatel vidí a potvrzuje: částku k odepsání ve zdrojové měně, částku k připsání v cílové měně, použitý kurz, výši spreadu a název sazby, poplatek jako samostatný řádek, jméno příjemce a maskovaný IBAN, symboly, poznámku a čas, do kdy kurz platí. Pokud se cokoli liší od zadání, server to označí a UI to zvýrazní.
- 7 Potvrzovací tlačítko má `setFilterTouchesWhenObscured(true)`; pokud je okno překryté, dotek se zahodí a zobrazí se vysvětlení. Při aktivním nahrávání obrazovky se potvrzení nepovolí vůbec.
- 8 Klient vyžádá biometrii vázanou na klíč — Android `BiometricPrompt` s `CryptoObject` nad klíčem ve `StrongBoxu`, iOS `SecKeyCreateSignature` nad `Secure Enclave` klíčem s `.biometryCurrentSet`. Výsledek callbacku se nepoužívá jako rozhodnutí; rozhodnutím je až existence podpisu.
- 9 Podepíše se `SHA-256(displayBlock)` — tedy přesně ta bajtová sekvence, která byla na obrazovce.
- 10 Klient zapíše do šifrované lokální DB záznam `pendingConfirm {intentId, idempotencyKey, hash, čas}` a teprve pak odešle `POST /payments/{intentId}/confirm` se `signature`, `keyId` a atestační `assertion`.
- 11 Server ověří podpis proti klíči registrovanému pro toto zařízení, shodu hashe s vydaným `displayBlockem`, platnost `intentu` a `quote`, a vyhodnotí rizikové skóre; při schválení přechází platba do zpracování.
- 12 Klient smaže `pendingConfirm` a přejde na obrazovku stavu; ta ukazuje 'odesláno, zpracovává se' a nikdy netvrdí 'hotovo', dokud nedorazí terminální stav ze serveru.
- 13 Po terminálním stavu se nabídne 'Sdílet potvrzení' jako serverem generované PDF — náhrada za screenshot, který je na Androidu zablokovaný `FLAG_SECURE`.

Klíčová vlastnost: mezi kroky 4 a 9 klient nespočítá ani jedno číslo. Všechno, co uživatel vidí a co podepisuje, přišlo ze serveru. Tím je splněn čl. 5(1) RTS doslova a při reklamaci existuje důkaz, co uživatel viděl.

Ztráta spojení mezi podpisem a odpovědí

- 1 Confirm byl odeslán, ale odpověď nedorazila — timeout, přepnutí sítě, zabití aplikace systémem nebo vybitá baterie. V lokální DB zůstal záznam `pendingConfirm`.
- 2 Klient NEOPAKUJE confirm. Přechází na stavový dotaz `GET /payments/intents/{intentId}`, který je jediná autorita.
- 3 Stav 'authorized' nebo dál: platba běží. Klient smaže `pendingConfirm` a zobrazí 'zpracovává se'.
- 4 Stav 'created': potvrzení nedorazilo. Pokud challenge ještě platí, klient smí poslat confirm znovu se STEJNÝM `Idempotency-Key` a stejným podpisem; server vrátí tutéž odpověď jako poprvé.
- 5 Stav 'created' a challenge už expirovala: `intent` se zahodí. Uživatel začíná znovu od kroku 3 předchozího toku, včetně nové biometrie. Podpis se nikdy nereguluje na nový `intent`.
- 6 Stav 'rejected' nebo 'expired': klient smaže `pendingConfirm` a ukáže důvod z chybového číselníku, lokalizovaný na klientovi podle kódu, ne text ze serveru.
- 7 Stavový dotaz se sám nepodaří: klient zkouší s exponenciálním backoffem a jitterem po dobu maximálně 60 sekund (1, 2, 5, 10, 20 s), pak přejde do stavu `unknownNeedsReconcile` a řekne uživateli pravdu — 'nevíme, jestli platba prošla, zkontrolujeme to a dáme vědět'. Nikdy netvrdí ani úspěch, ani neúspěch.
- 8 Při každém dalším studeném startu aplikace běží odsmiřovací krok PŘED vpuštěním uživatele na dashboard: projdou se všechny `pendingConfirm` a `unknownNeedsReconcile` záznamy a dotáží se stavy.
- 9 Dokud nějaký nevyřešený záznam existuje, na dashboardu je pruh 'jedna platba čeká na potvrzení stavu' a nová platba na stejného příjemce a stejnou částku vyžaduje explicitní potvrzení 'ano, chci poslat znovu'.

Toto je nejpodceňovanější tok celé aplikace a zároveň ten, kde se nejsnáze udělá duplicitní platba. Pro klienta, který posílá rodině do Venezuely měsíční příjem, je duplicita horší než selhání. Server musí držet idempotenci minimálně 24 hodin, protože nejhorší reálný výpadek uživatele je delší než jeho trpělivost.

Onboarding a device binding

- 1 Uživatel projde registrací a KYC (nativně; web na tenhle tok odkáže na aplikaci).
- 2 Klient vygeneruje asymetrický klíčový pár UVNITŘ hardwarového úložiště — Android KeyGenParameterSpec se `setIsStrongBoxBacked(true)` a odchytem `StrongBoxUnavailableException` s fallbackem na TEE, iOS `SecKeyCreateRandomKey` s `kSecAttrTokenIDSecureEnclave`. Klíč se nikdy nevytváří v paměti a neimportuje.
- 3 Klíč dostane atributy vynucující per-operation autentizaci: `setUserAuthenticationRequired(true)`, `setUserAuthenticationParameters(0, AUTH_BIOMETRIC_STRONG)`, `setInvalidatedByBiometricEnrollment(true)`, `setUnlockedDeviceRequired(true)`; na iOS `SecAccessControl` s `.privateKeyUsage` a `.biometryCurrentSet`.
- 4 Klient odešle veřejný klíč spolu s atestačním řetězem (Android Key Attestation, iOS App Attest) a s hlášením, jestli klíč vznikl ve StrongBoxu nebo jen v TEE.
- 5 Server ověří atestační řetěz proti aktuálnímu trust store — pozor na nový RKP root platný od 1. 2. 2026 a povinný pro RKP zařízení od 10. 4. 2026 — a podle úrovně hardwaru nastaví transakční limity: StrongBox plné, TEE snížené.
- 6 Registrace klíče proběhne v rámci SCA (dva prvky z různých kategorií), takže od tohoto okamžiku je instance aplikace platným prvkem vlastnictví.
- 7 Server odmítne dvě současně aktivní registrace téhož veřejného klíče z různých zařízení a jakoukoli registraci z klonovaného profilu nebo emulátoru.
- 8 Na iOS se do UserDefaults zapíše marker; při každém startu se porovná s obsahem Keychainu. Keychain totiž přežije odinstalaci, zatímco UserDefaults ne — chybějící marker při plném Keychainu znamená reinstalaci, a ta musí vést k vymazání klíčů a k novému onboardingu.

Obnova po ztrátě nebo výměně zařízení je samostatný a nejsložitější tok celé autentizace, zároveň nejčastější podvodný vektor a v původních odhadech úplně chybí. Nesmí se dát projít jen znalostním prvkem; vyžaduje buď původní zařízení, nebo plné znovuvěření totožnosti.

Rotace certifikátu pod pinningem

- 1 Nový klíčový pár vznikne v HSM. Jeho SPKI hash se přidá do pins.json jako druhý pin — certifikát se s ním zatím nevydává.
- 2 Podepsaná konfigurace se rozšíří klientům; sledovací metrika je podíl instalované báze hlásící verzi konfigurace, která nový pin obsahuje.
- 3 Čeká se minimálně 90 dní a zároveň dokud pokrytí nepřekročí 99,5 %. Obojí, ne jedno z toho — nová konfigurace se k zařízení, které je měsíc vypnuté, nedostane.
- 4 Teprve pak se vydá a nasadí certifikát s novým klíčem. Starý pin v konfiguraci zůstává.
- 5 Po dalších 90 dnech se starý pin odstraní a do konfigurace se přidá nový záložní klíč, který se hned začne stárnout stejným postupem. Vždy jsou v provozu dva piny.
- 6 Pokud po přepnutí certifikátu vzroste podíl zařízení hlásících selhání pinningu nad práh během 15 minut, spustí se poplach a nasazení se vrací zpět.
- 7 Pokud se vrátit nedá (například proto, že starý klíč byl kompromitován), použije se rescue endpoint — jiná doména, jiná CA, nezávislý pin set zapečený v binárce — kterým se distribuuje nová podepsaná konfigurace.

Bez rescue kanálu je jediná cesta z chybné rotace vynucený update ze storu, tedy dva až sedm dní bez plateb pro celou instalovanou bázi — incident hlásitelný podle DORA. Rescue kanál je trvalý provozní náklad a jeho funkčnost se musí testovat, jinak v den D nefunguje.

Směna mezi drženými měnami se sazebníkem podle stavu ekonomiky

- 1 Uživatel vybere zdrojovou a cílovou měnu z těch, které skutečně drží, a zadá částku.

- 2 Klient volá GET /fx/quote se zdrojem, cílem a částkou; nepočítá nic sám.
- 3 Server rozhodne, který sazebník platí — stačí, aby v hyperinflaci byla jedna strana, protože i příchozí převod do postižené země má dostat výhodnější sazbu — a vrátí kurz, spread, sazbu, poplatek a dobu platnosti.
- 4 Klient zobrazí obě částky, kurz, výši spreadu a název sazby, poplatek jako samostatný řádek a odpočet platnosti kurzu.
- 5 Potvrzení jde stejným podpisovým tokenem jako platba, protože směna je z pohledu RTS operace s finančním dopadem a musí být kryptograficky vázaná na částku a protistranu.
- 6 Vklad do do Safe Money z jiné měny, je z pohledu klienta jedna operace, ale server ji vydá jako jeden intent s displayBlockem, kde je směna a přesun do úschovy uvedený jako dva řádky s vlastními částkami — uživatel musí vidět, že po cestě proběhla směna a za jakou sazbu.
- 7 Srovnání udržení kupní síly proti kotvě se zobrazuje výhradně jako historické srovnání podle zveřejněné inflace, se zdrojem a datem měření, nikdy jako výnos, zhodnocení, úrok ani odhad budoucnosti — a nikdy nesmí být navázáno na dobu držení nebo na výši zůstatku.

Poslední krok je regulatorní, ne kosmetický: MiCA čl. 50 zakazuje úročení EMT a z toho plyne i zákaz jakékoli odměny odvozené od držení. Zákaz musí být vynucen v textech, v komponentě i v CI kontrole slovníku — jinak ho někdo za rok v marketingové iteraci vrátí zpátky.

Start aplikace: kontrola verze, integrity a stavu relace

- 1 Klient se pokusí o pinované spojení a stáhne podepsanou konfiguraci; pokud selže podpis nebo je verze nižší než uložená (rollback), konfigurace se zahodí a použije se poslední platná.
- 2 Klient odešle X-Client s verzí a buildem. Server odpoví buď normálně, nebo 426 Upgrade Required se strukturovaným lokalizovaným tělem.
- 3 Pod minVersion: blokující obrazovka s odkazem na aktualizaci; na Androidu se rovnou spustí In-App Update v režimu IMMEDIATE.
- 4 Pod minPaymentVersion, ale nad minVersion: aplikace se otevře v režimu jen pro čtení s trvalým pruhem vysvětlujícím, proč nejdou platby.
- 5 Souběžně se sbírají integritní signály a posílá se atestační token; verdikt vydá server a projeví se jako limity, ne jako hláška.
- 6 Běží odsmiřovací krok nad pendingConfirm záznamy z předchozího běhu.
- 7 Kontroluje se platnost relace. Pětiminutový limit nečinnosti je vynucen serverem; klientský odpočet je jen doplněk pro UX a upozorní uživatele 20 sekund předem s možností prodloužit jedním úkonem.
- 8 Při přechodu aplikace do pozadí se relace zamkne okamžitě a na iOS se překryje obsah, aby se nedostal do snapshotu v App Switcheru.

Pořadí je záměrné: konfigurace před verzí (protože prahy verzí jsou v konfiguraci), verze před integritou (nemá smysl vyhodnocovat atestaci u klienta, který stejně nepůjde dál) a odsmiřování před dashboardem (uživatel nesmí vidět zůstatek dřív, než víme, jestli mu odešla platba).

10.4 Rizika a opatření

Riziko	Opatření v návrhu
Nativní volba zdvojnásobí objem UI práce a tým to podcení. Původní odhad 190 MD na nativního klienta je v rozporu i s vlastní poznámkou o třech až šesti měsících dvou vývojářů; realistická hodnota je 350–450 MD a v ní stále není obnova po ztrátě zařízení, která je nejsložitější tok celé autentizace.	Rozdělit dodávku podle rizika, ne podle obrazovek: F1 postaví web s plnou funkcí pro nízkohodnotové operace a nativní aplikace přijdou až po rozhodnutí o licenci a tokenu. Do plánu explicitně zařadit obnovu a re-enrollment jako samostatnou položku s vlastním odhadem. Přijmout, že první nativní vydání má užší rozsah než web, a nesnažit se paritu vynutit k datu.

Riziko	Opatření v návrhu
Certificate pinning shodí celou instalovanou bázi při chybné rotaci. Bez záložního pinu a bez záchranného kanálu je jediná cesta ven vynucený update ze storu, tedy dva až sedm dní bez plateb — a to je hlásitelný incident podle DORA.	Vždy dva piny, z toho jeden záložní klíč držený offline v HSM a nikdy nepoužitý. Rotační procedura s 90denním předstihem a měřeným pokrytím konfigurace nad 99,5 %. Rescue endpoint na jiné doméně s jinou CA a nezávislým pin setem, jehož funkčnost se testuje čtvrtletně jako součást DORA testování odolnosti — netestovaný záchranný kanál v den D nefunguje.
Play Integrity nebo App Attest vypadnou nebo narazí na rate limit a hard fail politika shodí platby celé bázi kvůli výpadku třetí strany.	Definovaná degradační politika, ne binární rozhodnutí: cachovaný verdikt platí 15 minut, při nedostupnosti API se použije poslední známý verdikt až 24 hodin a nadlimitní operace se odloží se srozumitelným vysvětlením. Atestace je jedním vstupem rizikového skóre, nikdy jedinou podmínkou. Trust store pro Key Attestation musí být v provozním kalendáři — nový RKP root platí od 1. 2. 2026 a je povinný pro RKP zařízení od 10. 4. 2026, neaktualizovaný trust store odmítne legitimní nová zařízení.
Bezpečnostní opatření vyřadí uživatele s postižením a založí porušení EAA. Nejtvrdší kolize: plošné blokování accessibility služeb, randomizovaná PIN klávesnice nečitelná screen readerem a pětiminutový timeout proti WCAG 2.2.1.	Whitelist legitimních accessibility služeb podle package a podpisu, v podepsané konfiguraci s rychlou cestou k doplnění; neznámá služba vede na step-up, nikdy na blokaci. Randomizovaná klávesnice se nabízí jen když neběží screen reader, jinak systémové zabezpečené pole. Timeout s varováním 20 sekund předem a prodloužením jedním úkonem. Přístupnostní kontroly jako blokující CI job na všech třech platformách plus jeden externí audit s reálnými uživateli před vydáním.
Klientská peněžní logika z dema přežije do produktu. Sedm set řádků v src/store/useApp.ts počítá spread, poplatky a přepočty a je psaných tak, že se snadno okopírují do nového klienta s tím, že 'to už je hotové'.	Store se do produkčního repozitáře nepřenáší vůbec; přepíše se do dokumentu se specifikací sazebníku a do sady testovacích vektorů pro backend. V CI produkčního klienta zákaz importu čehokoli z demo repozitáře a lint pravidlo zakazující aritmetiku nad peněžním typem mimo formátovací vrstvu. Demo zůstane spustitelné, ale s trvalým označením simulace.
Chybné parsování částky podle locale způsobí platbu o tři řády vedle. Dnešní Number(amount.replace(',','')) na španělském vstupu 1.234,56 vrátí 1.234, a protože jde o platný počet, projde všemi kontrolami až k podpisu.	Locale-aware parser s odvozením skupinového a desetinného oddělovače z Intl.NumberFormat().formatToParts, výstup vždy jako celé číslo v minor units. Property-based testy nad všemi třemi jazyky a všemi podporovanými měnami. Server odmítne částku, která neodpovídá deklarovanému exponentu měny. A hlavně: potvrzovací obrazovka zobrazuje částku z displayBlocku serveru, takže i chyba v parseru je vidět dřív, než uživatel podepíše.
FLAG_SECURE odebere uživatelům screenshot a ti si najdou horší náhradu — vyfotí obrazovku druhým telefonem nebo si nechají poradit po telefonu, což je přesně vishingový scénář, proti kterému opatření míří.	Nasadit 'Sdílet potvrzení' jako serverem generované a podepsané PDF současně s FLAG_SECURE, ne později; v onboardingu jednou vysvětlit proč screenshot nejde a kde je náhrada. Sledovat metriku využití sdílení potvrzení jako indikátor, jestli náhrada funguje.
Web se stane nejslabším článkem. XSS na webovém klientovi dokáže přepsat zobrazený displayBlock, i když nedokáže podepsat jiný, a uživatel podepíše to, co si přečte na obrazovce.	Úzký rozsah operací vynucený serverem podle typu přihlašovacího prostředku, ne podle hlavičky klienta. CSP s nonce bez unsafe-inline a unsafe-eval, frame-ancestors none, explicitní connect-src a form-action, SRI na vše externí, Cache-Control no-store na stránkách se zůstatky. Žádné tokeny v localStorage — access token jen v paměti modulu, refresh v __Host-HttpOnly Secure SameSite=Strict cookie. Nižší denní limity než v nativní aplikaci a jasné vysvětlení v UI předem, které operace vyžadují telefon.
Konfigurace se stane novým zdrojem tvrdých závislostí. Když se do podepsané konfigurace dostane příliš mnoho rozhodnutí, přestane být jasné, co aplikace vlastně umí, a jedna špatná konfigurace shodí produkci bez nasazení kódu.	Konfigurace mění hodnoty a přepínače, nikdy toky. Každá změna prochází stejným review procesem jako kód, má verzi, autora a možnost okamžitého návratu. Klient odmítne konfiguraci s nižší verzí (anti-rollback) a při jakékoli chybě podpisu nebo schématu použije poslední platnou. V binárce zůstává bootstrap konfigurace jako poslední záchrana.
Tříjazyčnost se rozpadne v provozu. Dnes jsou všechny tři slovníky kompletní (284 klíčů), ale nic to nevynucuje — translate() při chybějícím klíči tiše spadne na češtinu, takže španělský uživatel dostane českou větu a nikdo se to nedozví.	CI kontrola úplnosti katalogu jako blokující krok, žádný runtime fallback mezi jazyky (chybějící klíč se v debug buildu zobrazí jako viditelný marker, v release jako klíč). Migrace na ICU MessageFormat kvůli plurálům — čeština má čtyři formy a dnešní řešení je neumí vůbec. Texty s regulačním významem (předmluvní informace, sazebník, upozornění na rizika) nepocházejí z klientského katalogu, ale ze serveru jako verzované dokumenty s ID, aby bylo doložitelné, jakou verzi uživatel viděl a odsouhlasil.

Riziko	Opatření v návrhu
Odhad podcení store review cykly a matici zařízení. Cílový trh běží na levných Androidech s vlastními ROM, agresivním zabíjením procesů na pozadí a nekonzistentní podporou StrongBoxu; iOS review u finanční aplikace s kryptoaktivy bývá pomalý a vrací se.	Matice zařízení postavená podle skutečného cílového trhu, ne podle vlastnictví týmu — Gradle Managed Devices plus alespoň deset fyzických levných zařízení. Do release kalendáře započítat dvě kola App Store review u každého většího vydání a mít připravenou dokumentaci licence a regulatorního statusu, kterou Apple u finančních aplikací vyžaduje. Fallback z StrongBoxu na TEE musí být otestovaný, ne jen odchycená výjimka, a musí se projevit na limitech, ne na pádu.

11. Fázování

Fáze nejsou milníky v čase, ale odpověď na otázku „co přežije rozhodnutí, které ještě nepadlo“. Fáze 1 je všechno, co bude potřeba bez ohledu na to, jaká licence, jaký token a jaká jurisdikce nakonec vyjdou. Fáze 2 se dá stavět až po tom rozhodnutí. Fáze 3 je to, co má smysl řešit až krátce před ostrým provozem.

Fáze	Komponent	Kdy se staví	Co do ní patří
Fáze 1	68	ihned, před licencí	Ledger, peněžní typ, cenové jádro, registr aktiv, základ platformy a CI. Jediný kód, který nezahodí žádné budoucí rozhodnutí.
Fáze 2	63	po rozhodnutí o licenci	SCA, compliance jádro, on-chain vrstva, safeguarding, karetní zúčtování, nativní klienti.
Fáze 3	6	před ostrým provozem	Provozní doladování, pokročilá observabilita, věci vázané na skutečný objem.

Komponenty fáze 1

Tohle je seznam, který se dá zadat do práce hned — nic z toho nezávisí na tom, jak dopadne rozhodnutí o licenci, tokenu ani jurisdikci.

Komponenta	Oblast	Odpovědnost (zkráceně)
Registr aktiv (asset registry)	Doménový model a ledger	Jediné místo, kde je definováno, co je 'peníze'. Tabulka asset(code PK, asset_class ENUM{fiat,emt,art,crypto_other,gas}, ledger_scale smallint NOT NULL, display_scale smallint NOT NULL, rounding_mode ENUM{half_even,floor,ceil} NOT NULL DEFAULT 'half_even', ...
Účtová osnova a ledger_account	Doménový model a ledger	ledger_account(id uuid PK, code text UNIQUE, account_type ENUM{asset,liability,equity,income,expense}, asset_code FK, legal_entity_id FK, owner_kind ENUM{client,house,counterparty}, owner_id, safeguarded bool, allow_negative bool, stripe smallint, status ...
Žurnál a zápisy (journal / posting) — jádro ledgeru	Doménový model a ledger	journal(id uuid PK (UUIDv7), seq bigint, legal_entity_id, type journal_type NOT NULL, request_id FK, correlation_id, effective_at timestamptz, booking_date date, value_date date, reverses_journal_id FK NULL, metadata jsonb, created_by, created_at). ...
Zůstatky a jejich vynucení (account_balance)	Doménový model a ledger	account_balance(ledger_account_id PK, asset_code, balance numeric(38,0) NOT NULL, allow_negative bool NOT NULL (denormalizováno a neměnné), last_journal_seq bigint, version bigint, updated_at). Aktualizuje se SYNCHRONNĚ ve stejné transakci jako postingy, ...
Zapisovací brána post_journal()	Doménový model a ledger	Jediná cesta, kterou se do ledgeru zapisuje. SECURITY DEFINER funkce (nebo jediný modul v aplikaci nad REVOKE INSERT rolí) s podpisem post_journal(request_id, type, effective_at, value_date, legs jsonb, metadata jsonb) → journal_id. Dělá v jedné transakci: ...
Idempotenční registr	Doménový model a ledger	request(request_id uuid PK, client_id, endpoint, request_fingerprint bytea (sha256 kanonizovaného těla + cesty + client_id), state ENUM{in_progress,succeeded,failed}, journal_id NULL, response_status, response_body jsonb, created_at, completed_at, ...
Cenové jádro — kotace, sazebník, ekonomický status	Doménový model a ledger	Cena vzniká na jednom místě a nikde jinde. rate_snapshot(id, source, observed_at, published_at) + rate_point(snapshot_id, base, quote, mid_rate numeric(30,12)) — kurz má vždy zdroj a čas platnosti, nikdy to není konstanta v kódu. tariff(tariff_id, key ...

Komponenta	Oblast	Odpovědnost (zkráceně)
Podkniha Safe Money a strukturální zákaz odměny	Doménový model a ledger	Safe Money není samostatný produkt, je to další závazkový účet klienta ve stejném aktivu: 2030 client:vault:{product_account}:{asset}. Přesun ve stejné měně = žurnál vault_move se dvěma nohami (D client:available / C client:vault). Vklad z jiné měny = žurnál ...
Core (modulární monolit) — jedna nasazovací jednotka, vynucené hranice modulů	Služby a jejich hranice	Drží moduly Ledger, Payments, Pricing/FX, Party&KYC, Cards a Reference Data. Jedna nasazovací jednotka, ale ne jedno bahno: každý modul má vlastní schéma v Postgresu, vlastní migrace, vlastní veřejné rozhraní jako Kotlin interface a zákaz sáhnout do cizí ...
Ledger (modul v Core, nikdy nedělený)	Služby a jejich hranice	Jediný zdroj pravdy o penězích. Podvojný append-only zápisy: každý peněžní pohyb je journal s ≥ 2 postings, součet přesně nula v každé měně zvlášť (deferred DB constraint). Částky celočíselné minor units, měna součástí typu, žádný float, žádné implicitní ...
Payments Orchestrator (modul v Core)	Služby a jejich hranice	Vlastní životní cyklus příkazu — jeden stavový automat pro VŠECHNY čtyři peněžní cesty (platba, směna, převod mezi vlastními účty, pohyb v Safe Money) a pro on-chain i karetní leg. Stav: created → quoted → screening → sca_required → authorized → posted → ...
Pricing & FX (modul v Core + sdílená deterministická knihovna)	Služby a jejich hranice	Jediné místo, kde vzniká cena. Sazebník podle stavu ekonomiky (hyperinflace: spread bez pevného poplatku; mimo: spread + poplatek), kurzový feed, vydávání kotací s quote_id, TTL a podpisem. Přímo zabíjí nález z auditu, že se sazebník uplatňuje jen v jedné ze ...
Party & KYC (modul v Core, ale vlastní DB a vlastní klíče)	Služby a jejich hranice	Klient, jeho identita, KYC případ, doklady, rozhodnutí ověřovacího poskytovatele, právní titul (legal_basis) u každé kategorie údajů, retence, práva subjektu. Ledger ani Payments neznají jméno — znají party_id. Tohle je nejlépe obhajitelný řez celé ...
Identity & Access / SCA (samostatný proces)	Služby a jejich hranice	Session, silné ověření klienta podle RTS 2018/389, device binding, registr veřejných klíčů zařízení, dynamic linking challenge, step-up, serverový timeout 5 minut nečinnosti, čítač 5 neúspěšných pokusů, revokace. Je oddělený proto, že je jako jediný ...
Compliance (samostatný proces: AML/CFT, screening, monitoring, travel rule)	Služby a jejich hranice	Sankční a PEP screening, transakční monitoring, case management, hlášení FIU, travel-rule výměna (IVMS101), ověření vlastnictví self-hosted adresy nad 1 000 EUR, on-chain screening protistran. Oddělený proces proto, že nezávislost MLRO je organizační ...
Reference Data & Product Config (modul v Core, ale pod change kontrolem)	Služby a jejich hranice	Registr aktiv a jurisdikcí — a tím i odpověď na blokátor XSGD/USDT. Záznam: {symbol, chain, contract, decimals, regime: EMT ART other, mica_authorized, issuer, whitepaper_ref, freeze_capable, transfer_returns_bool, offered_in[], custody_model, rate_feed}. ...
BFF / Client API (samostatný proces, jeden na rodinu klientů)	Služby a jejich hranice	Jediná internetem dosažitelná plocha pro klienta. Kompozice odpovědí (např. jméno z Party + zůstatek z Ledger), verzování veřejného API, terminace Idempotency-Key, rate limiting per credential, překlad interní chybové taxonomie na veřejnou, lokalizace ...
Audit & Evidence Sink (samostatná doména důvěry)	Služby a jejich hranice	Append-only, hash-chained auditní stopa: kdo, kdy, co, odkud, s jakým výsledkem, u peněžních operací předchozí i nový stav. Oddělný účet/tenant, write-only credentials z aplikace — kompromitace aplikace nesmí umožnit smazání logů (req. 8 to říká ...
Admin / Back-office plane (samostatná aplikace, samostatná síť)	Služby a jejich hranice	Provoz, compliance case management, ruční opravné zápisy se čtyřma očima, reklamace, uvolnění zadržené platby, manuální rozhodnutí u zaseknutého on-chain příkazu, správa limitů, wind-down operace. Není to route v klientském API — je to jiná aplikace s jinou ...
Notifications (samostatný proces)	Služby a jejich hranice	Push, e-mail, SMS, in-app schránka, šablony ve třech jazycích, oddělení transakčních a marketingových sdělení. Šablony procházejí registrem schváleným compliance — MiCA čl. 50 a 53 zakazují formulace typu 'zhodnocení' nebo 'výnos' u EMT a to se musí vynutit v ...
Dnešní frontend za portem/adaptérem (přežívající aktivum)	Služby a jejich hranice	Obrazovky, komponenty, styly, i18n (284 klíčů ve třech jazycích v ověřené paritě), formátování částek a logika srovnání kupní síly zůstávají. Mezi obrazovky a data se vkládá port (LedgerPort, PaymentsPort, PartyPort) s přesně těmi voláními, které bude ...

Komponenta	Oblast	Odpovědnost (zkráceně)
Identity Store (registr subjektů)	Identita a silné ověření klienta	Kanonická identita klienta jako entita nezávislá na přihlašovacích prostředcích: subject_id, stav životního cyklu (pending / active / restricted / provisional_recovery / frozen / offboarded), jurisdikční profil, úroveň KYC a její platnost, jazyk (CS/EN/ES) a ...
Credential Service (znalostní faktor)	Identita a silné ověření klienta	Uchování a ověření znalostního prvku (heslo pro web, PIN pro mobil) — výhradně serverově. PIN se na zařízení neukládá ani lokálně neověřuje; putuje po kanálu chráněném TLS 1.3 s pinningem uvnitř obálky podepsané klíčem zařízení. Autoritativní čítač ...
Session Manager	Identita a silné ověření klienta	Vydává a ruší relace, vynucuje serverem hlídání idle timeout max. 5 minut pro přístup k platebnímu účtu podle RTS čl. 4(3)(d) a nezávislý absolutní strop, rotuje identifikátor při každé změně úrovně oprávnění, detekuje znovupoužití refresh tokenu (rodina se ...
Policy Decision Point — autorizace a role	Identita a silné ověření klienta	Per-request autorizace podle RTS 2024/1774 čl. 21 — ne jen na gateway. Vyhodnocuje, zda daný subjekt/zaměstnanec smí na daném účtu provést danou operaci, s ohledem na roli k účtu (owner, spolumajitel, disponent, jen náhled, zmocněnec), KYC úroveň, stav ...
Audit & Evidence Store	Identita a silné ověření klienta	Nesmazatelná evidence všeho, co se v této oblasti stalo: každý pokus o SCA a jeho výsledek, každý vydaný a spotřebovaný grant včetně podepsaného payloadu a display_textu, každé rozhodnutí o výjimce s právním základem, každý enrollment a revokace zařízení, ...
Compliance Decision Point (compliance-gate)	Compliance jako běhová vrstva	Jediné synchronní místo, které pro každý peněžní záměr (platba, převod mezi vlastními účty, směna, vklad/výběr ze Safe Money, on-chain odchozí/příchozí transfer, karetní autorizace, změna limitu, výplata) vrací rozhodnutí ALLOW / STEP_UP / HOLD / DENY s ...
Rozhodovací deník (decision log) a replay	Compliance jako běhová vrstva	Neměnný záznam každého volání PDP: snímek vstupů, verze rulesetu, verze každého sankčního a PEP seznamu, verze modelu, výsledek, kdo/co jej přepsal a proč. Je to zároveň důkaz pro dohled, vstup pro ladění falešných poplachů a jediný způsob, jak zpětně obhájit ...
Restrikční primitiva v ledgeru (hold / freeze / restraint)	Compliance jako běhová vrstva	Blokace a zmrazení jako účetní entita, ne boolean na účtu. Typy: soft hold (dočasná blokace částky při STEP_UP nebo šetření), travel-rule hold, sankční freeze (bez lhůty, zrušitelný jen se schválením MLRO a doloženým právním důvodem), soudní/exekuční příkaz, ...
Evidence & retention vault (důkazní trezor)	Compliance jako běhová vrstva	Uložení všeho, co musí přežít 5 (resp. 10) let a co se nesmí redigovat: KYC složky, skeny a atributy dokladů, důkazy o provedeném ověření, screeningové zásahy a jejich vyhodnocení, obsah STR/SAR, Travel Rule payloady, korespondence s FIU. Vlastní retenční ...
Oprávnění, oddělení rolí a maker-checker framework	Compliance jako běhová vrstva	Vynucení čtyř očí a SoD na úrovni knihovny, kterou musí použít každá administrativní akce: schválení KYC, ruční opravný zápis, zmrazení a odmrazení, změna limitu nad práh, změna rulesetu, odeslání STR, přístup do KYC složky. Tvrdé pravidlo iniciátor ≠ ...
Registr politik a pravidel (ruleset registry) se shadow režimem	Compliance jako běhová vrstva	Pravidla, prahy, rizikové matice, jurisdikční profily a produktová omezení jsou verzované artefakty se schvalovacím workflow, ne konfigurace v .env a ne kód. Každá verze má autora, schvalovatele, datum účinnosti, dopadovou analýzu ze shadow běhu a možnost ...
Identitní a KYC datový model (compliance core data)	Compliance jako běhová vrstva	Kanonický model klienta pro compliance: identifikační atributy, doklady, skutečný majitel, PEP status, daňová rezidence a TIN (kvůli DAC8), účel vztahu, zdroj prostředků, rizikové skóre, historie stavů. U každé kategorie evidovaný právní titul (čl. 6 odst. 1 ...
Back-office / operátorská konzole	Compliance jako běhová vrstva	Jediné pracoviště compliance a podpory: vyhledání klienta, KYC fronta, případy, restrikce, ruční opravné zápisy, refundace, revize alertů, generování hlášení. V plánu tato položka chyběla úplně — bez ní skončí provoz u SQL konzole nad produkcí, což je samo o ...
Registr aktiv a řetězců (Asset & Chain Registry)	Blockchainová vrstva	Jediný zdroj pravdy o tom, co je dané aktivum: řetězec, adresa kontraktu, decimals, sémantická třída tokenu (vrací bool / nevrací, fee-on-transfer, nutný reset approve na nulu, podpora EIP-2612), typ freeze adaptéru, adresa proxy admina a hash známé ...

Komponenta	Oblast	Odpovědnost (zkráceně)
Ledgerový záměr a outbox (Transaction Intent + Outbox)	Blockchainová vrstva	Převádí obchodní požadavek (výběr, sweep, doplnění hot) na kanonický, neměnný záměr s idempotenčním klíčem a rezervuje prostředky podvojným zápisem ještě před tím, než se cokoli dostane k síti. Je to hranice mezi účetnictvím a řetězcem: on-chain vrstva nikdy ...
Adaptér poskytovatele úschovy (Custody Provider Adapter)	Blockchainová vrstva	Izoluje zbytek systému od toho, kdo klíče fakticky drží. Stejně rozhraní obsluhuje nakoupenou custody (Fireblocks / Copper / Taurus / Zodia), vlastní MPC cluster i cold multisig. Bez této vrstvy je výměna dodavatele přepsáním půlky backendu — a exit strategie ...
Neměnný auditní log podpisových operací (WORM)	Blockchainová vrstva	Zaznamenává každé volání podpisu, každou změnu politiky, každou změnu allowlistu, každý přístup ke klíčovému materiálu a každou odeslanou transakci: identita iniciátora a všech schvalovatelů, verze politiky, verze registru aktiv, hash podepisovaných dat, ...
Ledger DB (účetní jádro)	Data, úložiště a soukromí	Jediný zdroj pravdy o penězích. Podvojný zápis: tabulka postings, každá operace ≥ 2 řádky, součet přesně 0 v každé měně/aktivu zvlášť, vynuceno deferred constraint na úrovni transaction_id. Částky jako BIGINT v minor units (VES a hyperinflační měny: scale ...
Produktová DB (účty, karty, platby, trezory, KYC stav)	Data, úložiště a soukromí	Stav produktu bez osobních údajů: účty a jejich měny, virtuální karty a limity, příkazy k platbě (VS/KS/SS, IBAN/SWIFT jen jako token), Safe Money, stav KYC (jen enum a datum, ne doklady), jazyk klienta, nastavení. Každý sloupec má v katalogu přiřazený ...
PII trezor (vault service + vlastní DB)	Data, úložiště a soukromí	Jediné místo, kde existuje jméno, datum narození, adresa, e-mail, telefon, číslo a typ dokladu, IBAN protistrany a blockchainová adresa klienta. Vydává neprůhledné tokeny (UUIDv7) a jen ty putují do zbytku systému. Šifruje po polích AES-256-GCM klíčem ...
Audit trail (neměnný důkazní log)	Data, úložiště a soukromí	Kdo, kdy, co, odkud, s jakým výsledkem, u peněžních operací před/po. Řetězený hash: entry_hash = SHA-256(kanonický JSON prev_hash). Zapisuje se výhradně přes append-only API, aplikační role nemá UPDATE/DELETE, produkční účet nemá credentials do WORM účtu. ...
Hierarchie klíčů a KMS/HSM	Data, úložiště a soukromí	Root of trust a celý životní cyklus klíčů. Čtyři úrovně: root KEK v HSM (nikdy neopustí modul) → doménové KEK (vault, aml, ledger-at-rest, backup, logs, analytics-salt, chain-signing — každý s jiným IAM) → per-subject DEK → per-object DEK. Oddělení rolí: kdo ...
Shred store (klíčový materiál pro kryptografický výmaz)	Data, úložiště a soukromí	Malá tabulka subject_token → shred_secret (32 B). DEK klienta = HKDF(HSM_KEK_cohort, subject_token, salt = shred_secret). Zničení shred_secret zničí DEK navždy. Tento store má záměrně jinou zálohovací politiku než zbytek: Pitr max. 24 h, žádné logické dumpy, ...
Katalog dat a strojově čitelný ROPA	Data, úložiště a soukromí	Registr datových tříd: pro každou tabulku/sloupec/objektový prefix drží data_class, legal_basis, retenci, umístění (region + poskytovatel), příjemce a odpovědnou roli. Z něj se generuje záznam o činnostech zpracování podle čl. 30 i DORA Register of ...
Registr aktiv a referenčních dat	Data, úložiště a soukromí	Token, řetězec, jurisdikce a sazebník jako data. Tabulka asset(code, chain_id, contract_address, decimals, issuer, regulatory_status, mica_authorized, valid_from) — XSGD, USDT, USDC, EURC jsou řádky, ne konstanty; přepnutí na autorizovaný EMT je migrace dat a ...
Zálohy, DR a testovaná obnova	Data, úložiště a soukromí	Zálohy jsou provozní nástroj, ne archiv — proto krátké. Pitr 35 dní, snapshoty 90 dní, uložené v jiném cloud účtu s Object Lock proti ransomwaru, šifrované vlastním backup KEK, který produkční role nemůže použít k dešifrování. Dlouhodobé uchování dělá účelový ...
Landing zone — AWS Organizations a struktura účtů	Platforma a provoz	Nese hranici izolace. Účet je jednotka blast radiusu, ne VPC. Struktura: management, log-archive, security-tooling, network-hub, shared-services (CI runner, registry), dev, test, sandbox, staging, prod-app, prod-ledger, prod-keys, backup-vault, restore-test. ...
Síťová páteř a segmentace	Platforma a provoz	Rozděluje síť podle kritičnosti dat a vynucuje explicitní pravidla toku podle RTS 2024/1774 čl. 13. Pět zón: edge (CloudFront + WAF), ingress (interní ALB, VPC origin, žádné veřejné IP na aplikačních subnety), aplikační (EKS privátní subnety), datová ...

Komponenta	Oblast	Odpovědnost (zkráceně)
Běhové prostředí aplikací	Platforma a provoz	Tři EKS clustery (non-prod, staging, prod), každý ve svém účtu. Carpenter pro škálování, spot instance výhradně pro CI a dávkové úlohy — nikdy pro ledger, signer ani platební API. Ledger běží jako StatefulSet s PodDisruptionBudget a topologií přes tři AZ. ...
Prostředí a jejich oddělení	Platforma a provoz	Pět prostředí s odlišným účelem a odlišnou datovou politikou. dev — efemérní namespace per vývojář, syntetická data, testnet. test — vytvářeno a ničeno pipeline pro každý běh integračních testů. sandbox — stabilní veřejné prostředí pro partnery a investorské ...
Infrastruktura jako kód a policy as code	Platforma a provoz	Veškerá infrastruktura vzniká Terraformem; ruční zásah v konzoli je incident, ne postup. Stav v S3 s SSE-KMS a zámkem v DynamoDB, per účet a prostředí. Nad plánem běží politiky: žádná security group s 0.0.0.0/0 na jiném než 443, žádná RDS bez šifrování a bez ...
CI/CD pipeline s branami	Platforma a provoz	Jediná cesta kódu do produkce. Pořadí bran: lint → typecheck → unit testy včetně vlastnostních testů peněžních invariantů (dnes v repozitáři neexistuje jediný test — tohle je nejdražší dluh, který se doplňuje) → mutační testování na modulu ledger → SCA → SAST ...
Podepisování artefaktů a admission control	Platforma a provoz	Uzavírá řetězec důkazů. Každý image se podepisuje cosignem klíčem v AWS KMS (vlastní identita, ne keyless přes veřejný Fulcio), k němu se připojuje SBOM attestation a SLSA v1.0 provenance z GitHub Actions. Kyverno v produkčním clusteru vynucuje verifyImages: ...
Správa aplikačních tajemství a rotace	Platforma a provoz	HashiCorp Vault, jeden cluster na prostředí (3 uzly, Raft, auto-unseal přes KMS). Dynamické krátkodobé Postgres credentials s TTL 1 h — aplikace nikdy nedostane statické heslo do databáze. Transit engine pro aplikační šifrování, PKI engine pro interní ...
SBOM a kontrola závislostí	Platforma a provoz	SBOM při buildu je bezcenný, pokud se znovu nevyhodnocuje. Syft generuje CycloneDX 1.6 pro každý image i pro zdroj; SBOMy jdou do self-hostovaného Dependency-Track, který je průběžně přehodnocuje proti novým CVE a NVD/OSV feedům. Na dotaz "která běžící verze ...
Telemetrie — metriky, logy, trasování	Platforma a provoz	Jedna instrumentace (OpenTelemetry SDK), jedna OTLP roura, tři backendy. Trasování se vzorkuje 100 % na peněžních cestách (platba, směna, Safe Money, on-chain podpis) a tail-based 5 % jinde; trace ID je zároveň korelační ID, které prochází celým požadavkem a ...
Neměnný audit trail a log archive	Platforma a provoz	Oddělený od provozních logů, protože má jiný účel a jinou retenci. Vše, co se dotýká peněz, klíčů, oprávnění a konfigurace, jde přes Kinesis Firehose do S3 v účtu log-archive s Object Lock v režimu Compliance. Retence 10 let pro transakční a KYC záznamy ...
Registr informací a řízení dodavatelů	Platforma a provoz	Registr podle prováděcího nařízení 2024/2956 je udržován jako data v Gitu (YAML), validovaná v CI proti ITS schématu a exportovaná do předepsaného formátu — ne jako tabulka, kterou někdo jednou ročně dohledává. Každý záznam: LEI poskytovatele, podporovaná ...
Kapacita, náklady a FinOps	Platforma a provoz	Model roku 1: 50 tis. uživatelů, 5 plateb měsíčně, tedy ~250 tis. transakcí měsíčně a špička kolem 10 tx/s. Výpočetně nic — cenu žene compliance podlaha. Odhad měsíčně: EKS control plane 3× 73 USD; produkční uzly ~600 USD; Aurora prod 2× r7g.xlarge ~1 050 USD ...
Sandbox a nástupce dnešního investorského dema	Platforma a provoz	Dnešní stav — jednosouborový AES-GCM build na Cloudflare Pages za sdíleným heslem a Cloudflare Access — se převádí do sandbox prostředí platformy: identita per osoba místo sdíleného hesla, Sepolia testnet, mock KYC a mock SEPA, syntetická data, viditelné a ...
Kontraktní balík (@largo/contract)	Klientské aplikace	Jediný zdroj pravdy sdílený všemi třemi klienty: OpenAPI 3.1 schéma API, JSON schéma podepsané produktové konfigurace, číselník chybových kódů, číselník stavů platby a zlaté testovací vektory formátování (hodnota × měna × jazyk → očekávaný řetězec). ...
Lokalizační katalog (@largo/i18n)	Klientské aplikace	CS/EN/ES texty v ICU MessageFormat s plurály a select formami, klíče jako jediná identita, žádný tichý fallback mezi jazyky. Přebírá 284 hotových klíčů z dnešního src/i18n/{cs,en,es}.ts a doplňuje plurálové kategorie, které dnešní řešení neumí vůbec (čeština ...

Komponenta	Oblast	Odpovědnost (zkráceně)
Formátovací a parsovací vrstva částek	Klientské aplikace	Zobrazení a čtení částek podle locale a podle měny, s peněžními hodnotami držených výhradně jako celá čísla v minor units. Řeší dnešní chybu v <code>src/screens/Payments.tsx:171</code> — <code>Number(amount.replace(',', ''))</code> na vstupu <code>'1.234,56'</code> ve španělštině vrátí <code>1.234</code> , tedy ...
Designové tokeny a UI kit	Klientské aplikace	Barvy, typografie, poloměry, odstupy a stavy komponent v jednom zdroji, generované do tří cílů. Součástí je kontrastní audit — dnešní <code>src/styles/tokens.css</code> nebyl proti WCAG kontrolován a tlumený text na světlém pozadí typicky nedosahuje 4,5:1.
Webový klient (PWA)	Klientské aplikace	Plnohodnotný přehled, historie, výpisy, správa karet bez zvýšení limitů, tuzemské platby na známé příjemce, směna do limitu. Instalovatelná, offline read-only. Primární kanál pro cílovou zemi, kde je stažení nativní aplikace ze storu drahé nebo nedostupné. ...
Stavová a synchronizační vrstva	Klientské aplikace	Server-authoritative cache. Klient nikdy nemodifikuje read model lokálně — nemá optimistický zápis zůstatku. Delta synchronizace kurzorem, každá zobrazená hodnota nese značku <code>asOf</code> , kterou UI ukáže, jakmile je starší než 60 sekund bez spojení.
Přístupnostní vrstva (EAA)	Klientské aplikace	Zajišťuje soulad se směrnicí (EU) 2019/882 přes EN 301 549 v3.2.1 / WCAG 2.2 AA. Musí být zabudována od první obrazovky, ne dolepena — zejména proto, že se přímo sráží s bezpečnostními opatřeními (randomizovaná PIN klávesnice vs. screen reader, blokace ...

12. Nezávislá oponentura

Návrh prošel třemi nezávislými kritickými pohledy. Texty jsou uvedeny bez úprav. Nesouhlasí spolu ve všem — investorský pohled chce škrtat, dohledový pohled chce přidávat — a právě ten rozpor je informace.

Posudek přiměřenosti

Investor a CTO: co je přeінženýrované, co koupit místo stavět a jaká je nejmenší verze, která se za rok nepřepisuje.

Posudek přiměřenosti — LargoVerse cílová architektura

Shrnutí pro investora

Sečteno z podkladu: **3 152 člověkodní** ve 59 mezerách, z toho 85 z 130 požadavků je tvrdá právní povinnost. To odpovídá 24–33 měsícům při plně obsazeném týmu 20 lidí — ale jen pokud je tým kompletní od prvního dne, což nikdy není. Reálná spotřeba peněz před prvním klientem: platforma 25–40 tis. EUR/měsíc podle vlastního odhadu návrhu, lidé při 14–25 hlavách dalších 100–200 tis. EUR/měsíc, kapitál 475 tis. EUR nezapočitatelně (125 CASP + 350 EMI). **Dohromady 6–12 mil. EUR předtím, než přijde první euro tržby.** Toto číslo v návrhu nikde není a je to jediné číslo, které investor potřebuje.

Návrh je technicky mimořádně kvalitní — v mnoha bodech lepší, než co jsem viděl v provozovaných institucích. Právě to je problém: je to architektura pro instituci ve třetím roce provozu, ne pro firmu s nula klienty a bez licence.

Druhý nález, který mě znepokojuje víc než jakékoli jednotlivé přeінženýrování: dokument není jedna architektura, je to sedm nezávislých architektur, které se nikdy nepotkaly.

- Registr aktiv je definován pětkrát v pěti oblastech s pěti různými sadami sloupců.
- Neměnnost auditu: jedna oblast říká Merkle strom každých 60 s podepsaný v HSM do WORM, druhá říká Merkle root každých 5 minut s kvalifikovaným časovým razítkem eIDAS. Obojí zdůvodněné, vzájemně nesladěné.
- Custody: ADR-01 říká "kupujeme, nestavíme", ADR-02 hned popisuje vlastní MPC/TSS nad HSM, a platformní oblast rozpočtuje CloudHSM cluster za 2 100 USD/měsíc jako kořen důvěry pro "on-chain podpisové shares", které při nakoupené custody vůbec neexistují.
- "Žádné vlastní smart kontrakty" versus CREATE2 forwarder s výjimkou na půl stránky.
- "Ne dvanáct mikroslužeb" versus osm nasazovacích jednotek.
- Idempotence: jedna oblast TTL 7 dní v Redisu, druhá 90 dní s trvalým archivem. To je rozdíl mezi "dvojitá platba po devíti dnech projde" a "neprojde".
- Zápis do ledgeru má podle jedné oblasti povinný `quote_id`, podle jiné povinný nespotřebovaný `decision_id` z compliance. Nikde není jedna definice toho, co `post_journal()` skutečně vyžaduje.

Než se cokoli začne stavět, musí vzniknout **jeden konsolidovaný dokument s jedním vlastníkem**. Jinak se ty rozpory zaplatí v kódu.

1. Co je přeінženýrované

64 stripes na domovních účtech. Návrh sám počítá špičku 10 tx/s. Striping je optimalizace pro tisíce zápisů za sekundu; při deseti stojí jen složitost, kterou zaplatí každý report a každá reconciliace. Jeden řádek zůstatku vydrží dva řády růstu.

Deterministické pořadí zámek proti deadlocku mezi souběžnou směnou $A \rightarrow B$ a $B \rightarrow A$. Správná úvaha, nulová pravděpodobnost výskytu při této zátěži. Ponechat jako tři řádky v `post_journal()` (je to zdarma), ale nestavět kolem toho argumentaci o volbě izolační úrovně.

Dvě kryptografické atestační vrstvy. Merkle + HSM podpis + WORM v cizím účtu + eIDAS razítko. Pro fázi bez klientů stačí: append-only tabulka, `REVOKE UPDATE/DELETE`, denní hash chain, S3 Object Lock. Rozdíl v důkazní síle je pro dohled nulový, dokud nejsou transakce, které by kdo popíral.

Čtrnáct AWS účtů, Istio ambient s waypoint proxy a ext_authz do OPA, tři EKS cluster, Karpenter, self-hostovaná LGTM sestava, self-hostovaný Rekor, vlastní CodeArtifact proxy, vlastní Ethereum full node. Tohle je zaměstnání pro 3–4 platform inženýry na plný úvazek. Při týmu 14–25 lidí je to pětina firmy věnovaná provozu infrastruktury pro nula klientů. Self-hostovaný Rekor je navíc logický nesmysl: transparentní log má hodnotu tehdy, když ho neprovozuje ten, kdo podepisuje.

Vlastní PII trezor s crypto-shreddingem, blind indexem a per-object DEK. Odhad 4–6 člověkoměsíců je optimistický a hlavně ignoruje, že tu službu pak pět let provozujete, rotujete a auditujete. Ve fázi 1 stačí oddělené schéma s šifrováním sloupců přes KMS a jedním klíčem per klient — architektonicky totožné, provozně desetkrát levnější, a přechod na plný trezor je migrace dat, ne přepis.

Šest cest obnovy přístupu se stavovým automatem, karanténou a čtyřma očima. U 1 000 klientů je obnova ruční proces: videohovor, dva lidi, zápis do case managementu. Automat se staví, až když jich je 50 měsíčně.

Exemption engine podle RTS čl. 10–18, TRA podle čl. 18, tuning lab s champion–challenger a below-the-line testováním, pololetní statistika podvodů podle PSD2 čl. 96(6). Výchozí stav "vždy SCA, žádné výjimky" je legální, zdarma a pro remitence do hyperinflační země správný. Tuning lab bez alertů nemá co ladit.

Uzávěrky, `statement\_period` s `document\_hash`, čtvrtletní výpis z registru pozic podle čl. 75, intercompany žurnály $SG \leftrightarrow LT$, karetní auth/capture/chargeback, PCI segment. Dceřinka neexistuje, karty nejsou v produktovém jádru remitence, výpisy nemá kdo číst.

Tři samostatné klientské codebase (Swift + Kotlin + React). Ze 190 + 50 + 60 + 30 + 22 MD klientských mezer je většina zdvojená napříč platformami. Pro první tisíc klientů v Caracasu je web PWA nejen dostačující — je to podle vlastní analýzy návrhu **primární kanál**. Nativní klienti jsou fáze 2.

2. Co koupit místo stavět

| Oblast | Rozhodnutí | Dopad |

|---|---|---|

| Custody klíčů | Kupovat (Fireblocks/Copper/Zodia) — návrh to říká, ale pak si to třikrát protiřečí | Odpadá MPC/TSS, cold multisig 4-ze-7, KCP, hardened podpisové prostředí, CloudHSM. Z gapů ≈ 220 MD $\rightarrow$ integrace 60–80 MD. Úspora ~ 140 MD a **2 FTE bezpečnostního profilu**. Cena 8–15 tis. USD/měsíc začíná až s reálnými aktivy |

| Depozitní adresy, indexer, nonce, gas | Součást custody providera | Odpadá CREATE2 forwarder (a jeho audit), vlastní indexer, vlastní full node. ≈ 70 MD a jeden auditovaný kontrakt méně |

| SIEM | Nekupovat Elastic za 2,5–3,5 tis. EUR/měsíc před licencí | CloudTrail + alerty nad audit traillem. Úspora 60–80 tis. EUR do spuštění |

| Observabilita | Managed místo self-hosted LGTM | Úspora $\sim 0,5$ FTE |

| Tajemství | Secrets Manager místo Vault clusteru na prostředí | Dynamické DB credentials s TTL 1 h jsou správné, ale ne dřív než je co chránit |

| Kryptografie at rest | KMS, **ne** CloudHSM | 25 tis. USD/rok za modul, jehož jediný účel (on-chain shares) při nakoupené custody neexistuje |

| Karty | Nestavět vůbec ve fázi 1 | 95 + 65 MD ušetřeno, PCI rozsah zůstane nulový |

| KYC, sankce/PEP, travel rule, chain analytics | Kupovat — návrh správně | — |

Nejdůležitější "kup místo stav" v celém dokumentu chybí: licence. Cesta přes **agenta nebo distributora existující litevské EMI** odloží 220 MD licenčního projektu, 475 tis. EUR kapitálu a 4–12 měsíců řízení. Získáte reálné klienty, reálná transakční data (která žádost o vlastní licenci dramaticky zesílí) a reálnou odpověď na otázku, jestli o produkt někdo stojí. Cena: nižší marže a závislost na partnerovi. Pro firmu, která ještě neověřila poptávku, je to nesrovnatelně lepší obchod než 12 měsíců psaní programu činností.

Naopak nekupovat: ledger. To je jediná věc, která musí být naše — je to zdroj pravdy o penězích, důkazní materiál pro dohled a jediná komponenta, jejíž pozdější výměna je nemožná. 85 MD podvojného jádra je nejlépe investovaná položka celého rozpočtu.

3. Nejmenší verze, která se za rok nepřepisuje

Rozdělení je jednoduché: **nevratné = to, jehož pozdější doplnění znamená migraci peněz nebo přepis domény.** Všechno ostatní je nová tabulka nebo nová služba vedle a počká.

Musí být od prvního commitu (nevratné, dohromady ≈ 400 MD):

- Celočíselné minor units, škála z registru aktiv (nikde konstanta 2, nikde float).
- Podvojný append-only žurnál, balance per aktivum vynucená DB, složený FK (*account_id*, *asset_code*), žádný UPDATE/DELETE, oprava jen stornem.
- Synchronní *account_balance* v téže transakci s *CHECK(allow_negative OR balance >= 0)*.
- Jediná zapisovací brána *post_journal()* s odepřeným INSERT aplikační roli — **a s jednou konsolidovanou definicí toho, co vyžaduje** (*quote_id*, *decision_id*, *request_id*).
- Idempotenční registr commitovaný spolu se žurnálem, klíč z hlavičky, u peněžních endpointů retence do archivu, ne 7 dní.
- Cena vzniká výhradně v kotaci; CHECK na *quote_id* u všech křížoměnových typů. Tohle jediné ruší nález o dvojí ceně téže konverze.
- V *journal_type* neexistuje hodnota vyjadřující úrok ani odměnu za držení. Enum, zdarma, nevratné.
- *party_id* v ledgeru, osobní údaje v odděleném schématu s vlastním klíčem. Pozdější rozřezání je nejdražší migrace, jaká existuje.
- *booking_date* (institucionální) i *effective_at* (timestamp)z uložené oba.
- *legal_entity_id* na každém účtu, i když je entita jedna.
- Registr aktiv místo literálů tokenů (dnes tři řádky: EUR, CZK, EURC).
- Server je autorita nad penězi; dnešní frontend za portem, *useApp.ts* jde do koše jako specifikace, ne jako kód.
- Audit trail append-only s hash chainem do S3 Object Lock.
- Kontraktní balík: OpenAPI, ICU katalog 3 jazyků, zlaté formátovací vektory, designové tokeny.
- **Property-based testy peněžních invariantů v CI od prvního dne.**

Infrastruktura fáze 1: jeden modulární monolit, jeden Postgres s read replikou, tři AWS účty (prod / nonprod / log+backup), ECS Fargate nebo jedna malá EKS bez meshe, KMS, CI/CD s branami a podpisem image, sandbox prostředí nahrazující dnešní Cloudflare demo. Jeden klient: web PWA.

Odhad: zbude zhruba **1 000–1 200 MD z 3 152**, tedy 8–10 lidí × 12 měsíců. To je rozdíl mezi rozpočtem 3 mil. a 10 mil. EUR.

Všechno ostatní — SCA a device binding, nativní klienti, on-chain vrstva, karty, uzávěrky a výpisy jako dokumenty, plný rekonciliační stroj, SIEM, service mesh, druhý region, ISO 27001, TLPT — se přidává vedle, ne dovnitř. Ani jedna z těch věcí nevyžaduje sáhnout do žurnálu.

Jednu výjimku bych udělal proti vlastnímu pravidlu: **kanonický `displayBlock` a intent kontrakt navrhnout hned**, i když podpis přijde až s nativním klientem. Je to schéma a endpoint, stojí to dny, a jeho pozdější zavedení znamená přepis každé potvrzovací obrazovky.

4. Kde je návrh naopak příliš skromný

Testy — 70 MD je fikce. Podvojný ledger s invarianty potřebuje property-based testy, deterministickou simulaci souběhu a fuzzing zaokrouhlování. Počítejte dvojnásobek a považujte to za nesmlouvatelné. Je to jediná položka rozpočtu, u které škrt znamená, že se nález "hodnota vzniká zaokrouhlením" vrátí, jen tentokrát s cizími penězi.

Lidé — 45 MD na "chybí lidé" je účetní nesmysl. MLRO jako litevský daňový rezident, compliance officer, DPO, fit-and-proper statutár: náborové lhůty 3–6 měsíců a fixní roční náklad 400–600 tis. EUR. Není to člověkodní, je to payroll, a je to největší položka rozpočtu, kterou návrh vůbec nekvantifikuje. Nábor MLRO musí začít dřív než kód.

Bankovní vztah. Návrh o safeguardingu píše, že "ledger ho nevyrobí, jen ho eviduje". Správně — ale otevření oddělených safeguarding účtů u úvěrové instituce pro nový CASP/EMI se singapurskou matkou a venezuelskou klientelou je **6–12 měsíců vyjednávání s nejistým výsledkem** a je to nejpravděpodobnější místo, kde celý projekt zemře. Musí to být pracovní balík s vlastníkem a startem v týdnu jedna, ne předpoklad.

Treasury a měnové riziko. Existuje účet `fx_position:{asset}`, ale nikde politika: kdo drží otevřenou pozici ve VES, jaký je limit a jak se zajišťuje. **VES se prakticky hedgovat nedá.** Při spreadu 1,5 % a denní inflaci v hyperinflačním režimu může jedna noc s nezajištěnou pozicí sníst čtvrtletní marži. Tohle je největší finanční riziko produktu a architektura o něm mlčí, zatímco tři odstavce věnuje monitoringu pegu EURC.

Poslední míle do Venezuely. Ani jedna z devíti oblastí neodpovídá na otázku, jak se hodnota fyzicky dostane k příjemci v Caracasu. Korespondenční banky VES odmítají. Bez odpovědi je celá vrstva pod tím akademická.

Náklady na zneužití placených externích volání. KYC za 1–2,5 EUR za ověření je přímý finanční vektor: 10 000 falešných registrací = 25 000 EUR z účtu. Návrh má rate limiting na gateway, ale nikde nepočítá cenu jednoho volání jako bezpečnostní parametr.

Support jako nákladová položka. U remitencí je zákaznická podpora typicky 30–40 % provozních nákladů a je to hlavní důvod odchodu klientů. Návrh má maker-checker engine a admin konzoli jako jednu odrážku — bez SLA, obsazení a španělsky mluvícího pokrytí mimo evropskou pracovní dobu.

Kompromitace vývojářské stanice. Sedmidenní karanténa npm balíčků je výborné a levné opatření. Ale Bybit i Radiant začaly u vývojářského stroje, ne u knihovny. Když custody kupujeme, největším zbývajícím útočným povrchem je notebook s přístupem do CI, které nasazuje do produkce. To si zaslouží víc pozornosti než celá kapitola o Merkle stromech.

Exit plán z custody providera. DORA čl. 28–30 vyžaduje otestovatelnou cestu ven. U custody je to nejtěžší exit v celém registru a v podstatě se otestovat nedá. Návrh správně kupuje, ale musí mít napsáno, co se stane, když dodavatel skončí — a musí to mít napsáno dřív, než podepíše smlouvu.

5. Investorský závěr

Postavil bych to takto:

- **Měsíce 0–3, 5–6 lidí:** rozhodnout token (EURC), jurisdikci a licenční cestu; začít nábor MLRO; začít vyjednávat s partnerskou EMI a s bankou; konsolidovat sedm architektur do jedné; postavit sandbox pro investory. Otestovat poptávku bez řádku backendu.
- **Měsíce 3–12, 8–10 lidí:** ledger core plus nevratná vrstva výše, web PWA, KYC od dodavatele, fiat-only produkt **bez on-chain vrstvy vůbec**, provoz pod licenci partnera.
- **Měsíce 12+:** vlastní licence financovaná z prokázané trakce, nakoupená custody, on-chain vrstva, nativní klienti, karty.

Návrh, který mám na stole, je dobrá mapa cílového stavu a měl by být zachován jako referenční dokument — konkrétně seznam nevratných rozhodnutí je to nejcennější, co v něm je. Jako plán práce na příštích dvanáct měsíců je ale nefinancovatelný: požaduje kompletní tým a 6–12 mil. EUR dříve, než kdokoli ověří, že o produkt někdo stojí.

Pohled dohledu

Pracovník dohledu čte popis architektury jako přílohu žádosti o licenci a ptá se, co chybí a co si nechá doložit.

Úvodem

To, co jste předložili, je návrh ICT architektury. Žádost o autorizaci CASP podle čl. 62 MiCA a o licenci EMI podle EMD2 to není a ani z 30 % ne. Popis IT infrastruktury je jedna položka ze seznamu příloh; posuzuji ho proti programu činností, obchodnímu plánu, systému správy a řízení, popisu safeguardingu, AML rámci a wind-down plánu — a žádný z nich jsem nedostal. Bez nich nedokážu posoudit ani přiměřenost samotné architektury, protože nevím, jaké činnosti má nést.

Zároveň: kvalita technického uvažování je nadprůměrná a materiál je nezvykle upřímný o vlastních vadách. To vám v posouzení pomůže víc než leštěná prezentace. Následující je proto seznam otázek, ne odmítnutí.

A. Co chybí, aby byla žádost úplná

A1. Perimetr činností. Nikde není uvedeno, o které služby podle čl. 62 MiCA žádáte. Z architektury odvozují úschovu a správu (čl. 75), směnu za peněžní prostředky a převodní služby — tedy třídu 2, tj. 125 000 EUR podle Přílohy IV. Potvrďte výslovně. Bez seznamu služeb nelze určit kapitálovou třídu, rozsah čl. 70 vs. čl. 75, ani co spadá pod PSD2.

A2. Vztah CASP a EMI a stanovisko EBA/Op/2025/08. Držíte-li a převádíte EMT jménem klienta, jde o platební službu. Přechodné období skončilo 1. 3. 2026. Uvedte, do kterého ze tří scénářů stanoviska spadáte k datu podání. Uvedte také, zda hodláte EMT **vydávat** (pak platí čl. 48–55 a plán odkupu podle čl. 55 do šesti měsíců), nebo pouze distribuovat cizí. Architektura má *issuer_id* a nikde neříká, kdo jím je.

A3. Konkrétní aktiva. „Token je řádek v registru“ je dobrý inženýrský princip a zároveň neodpověď na žádost. Autorizace se uděluje na popsanou činnost s popsanými aktivy. Nemohu autorizovat žadatele, jehož nabídka aktiv je „bude rozhodnuto“. Uvedte konkrétní seznam s odkazem na registr ESMA/EBA. Pokud je odpověď XSGD nebo USDT pro klienty v EU, je to problém věcný, nikoli konfigurační. Grandfathering v Litvě skončil 1. 1. 2026; model „spustíme a doplníme“ není dostupný.

A4. Kapitál a vlastní zdroje. Chybí kapitálový plán. Upozorňuji na to, co ve vašich číslech nesedí: uvádíte provozní run rate platformy a dodavatelů 25–40 tis. EUR měsíčně bez lidí, tým 14–25 osob a horizont 24–33 měsíců. Fixní režijní náklady se tím dostanou řádově na 3–4 mil. EUR ročně. Jedna čtvrtina z toho je 750 tis. – 1 mil. EUR — tedy CASP záruka podle čl. 67 je u vás určena písmenem (b), ne částkou 125 000 EUR, a to zhruba šestinásobně. K tomu se **nesčítaně nezapočítává** počáteční kapitál EMI 350 000 EUR a průběžné vlastní zdroje metodou D. Předložte výpočet a doklad zdroje kapitálu.

A5. Governance a substance. Chybí organigram, tři linie obrany, jmenovitě obsazené funkce, fit-and-proper podklady, doklad o litevské právnické osobě, fyzické kanceláři, alespoň jednom členovi vedení s bydlištěm v LT a MLRO jako litevském daňovém rezidentovi. „Compliance je samostatný proces“ je výrok o nasazovací jednotce, ne o nezávislosti MLRO.

A6. Skupinová struktura SG/LT. Popište, kdo systémy fakticky provozuje a kdo zaměstnává vývojáře a administrátory. Pokud singapurská matka drží produkční přístupy nebo JIT eskalaci, jde o vnítruskupinový outsourcing kritické funkce (čl. 73 MiCA, DORA čl. 28–30) a současně o předání do třetí země podle kap. V GDPR — vzdálený přístup je předání, i když se žádný řádek nezkopíruje. Tvrzení „Singapur dostane jen agregáty“ tuto otázku neřeší.

A7. Chybí úplně: obchodní plán a finanční projekce; celopodnikové hodnocení rizik AML/CFT a risk appetite (u koridoru Venezuela–EU je to jádro věci, ne příloha); postup vyřizování stížností podle čl. 71 MiCA a čl. 101–103 PSD2 včetně lhůty 15 pracovních dnů a ADR subjektu v LT; plán řádného ukončení činnosti podle čl. 74 s mapou ICT

závislostí a jejich financováním v run-off; custody policy podle čl. 75(1); politika oceňování pro čtvrtletní výpis z registru pozic; registr informací podle prováděcího nařízení 2024/2956 ve stanoveném formátu, vyplněný; DPIA, ROPA a jmenování DPO; seznam členských států pro passporting podle čl. 65 a jazykový režim (mimoходом — nabízíte CS/EN/ES a nikoli LT; vysvětlete).

B. Tvzení, která chci doložit důkazem

Ke každému uvádím, co uznám. Prohlášení v žádosti neuznám u ničeho z toho.

1. **„Nevyvážený žurnál nelze zapsat.“** Chci DDL, výpis oprávnění (*\dp*) pro všechny role a protokol z útoku na invariant: pokus zapsat nevyvážený žurnál, žurnál v cizí měně a přímý *UPDATE* postingu z každé existující role včetně migrační a DBA. Očekávám selhání ve všech případech nebo přiznání, které role to obejmou.
2. **„Zůstatek je odvozený agregát.“** Chci protokol z plného přepočtu od nuly nad syntetickým rokem provozu a záznam, co systém udělá při zjištěné odchylce — zastaví zápis, nebo pošle alert? Odpověď „alert“ znamená, že máte dvě pravdy o penězích.
3. **„Cena nemůže vzniknout mimo kotaci.“** Chci test, který se pokusí záúčtovat křížoměnový pohyb ve všech čtyřech peněžních cestách bez kotace a s vypršelou kotací.
4. **„Odměna za držení EMT je nevyjádřitelná.“** ENUM žurnálu je slabý důkaz. Zákaz podle čl. 50 dopadá i na nepřímé formy — slevy, prominuté poplatky, lepší spread, věrnostní pásma. Váš *tariff* nemá žádné omezení vstupů. Chci constraint nebo doložený přezkum, který vyloučí, aby cena byla funkcí zůstatku nebo doby držení, plus právní stanovisko.
5. **Srovnání kupní síly.** Chci snímky obrazovek ve všech třech jazycích, přesné znění všech 284 klíčů katalogu dotčených touto funkcí, a právní posouzení proti čl. 50, 53 a 66(4). Lexikální lint na slova „výnos / yield / rendimiento“ nestačí: věta „vaše peníze si udržely hodnotu, zatímco bolívar ztratil 40 %“ je výkonnostní sdělení bez jediného zakázaného slova.
6. **Safeguarding.** Chci potvrzení banky o charakteru účtu, smluvní trust/segregation ujednání, právní stanovisko k insolvenční odolnosti podle litevského práva a záznamy denní rekondiliace. Dále: váš invariant počítá pokrytí proti **vlastnímu** ledgerovému účtu nostro. To je kruhové — chyba ve vlastním účtování vypadá jako pokrytí. Chci pokrytí počítané proti externě potvrzenému zůstatku (camt.053).
7. **Úschova kryptoaktiv.** Jméno custodiana, jeho autorizace podle MiCA (status „v procesu“ není autorizace a je to samostatná otázka), SOC 2 Type II nebo CCSS, pojistný certifikát s limity a výlukami, řetězec sub-custody, smluvní alokace odpovědnosti podle čl. 75(8) a doklad o segregaci klíčů.
8. **Obnova ze zálohy.** Poslední čtyři protokoly týdenního testu obnovy s časy, včetně doložení, že proběhl krok přehrání tombstone journalu a že byl testován.
9. **DORA.** Registr informací v předepsaném formátu; smlouvy s kritickými dodavateli s doložkami podle čl. 30; stanovisko k zařazení do TLPT; poslední pentest; ISO 27001 nebo gap analýza s termíny.
10. **Kryptografie.** Číslo certifikátů FIPS 140-3 modulů, scénář key ceremony s podpisy svědků, doklad, že klíčový materiál pro crypto-shredding neexistuje v žádné záloze ani replice — jinak výmaz zničením klíče nefunguje.
11. **Aktuální demo.** Doložte, zda kdy zpracovalo skutečné klientské údaje nebo prostředky, komu bylo zpřístupněno a jak. Sdílené heslo v cleartextu ve složce synchronizované do OneDrive je nález k dnešnímu dni, ne k cílovému stavu.
12. **Archiv marketingových materiálů.** Ve svém popisu uvádíte, že konstanta 2,4 % p. a. z produktu „už jednou odešla po právní rešerši“. To znamená, že příslib zhodnocení EMT existoval a mohl být komunikován. Chci všechny verze klientských a investorských materiálů, které ho obsahovaly, a seznam adresátů.

C. Rozpory mezi tím, co slibujete, a tím, co architektura umožňuje

C1. Dva různé zápisové kontrakty do téhož ledgeru. Compliance oblast tvrdí databázový constraint vyžadující platné, dosud nespotřebované *decision_id* u každého peněžního zápisu. Ledgerová oblast žádný takový sloupec ani

CHECK nemá a `post_journal()` nemá odpovídající parametr. Dvě části jedné žádosti popisují jinou zápisovou cestu do stejné tabulky. Buď je vynucení compliance smyšlené, nebo je popis ledgeru neúplný.

C2. FX pozice financovaná z ničeho. Ve vašem zaúčtování směny se nakupovaná měna vydává z `fx_position:{buy}`. Nemá-li dům tuto měnu, jde pozice do mínusu — tedy `allow_negative = true`. Vznikne klientský závazek v měně B bez odpovídajícího chráněného aktiva v měně B. Denní kontrola safeguardingu to zachytí až večer a automatický `safeguarding_topup` to vyléčí. Vaše architektura tedy **strukturálně připouští vnitrodenní podkrytí klientských prostředků a považuje ho za normální stav, který se sám opraví**. To je pro mě prudenciální otázka první kategorie. Chci: limity otevřené pozice, politiku financování, potvrzení, že klientské prostředky nikdy nefinancují pozici domu, a frekvenci kontroly krytí jinou než denní. Automatické doplnění, o kterém se nikdo nedozví, je zakrytí incidentu.

C3. Úschova („trezor“) vedle zákazu přijímání vkladů. EMI nesmí přijímat vklady (čl. 6 odst. 2 EMD2) a přijaté prostředky musí neprodleně vyměnit za elektronické peníze. Produkt jménem „úschova / trezor“, členěný po měnách, s vlastní obrazovkou a se srovnáním proti inflaci, je pro retailového klienta v hyperinflační zemi spořicí produkt bez ohledu na to, že v ledgeru je to jen další závazkový účet. Zákaz úročení podle čl. 50 je zde tou menší otázkou. Chci právní posouzení klasifikace produktu.

C4. SCA v F1 neexistuje, produkt v F1 ano. Podle EBA/Op/2025/08 je SCA povinné pro přístup k peněžence a pro převody EMT. Device binding, podpisová vrstva, exemption engine i fraud engine jsou u vás F2. Web jako F1 kanál přitom má umožňovat platby na známé příjemce do limitu — to je uplatnění výjimek podle čl. 13 a 16 bez evidenčního stroje, který je F2. Buď v F1 nespouštíte licencovanou činnost (pak to napište), nebo je F1 by design nesouladné.

C5. Kupujeme custody vs. stavíme podpisovou doménu. Jedna oblast rozhoduje nakoupit custody a nestavět MPC. Druhá rozpočtuje CloudHSM jako kořen důvěry pro on-chain podpisové shares a popisuje vlastní hot/warm/cold domény. Žádost musí popsat jedno faktické uspořádání, ne dvě varianty.

C6. Vlastní smart kontrakty v cestě klientských aktiv. Zásada „nestavíme vlastní kontrakty“ a CREATE2 forwardery vedle sebe neobstojí. Forwarder je váš immutable kontrakt v depozitní cestě. Chci audit, a hlavně odpovědi na: co se stane při chybě v immutable forwarderu (adresa klienta je trvale nepoužitelná?), co při příjmu jiného než konfigurovaného tokenu, co u fee-on-transfer tokenu.

C7. Výmaz vs. depozitní adresa. Mažete mapování adresa↔klient. Poté přijde platba na tu adresu. Prostředky sednou v omnibusu bez majitele a bez možnosti atribuce, přičemž AML povinnost k nim trvá. Postup chybí. Zároveň: adresa je deterministicky odvozená z `client_id` — po opětovném onboardingu téhož klienta dostanete tutéž adresu, kterou jste prohlásili za nikdy znovu nepoužitou.

C8. Retence má v jedné žádosti tři různá čísla (5 let, 10 let, řádek s `valid_from`), a datová oblast cituje **zákon č. 253/2008 Sb. a ČNB**. Pro litevskou entitu je to irrelevantní právo a irrelevantní orgán. Dokument evidentně vznikl pro český perimetr a nebyl adaptován. To beru jako signál o pečlivosti celé žádosti.

C9. „V ledgeru nejsou osobní údaje“ vs. schéma `statement_line`, které nese `counterparty_ref` a symboly přímo. V témže odstavci tvrdíte, že tyto údaje leží odděleně v `payment_instruction`. Vyjasněte.

C10. Hyperinflační sazba jako „datovaný rozhodnutý fakt“. Rozhodnutím koho a podle jakých zveřejněných kritérií? Sazebník publikujete před účinností, ale spouštěč jeho aplikace je vaše interní rozhodnutí, které mění cenu klientovi. To je jednostranně určená cenová podmínka. Chci objektivní, ověřitelná a zveřejněná kritéria a oznamovací lhůtu.

C11. Zaokrouhlovací zbytek jako výnosový účet. U VES se škálou 0 není zbytek zanedbatelný. Chci rozdělení znaménka `rounding_income` vs. `rounding_expense` na simulovaném roce. Pokud je klient systematicky na ztrátové straně, je to otázka podle čl. 66 MiCA, ne otázka přesnosti.

D. Opatření, která budu vyžadovat navíc

1. Vnitrodenní kontrola krytí safeguardingu proti externě potvrzeným zůstatkům, s tvrdým zastavením nové expozice při podkrytí a s okamžitým hlášením — ne s automatickou tichou opravou.
2. Limit otevřené FX pozice per měna a per den, schválený vedením, s doložením, že klientské prostředky pozici nefinancují.
3. Zákaz cenových podmínek závislých na zůstatku nebo době držení vynucený ve schématu sazebníku, ne jen v ENUMu žurnálu; k tomu registr marketingových a notifikačních šablon se jmenovaným schvalovatelem z compliance a s auditní stopou (dnes nemá vlastníka).
4. Předsunutí do F1: SCA včetně dynamic linkingu, evidence výjimek, sankční screening, travel rule, klasifikační služba incidentů a rekondilační stroj. Všechno to jsou vstupní podmínky provozu, ne optimalizace.
5. Kopie neměnného audit trailu u druhého poskytovatele, nikoli jen kopie Merkle kořene. Jiný AWS účet není jiný dodavatel a koncentrační riziko podle čl. 29 DORA tím nezmizí.
6. Testovaný exit plán z AWS, nebo formální akceptace substitučního rizika statutárním orgánem — vaše compliance argumentace stojí na CloudHSM, Object Lock v Compliance režimu, Backup Vault Lock a KMS custom key store, tedy přesně na tom, co je nepřenositelné.
7. Nezávislé ověření podvojných invariantů třetí stranou před spuštěním (dnes v repozitáři neexistuje jediný test — to je stav vašeho kontrolního prostředí, jakkoli se cílový stav popisuje jinak).
8. Procedura obnovy přístupu s doloženou SLA a s alternativou pro klienta, který v karanténě 24–72 hodin potřebuje odeslat remitenci; a popis „papírové cesty R6“ včetně kontrol — papírový kanál do obnovy účtu je klasický podvodný vektor.
9. Politika k OFAC. U venezuelské klientely to není otázka rizikového apetitu, ale rozhodnutí, které chci vidět písemně, včetně vztahu k unijnímu blokačnímu nařízení.
10. Test nerozlišitelnosti stavů z pohledu klienta: zadržená platba, sankční zámek a šetření musí být pro klienta nerozlišitelné včetně časování odezvy. Váš jednotný chybový kód to sám o sobě nezajišťuje, protože stav prosakuje do projekce životního cyklu a do výpisu.

E. Co vede k dalšímu kolu dotazů

Otevřeně: takto podaná žádost projde nejméně dvěma koly, a to i při plné součinnosti. Důvody v pořadí významu:

1. **Nerozhodnutý token a nerozhodnutá jurisdikce.** Toto je ta jediná věc, kterou konfigurovatelnost nenahradí. Dokud nevím, jaké aktivum komu nabízíte, není co posuzovat, a lhůta 25 + 40 pracovních dnů podle čl. 63 mi ani nezačne běžet.
2. **Rozpory uvnitř materiálu (C1, C5, C8).** Když dvě části popisují jinou zápisovou cestu do ledgeru a jinou retenci, musím se ptát na obojí a k odpovědi nemám důvod přistupovat jinak než skepticky.
3. **České právo a ČNB v litevské žádosti.** Vyvolá to plošnou kontrolu, zda i zbytek právních odkazů odpovídá skutečnému perimetru.
4. **Fázování, které odsouvá povinné kontroly za spuštění.** Každá položka v F2 nebo F3, která je právní povinností od prvního klienta, je jeden dotaz.
5. **Věřohodnost zdrojů.** Tým 14–25 lidí má podle tohoto návrhu postavit a provozovat čtrnáct AWS účtů, vlastní PII trezor, vlastní SCA orchestrátor, vlastní uzel Etherea, self-hostovanou observabilitu a Rekor, tři klientské aplikace, back-office, compliance nástroje a k tomu tři linie obrany s nezávislým interním auditem. Nevěřím tomu a zeptám se na plán zdrojů, na to, co bude v okamžiku autorizace skutečně živé, a kdo konkrétně je nezávislý interní audit.
6. **Dodavatelé jmenovaní bez smluv.** Fireblocks, Copper, Zodia, iDenfy, Sumsu, ComplyAdvantage, Enfuze, Alchemy, Infura, Chainalysis — bez smluv, bez posouzení kritičnosti, bez exit plánů a bez řetězce subdodavatelů. Registr informací se předkládá vyplněný.
7. **Kapitálový výpočet podle písmene (b) čl. 67,** který ve vašich vlastních číslech vychází řádově jinak, než na co se zjevně plánuje.

Doporučení, které myslím vážně: nepodávejte, dokud nepadne rozhodnutí o aktivu a o licenčním perimetru, a dokud nemáte program činností a wind-down plán. Architektura je na podání připravenější než organizace, a to je u této žádosti ten menší problém.

Kde se to rozbije

Architekt po post-mortemech platebních systémů hledá konkrétní scénáře selhání, ne obecné výhrady.

Kde se to rozbije

Návrh má silné invarianty *uvnitř* každé oblasti a skoro žádného vlastníka životního cyklu *napříč* nimi. Proto skoro všechny scénáře níže sedí na švech: mezi DB a sítí, mezi ledgerem a řetězcem, mezi kotací a podpisem, mezi regionem a regionem. Druhý kořen je systematický: **`bigserial`/sekvence se v návrhu na třech místech používá jako by znamenala pořadí commitů — neznamená.** Třetí je, že skoro každá bezpečnostní kontrola je fail-closed a nikdo nesečetl, kolikrát ročně to dohromady zastaví výběry.

A. Kde peníze zmizí nebo se zdvojí

A1. Failover do eu-west-1 s RPO ≈ 1 s nad nevratným on-chain broadcastem.

Aurora Global Database je asynchronní. Sekundu potvrzených žurnálů lze při neplánovaném failoveru ztratit. V té sekundě se ale mohl stát nevratný vnější efekt: podepsaná a odvysílaná on-chain transakce, odeslaná SEPA instrukce, capture do schématu. Po failoveru ledger tvrdí, že se to nestalo, klientský zůstatek je zpátky, a peníze jsou pryč. Horší varianta přes nonce: tabulka `onchain_tx` ztratí řádek s nonce N, gateway po startu přečte z DB nonce N a přidělí ho *jinému* klientovi. V mempoolu jsou dvě transakce na stejný nonce s různými příjemci; potvrdí se jedna. Jeden klient dostane výběr, který mu ledger nepřipsal, druhý má v ledgeru odchozí převod, který nikdy neproběhl — a `eth_getTransactionCount` po startu nesouhlasí, takže se podle vlastního pravidla zastaví celá fronta výběrů.

Návrh si navíc protiřečí: v RTO/RPO tabulce má „platby a ledger RPO ≈ 0 “, v textu o DR „RPO ≈ 1 s“.

Chybí: pravidlo, že žádný nevratný vnější efekt nesmí předcházet *replikovanému* commitu (buď synchronní potvrzení sekundáru pro peněžní žurnály, nebo broadcast až z workeru čtoucího z replikovaného stavu); povinná rekonziliace proti řetězci, bance, PSP a schématu jako *podmínka* obnovení provozu po failoveru, ne jako noční job; a nonce alokace jako explicitní stavový záznam (reserved/broadcast/abandoned) s tvrdou vazbou 1:1 na intent, který přežije failover.

A2. Díra v outboxu: zaúčtováno, ale nikdy neoznámeno.

`outbox(id bigserial)` + pollovací relay. Hodnota sekvence se přiděluje *před* commitem. Transakce, která dostala id 997, může commitnout až po transakci s id 1002. Relay, který si drží kurzor „naposledy publikováno 1002“, událost 997 nikdy neuvidí. Konkrétní dopad: platba je zaúčtována, ale sága se nikdy neposune do `submitted`, notifikace nedorazí, rekonziliční konzument nikdy nedostane událost — a protože ledger sedí, žádná kontrola to nezachytí. Objeví se to jako „klientovi odešly peníze a nic se nestalo“ jednou za pár tisíc transakcí, tedy přesně v hustotě, která se ladí půl roku.

Chybí: relay bez monotónního kurzoru — `published_at IS NULL + FOR UPDATE SKIP LOCKED`, nebo viditelnost přes `pg_current_snapshot()/xmin`. A test, který to reprodukuje: dvě souběžné transakce s vynuceným opačným pořadím commitu.

A3. Dvě idempotenční vrstvy na dvou různých klíčích.

Oblast 2 říká, že BFF *terminuje* `Idempotency-Key` a jeho úložiště je Redis s TTL 7 dní („Redis může vypadnout, TTL může vypršet“). Oblast 1 říká, že idempotenční řádek commituje ve stejné transakci jako žurnál. To nejde obojí — Redis nelze commitnout s Postgresem. Pokud BFF klíč spotřebuje a dolů posílá vlastní volání s vlastním identifikátorem, je databázová záruka na jiném klíči než klientská a *nechrání před ničím*: výpadek Redisu při retry klienta = dvojitá zaúčtování. Navíc tři různé retence pro totéž: 90 dní (oblast 1), 7 dní (oblast 2), „minimálně 24 hodin“ (oblast 7).

Chybí: rozhodnutí, že klientský *Idempotency-Key* se propaguje *beze změny až do request.request_id* a BFF ho nesmí terminovat ani přemapovat; jedna retenční hodnota; a explicitní zákaz Redisu jako autority (smí být jen cache před DB).

A4. Re-kotace zablokuje platbu natrvalo (fingerprint × klíč-na-záměr).

Oblast 1: *request_fingerprint* = hash kanonizovaného těla; jiný otisk se stejným klíčem = 409. Oblast 7: klíč se generuje **per uživatelský záměr** a persistuje se před prvním odesláním. Kotace vyprší za 90 s. Uživatel podepíše, spojení spadne, klient si vyžádá novou kotaci a znovu odešle *stejný záměr* se **stejným klíčem** a **jiným tělem** → trvalé 409. Klient podle vlastního ADR nesmí klíč regenerovat, protože to je „týž záměr“. Platba je nezaseknutelně mrtvá a chybová hláška říká „konflikt“.

Chybí: definice, co přesně je „záměr“ — buď je *quote_id* mimo otisk (a pak se validita ceny řeší jinde), nebo se klíč odvozuje od *intent_id* a re-kotace zakládá nový pokus pod tímž intentem. A pravidlo, že 409 na idempotenci klient nikdy nesmí ukázat jako chybu, ale musí přejít na stavový dotaz.

A5. Chargeback a SEPA recall proti prázdnému účtu nejdou zaúčtovat.

CHECK(allow_negative OR balance >= 0) na klientském závazkovém účtu znamená, že žurnál, který klienta debetuje bez krytí, databáze odmítne. Jenže vrácení karetní transakce, R-transakce, dodatečné doučtování poplatku schématu a soudní příkaz jsou přesně tohle a v praxi přicházejí poté, co klient účet vyprázdnil. Systém fyzicky nedokáže zaúčtovat skutečnost, která se stala. Provoz to obejde adjustmentem na *client_receivable* — ale to není v návrhu popsáno, takže to vznikne ad hoc a bez pravidel, kdy se pohledávka uznává a jak se vymáhá.

Chybí: typová matice „který typ žurnálu smí na kterém účtu způsobit debet bez krytí“ (ne globální *allow_negative*), definovaný přechod na *1200 client_receivable* včetně toho, kdo ho schvaluje, a jak se pohledávka objeví na výpisu a v safeguardingu.

A6. Částečný capture karty × zákaz částečného storna.

Autorizace 100, capture 80 je normální stav, ne výjimka. Návrh povoluje jen úplné storno a přeúčtování. Mezi stornem blokace (klientovi se vrátí 100 do disponibilního) a novým zaúčtováním 80 existuje okno, ve kterém klient může 100 utratit — a v hyperinflační zemi ho utratí. Pokud je to jedna transakce, je to v pořádku, ale návrh popisuje storno jako *opravný postup*, ne jako atomické primitivum.

Chybí: buď first-class typ „částečné uvolnění blokace“ (což je v kartách standard), nebo tvrdý zápis, že storno + přeúčtování je vždy jedna transakce v *post_journal*. A vlastník expirace autorizací — dnes ji nikdo nemá, takže blokace zůstanou viset navždy.

A7. Float na depozitních forwarderech není v účtové osnově — invariant čl. 75 nikdy nesedne.

Oblast 4 zavádí CREATE2 forwardery, oblast 1 má jen *onchain:{hot|warm|cold}* a *in_flight*. Tokeny, které dorazily na forwarder a ještě nebyly sweepnuté, nejsou na žádném z těch účtů. Přitom *onchain_in* debetuje *onchain:hot*. Takže od okamžiku prvního depozitu je invariant *SUM(client:emt) + house = SUM(onchain:*)* porušený o objem nesweepnutých vkladů — permanentně, u každého klienta. Proof of reserves i denní rekonsiliace budou hlásit break, který nemá řešící žurnál, a protože se break „zavírá výhradně ukázáním na žurnál“, zůstane otevřený. Do měsíce je fronta breaků nepoužitelná.

Chybí: třída účtů pro nesweepnutou depozitní držbu (*1035 onchain:deposit_forwarder:{token}*), sweep jako vlastní typ žurnálu mezi ní a cold, a rozhodnutí, jestli forwarder float patří do čl. 75 registru (patří — je to klientův majetek v naší kontrole).

A8. Spálený nonce zastaví celou frontu výběrů.

Nonce se bere z DB sekvence „ve stejné transakci“. Sekvence se nerollbackují. Jakýkoli rollback po *nextval* (deadlock, timeout, selhání policy enginu, restart) spálí nonce N. Nonce N už nikdy nikdo neodvysílá, takže transakce N+1, N+2... zůstanou v mempoolu navždy. A protože platí pravidlo „neshoda s RPC = zastav a alertuj, nikdy

nedopočítávej", odblokování vyžaduje ruční 0-hodnotovou transakci na spálený nonce — což je podpisová operace, kterou vlastní monitoring vyhodnotí jako „odchází transfer bez odpovídajícího žurnálu" a spustí circuit breaker.

Chybí: nonce jako řádek v tabulce s explicitními stavy a možností vrátit ho do poolu při rollbacku (ne sekvenční); předschválený „nonce plug" postup s vlastním typem záměru, který monitoring zná; a pravidlo, že opuštění nonce je vždy lidské rozhodnutí, nikdy timeout.

A9. ADR-08 (vlastní nonce serializer) je neimplementovatelné s ADR-01 (koupená custody).

Fireblocks, Copper ani Zodia vám nedovolí diktovat nonce, gas ani RBF — spravují je samy. Celý argument „stejný záměr → bajtově identická transakce → síť deduplikuje" tím padá a idempotence vůči síti se stává vlastností dodavatelova *externalTxId*, tedy vlastností, kterou neřídíte a nemůžete testovat. Stejně tak ADR-05: forwardery vyžadují vlastní deployer klíč a vlastní gas sponzoring mimo custody model.

Chybí: rozhodnout to teď. Buď se ADR-08 a ADR-05 přepíšou na „idempotence vůči dodavateli přes jeho ID + naše mapování intent→externalTxId", nebo se přizná, že hot/warm cesta je vlastní podepisování a kupuje se jen cold.

A10. Prázdná hot peněženka: výběr záúčtování, nevykonatelný.

D client:emt / C onchain:in_flight bilancuje i tehdy, když na hot adrese nic není — nedostatek se projeví až u sweep-out žurnálu, tedy pozdě. Doplnění z warm je dávkově 2× denně se čtyřma očima a reaktivní doplnění z cold je *zakázané*. Při běžné výplatní špičce (remitenční produkt má odtok koncentrovaný do dvou dnů v měsíci) tedy klient dostane potvrzený výběr, který se hodiny nepohne. U EMT s právem na odkup v nominální hodnotě to není provozní nepříjemnost.

Chybí: kontrola proti *hot likviditě* už při vydání kotace/intentu (ne až při účtování), zveřejněné ETA a fronta jako součást produktu, a definovaná nouzová cesta doplnění, která není *zakázané* reaktivní čerpání z cold — např. předschválené warm→hot okno vázané na p99 odtoku, ne na lidský podpis.

B. Kde se rozejdou dvě pravdy

B1. `running\_balance` na výpisu nesedí s pořadím commitů.

journal.seq je ze sekvenční a smí mít mezery — přiděluje se před commitem. Kumulativní zůstatek na *statement_line* řazený podle *seq* bude u souběžných zápisů na jeden účet v jiném pořadí než skutečné aplikování zůstatku. Klient uvidí historii, jejíž poslední řádek nesedí s aktuálním zůstatkem. Je to stejná příčina jako A2.

Chybí: samostatný *applied_seq* přidělovaný uvnitř *post_journal* až po aktualizaci zůstatku (pod tímtež zámkem řádku *account_balance*), a explicitní zákaz řadit klientskou historii podle *seq* nebo *effective_at*.

B2. Intercompany se denně nevynuluje — konstrukčně.

Obchodní datum je institucionální podle časového pásma entity. Singapur a Vilnius se liší o 5–6 hodin, tedy zhruba čtvrtina pohybů padne na různé obchodní dny. Denní rekonsiliace *intercompany_due_to / due_from* na nulu proto nemůže vyjít nikdy, a protože se break zavírá výhradně žurnálem, timing rozdíly se nedají zavřít vůbec.

Chybí: taxonomie breaků s kategorií „časový rozdíl" a aging politikou, průchozí účet pro položky v transitu a automatické párování při dorazu protistrany. Bez toho se pravidlo „vyřešeno ručně neexistuje" poruší v prvním týdnu a už se neobnoví.

B3. Sdílená cenová knihovna na klientovi × ADR-C2.

Oblast 2 zavádí „verzovanou knihovnu čistého výpočtu sdílenou mezi serverem a klientem" pro předběžné zobrazení. Oblast 7 zakazuje klientovi počítat spread a poplatek. To jsou opačná rozhodnutí. Praktický dopad: klient s cachovanou starší verzí sazebníku ukáže náhled, který se liší od serverové kotace v *displayBlock* — podpis je sice bezpečný, ale uživatel viděl dvě různá čísla během jednoho toku. Ve třech jazycích a s hyperinflační měnou to je stížnostní generátor.

Chybí: jedno rozhodnutí. Doporučuji ADR-C2 a knihovnu zrušit: kotace je levná, náhled bez ceny je poctivější než náhled s jinou cenou.

B4. Tři různé definice, kdy je on-chain vklad „skutečný“.

Oblast 1 účtuje *onchain_in* „hned po zachycení“ (0 potvrzení). Oblast 4 účtuje až po *safe* a disponibilní až po *finalized*. Oblast 6 měří SLO „do 25 min po finalitě“. Když se účtuje na *onchain:hot* při nule potvrzení, rekonciliace ledger vs. RPC porovnává zůstatek včetně nepotvrzených peněz proti zůstatku, který je neobsahuje — a reorg pak stornuje žurnál, který už vstoupil do proof of reserves.

Chybí: jeden tag jako normativní pro každý typ zápisu, zapsaný v *chain_policy*, a pravidlo, že rekonciliace proti řetězci se počítá ke stejnému tagu, ke kterému se účtuje.

B5. Stripy domovních účtů: buď falešné odmítnutí, nebo žádná kontrola krytí.

64 řádků, výběr *hash(request_id) % 64*. Pokud stripe zdědí *allow_negative = false* (nostro, safeguarding), jednotlivý stripe půjde do mínusu při součtu v plusu a databáze legitimní transakci odmítne — náhodně, podle hashe. Pokud *allow_negative = true*, zmizí kontrola krytí nostro účtu úplně. Navíc **storno má jiný `request\_id` než originál**, takže padne na jiný stripe: pár žurnálů, který má být na účtu nulový, po sobě nechá dva nenulové stripy a drift roste monotónně.

Chybí: stripe se odvozuje z *ledger_account_id* cílového protiúčtu nebo z původního žurnálu (storno *musí* trefit stejný stripe), kontrola krytí u strippovaných účtů se dělá na agregátu jinou cestou než check constraintem, a stripování se vůbec nepoužívá na účty, kde krytí něco znamená.

B6. Merkle atestace nekryje to, co se opravdu dá přepsat.

Atestují se žurnály. *account_balance* — jediná tabulka, ze které se rozhoduje o krytí a která se klientovi zobrazuje — atestovaná není a její neshoda se odhalí až nočním přepočtem. A celá „strukturální nemožnost“ stojí na funkci *SECURITY DEFINER*, kterou jedna migrace přepíše. Cesta pro DDL do produkční DB v návrhu není oddělenou schvalovací doménou; deploy job má typicky elevated credentials.

Chybí: DDL na ledgerovém schématu jako samostatná maker-checker doména s jiným okruhem lidí než aplikační release; hash těla *post_journal* a definice triggerů v atestované dávce a jeho kontrola za běhu; alarm na změnu *pg_proc/pg_trigger*, ne jen na *session_replication_role*. A hash chain přes Kinesis Firehose (oblast 6) pořadí negarantuje — buď řetězec per shard s epochou, nebo Merkle per dávka jako u ledgeru.

C. Fail-closed kaskády a chování při přetížení

C1. Compliance jako DB constraint zastaví i storna a safeguarding.

„Ledger má constraint, který zápis bez platného, dosud nespotřebovaného *decision_id* odmítne.“ Pokud to platí pro všechny žurnály, pak při výpadku screeningového dodavatele nejde zaúčtovat ani *reversal* chybného zápisu, ani *safeguarding_topup* při podkrytí, ani *fx_revaluation*, ani *opening*. Tedy: dodavatelský výpadek vám zablokuje nápravné operace přesně v okamžiku, kdy je potřebujete.

Druhá vada: rozhodnutí je jednorázové a compliance má vlastní DB (oblast 2). Spotřeba rozhodnutí tedy není ve stejné transakci jako žurnál. Při rollbacku transakce je rozhodnutí spálené a retry se stejným idempotenčním klíčem dostane compliance zamítnutí — které je záměrně neinformativní („compliance/operation_unavailable“), takže ani support klientovi neřekne, proč mu platba zmizela.

Chybí: explicitní množina systémových typů žurnálu vyňatých z brány; spotřeba rozhodnutí ve stejné transakci jako posting (tedy rozhodnutí *musí* mít materializovaný záznam v ledgerové DB, byť rozhoduje jiná služba); break-glass se čtyřma očima, který je sám evidovaným rozhodnutím; a pravidlo, že spotřeba se váže na *request_id*, ne na jeden pokus.

C2. Sedm nezávislých circuit breakerů, žádná matice.

Automaticky zastavují provoz: *Upgraded* event na proxy tokenu, depeg > 50 bps, neshoda mezi RPC zdroji, neznámý odchozí transfer, výpadek screeningu, výpadek travel-rule protistrany, překročení rolling limitu. Emitenti (i Circle) proxy upgradují rutině. 50 bps je při tržním stresu běžná odchylka. RPC provider běžně zaostává o pár bloků — což není fork, ale pravidlo „neshoda = zastavit připisování“ to nerozlišuje. Součet: několik plných výpadků výběrů ročně, každý z nich pravděpodobně závažný ICT incident podle 2024/1772 se čtyřhodinovou lhůtou, a u EMT navíc kolize s právem na odkup.

Chybí: odstupňovaná matice (zastavit co — příjmy, výdeje, nebo jen dané aktivum), rozlišení „lag vs. fork“ s kvórovým pravidlem, allowlist známých bytecode hashů emitentů s předschválenou cestou obnovy, a spočítaný roční rozpočet výpadků z těchto pravidel s explicitním rozhodnutím, že je akceptovatelný.

C3. Kotace 90 s × SCA grant 120 s × stáří kurzu 30 s.

Tři různé životnosti na jeden uživatelský úkon. Na pomalém mobilním spojení v Caracasu vyprší kotace po biometrickém podpisu pravidelně. Kdo nese kurzový posun mezi náhledem a zaúčtováním, není nikde napsáno. A protože SLO říká „stáří kurzu < 30 s“, při výpadku kurzového feedu nebo prudkém pohybu se kotování zastaví — tedy produkt se vypne přesně v okamžiku, kdy klienti nejvíc chtějí konvertovat. Sazebník navíc nejde změnit rychle, protože *CHECK(published_at <= valid_from)*.

Chybí: TTL kotace ≥ TTL grantu; pravidlo pro re-kotaci bez nového SCA, pokud nová cena není pro klienta horší (a rozhodnutí, jestli je to právně únosné); a **stav „kotování pozastaveno“ oddělený od změny sazebníku**, protože pozastavení není změna ceny a nesmí podléhat publikační lhůtě.

C4. Retry storm zabudovaný do kontraktu.

Oblast 1: *state='in_progress'* → 409 s pokynem opakovat. Oblast 7 ADR-C6: při nejistotě se **neopakuje**, volá se stavový dotaz. Klient dostane dvě protichůdné instrukce. Když je DB pomalá, počet in_progress roste, klienti podle prvního pravidla retryují, retry prodlužuje in_progress. Klasická samozesilující smyčka a jediné, co ji zastaví, je rate limiter, který zároveň odřízne legitimní stavové dotazy.

Chybí: jedno pravidlo (stavový dotaz, nikdy retry confirmu), povinné *Retry-After* s jitterem v kontraktu, a oddělená kvóta pro stavové dotazy, aby se nezhazovaly spolu s mutacemi.

C5. Fronty s lidmi jako skutečný SPOF.

Ruční revize KYC (SLO 24 h), odvolání s jiným posuzovatelem, obnova zařízení cestami R5/R6 s videohovorem a čtyřma očima, manual_review u nekompenzovatelné on-chain nohy, schvalování warm→hot, rozhodování breaků. Při týmu 14–25 lidí je compliance tým reálně 2–4 lidé. Kampaň, incident nebo devalvace VES vytvoří špičku, která tyto fronty zahltní — a všechny jsou fail-closed.

Chybí: kapacitní model pro každou lidskou frontu (příchod, doba obsluhy, počet lidí, chování při zahlcení) a definované degradační chování — co se stane, když fronta obnovy má 400 lidí a SLA je 72 hodin.

C6. Obnova přístupu: nejhorší den klienta.

Legitimní uživatel, kterému ukradli jediný telefon, nikdy nepřidal důvěryhodného příjemce a jeho účet je jeho výplata. Po obnově má 72 hodin karanténu, nesmí vytvořit nový cíl platby a výplata jde jen na destinaci whitelistovanou před zahájením obnovy — tedy nikam. To je hlavní cílový uživatel produktu. Zároveň: kill-switch a všechna oznámení jdou na e-mail/SMS, tedy na kanály, které si návrh sám správně prohlásil za nedůvěryhodné; útočník, který převzal schránku (typický scénář), oběť nikdy neinformuje.

Chybí: definovaná nouzová výplatní cesta v karanténě (např. na účet ověřený bankovní identitou/eIDAS na stejné jméno — to není „nový cíl“, to je doložená identita); oznamovací kanál, který si útočník nevybírám (poštovní adresa, ostatní registrovaná zařízení); a **pozitivní potvrzení** místo „mlčení znamená souhlas“.

Dále: čítač 5 neúspěšných pokusů vázaný na subjekt je zamykací DoS. Musí se inkrementovat až po prokázání držení *k_dev*, jinak vám kdokoli se znalostí identifikátoru zamkne klienta.

D. Migrace a schéma s penězi v letu

D1. `journal_type` jako ENUM je compliance control, který jde jen zvětšovat.

Zákaz úročení stojí na tom, že hodnota v ENUMu neexistuje. Jenže do Postgres ENUMu se hodnota jen přidává, nikdy neubírá, a přidání nejde rollbacknout v transakci. Omylem nebo pod tlakem přidaná hodnota je v datovém modelu navždy a v migračním PR je to jeden řádek, který v code review vypadá nevinně.

Chybí: ENUM nahradit referenční tabulkou typů s `valid_from/valid_to` a čtyřočním schvalováním *obsahu* (což je stejná ochrana, ale reverzibilní a auditovatelná), plus CI kontrola, která na změnu množiny typů vyžaduje podpis compliance, ne jen review.

D2. Canary 5 % = dva různé tvary žurnálu v jednom dni.

Když se změní recept noh (jiné rozdělení spread/fee, jiný protiúčet), běží stará a nová verze současně nad jedním ledgerem. Vše, co odvozuje výpisy, výnosy a rekongiliaci pattern-matchingem na tvar noh, se na smíšeném dni rozbije — a najde se to až při měsíční závěrce.

Chybí: `posting_recipe_version` na žurnálu, receptura jako verzovaný append-only artefakt, a pravidlo expand/contract: nový recept se nasazuje jako nová verze, čtenáři musí umět obě, staré se nikdy nemění.

D3. Redenominace VES s otevřenými blokacemi a platbami v letu.

Návrh správně říká „nové `asset_code` + povinný konverzní žurnál“. Neříká, co se stane s tím, co je v okamžiku přepnutí rozpracované: karetní autorizace na `client:hold` ve staré měně, nezúčtované příchozí, čekající travel-rule, otevřené kotace, karetní limity, sazebník, `asset_economic_status`, uzavřené statement periody. A konverzní žurnál je křížoměnový, takže `CHECK` bude vyžadovat `quote_id` — jenže pro redenominaci žádná tržní kotace neexistuje, je to dekretovaný kurz. Buď se udělá fiktivní kotace (a tím se zředí smysl kontroly), nebo se to nedá zúčtovat.

Chybí: runbook redenominace jako součást návrhu (VES to udělal třikrát od 2008, je to jistota, ne riziko): zmrazovací okno, vynucené uzavření všech holdů a in-flight položek před přepnutím, typ kotace „decreed“ s vlastním schvalovacím režimem, a pravidlo pro hranici statement periody.

D4. Obnova ze zálohy je popsána jen do poloviny.

Týdenní test obnovy do izolovaného účtu je správně. Ale konzistentní bod obnovy musí zahrnout ledger, compliance DB, Party&KYC, KYC objekty, shred store a stav řetězce — a shred store má schválně Pitr ≤ 24 h, zatímco ledger 35 dní. Hlavně: obnova ledgeru na T-10 dní je bez následné dopředné rekonstrukce **k ničemu**, protože řetězec, karetní schéma a banka mezitím deset dní žily svým životem a jsou nevratné. Tombstone journal řeší jen výmazy.

Chybí: popsáný forward-recovery postup — ledger musí být rekonstruovatelný z vnějších důkazů (camt.053, clearingové soubory, indexer, PSP), včetně pořadí a toho, co se stane s idempotenčními klíči a spotřebovanými rozhodnutími v přehrávaném okně. A definice, že Pitr delší než minuty je pro peněžní jádro nepoužitelný bez tohoto postupu.

D5. Přepočet od nuly přestane být možný po pěti letech.

Měsíční plný přepočet ze zápisů + odpojování partitions po pěti letech + `3020 opening_balance` jen pro genesis znamená, že po roce 5 je „přepočet od nuly“ ve skutečnosti přepočet od nejstarší živé partition a jakákoli chyba před tím bodem je nedetekovatelná navždy.

Chybí: periodické atestované `opening_balance` žurnály na hranici archivace, se stejným Merkle podpisem jako běžné žurnály.

E. Ostré hrany, které se projeví až v provozu

E1. Karanténa a travel-rule suspense: čím to jsou peníze.

Příchozí prostředky se sankčním zásahem se drží a nikdy nevracejí. Self-hosted vklad nad 1 000 EUR, u kterého klient nikdy nedoloží kontrolu adresy, nemá terminální stav. Vzniká rostoucí objem peněz, které nejsou klientovým disponibilním zůstatkem, nejsou naše, nejsou v čl. 75 registru a v safeguarding invariantu jsou podle výkladu buď na obou stranách, nebo na žádné. Navíc invariant slévá dva právní režimy: safeguarding EMI (fiat u úvěrové instituce) a custody podle MiCA (token na adrese) — mají jiné testy krytí i jiná nápravná opatření.

Chybí: oddělené testy krytí pro fiat a pro kryptoaktiva; explicitní zařazení karantény a suspense do obou; a terminální stav s lhůtou (kdy se z toho stane deponovaná částka, kdo o tom rozhoduje a jak se to vykazuje).

E2. Crypto-shredding neplatí na vyrenderované artefakty.

Výpis je neměnný PDF s hashem v úložišti, *payment_instruction* je odděleně šifrovaná. Ale PDF obsahuje jméno protistrany a IBAN v otevřené podobě, stejně jako archivované ISO 20022 zprávy a travel-rule payloady. Zničení klienta DEK je nezničí. Navíc *request.response_body_jsonb* archivovaný „trvale“ obsahuje odpovědi API včetně částek a příjemců — to je nepojmenované PII úložiště s nekonečnou retencí.

Chybí: každý vyrenderovaný artefakt šifrovaný pod DEK subjektu (a pak je shredding konzistentní), *request_archive* bez těla odpovědi (jen hash), a přiznání, že u AML kategorií se výmaz stejně odmítá — což je v pořádku, ale pak nelze tvrdit, že shredding řeší výmaz plošně.

E3. Ekonomika sweepu zabije remitenční produkt dřív než regulace.

Finalita 12,8 min, Alchemy/Infura, gas jako náklad — to je Ethereum L1. Medián remittance je desítky eur. Nasazení forwarderu + sweep při špičkovém gasu stojí víc než vklad. Gas navíc drahne přesně tehdy, když roste odtok. A sponzorský/deployer EOA, který gas platí, je hot klíč mimo custody model, mimo MPC, a když vyschne, přestanou se sweepovat všechny vklady — což neztratí peníze, ale trvale rozbije čl. 75 invariant a proof of reserves.

Chybí: minimální výše vkladu nebo dávkové sweepty s ekonomickým prahem; volba řetězce jako *produktové* rozhodnutí (ne jen konfigurační řádek — finalita a cena jsou zabezpečeny v ADR-04 a v nákladovém modelu); a vlastník, monitoring a doplňování gas sponzora včetně toho, kdo ho podepisuje.

E4. Zmrazení forwarderu emitentem.

USDT i USDC umí zablokovat adresu. Zablokovaná depozitní adresa jednoho klienta je trvale otrávená a v návrhu není žádná cesta rotace — adresa je deterministicky odvozená z $H(client_id, asset, chain, verze)$, takže rotace je změna verze, ale nikde není popsáno, kdo ji spouští, co se stane s prostředky na staré adrese a jak se klientovi řekne, že jeho adresa, kterou dal odesílateli, už neplatí.

Chybí: procedura rotace depozitní adresy při zmrazení nebo kontaminaci, včetně komunikace odesílateli a účetního osudu uvíznuté částky.

E5. PCI rozsah se rozhoduje na obrazovce, o které návrh mlčí.

„PAN, CVV a PIN u nás nejsou“ — ale virtuální kartu musí klient někde přechíst, aby ji použil. Buď to renderuje SDK vydavatele v klientské aplikaci (pak je aplikace v rozsahu), nebo to teče přes BFF (pak je BFF v rozsahu, a s ním celý Core, protože Cards je *modul* v *Core* a modul nemůže mít vlastní síťový segment). Rozhodnutí „Cards je modul v Core s vlastním síťovým segmentem a PCI rozsahem“ je vnitřně rozporné.

Chybí: popsaný mechanismus zobrazení karetních údajů a z něj odvozený PCI rozsah — a pokud má být Cards mimo Core, je to samostatná nasazovací jednotka, ne modul.

E6. Srovnání kupní síly je nejlepší kandidát na mis-selling.

Negeneruje posting, správně. Ale zobrazuje se jako číslo vedle zůstatku ve třech jazycích a odvozuje se ze zveřejněné inflace — bez ohledu na spread a poplatek, které klient při vkladu do Safe Money a při výběru skutečně zaplatil. Když klient podle toho čísla jedná a čistý výsledek je horší, je to reklamační, a v horším čtení sdělení o výkonnosti u EMT.

Chybí: pravidlo, že srovnání se počítá **netto po skutečně účtovaných poplatcích a spreadech z klientova vlastního žurnálu**, ne z indexu; a povinné zobrazení, že jde o historický popis, s textem schváleným v registru šablon vedle marketingových sdělení.

E7. Kotace vs. přepnutí ekonomického statusu na hranici dne.

Kotace vydaná 30 s před půlnocí Vilnius s hyperinflačním sazebníkem, potvrzená 60 s po půlnoci, kdy už platí jiný řádek *asset_economic_status.post_journal* ověřuje, že kotace nevypršela a že nohy sedí — ale neověřuje (nebo není napsané), jestli tarif platí k *effective_at* zaúčtování. Obě odpovědi jsou obhajitelné, žádná není zvolená.

Chybí: explicitní pravidlo „rozhoduje *created_at* kotace, ne čas zaúčtování“ (a pak to musí být v *displayBlock*), a test na hranici dne v obou směrech.

Co bych chtěl vidět v příští verzi, než se cokoli začne stavět

1. **Jeden objekt vlastní celý životní cyklus jednoho uživatelského úkonu** — kotace, compliance rozhodnutí, SCA grant a idempotenční klíč jsou dnes čtyři nezávislé jednorázové tokeny se čtyřmi různými TTL a bez společného vlastníka. Skoro každý zaseknutý stav výše vzniká na jejich rozporu.
2. **Explicitní pravidlo o pořadí commitů.** *bigserial* a sekvence nejsou pořadí commitů. Platí to pro outbox, pro *journal.seq*, pro *running_balance* i pro nonce. Jedna oprava, tři odstraněné třídy vad.
3. **Rozpočet fail-closed výpadků.** Sečíst, kolikrát ročně se čekaně zastaví výběry ze všech breakerů a lidských front dohromady, a proti tomu postavit povinnost odkupu u EMT a hlásící lhůty DORA. Pokud to číslo nikdo nespočítal, je to jediné číslo v celém návrhu, které se dozví regulátor dřív než vy.

13. Bezpečnostní signály

Samostatná rešerše ke čtyřem technologiím, na které se ptal klient: ARM CCA / Realms, postkvantová kryptografie, behaviorální biometrie a FIDO2. U každé je stav k srpnu 2026, proti čemu pomáhá — a hlavně proti čemu **nepomáhá**, protože právě to je u těchto technologií nejčastější zdroj nedorozumění.

Technologie	Verdikt	Stav a proč
Postkvantová kryptografie	Nasadit hned	"Nasadit hned" ale s upřesněním, které je důležitější než samotný verdikt: nejde o vývojový projekt, jde o ověření a dokumentaci stavu, který u vás už s vysokou pravděpodobností platí. Proč hned: hybridní výměna klíčů v TLS je v srpnu 2026 hotová věc na všech vrstvách, které vás zajímají — RFC 10024 je Standards Track, FIPS 203 je finální dva roky, všechny čtyři hlavní prohlížeče to mají zapnuté, OpenSSL 3.5 je LTS s podporou do 2030 a Cloudflare, na kterém běží largoverse-demo.pages.dev za Cloudflare Access, to má zapnuté plošně a zdarma. Náklad implementace je nula. Když je cena nula a přínos nenulový, o čem ...
Behaviorální biometrie	Odložit	Technologie je reálná a zralá, ale dnes ji nasadit NELZE a nasadit by ji bylo chybou i kdyby to šlo. Proč ne teď (tři blokující důvody, žádný z nich není o technologii): 1. Není backend. Behaviorální skóre počítané a vyhodnocované na klientovi je bezcenné — útočník, který kontroluje zařízení, ho přepíše. Bez serverové strany nemá integrace co chránit. 2. Nejsou uživatelé. Modely potřebují historii chování na účet (zdroje uvádějí minimálně jednotky relací; IBM Verify alespoň 8). Na klientské simulaci bez reálného provozu je model prázdný a nasazení je pouze demonstrační kulisa. Do investorské prezentace demo "s ...
ARM Confidential Compute Architecture	Odložit	Odpověď na přímou otázku klienta: NE, fintech dnes nemůže postavit produkt, který používá Arm Realms. Na mobilu neexistuje zařízení, kde by to šlo, a i kdyby existovalo, aplikace třetí strany nemá API (MANAGE_VIRTUAL_MACHINE je systémové). V cloudu je jediné potvrzené CCA křemíkové nasazení Azure Cobalt 200, jehož VM jsou od června 2026 v preview, ale bez zákaznický dostupného confidential/realm SKU, který bych dokázal ověřit. Linuxový hostitelský stack (KVM) byl ještě v polovině 2025 mimo mainline. Pro tým s jedním člověkem a horizontem 24–33 měsíců je to technologie, kterou lze zmínit jako směr architektury, ...
FIDO2 / WebAuthn / passkeys jako prvek SCA pro platební instituci v EU	Odložit	PŘÍMÁ ODPOVĚĎ NA VAŠI OTÁZKU: Ano, FIDO2/WebAuthn se dá použít jako plnohodnotný prvek SCA pro platební instituci v EU — ale jen v konkrétní konfiguraci, a s tím, že poslední slovo nemáte od regulátora, nýbrž od vlastní rizikové analýzy, kterou musíte umět obhájit. Obhajitelná konfigurace vypadá takto: passkey ve VAŠÍ nativní aplikaci, s vynuceným user verification, s residentKey; pro autorizaci plateb odmítáte credentials s příznakem BE=1, kde to platforma dovolí, a na iOS, kde to nedovolí nikdy, kompenzujete druhou vrstvou (session binding nebo vlastní device-bound klíč v Secure Enclave vedle passkeye); ...

Postkvantová kryptografie (PQC) — hybridní výměna klíčů v TLS a příprava dlouhodobých archivů

Sada šifrovacích algoritmů odolných vůči útoku kvantovým počítačem, které nahrazují RSA, ECDH a ECDSA. V praxi roku 2026 se to týká skoro výhradně jedné věci: výměny klíčů v TLS 1.3 pomocí hybridní skupiny X25519MLKEM768, tedy klasického X25519 zkombinovaného s ML-KEM-768 (FIPS 203). "Hybridní" znamená, že spojení je bezpečné, dokud drží aspoň jeden z obou mechanismů — proto ho evropské autority (BSI, ANSSI) požadují místo čistého PQC. Autentizace, tedy TLS certifikáty a podpisy, zůstává v roce 2026 klasická; postkvantové certifikáty veřejné CA zatím nevydávají. Pro LargoVerse to není vývojový úkol, ale ověření a zdokumentování stavu, který už pravděpodobně platí.

Hledisko	Zjištění
Stav 2026	HOTOVÉ STANDARDY NIST - FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA) — finální od 13. 8. 2024, stabilní základ, beze změn. - SP 800-227 "Recommendations for KEMs" — finální 18. 9. 2025 (ověřeno na csrc.nist.gov). Doplní FIPS 203 o to, jak KEM správně použít. - SP 800-230 ipd "Additional SLH-DSA Parameter Sets" — draft 13. 4. 2026; revize SP 800-133 (generování klíčů) — draft 17. 4. 2026. - HQC: vybráno 11. 3. 2025 jako záložní KEM s jinou matematickouází. Draft FIPS k srpnu 2026 na stránce novinek NIST uveden není; finalizace se očekává ~2027. Není na co dnes spoléhat. - FIPS 206 (FN-DSA / Falcon): k srpnu 2026 nevydáno. - Doplnkové kolo podpisů: 14. 5. 2026 postoupilo 9 kandidátů do 3. kola. Signál, že podpisová strana je pořád otevřená. TLS A HYBRIDNÍ VÝMĚNA KLÍČŮ - RFC 10024 "Post-Quantum Traditional (PQ/T) Hybrid Key Agreement Mechanisms for TLS 1.3", Standards Track, srpen 2026. Definuje X25519MLKEM768 (kód 4588 / 0x11EC, IANA Recommended = Yes), SecP256r1MLKEM768 (4587) a SecP384r1MLKEM1024 (4589); ruší experimentální Kyber-draft kódy. To je hlavní novinka od loňska — z de-facto standardu se stal formální RFC. - Prohlížeče: Chrome od v124 (04/2024), Firefox od v132, Apple od macOS 26 / iOS 26 (podzim 2025). K roku 2026 zapnuto ve výchozím stavu ve všech čtyřech hlavních prohlížečích. - OpenSSL 3.5 LTS (vydáno 8. 4. 2025, podpora do 4/2030) má ML-KEM/ML-DSA/SLH-DSA nativně a X25519MLKEM768 ve výchozím seznamu skupin. Ověřeno lokálně na tomto stroji: ...
Proti čemu pomáhá	Proti jediné hrozbě: "harvest now, decrypt later" (HNDL) — protivník dnes pasivně nahrává šifrovaný provoz a rozšifruje ho, až bude existovat kryptograficky relevantní kvantový počítač. Hybridní výměna klíčů v TLS to řeší úplně, protože relační klíč se z nahreného handshake už nedá zpětně odvodit. CO TO ZNAMENÁ PRO PLATEBNÍ DATA Většina platebního provozu má krátkou životnost: session tokeny, autorizační zprávy, zůstatky. Rozšifrovat je za 8 let nemá valný smysl. Výjimka jsou trvalé identifikátory, které se z nich dají vytáhnout — IBAN, PAN, jméno, adresa, párování osoby a transakční historie. Ty se nedají rotovat a jsou použitelné k podvodu i po deseti letech. Nákladově je to ale stejně jedno: TLS se ošetří jedním nastavením pro všechny provoz najednou, takže se nevyplácí rozlišovat. CO TO ZNAMENÁ PRO KYC ARCHIVY (jádro vaší otázky) AMLD5 a nově AMLR (EU) 2024/1624, použitelné od července 2027, vyžadují uchování dokumentace 5 let od konce obchodního vztahu, s možností prodloužení na 10 let národní úpravou. Litva prodloužení uplatňuje. Obsahem jsou skeny dokladů, selfie a liveness záznamy, doklady o původu prostředků, PEP a sankční prověrky. To je nejhorší možná kombinace pro HNDL: dlouhý horizont důvěrnosti, nerotovatelný obsah (biometrii ani číslo pasu nevyměníte jako heslo) a u biometrie zvláštní kategorie podle čl. 9 GDPR. Klíčové rozlišení, které se v prezentacích běžně plete a stojí za to ho mít správně: samotná data v klidu jsou chráněná AES-256, což je symetrická ...
Proti čemu NEpomáhá	Tohle je ta část, kterou je potřeba mít v prezentaci napsanou, protože technicky gramotný investor nebo právník se na to zeptá. - NEPOMÁHÁ proti ničemu, co vás v letech 2026–2028 reálně ohrožuje: phishing, převzetí účtu, SIM swap, malware na zařízení klienta, zneužití API, interní pachatel, podvod v AML rovině. Sto procent incidentů, které jednočlenný fintech potká před ostrým provozem, PQ neřeší. - NEPOMÁHÁ blockchainové vrstvě. XSGD i jakýkoli ERC-20 token stojí na ECDSA nad secp256k1. Kvantový útočník neláme webovou aplikaci, láme peněženky, a hybridní TLS s tím nemá nic společného. Žádný z řetězců, které byste reálně použili, nemá v produkci postkvantové podpisy. Formulace typu "kvantově odolná blockchainová vrstva" je v roce 2026 nepravdivá a snadno ověřitelná. - NEPOMÁHÁ datům v klidu. AES-256 kvantové výpočty prakticky neohrožují a PQ výměna klíčů se šifrování databáze vůbec nedotýká. Kdo tvrdí, že PQ "chrání vaše uložená data", popisuje něco jiného. - NENAHRAZUJE silné ověření klienta podle PSD2. SCA je o autentizačních prvcích, ne o výměně klíčů; ML-KEM na povinnostech SCA nic nemění. - "Hybridní TLS" NENÍ "postkvantově certifikováno". Autentizace v TLS je i v roce 2026 klasická ECDSA, protože veřejné CA postkvantové certifikáty nevydávají. Tvzení "naše spojení je plně postkvantové" je nepřesné. - NEDĚLÁ z aplikace "quantum-safe". Tenhle pojem v marketingovém smyslu neexistuje; existuje jen konkrétní seznam, které algoritmy kde běží. - A nepomáhá ani jako ...
Regulace	DORA — nejrelevantnější a jediné, o co se dá dnes opřít. Nařízení Komise v přenesené pravomoci (EU) 2024/1774, čl. 6 (šifrování a kryptografické kontroly) a čl. 7 (správa klíčů): finanční subjekt musí mít kryptografickou politiku, musí sledovat vývoj v kryptoanalýze "včetně hrozeb plynoucích z kvantového pokroku" a musí být schopen kryptografickou technologii aktualizovat nebo vyměnit; kdo toho schopen není, musí zavést kompenzační opatření. Není to explicitní příkaz nasadit PQ, ale je to auditovatelný háček. Pro EMI/CASP v Litvě to znamená, že "kryptografická agilita" patří do bezpečnostní dokumentace k licenci — a hybridní TLS je nejlevnější způsob, jak k tomu doložit konkrétní krok. EU roadmapa (Doporučení Komise 2024/1101 + NIS Cooperation Group, 23. 6. 2025) — není závazná, ale je to referenční časová osa, na kterou se supervizoři odvolávají: národní strategie do konce 2026, vysoce riziková použití do konce 2030, dokončení do konce 2035. Platební infrastruktura patří do kategorie 2030. PSD2 / SCA — bez přímé vazby. RTS (EU) 2018/389 požaduje "silné kryptografické techniky" obecně, nic postkvantového. Hybridní TLS neplní ani neporušuje žádnou konkrétní povinnost SCA. Do prezentace tedy nepatří jako "splňujeme PSD2 díky PQ". PSD3/PSR jsou stále v legislativním procesu, jejich finální znění jsem neověřoval. GDPR — čl. 32 vyžaduje opatření "s přihlédnutím ke stavu techniky". Jakmile je hybridní TLS v roce 2026 výchozím stavem v prohlížečích i u CDN, stává se součástí ...

Hledisko	Zjištění
Náklady	HNED TEĎ, PŘI SOUČASNÉM STAVU (klientská simulace na Cloudflare Pages za Cloudflare Access) - Hybridní TLS: 0 člověkodnů implementace. Cloudflare má PQC výměnu klíčů zapnutou plošně a zdarma, včetně Zero Trust / Access, který používáte. Nic se nezapíná ani nekonfiguruje. - Ověření a zápis do dokumentace: 0,5–1 člověkodnů. Ověřovací příkaz (OpenSSL 3.5+, který na vašem stroji je): <code>openssl s_client -connect largoverse-demo.pages.dev:443 -servername largoverse-demo.pages.dev -tls1_3 -groups X25519MLKEM768</code> a v hlavičce hledat řádek "Negotiated TLS1.3 group: X25519MLKEM768". POZOR: tohle jsem za vás NEOVĚŘIL — v mém sandboxu neprošlo DNS (connect: errno=11001). Než to dáte do investorské prezentace, spusťte to sami; teprve výstup toho příkazu je doklad. - Kryptografická inventura (kde všude se používá asymetrická kryptografie, jaký algoritmus, jaká délka klíče, jaký horizont důvěrnosti dat): 3–5 člověkodnů v současném rozsahu. Tohle je ta položka, kterou po vás bude chtít regulátor i due diligence, a jediná, která má dnes reálnou hodnotu. - Zápis "kryptografická agilita" do cílové architektury pro DORA: 2–3 člověkodny, použitelné znovu při licencování. Celkem dnes: zhruba 5–9 člověkodnů, z toho nula na kód. PROVOZNÍ NÁKLAD Prakticky nulový. ML-KEM-768 přidá zhruba 1,2 kB do ClientHello a 1,1 kB do odpovědi serveru, tedy jeden handshake navíc o velikosti malého obrázku; měřitelný dopad na latenci je pod hranicí, kterou uživatel pozná. Cloudflare za to neúčtuje nic ...

Behaviorální biometrie (behavioural biometrics) v bankovníctví — stav k srpnu 2026

Průběžné měření toho, JAK uživatel zachází se zařízením, ne kdo je podle dokladu: dynamika psaní (prodlevy mezi klávesami, doba stisku), pohyb a akcelerace myši, gesta a tlak na dotykové ploše, úhel držení telefonu a mikrootřesy z akcelerometru/gyroskopu, rychlost navigace aplikací, způsob vyplňování formulářů (psaní vs. vložení ze schránky vs. autofill). Z těchto signálů se staví profil konkrétní relace a porovnává se s historickým profilem účtu; výstupem je skóre odchylky, ne binární "ano/ne". Technicky jde o SDK v aplikaci (web JS + mobilní SDK), které streamuje telemetrii na backend dodavatele nebo do vlastního rizikového enginu. Do stejné kategorie se často nesprávně řadí čistě kontextové signály (IP, geolokace, otisk zařízení) — to jsou zařízení a prostředí, ne chování člověka, a regulatorně se posuzují jinak.

Hledisko	Zjištění
Stav 2026	HOTOVÉ A KOMERČNĚ DOSTUPNÉ. Není to výzkum, je to zavedený produktový segment s reálnými bankovními nasazeními od cca 2016. Dodavatelé: BioCatch (nejrozšířenější v retailovém bankovníctví, v březnu 2026 uvedl DeviceIQ pro detekci emulátorů a spoofingu zařízení), BehavioSec (od 2022 součást LexisNexis Risk Solutions, prodává se spolu s ThreatMetrix), Feedzai (pohltil Revelock/buguroo), ThreatMark (české, Brno — pro klienta v ČR relevantní jazykově i smluvně), Callsign, XTN Cognitive Security, TypingDNA (jediný, kdo prodává i samostatný "typing" faktor jako 2FA), Nethone (Mangopay), Darwinium, Sumsu, IBM. Analytická matice QKS/Datos Insights z 2025–2026 řadí mezi lídry Feedzai, BioCatch, IBM, Sumsu, ThreatMark, XTN a LexisNexis. DŮLEŽITÁ KOREKCE K ZADÁNÍ: Zimperium do tohoto seznamu nepatří. Zimperium je mobile app protection / RASP a detekce hrozeb na zařízení (root/jailbreak, malware, overlay útoky, screen sharing). Je to komplementární vrstva, ale řeší jinou hrozbu a nakupuje se zvlášť. Míchat to do jednoho slidu s BioCatch je věcná chyba, kterou technicky gramotný investor odhalí. CO SE NEPODARIL OVĚŘIT: (a) Žádný z dodavatelů nepublikuje ceník. Cenové rozpětí uvedené v nákladech je odhad z veřejných zmínek a analogií, ne ověřený fakt. (b) Účinnostní čísla dodavatelů (typicky "o 66 % méně falešných poplachů", "99,2 % přesnost") pocházejí z jejich vlastních case studies a nezávisle ověřitelná nejsou — nezávislý benchmark srovnatelný s NIST FRVT pro obličejovou ...
Proti čemu pomáhá	Konkrétně proti čemu to pomáhá: 1. ACCOUNT TAKEOVER po odcizení přihlašovacích údajů (phishing, credential stuffing, infostealer malware) — útočník má správné heslo i SMS kód, ale píše, scrolluje a naviguje jinak než majitel účtu. Tohle je hlavní a nejlépe doložený případ užití. 2. REMOTE ACCESS TROJANS / vzdálená správa (AnyDesk, TeamViewer scam) — pohyb myši generovaný vzdáleně má jinou fyziku než lidská ruka; detekuje se spolehlivě. 3. BOTI A AUTOMATIZACE při zakládání účtů a hromadném testování karet — chybí lidská variabilita, autofill místo psaní, nulové váhání. 4. SOCIÁLNÍ INŽENÝRSTVÍ ZA BĚHU (tzv. coaching/duress) — oběť je při telefonu s podvodníkem, což mění tempo: dlouhé pauzy před poli, opakované návraty, opisování čísla účtu místo vložení. Tady je to jediná vrstva, která vidí něco, co transakční monitoring nevidí. Účinnost je ale výrazně nižší než u ATO a dodavatelské claimy jsou zde nejméně podložené. 5. MULE ÚČTY — sdílené vzorce chování napříč zdánlivě nesouvisejícími účty. Pro LargoVerse je věcně nejsilnější argument bod 1 a 2: aplikace s vlastní blockchainovou vrstvou a stablecoinovým zůstatkem má nevratné transakce, takže detekce ATO PŘED podpisem transakce má výrazně vyšší hodnotu než u SEPA převodu, který jde recallovat.

Hledisko	Zjištění
Proti čemu NEpomáhá	Proti čemu se to nabízí mylně: 1. NENÍ TO NÁHRADA SCA. Nejčastější omyl v prodejních materiálech. Podle EBA Q&A 2020_5353 musí prvek inherence splnit požadavky čl. 8 RTS 2018/389 SÁM O SOBĚ — nelze poskládat "kompozitní profil", kde se biometrický a nebiometrický údaj (lokalita, prohlížeč, IP) dělí o rozhodnutí. EBA výslovně říká, že lokalita a údaje o prohlížeči nejsou součástí SCA a smí sloužit jen jako doplňkové bezpečnostní opatření nebo pro výjimku TRA. Kdo prodává "behaviorální SCA" složené z chování + IP + zařízení, prodává něco, co EBA už explicitně vyloučila. 2. NEPOMÁHÁ PROTI APP PODVODŮM V ZÁKLADU. Když oběť sama a dobrovolně pošle peníze, projde jakoukoli autentizací. Detekce nátlaku (duress) je nadstavba s výrazně horší přesností než detekce ATO a nelze ji prezentovat jako řešení APP fraudu. Pod PSR se přitom odpovědnost za část podvodů s předstíranou identitou přesouvá na PSP, takže tenhle rozdíl má přímý finanční dopad. 3. NEPOMÁHÁ PROTI KOMPROMITACI NA STRANĚ SERVERU, chybám v smart kontraktech, únikům klíčů z custody řešení ani proti insider hrozbě. Se stablecoinovou vrstvou XSGD nemá behaviorální biometrie žádný průnik. 4. NENÍ TO KYC/AML. Nezjišťuje totožnost, jen kontinuitu chování. Nesplňuje nic z AMLD/AMLR. 5. NEFUNGUJE U NOVÝCH A PŘÍLEŽITOSTNÝCH UŽIVATELŮ. Cold start: bez historie není baseline. U onboardingu pomáhá jen detekce botů, ne rozpoznání osoby. 6. NENÍ TO ANTI-MALWARE NA ZAŘÍZENÍ. To je Zimperium/Promon/Appdome, jiná kategorie a jiný ...
Regulace	PSD2 / RTS 2018/389 (platné právo dnes): - EBA Opinion on the elements of SCA (EBA-Op-2019-06), bod 34: inherence zahrnuje fyzické vlastnosti, fyziologické charakteristiky A CHOVÁNÍ vytvářené tělem. EBA výslovně jmenuje dynamiku psaní na klávesnici a úhel držení zařízení jako přípustné prvky inherence. - Podmínka je jediná, ale tvrdí: čl. 8 RTS vyžaduje "velmi nízkou pravděpodobnost, že se neoprávněná strana autentizuje jako plátce". Číselný práh regulace NESTANOVUJE. - EBA Q&A 2020_5353: prvek inherence musí splnit čl. 8 sám o sobě; nelze míchat biometrické a nebiometrické signály do jednoho "profilu" a tvrdit, že to dohromady je inherence. - EBA Q&A 2020_5620: behaviorální data a skóre z nich SMÍ být prvkem inherence, ale "bez dotčení požadavků GDPR". EBA tím odpovědnost za datovou ochranu explicitně přehazuje na PSP. - Praktický důsledek: publikované laboratorní EER pro dynamiku psaní a dotyku se pohybují kolem 2-5 % (např. 2,45 % desktop / 1,76 % mobil u transformerových modelů, 2,48 % u Scaled Manhattan, 4,66 % u pohybové biometrie). Pro srovnání, u fyziologické biometrie se v praxi očekává FAR řádu 1:10 000 (ISO/IEC 30107, FIDO) až 1:1 000 000 (Face ID). Rozdíl jsou tři až pět řádů. Argumentovat před regulátorem, že 2-5 % EER je "velmi nízká pravděpodobnost", je neobhajitelné. Proto v EU behaviorální biometrii jako samostatný faktor SCA prakticky nikdo nenasazuje. PSD3 / PSR (budoucí právo): - Politická dohoda 27. 11. 2025, dohodnuté texty publikovány 23. 4. 2026, ...
Náklady	ČLOVĚKODNY (odhad, jednočlenný tým): - Integrace SDK do webu a mobilní aplikace: 15-25 MD - Backendový sběr a předání telemetrie + rizikové API + rozhodovací logika (step-up, blok, tichý alert): 25-40 MD. POZOR: dnes žádný backend neexistuje, takže tohle je závislé na jeho vzniku, ne samostatná položka. - DPIA, záznam o činnostech zpracování, informační povinnost, právní posouzení čl. 9 GDPR: 15-25 MD, z toho většina externí právník - Dodavatelské due diligence + smluvní ujednání dle DORA čl. 28-30 (registr ICT dodavatelů, exit strategie, audit rights, subdodavatelé): 10-20 MD, opět převážně právník - Ladění, vyhodnocování alertů, správa false positives: TRVALÝ náklad, realisticky 0,2-0,5 FTE. Tohle je položka, kterou týmy podceňují nejčastěji — nakoupí systém a nemají nikoho, kdo by denně procházel alerty. CELKEM prvotní nasazení: cca 65-110 MD vlastní práce plus externí právní kapacita. PROVOZNÍ NÁKLAD: modely jsou per aktivní uživatel/měsíc nebo per relace, s ročním minimálním závazkem. Ceníky nejsou veřejné; z veřejných zmínek a analogií z fraud-tech odhaduji minimální roční závazek u zavedených dodavatelů v řádu desítek až nižších stovek tisíc EUR ročně. TENTO ÚDAJ JSEM NEDOKÁZAL OVĚŘIT a v investorské prezentaci by měl být uveden jako "vyžaduje poptávku", ne jako číslo. ZÁVISLOSTI, KTERÉ DNES NEJSOU SPLNĚNY: - Backend. Bez serverové strany není kam telemetrii posílat a klientské skóre je bezcenné (účinník ho přepíše). - Reálný provoz. Systém potřebuje historii ...

ARM Confidential Compute Architecture (CCA) / Realms — stav k srpnu 2026

CCA je bezpečnostní architektura Armv9-A, jejímž hardwarovým základem je rozšíření RME (FEAT_RME, Armv9.2-A). RME přidává k dosavadním "světům" (Normal, Secure) dva další — Root a Realm — a hardwarově vynucuje přiřazení fyzické paměti jednotlivým světům přes Granule Protection Table; hypervizor ani hostitelský OS se do paměti Realmu nedostane, i když je kompromitovaný. Realm je izolovaná VM, kterou spravuje Realm Management Monitor (RMM) běžící v Realm EL2; hypervizor mu přes rozhraní RMI zadává správu zdrojů (paměť, plánování vCPU), host uvnitř Realmu komunikuje s RMM přes RSI a může si vyžádat attestation token (CCA platform token + realm token ve formátu CBOR/EAT dle IETF RATS), který ověří vzdálený verifikátor (např. open-source Veraison). Referenční implementace je TF-RMM, podpora v TF-A existuje; specifikace RMM je publikovaná (v1.0-rel0 finální, v2.1 v ALPHA kvalitě, mimo jiné pro přiřazování PCIe zařízení). Není to náhrada TrustZone ani Secure Enclave — je to model "confidential VM" pro Arm, obdoba Intel TDX / AMD SEV-SNP.

Hledisko	Zjištění
Stav 2026	HOTOVÉ: specifikace (RME 1.0/1.1, RMM 1.0-rel0), referenční firmware (TF-A, TF-RMM), Linux jako HOST uvnitř Realmu (guest support v mainline od 6.13/6.14-rc1), attestation formát a verifier (Veraison; Linaro provozuje verifier pro "pre-silicon CCA platformy", tj. simulátor FVP). Podpora KVM na straně hostitele byla v červnu 2025 stále mimo mainline (série patchů v9 od Stevena Price, Arm); že by byla mezitím sloučena, jsem ověřit nedokázal — počítejte s tím, že produkční Linuxový stack je nezralý. SERVER/CLOUD: RME mají Neoverse V3, N3 a CSS V3. Reálná nasazení: Microsoft Azure Cobalt 200 (132 jader Neoverse CSS V3, oznámen 18. 11. 2025) — Microsoft i Arm výslovně uvádějí podporu CCA a always-on šifrování paměti; VM série Dpsv7/Dplsv7/Epsv7/Mpsv4/Lpsv5 jsou v preview od Buildu (2. 6. 2026) v 8 regionech. ALE: oznámení preview VM nezmiňuje ani confidential VM SKU, ani Realms — zákaznicky dostupný "confidential VM na Armu" jsem k srpnu 2026 nenašel. AWS Graviton5 (192 jader Neoverse V3, GA červen 2026, M9g/C9g) — AWS komunikuje formálně verifikovanou izolaci přes Nitro Isolation Engine, nikoli CCA; jediná zmínka o CCA na Graviton5, kterou jsem našel, je z blogu nízké kvality a považuji ji za neověřenou. Azure DCasv5/v6 (AMD SEV-SNP) a DCesv6 (Intel TDX) zůstávají jedinými GA confidential VM produkty. MOBIL: nulová dostupnost. Nenašel jsem jediný telefon ani mobilní SoC (Dimensity 9500, Snapdragon 8 Elite Gen 5 ani starší Cortex-X925/A725), u kterého by výrobce deklaroval ...
Proti čemu pomáhá	Konkrétní hrozba, proti které Realms pomáhají: kompromitovaný hypervizor nebo hostitelský OS u poskytovatele infrastruktury, případně zlovolný/zvědavý insider u cloud providera nebo hostera. Realm chrání paměť a stav VM i před tím, kdo tu VM provozuje — to je relevantní pro komponenty jako správa klíčů k XSGD peněženice, podepisování transakcí, transaction monitoring nad osobními daty, KYC dokumenty. Attestation navíc umožňuje, aby protistrana (banka, custody partner, auditor) kryptograficky ověřila, JAKÝ kód v izolovaném prostředí běží, dřív než mu vydá klíč. Na mobilu by CCA teoreticky umožnil běh citlivé části aplikace mimo dosah kompromitovaného Androidu — to dnes nelze a je to hlavní důvod, proč je to zajímavé; jenže právě mobilní část je nejdál od dostupnosti.
Proti čemu NEpomáhá	Realms NEPOMÁHAJÍ proti tomu, proti čemu se v prezentacích nejčastěji mylně nabízejí: (1) proti kompromitovanému telefonu uživatele a malwaru s accessibility právy — na mobilu CCA nikde neběží a i pKVM dnes běžné aplikaci nepomůže; proti tomuhle je řešením StrongBox/Secure Enclave, attestation a serverová detekce podvodů; (2) proti phishingu, sociálnímu inženýrství a APP fraud — uživatel autorizující platbu podvodníkoví ji autorizuje i v Realmu; (3) proti chybám v aplikační logice, ve smart kontraktu nebo ve zpracování stablecoinu — izolovaná VM špatný kód spustí stejně spolehlivě; (4) jako náhrada certifikovaného HSM nebo custody řešení pro klíče — regulátor ani auditor CCA neuznává jako ekvivalent FIPS 140-3 / CC certifikace; (5) proti side-channel útokům obecně — CCA je proti nim tvrzena jen částečně a je to aktivní výzkumné téma; (6) jako splnění nějakého konkrétního regulatorního požadavku — žádný takový požadavek neexistuje.
Regulace	PSD2/SCA: RTS (EU) 2018/389, čl. 6–9, vyžaduje mimo jiné oddělení prvků autentizace na víceúčelovém zařízení a výslovně uznává "oddělená bezpečná prostředí pro vykonávání kódu" — tomu odpovídá TEE / secure element, tedy StrongBox a Secure Enclave, které jsou dnes běžnou a auditory akceptovanou praxí. Arm CCA v žádném textu PSD2/RTS ani ve stanoviscích EBA jmenováno není; není povinné ani uznávané, je to nadstandard. (PSD3/PSR jsou v legislativním procesu — konkrétní dopad na požadavky na zabezpečení zařízení jsem k srpnu 2026 neověřoval, doporučuji nechat právníkům.) DORA (nařízení 2022/2554): technologicky neutrální, žádnou z těchto technologií nevyžaduje; relevantní je spíš to, že každý použitý poskytovatel (Google Play Integrity, Apple App Attest, AWS/Azure confidential computing, custody partner) je ICT třetí strana, kterou je nutné vést v registru a smluvně ošetřit. GDPR čl. 32: "stav techniky" — confidential computing lze uvést jako doplňkové technické opatření, ale není povinné; opírat compliance o nedostupnou technologii je horší než opřít ji o šifrování a HSM. Certifikace: pKVM/AVF má SESIP Level 5, CCA jako taková zatím certifikační schéma (EUCC/SESIP) pro produkty nemá, takže se s ní vůči auditorovi nedá argumentovat. MiCA na tuto vrstvu nedopadá. Právní riziko je hlavně komunikační: uvádět Realms jako vlastnost produktu, který je nemá a mít nemůže, je zavádějící prohlášení vůči investorům.
Náklady	REALMS DNES: nelze vyčíslit jako produktovou položku, protože není co nasadit. Realistický náklad na "pochopit a mít prototyp na simulátoru FVP + Veraison verifier" je řádově 15–30 člověkodnů seniorního systémového inženýra (nízkourovňový Linux/KVM, firmware) — což jednočlenný tým bez systémového specialisty nemá. Provozní přínos nula, protože výstup nejde dodat zákazníkovi. CO STOJÍ REÁLNÁ ALTERNATIVA (odhady, ne nabídka): - Klíč v StrongBox na Androidu + Secure Enclave na iOS, s key attestation a serverovým ověřením řetězce: ~5–10 člověkodnů na platformu + ~5 dnů server. Provozní náklad prakticky nulový. Pozor: Google aktivoval nový RKP attestation root k 1. 2. 2026, server musí po přechodné období akceptovat oba rooty — to je konkrétní údržbová položka. - Play Integrity API / Apple App Attest + DeviceCheck: ~5 dnů na platformu, zdarma, ale závislost na Google/Apple backendu (dostupnost, rate limity) → v DORA registru to je ICT třetí strana. - AWS Nitro Enclaves (GA od 2020, funguje i na Graviton instancích C7g/M6g a dalších od 10/2022): ~10–25 člověkodnů na první funkční enclave včetně KMS attestation policy. Provozní náklad: enclave si ukrájí vCPU a RAM z rodičovské instance (platíte instanci, ne enclave zvlášť), žádné trvalé úložiště, žádná síť kromě vsoc — to je zásadní architektonické omezení, ne detail. - Intel TDX / AMD SEV-SNP confidential VM (Azure DCesv6 / DCasv6, GCP): nasazení dnů, ne týdnů, protože běží nemodifikovaný OS; cenová přírůžka řádu jednotek až ...

FIDO2 / WebAuthn / passkeys jako prvek SCA pro platební instituci v EU (stav k srpnu 2026)

FIDO2 je dvojice standardů: WebAuthn (API prohlížeče/OS, W3C) a CTAP (protokol k externímu autentikátoru, FIDO Alliance). Uživatel se na zařízení vygeneruje pár klíčů, privátní klíč nikdy neopustí bezpečný prvek (Secure Enclave, TEE, TPM, čip tokenu) a server (relying party) si ukládá jen veřejný klíč. Podpis je vázaný na doménu relying party, což dává vlastnost, kterou SMS ani TOTP nemají: odolnost vůči phishingu a proti man-in-the-middle na úrovni protokolu. "Passkey" je marketingové jméno pro FIDO2 credential a rozpadá se na tři technicky odlišné věci: (1) hardwarový token (YubiKey a spol.) — klíč je fyzicky v samostatném zařízení, nedá se exportovat, dostupná je atestace výrobce; (2) platformní authenticator vázaný na zařízení (device-bound) — klíč v čipu telefonu/notebooku, nepřenositelný, ztráta zařízení = ztráta credentialu; (3) synchronizovaný passkey — klíč je zálohovaný a replikovaný přes iCloud Keychain, Google Password Manager nebo správce hesel, takže žije na všech zařízeních daného cloud účtu. Rozdíl mezi (2) a (3) je z pohledu regulace zásadní, z pohledu API téměř neviditelný — server ho pozná jen z advisory příznaků BE (backup eligible) a BS (backup state) v authenticator data, které nejsou kryptograficky doložené atestací.

Hledisko	Zjištění
Stav 2026	HOTOVÉ A DOSTUPNÉ: WebAuthn Level 2 je W3C Recommendation, Level 3 finalizovaný; podpora je univerzální ve všech aktuálních prohlížečích a v iOS (ASAuthorization) i Android (Credential Manager). Serverové knihovny jsou zralé a zdarma (SimpleWebAuthn pro Node, webauthn4j / java-webauthn-server pro JVM, py_webauthn). Komerčně: Corbado, Hanko, Authsignal, Stytech, Transmit Security, OneSpan, Wultra — Wultra a OneSpan cílí přímo na PSD2 use case. NEDOŘEŠENÉ — a to jsou přesně ty body, na které se ptáte: 1. Regulace mlčí. K srpnu 2026 se mi nepodařilo najít ŽÁDNÝ dokument EBA (opinion, Q&A, guidelines), který by slovo "passkey" nebo "WebAuthn" vůbec zmiňoval. Platí tedy obecné texty: RTS (EU) 2018/389, EBA Opinion EBA-2018-Op-04 (červen 2018) a EBA-Op-2019-06 (21. 6. 2019). Ty říkají, že vlastnictví nemusí být fyzické — stačí "spolehlivý prostředek k potvrzení vlastnictví" a device binding, tedy jedinečné spojení mezi aplikací/klíčem a zařízením. Passkey tomu odpovídá, ale nikdo to oficiálně nefekl. 2. Synchronizované passkeys — nejrizikovější bod. U syncovaného passkeye se předmět "vlastnictví" posouvá ze zařízení na cloudový účet (Apple ID / Google účet). "Něco, co má jen uživatel" je pak účet, jehož recovery flow, ochrana i obnova jsou zcela mimo kontrolu platební instituce. Autoritativní stanovisko EBA k tomu neexistuje. Praxe trhu je taková, že se to považuje za akceptovatelné (Revolut, Finom), ale je to interpretace poskytovatele, ne potvrzení regulátora. 3. Atestace u ...
Proti čemu pomáhá	Konkrétně a měřitelně proti třem hrozbám: 1. PHISHING A REAL-TIME MITM. Toto je hlavní přínos a je strukturální, ne statistický. Podpis WebAuthn je vázaný na origin (RP ID); credential vydaný pro largo.example se prostě nedá použít na largo-secure.example, i kdyby uživatel udělal všechno špatně. Falešná stránka nedostane nic užitečného. Proti SMS OTP a TOTP, kde real-time proxy útok (Evilginx a spol.) funguje spolehlivě, je to kvalitativní rozdíl. Pro EMI/CASP s krypto vrstvou, kde jsou transakce nevratné, je to nejrelevantnější hrozba vůbec. 2. SIM SWAP A ÚTOKY NA SMS KANÁL. Odpadá telco jako závislost i jako útočná plocha. 3. ÚNIK CREDENTIALS NA STRANĚ SERVERU. Neukládáte žádné sdílené tajemství, jen veřejné klíče. Databáze credentials po úniku nemá pro útočníka hodnotu. To zároveň zjednodušuje váš vlastní bezpečnostní perimetr — není co chránit HSM. 4. VEDLEJŠÍ, ALE PODSTATNÉ: u operace, kde chcete SCA, dostanete oba faktory jedním gestem. Konverzní ztráta oproti OTP je řádově menší a tohle je argument, který funguje i v investorské prezentaci — nejde jen o bezpečnost, ale o drop-off v onboardingu a při potvrzování plateb.
Proti čemu NEpomáhá	Proti čemu se FIDO2 často mylně nabízí: 1. NEPOMÁHÁ PROTI SOCIÁLNÍMU INŽENÝRSTVÍ A AUTHORIZED PUSH PAYMENT FRAUD. Pokud podvodník uživatele telefonicky přesvědčí, aby sám poslal peníze, passkey transakci podepíše bez zaváhání a dokonale. To je dnes v EU dominantní typ platebního podvodu a FIDO2 na něj nemá vliv. Na tohle slouží fraud monitoring, limity a zpoždění u nových příjemců — nikoli silnější autentizace. PSR to ostatně řeší samostatně přes ověření shody jména a IBAN. 2. NEPOMÁHÁ PROTI MALWARU NA KOMPROMITOVANÉM ZAŘÍZENÍ. Malware s přístupem k relaci může iniciovat operaci, kterou uživatel odsouhlasí v domněnání, že jde o něco jiného. Bez důvěryhodného displeje na autentikátoru (což platformní passkeys nemají) je "podepisuji přesně to, co vidím" záruka aplikační, ne kryptografická. 3. NENAHAZUJE DYNAMIC LINKING. Toto je nejčastější a nejdražší omyl. Passkey sám o sobě podepisuje challenge, ne transakci. Dokud do challenge nedáte hash částky a příjemce a nezobrazíte je ve vlastním, chráněném UI, čl. 5 RTS nesplňujete. Kdo tvrdí "máme passkeys, takže máme SCA", má polovinu. 4. NENAHAZUJE KYC/AML ANI OVĚŘENÍ TOTOŽNOSTI. FIDO2 ověřuje, že jde o stejného aktéra jako při registraci. Kdo to je, neřeší vůbec. Vazba na skutečnou osobu vzniká jinde a passkey ji jen udržuje. 5. NEŘEŠÍ BEZPEČNOST BLOCKCHAINOVÉ VRSTVY. Podpis on-chain transakce a správa klíčů k XSGD je zcela jiný problém. Nepředstírejte, že passkey chrání custody. 6. NENÍ TO ARGUMENT PRO ZÍSKÁNÍ LICENCE. ...

Hledisko	Zjištění
Regulace	PSD2 / RTS (EU) 2018/389 — ZDE JE JÁDRO ODPOVĚDI NA VAŠI OTÁZKU. Dva nezávislé faktory (čl. 4 a 9): Jedna WebAuthn asertace s vynuceným user verification nese vlastnictví (privátní klíč v bezpečném prvku) a inherenci nebo znalost (biometrie nebo PIN, signalizované UV flagem). To je standardní tržní interpretace. Čl. 9 RTS požaduje, aby prolomení jednoho prvku neohrozilo spolehlivost ostatních; čl. 9(3) víceúčelová zařízení výslovně připouští za podmínky oddělených bezpečných prováděcích prostředí — Secure Enclave a TEE tomu odpovídají. Tato část je obhajitelná. PROBLEMATICKÝ BOD, KTERÝ MUSÍTE ZNÁT: EBA Q&A 2021_6145 (publikováno 31. 1. 2023 v balíku šesti Q&A k digitálním peněženkám) uvádí, že odemčení mobilu biometrií nebo PINem nelze považovat za platný prvek SCA, pokud mechanismus zamykání obrazovky není pod kontrolou vydavatele. Výjimky jsou dvě: mechanismus JE pod kontrolou vydavatele, nebo byl plátce dříve spojen s daným kredencialem samostatnou SCA podle čl. 24(2)(b) RTS. Toto stanovisko vzniklo pro enrolment karty do peněženky, ne pro WebAuthn — a lze proti němu argumentovat, že WebAuthn user verification není odemčení obrazovky, nýbrž samostatné ověření vyžádané per-asertací, jehož výsledek je kryptograficky signalizován ve flagu a jehož vyžádání kontroluje relying party. Je to obhajitelný argument, ale je to argument, ne jistota. Toto je nejbližší existující nepříznivé vyjádření regulátora a musí být v licenčním spisu adresováno explicitně, ne ...
Náklady	ČLOVĚKODNY (odhad pro produkční, ne demo implementaci, jednočlenný tým): - Serverová RP část (registrace, autentizace, správa credentials, ověření podpisů) s hotovou open-source knihovnou: 10–15 dnů. Samotná kryptografie je hotová, čas jde do stavových a životních cyklů. - Web frontend: 3–5 dnů. - Nativní iOS + Android (ASAuthorization / Credential Manager) včetně associated domains — apple-app-site-association a assetlinks.json, hostované na vaší doméně: 10–15 dnů dohromady. Konfigurace associated domains je typický zdroj vícedenních ztrát. - Dynamic linking: zobrazení částky a příjemce ve vaší vlastní aplikaci + challenge = hash(částka, příjemce, nonce, timestamp) + serverové ověření + auditní log: 5–10 dnů. - Recovery a ztráta zařízení, správa více credentials na účet, deaktivace, fallback kanál: 10–20 dnů. TOHLE JE NEJPODCEŇOVANĚJŠÍ POLOŽKA. Recovery flow je zároveň nejslabší článek celého schématu — pokud je obnovitelnost přes e-mail nebo SMS, snížili jste zabezpečení zpátky na úroveň toho slabšího kanálu. - Dokumentace pro licenční spis a pro právníky (popis metody SCA, mapování na čl. 4, 5, 6, 7, 8, 9 RTS, riziková analýza syncovaných credentials): 5–10 dnů plus externí právník. CELKEM zhruba 45–75 člověkodnů. Pro jednočlenný tým to je 3–4 měsíce čisté práce, reálně půl roku. PROVOZNÍ NÁKLAD: - Open-source knihovna: 0 EUR licenčně. Provoz je jen běžný backend. - Managed vendor (Corbado, Hanko, Authsignal, Stytech): od nízkých stovek EUR/měsíc u malých objemů; ...

14. Doporučení k bezpečnostním signálům

Bezpečnostní signály LargoVerse — věcné doporučení

Podklad pro investorskou prezentaci i pro právní revizi. Vše k srpnu 2026. Čísla v človehkodnech jsou odhady pro jednočlenný tým, ne nabídka.

1. Co je reálné a co je slide

| Technologie | Stav | Nasaditelné dnes? |

| --- | --- | --- |

| **FIDO2 / WebAuthn / passkeys** | Zralý standard, univerzální podpora v prohlížečích i OS, zdarma dostupné serverové knihovny, banky to nasazují | **Ano** — ale až bude backend |

| **Postkvantová kryptografie (hybridní TLS)** | Hotová věc: RFC 10024 (Standards Track, srpen 2026), FIPS 203 finální od 2024, Cloudflare to má zapnuté plošně a zdarma | **Už to máte zapnuté**, aniž byste o tom věděli. Není co nasazovat, jen ověřit a zapsat |

| **Behaviorální biometrie** | Komerčně zralý segment (BioCatch, ThreatMark, Feedzai...), reálná bankovní nasazení od 2016 | **Ne** — technologie ano, vaše situace ne. Detaily níže |

| **ARM CCA / Realms** | Specifikace hotové, křemík existuje v jednom cloudu, produkční Linuxový stack nezralý | **Ne. A na mobilu ani teoreticky** |

ARM Realms je jediná ze čtyř, která je v roce 2026 pro fintech čistě marketingové heslo. Na mobilu neexistuje jediný telefon ani SoC, kde by výrobce deklaroval zapnuté RME. I kdyby existoval, aplikace z Google Play nedostane API pro spouštění izolovaných VM (`MANAGE_VIRTUAL_MACHINE` je `@SystemApi`, v Androidu 15 jen pro předinstalované aplikace). Apple CCA nepoužívá vůbec. V cloudu je jediné potvrzené CCA nasazení Azure Cobalt 200, jehož VM jsou od června 2026 v preview — ale oznámení preview nezmiňuje ani confidential VM SKU, ani Realms; zákaznický dostupný „confidential VM na Armu“ k srpnu 2026 neexistuje. AWS Graviton5 komunikuje izolaci přes Nitro Isolation Engine, ne CCA.

Behaviorální biometrie je zvláštní případ: technologie není heslo, ale ve vašem kontextu by heslem byla. Blokuje to tři věci, žádná z nich technická:

- Není backend. Skóre počítané na klientovi je bezcenné — útočník, který ovládá zařízení, ho přepíše.
- Nejsou uživatelé. Modely potřebují historii chování na účet (IBM Verify vyžaduje minimálně 8 relací). Na demu je model prázdný a nemá co detekovat.
- Ekonomika. Enterprise smlouvy mají minimální roční závazek; pod cca 10 000 aktivních uživatelů stojí licence víc než ztráty, kterým má bránit.

Drobná korekce k zadání: **Zimperium do téhle kategorie nepatří.** To je mobile app protection / RASP (detekce rootu, overlay útoků, screen sharingu). Komplementární vrstva, jiná hrozba, jiný nákup. Kdyby byl na jednom slidu s BioCatchem, technicky gramotný investor to pozná.

2. Co nasadit jako první: FIDO2 / passkeys

Nejdřív vyčistím zdánlivý rozpor. PQC má formálně verdikt „nasadit hned“, ale **není to projekt** — je to půl dne ověření a zápisu do dokumentace u něčeho, co už na vašem hostingu běží. To se udělá mimochodem, ne místo něčeho jiného. Otázka „co nasadit jako první“ se tedy ptá na skutečnou investici, a tam je odpověď FIDO2.

Proč právě to, při vašich omezeních:

- **Řeší hrozbu, která vás reálně potká.** Phishing a real-time MITM (Evilginx a spol.) je dominantní vektor převzetí účtu. WebAuthn podpis je vázaný na origin: credential vydaný pro *largo.example* se nedá použít na *largo-secure.example*, i kdyby uživatel udělal všechno špatně. To je strukturální vlastnost protokolu, ne statistika z case study dodavatele. SMS OTP a TOTP tuhle vlastnost nemají.
- **Nevratné transakce zvyšují cenu chyby.** SEPA převod jde recallovat, on-chain převod ne. Zabránit převzetí účtu *před* podpisem transakce má u vás vyšší hodnotu než u běžné banky.
- **Nemá provozní ocas.** Behaviorální biometrie znamená trvale 0,2–0,5 FTE na vyhodnocování alertů — kapacitu, kterou jednočlenný tým nemá a která je jedinou položkou, kterou týmy podceňují nejčastěji. FIDO2 po nasazení běží.
- **Nemá licenční závazek.** Open-source knihovna, 0 EUR licenčně. Žádná smlouva s minimálním odběrem před tím, než máte uživatele.
- **Je to čisté vůči GDPR.** Biometrie neopouští zařízení, vy dostanete jen boolean *UV* flag. Nezpracováváte biometrické údaje ve smyslu čl. 9 — právně výrazně čistší než jakékoli serverové biometrické řešení.
- **Konverze.** U operace, kde chcete SCA, dostanete oba faktory jedním gestem. Nižší drop-off než u OTP je argument, který funguje i v investorské prezentaci.

Ale ne dnes. WebAuthn se bez serveru neimplementuje — challenge, uložení veřejného klíče, ověření podpisu a signature counteru jsou serverové operace. Cokoli, co byste dnes dali do dema, by bylo volání *navigator.credentials.create()* bez protistrany, která by cokoli ověřovala. Kulisa, která se při první technické due diligence rozpadne.

3. Jak to implementovat konkrétně

Krok 0 — tento týden, zdarma, a musí se to udělat teď

Rozhodněte a zaregistrujte finální produkční doménu. RP ID je na ni natvrdo vázané; změna domény zneplatní úplně všechny vydané credentials. Je to jediné rozhodnutí, které se dnes udělat *musí*, protože později stojí migraci celé uživatelské báze.

Zároveň (celkem ~0,5 dne) ověřte hybridní TLS a zapište to do dokumentace:

```
,
openssl s_client -connect largoverse-demo.pages.dev:443 \
-servername largoverse-demo.pages.dev -tls1_3 -groups X25519MLKEM768
,
```

V hlavičce hledejte *Negotiated TLS1.3 group: X25519MLKEM768*. Tohle si pusťte sami — v rešeršním prostředí neprošlo DNS, takže to není ověřený fakt, dokud nevidíte výstup. Teprve ten výstup je doklad do spisu. OpenSSL 3.5.4 na vašem stroji hybridní skupiny umí, ověřeno.

Krok 1 — první sprint po vzniku backendu: passkey jako přihlášení

Nízkoriziková část. Získáte provozní zkušenost a měřitelný přínos proti phishingu, aniž by na tom visela autorizace plateb.

| Položka | MD |

|---|---|

| Serverová RP část (registrace, autentizace, správa credentials, ověření podpisů a counteru) s hotovou knihovnou (SimpleWebAuthn / webauthn4j) | 10–15 |

| Web frontend | 3–5 |

| Nativní iOS + Android (ASAuthorization / Credential Manager) včetně *apple-app-site-association* a *assetlinks.json* | 10–15 |

| **Fáze 1 celkem** | 23–35 |

Associated domains jsou typický zdroj vícedenních ztrát — počítejte s tím.

Krok 2 — až po tom: passkey jako SCA pro platby

| Položka | MD |

| --- | --- |

| Dynamic linking: challenge = hash(částka, příjemce, nonce, timestamp), zobrazení ve vlastním UI, serverové ověření, auditní log | 5–10 |

| Recovery, ztráta zařízení, více credentials na účet, deaktivace, fallback | 10–20 |

| Dokumentace pro licenční spis: mapování na čl. 4, 5, 7, 8, 9 RTS 2018/389 + explicitní odpověď na EBA Q&A 2021_6145 | 5–10 + externí právník |

| **Fáze 2 celkem** | 20–40 |

Celkem 45–75 MD. Pro jednoho člověka to jsou 3–4 měsíce čisté práce, reálně půl roku.

Recovery je nejpodceňovanější položka a zároveň nejslabší článek celého schématu. Pokud je obnova přes e-mail nebo SMS, snížili jste zabezpečení zpátky na úroveň toho slabšího kanálu a celá investice do phishing-resistance je pryč. Navrhněte to dřív, než napíšete první řádek registrace.

Obhajitelná konfigurace (tohle je ta část, kterou musí vidět právník)

Passkey ve **vaší nativní aplikaci**, s vynuceným user verification, s residentKey. Pro autorizaci plateb odmítat credentials s příznakem *BE=1*, kde to platforma dovolí. **Na iOS to nedovolí nikdy** — passkey vytvořený běžnou aplikací se vždy synchronizuje do iCloud Keychain a Apple deklaroval, že atestaci u multi-device passkeys podporovat neplánuje. Tam se kompenzuje druhou vrstvou (session binding nebo vlastní device-bound pár klíčů v Secure Enclave vedle passkeye).

Dva regulatorní body, které nesmíte obejít:

- **EBA Q&A 2021_6145** (31. 1. 2023) říká, že odemčení mobilu biometrií nebo PINem není platný prvek SCA, pokud zamykání obrazovky není pod kontrolou vydavatele. Vzniklo to pro enrolment karty do peněženky, ne pro WebAuthn, a dá se proti tomu argumentovat: WebAuthn user verification není odemčení obrazovky, ale samostatné ověření vyžádané per-asertací, jehož výsledek je kryptograficky signalizován ve flagu a jehož vyžádání kontroluje relying party. **Je to obhajitelný argument, ne jistota.** V licenčním spisu musí být adresován explicitně.
- **Synchronizované passkeys.** U syncovaného credentialu se předmět „vlastnictví“ posouvá ze zařízení na cloudový účet (Apple ID / Google účet), jehož recovery flow je zcela mimo vaši kontrolu. Autoritativní stanovisko EBA k tomu neexistuje; trh (Revolut, Finom) to považuje za akceptovatelné, ale je to interpretace poskytovatele. **Závěr: syncovaný passkey nestavět jako jediný prvek vlastnictví pro autorizaci platby. Pro přihlášení k účtu ano.**

Na čem to závisí

- **Backend.** Bez něj nula.
- **Stabilní doména.** Viz krok 0.
- **Apple a Google.** Chování platformních passkeys, sync, dostupnost atestace i UI dialogů určují oni a mění to bez ohledu na vás. Nemáte smluvní ani technickou páku. **Pro DORA je to koncentrační riziko u třetí strany, které musíte popsat a nemůžete smluvně řídit** — to do spisu patří, ne se to schová.

- **Nespoléhat na Secure Payment Confirmation.** SPC je k červenci 2026 Candidate Recommendation a běží jen v Chromiu; Apple ani Mozilla se nezavázali. Pro iOS web je nepoužitelné. Sledujte to, neplánujte na to.

Provozní náklad

- Knihovna 0 EUR, provoz je běžný backend.
- Managed vendor, pokud byste nechtěli stavět sami: Corbado / Hanko / Stytech od nízkých stovek EUR/měsíc; banking-grade (OneSpan, Transmit, Wultra) desítky tisíc EUR ročně s minimálním odběrem.
- Hardwarové tokeny pro high-value účty, pokud je nabídnete: 25–60 EUR/kus plus logistika.
- **Skrytý náklad: podpora.** Ztracená zařízení, výměny telefonů, uživatelé, kteří nechápou, kde jejich passkey je. U banky je to trvalá zátěž.

Co se tím doopravdy získá

Odolnost proti phishingu a real-time MITM na úrovni protokolu. Odpadá SIM swap i telco jako závislost. Databáze credentials po úniku nemá pro útočníka hodnotu — neukládáte žádné sdílené tajemství. A doložitelná metoda SCA do licenčního spisu.

Co se tím nezíská: nic proti APP fraudu (podvedený uživatel podepíše dokonale), nic proti malwaru na kompromitovaném zařízení, nic pro KYC/AML, nic pro bezpečnost blockchainové vrstvy a custody klíčů k XSGD. A **passkey sám o sobě není dynamic linking** — dokud do challenge nedáte hash částky a příjemce a nezobrazíte je ve vlastním UI, čl. 5 RTS nesplňujete. „Máme passkeys, takže máme SCA“ je nejčastější a nejdražší omyl v téhle oblasti.

4. Co zní dobře a při due diligence se to obrátí proti vám

① „Naše aplikace využívá Arm CCA / Realms pro hardwarovou izolaci“

Nejhorší z celého seznamu. K srpnu 2026 to není pravda a nemůže být — neexistuje mobilní zařízení, kde by to šlo, a aplikace třetí strany nemá API. Vůči investorům je to zavádějící prohlášení bez jakéhokoli přínosu.

→ **Pravdivě:** „Serverovou izolovanou komponentu navrhujeme attestation-agnosticky (rozhraní typu *vydej klíč jen ověřenému měřenému kódu*), dnes realizovatelnou přes Nitro Enclaves nebo confidential VM na TDX/SEV-SNP. Přechod na Arm CCA, až bude zákaznický dostupný, bude výměna backendu, ne přepis produktu.“

② „Kvantově odolná blockchainová vrstva“ / „quantum-safe“

XSGD i jakýkoli ERC-20 stojí na ECDSA nad secp256k1. Žádný řetězec, který byste reálně použili, nemá v produkci postkvantové podpisy. Hybridní TLS s tím nemá nic společného. Tohle je ověřitelné za třicet vteřin a je to nepravdivé. Zároveň: hybridní TLS **není** „plně postkvantové spojení“ — autentizace je i v roce 2026 klasická ECDSA, protože veřejné CA postkvantové certifikáty nevydávají (CA/B Forum nemá schválená pravidla, Let's Encrypt míří na produkci 2027).

→ **Pravdivě:** „Postkvantová hybridní výměna klíčů (X25519MLKEM768, RFC 10024) je aktivní na veškerém provozu. Autentizace zůstává klasická, protože postkvantové certifikáty veřejné CA zatím nevydávají. Chrání to proti *harvest now, decrypt later* — u nás konkrétně proti expozici KYC archivů s 5–10letou AML retencí.“

③ „Máme behaviorální biometrii“ (na demu bez uživatelů)

Model bez historie nemá co detekovat. Při jakémkoli technickém dotazu se ukáže, že je to kulisa. Navíc: prezentovat ji jako *faktor SCA* je regulatorně mrtvé — publikované EER pro dynamiku psaní jsou 2–5 %, zatímco u fyziologické biometrie se očekává FAR řádu 1:10 000 až 1:1 000 000. To jsou tři až pět řádů rozdílu a před regulátorem to jako „velmi nízká pravděpodobnost“ podle čl. 8 RTS neobhájíte. EBA Q&A 2020_5353 navíc výslovně vylučuje skládání kompozitního profilu z chování + IP + zařízení.

→ **Pravdivě:** „Architektonicky připraveno — backend od začátku ukládá událostní telemetrii relace v podobě napojitelné na libovolného dodavatele. Nasazení jako *rizikový signál do fraud engine*, nikdy jako faktor SCA, po získání licence a při prvních tisících uživatelů.“

④ „Passkeys = splňujeme PSD2 SCA“

Chybí dynamic linking a chybí odpověď na EBA Q&A 2021_6145. Právník protistrany se na obojí zeptá.

→ **Pravdivě:** „FIDO2 zvolen jako metoda SCA. Dynamic linking řešíme hashem částky a příjemce v challenge se zobrazí ve vlastním UI. Rizikovou analýzu synchronizovaných credentials a stanovisko k EBA Q&A 2021_6145 máme v licenčním spisu.“

Průřezově: účinnostní čísla dodavatelů behaviorální biometrie („99,2 % přesnost“, „o 66 % méně falešných poplachů“) jsou z jejich vlastních case studies. **Nezávislý benchmark srovnatelný s NIST FRVT pro behaviorální biometrii neexistuje.** Necitujte je. A nepoužívejte referenci ABANCA — pochází z jediného dodavatelského zdroje a nepodařilo se ji nezávisle potvrdit.

5. Co je důležitější než všechny čtyři dohromady

Seřazeno podle toho, co vás může zabít nejdřív.

① MiCA a volba stablecoinu — existenční, ne bezpečnostní

XSGD ani USDT nejsou v EU autorizované; autorizované jsou USDC a EURC. Čl. 50 MiCA zakazuje úročení. Pokud produkt stojí na XSGD, žádná bezpečnostní vrstva to nevyváží — je to licenční problém, ne kryptografický. **Tohle vyřešit dřív než cokoli ze čtyř signálů**, protože determinuje, jestli produkt v EU vůbec existuje.

② Custody a správa klíčů

Pro EMI/CASP licenci v Litvě bude auditor chtít certifikovaný HSM (FIPS 140-3 L3 / CC EAL4+) nebo MPC custody providera. To je hlavní nákladová položka celého projektu — řádově tisíce EUR měsíčně — a je to jediné místo, kde je selhání nevratné. On-chain převod se nerecalluje. Ani jedna ze čtyř technologií to nenahrazuje; regulátor CCA jako ekvivalent certifikace neuznává.

③ Backend a základní hygiena autorizace

Dnes je LargoVerse klientská simulace. Nejdůležitější bezpečnostní rozhodnutí příštích měsíců není žádný ze čtyř signálů, ale to, že **autorizace, limity a stavy zůstatků žijí na serveru a klient je nikdy nesmí určovat**. Tohle je ta věc, na které fintechy skutečně padají, a je zdarma, když se udělá na začátku.

④ Ochrana proti APP fraudu — limity, zpoždění, ověření příjemce

Dominantní typ platebního podvodu v EU dnes. **Žádná ze čtyř technologií proti němu nepomáhá** — passkey podvodnou transakci podepíše dokonale, Realm ji spustí dokonale, PQC ji dokonale zašifruje. Pomáhá: limity, zpoždění u nových příjemců, ověření shody jména a IBAN (PSR to řeší samostatně), a u nevratných on-chain převodů whitelist adres s časovým zámekem. Levné, nudné, účinné. A PSR přesouvá část odpovědnosti za podvody na PSP — takže to má do 2027–2028 přímý dopad na P&L.

⑤ Bus factor 1

Jednočlenný tým je pro DORA i pro licenční řízení samostatný problém — a pro investora je to větší riziko než jakákoli technická vrstva. Přístup ke klíčům, obnova provozu, dokumentace, zástupnost. Tohle se řeší lidmi a procesem, ne technologií.

⑥ Kryptografická inventura (3–5 MD)

Kde všude se používá asymetrická kryptografie, jaký algoritmus, jaká délka klíče, jaký horizont důvěrnosti dat. Chce to regulátor (DORA čl. 6 a 7 delegovaného nařízení 2024/1774 — musíte prokázat, že sledujete kryptoanalytický vývoj včetně kvantového a umíte algoritmy vyměnit), chce to due diligence, a je to jediná položka z celého PQC tématu, která má dnes reálnou hodnotu. U KYC archivů (AML retence 5–10 let, tedy do 2032–2037) se to protíná s PQC lhůtami (EU milník 2030 pro vysoce riziková použití) — a rozhoduje se tam ještě předtím, než backend a KYC dodavatel vůbec existují. Do budoucí smlouvy s KYC dodavatelem a do výběru HSM запиšte požadavek na FIPS 203/204 dřív, než se podepíše.

Shrnutí v jedné tabulce

| | Verdikt | Kdy | Náklad |

| --- | --- | --- | --- |

| **FIDO2 / passkeys** | Nasadit — první skutečná investice | Doména rozhodnout teď; login v 1. sprintu po backendu; SCA pro platby potom | 45–75 MD, 0 EUR licenčně |

| **PQC hybridní TLS** | Ověřit a zdokumentovat | Tento týden | 0,5–1 MD + 3–5 MD inventura |

| **Behaviorální biometrie** | Odložit, architektonicky připravit | Nákup měsíc 18–24, po licenci a při 10k+ uživatelích | Dnes pár dní na formát telemetrie |

| **ARM CCA / Realms** | Nenasazovat, nezmiňovat jako vlastnost | Revidovat za 12–18 měsíců podle Azure/AWS | 0 |

Co jsem nedokázal ověřit — před použitím vůči právníkům ověřte

- Skutečně vyjednanou TLS skupinu na largoverse-demo.pages.dev (v rešeršním prostředí neprošlo DNS) — příkaz máte v kroku 0.
- Zda je PSR už publikován v Úředním věstníku a finální číslování článků o SCA. Časová osa (dohoda 27. 11. 2025, COREPER 23. 4. 2026, aplikace ~2028) je z advokátních zdrojů, ne z primárního textu.
- Nenašel jsem **žádný** dokument EBA, který by zmiňoval „passkey“ nebo „WebAuthn“ jmenovitě, ani žádné stanovisko Lietuvos bankas či BaFin. → **Doporučuji položit dotaz přímo Lietuvos bankas v rámci předlicenční komunikace.** Je to zdarma a odpověď má pro spis vyšší hodnotu než jakákoli analýza.
- Adopční číslo ~67 % z Cloudflare Radar (stránka vrací HTTP 403), datum 31. 12. 2031 z BSI TR-02102-1 (jen sekundární zdroje), roadmapa G7 Cyber Expert Group (stažení vypršelo), avizovaný dopis ECB ke kvantovému riziku.
- Cenová rozpětí u dodavatelů behaviorální biometrie — nikdo ceník nezveřejňuje. V prezentaci uvádět jako „vyžaduje poptávku“, ne jako číslo.

15. Co je nutné rozhodnout

Oponentura našla v návrhu věci, které nejsou chyba v technice, ale nerozhodnutá otázka. Dokud nepadnou, bude architektura popisovat dvě varianty najednou — a to je přesně to, co dohled odmítne.

	Rozhodnutí	V čem je problém	Proč to nejde odložit
R1	Jaké aktivum a komu	Návrh dělá z tokenu konfiguraci, což je inženýrsky správně a zároveň to není odpověď na žádost o licenci. Autorizace se uděluje na popsanou činnost s popsány aktivy. XSGD ani USDT nejsou autorizované EMT v EU; grandfathering skončil.	Bez tohoto rozhodnutí nelze podat žádost a lhůta řízení ani nezačne běžet.
R2	Licenční perimetr	Které služby podle čl. 62 MiCA a zda se EMT bude vydávat, nebo jen distribuovat. Z toho plyne kapitálová třída a to, jestli se souběžně žádá o EMI.	Určuje kapitál, rozsah dokumentace i to, které komponenty fáze 2 vůbec vzniknou.
R3	Custody: koupit, nebo postavit	Jedna část návrhu rozhoduje custody nakoupit, druhá rozpočtuje vlastní podpisovou doménu s HSM. Žádost musí popsat jedno faktické uspořádání.	Rozdíl je řádově 200+ člověkodní a jedna licenční třída.
R4	Zápisový kontrakt do ledgeru	Compliance vrstva předpokládá, že každý peněžní zápis nese platné rozhodnutí compliance jádra vynucené databází. Ledgerová vrstva takový sloupec nemá.	Buď je vynucení compliance smyšlené, nebo je popis ledgeru neúplný. Nutné sjednotit.
R5	Vnitrodenní krytí klientských prostředků	Návrh připouští, aby FX pozice šla vnitrodenně do mínusu a doplnila se až večerní kontrolou. To je strukturálně přípuštěné podkrytí klientských prostředků.	Prudenciální otázka první kategorie. Vyžaduje limity pozice a kontrolu častější než denní.
R6	Klasifikace produktu „úschova / trezor“	Instituce elektronických peněz nesmí přijímat vklady. Produkt členěný po měnách, s vlastní obrazovkou a se srovnáním proti inflaci je pro retailového klienta spořicí produkt bez ohledu na to, jak je veden v ledgeru.	Vyžaduje právní posouzení dřív, než se postaví.
R7	Co skutečně poběží ve fázi 1	Silné ověření klienta, evidence výjimek, sankční screening a Travel Rule jsou v návrhu ve fázi 2, ale jsou to vstupní podmínky licencované činnosti.	Buď se ve fázi 1 nespouští licencovaná činnost — a to se musí napsat — nebo je fázování špatně.

Kde se oponentury shodly

Investorský i dohledový pohled se nezávisle sešly na jednom: **nerozhodnutý token a nerozhodnutý licenční perimetr** blokuji všechno ostatní. Investor to říká jako „nefinancovatelný rozsah“, dohled jako „není co posuzovat“. Je to totéž rozhodnutí a stojí jedno memo, ne rok vývoje.

Doporučené pořadí

- 1 Rozhodnout R1 a R2 — aktivum, komu se nabízí a o co se žádá. Bez toho nemá smysl psát ani řádek backendu.
- 2 Sjednotit R3 a R4 v návrhu tak, aby popisoval jedno uspořádání, ne dvě varianty.
- 3 Postavit fázi 1: ledger, peněžní typ, cenové jádro, registr aktiv. Šedesát osm komponent, z toho jádro zvládne jeden až dva vývojáři za tři měsíce.
- 4 Teprve potom otevřít R5, R6 a R7 s právníky a s regulátorem — na hotovém základu se o nich mluví jinak než na prezentaci.

Návrh vznikl osmi paralelními návrhovými pohledy a třemi nezávislými oponenturami nad repozitářem largoverse-beta a nad řešerší 130 regulatorních požadavků ze dne 16. srpna 2026. Regulatorní části jsou podkladem pro právní posouzení, nikoli právním stanoviskem.